Paul Voigt
Nils Hullen

The EU AI Act

Answers to Frequently Asked Questions

Springer

The EU AI Act

Paul Voigt • Nils Hullen

The EU AI Act

Answers to Frequently Asked Questions

Springer

Paul Voigt
Taylor Wessing
Berlin, Germany

Nils Hullen
Berlin, Germany

ISBN 978-3-662-70200-0 ISBN 978-3-662-70201-7 (eBook)
https://doi.org/10.1007/978-3-662-70201-7

Translation from the German language edition: “Handbuch KI-Verordnung” by Paul Voigt and Nils Hullen, © Der/die Herausgeber bzw. der/die Autor(en), exklusiv lizenziert an Springer-Verlag GmbH, DE, ein Teil von Springer Nature 2024. Published by Springer Berlin Heidelberg. All Rights Reserved.

© The Editor(s) (if applicable) and The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024
This work is subject to copyright. All rights are solely and exclusively licensed by the Publisher, whether the whole or part of the material is concerned, specifically the rights of translation, reprinting, reuse of illustrations, recitation, broadcasting, reproduction on microfilms or in any other physical way, and transmission or information storage and retrieval, electronic adaptation, computer software, or by similar or dissimilar methodology now known or hereafter developed.
The use of general descriptive names, registered names, trademarks, service marks, etc. in this publication does not imply, even in the absence of a specific statement, that such names are exempt from the relevant protective laws and regulations and therefore free for general use.
The publisher, the authors and the editors are safe to assume that the advice and information in this book are believed to be true and accurate at the date of publication. Neither the publisher nor the authors or the editors give a warranty, expressed or implied, with respect to the material contained herein or for any errors or omissions that may have been made. The publisher remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

This Springer imprint is published by the registered company Springer-Verlag GmbH, DE, part of Springer Nature.
The registered company address is: Heidelberger Platz 3, 14197 Berlin, Germany

If disposing of this product, please recycle the paper.

Preface

Data Act, Data Governance Act, Digital Services Act, Digital Markets Act, NIS2 and the Cyber Resilience Act—the European Union has created a comprehensive regulatory framework for digital products and services to implement its program 'A Europe Fit for the Digital Age' policy program. The practical impact of the various regulations will become fully visible in only a few years' time.

Among the plethora of digital legislation, there is one act that stands out: the AI Act. Few European laws have generated as much discussion, especially before their adoption, as the AI Act has. It regulates the development, use and distribution of artificial intelligence in a risk-based but comprehensive manner. Like almost all new EU digital laws, the AI Act takes an extraterritorial approach. Thus, even companies located outside of the European Union must comply with the AI Act. The EU is once again hoping for a 'Brussels effect', a phenomenon which helped to globalise the GDPR principles: European AI requirements will be recognised around the world and encourage legislators in other countries to create comparable regulation.

The AI Act is a mixture of classic product safety rules and digital regulation. In some instances, one can rely on proven practices of product safety, but much is new and still unknown territory. This handbook provides an introduction to the subject matter and presents the most important issues arising from the AI Act in a Q&A style. It also provides an overview of important AI requirements from other laws, such as the GDPR and the General Product Safety Regulation. International regulatory approaches, voluntary commitments and codes of conduct as well as technical standards will also be addressed.

The authors would like to thank Julian Pusch and Jannis Stöter as well as Jakob Horn for their great support in the preparation of this handbook and Johannes Kevekordes for his extensive support in the preparation of the chapter on data protection. Special thanks to Nicolette Chasse and Eric Pfauth for contributing their AI expertise and linguistic knowledge to the English version of this handbook. All statements in this book reflect the personal opinion of the authors.

Berlin, Germany — Paul Voigt
Berlin, Germany — Nils Hullen
August 2024

Contents

1 Scope and General Requirements 1
1.1 What Is the 'New Legislative Framework'? 1
1.2 Which Types of AI Does the AI Act Apply to? 3
1.2.1 What Is an AI System? 5
1.2.2 What Is an AI Model? 6
1.2.3 Which AI Practices Are Prohibited? 7
1.2.4 What Is a High-Risk AI System? 7
1.2.5 Which AI Systems Are Subject to Special Transparency Obligations? 8
1.2.6 What Is a General-Purpose AI Model (GPAI Model)? 9
1.2.7 Which AI Applications Are Excluded from the Scope of the AI Act? 10
1.3 Which Operators Are Covered by the AI Act? 11
1.3.1 Who Is a Provider? 11
1.3.2 Who Is a Deployer? 14
1.3.3 Who Is an Importer? 15
1.3.4 Who Is a Distributor? 15
1.3.5 Who Is the Product Manufacturer? 16
1.3.6 Who Is an Authorised Representative Under the AI Act? 16
1.3.7 Under What Circumstances Are Distributors, Importers, Deployers and Other Third Parties Considered Providers of High-Risk AI Systems? 17
1.3.8 Can One Entity Take on the Roles of Several Operators at the Same Time? 19
1.3.9 What Is the Territorial Scope of the AI Act? 19
1.3.10 What Requirements Apply to Companies Outside the EU? 20
1.3.11 Which Operators Are Excluded from the Scope of the AI Act? 22
1.3.12 What Special Provisions Apply to SMEs, Including Start-Ups? 22

1.4 Through What Actions Do Operators Trigger the Application of the AI Act? . . . 24
1.4.1 When Is an AI Application Placed on the Market? . . . 25
1.4.2 When Is an AI Application Put into Service? . . . 26
1.4.3 When Is an AI System Substantially Modified? . . . 27
1.5 When Does the AI Act Apply? . . . 27
1.5.1 When Does the Application of the AI Act Begin? . . . 27
1.5.2 Does the AI Act Also Apply to AI Applications That Were Placed on the Market or Put into Service Before Its Entry into Force? . . . 28
1.6 What Are the General Minimum Requirements for All AI Systems? . . . 29
1.6.1 What Are the Requirements for Promoting AI Literacy? . . . 30
1.6.2 What Are Codes of Conduct for Voluntary Application? . . . 31
1.6.3 What General Safety Requirements Can Be Applicable to AI Systems? . . . 31
1.6.4 What Are the AI Ethics Guidelines? . . . 32
1.7 What Rights Does the AI Act Grant to Third Parties? . . . 32
1.7.1 What Rights Apply in Case of a Suspected Breach of the AI Act? . . . 33
1.7.2 When Does the Right to an Explanation of an AI Based Decision Apply? . . . 34
1.7.3 What Rights Do Providers Who Integrate a GPAI Model into Their AI System Have? . . . 35

2 What AI Practices Are Prohibited? . . . 37
2.1 What Requirements Apply to Subliminal, Manipulative and Deceptive Techniques? . . . 38
2.2 Which Requirements Apply to the Exploitation of a Person's Vulnerability? . . . 40
2.3 Which Requirements Apply to Social Scoring? . . . 41
2.4 Which Requirements Apply to Predictive Policing? . . . 42
2.5 Which Requirements Apply to the Scraping of Facial Images? . . . 43
2.6 Which Requirements Apply to Emotion Recognition in the Workplace and in Educational Institutions? . . . 43
2.7 Wh Requirements Apply to Biometric Categorization Systems? . . . 44
2.8 What Requirements Apply to Real-Time Remote Biometric Identification Systems? . . . 45
2.9 What Prohibitions from Other Laws Must Be Observed? . . . 46

3 Which Requirements Apply to High-Risk AI Systems? . . . 47
3.1 Which AI Systems Are High-Risk AI Systems? . . . 47
3.1.1 Which Products Are or Contain High-Risk AI Systems? . . . 48

3.1.2 Which 'Stand-Alone' AI Systems in Critical Use Cases Are Considered High-Risk? 54
3.2 Which Requirements Apply to High-Risk AI Systems? 69
3.2.1 Which Requirements Apply to the Risk Management System of High-Risk AI Systems? 72
3.2.2 Which Requirements Apply to Data Quality and Data Governance for High-Risk AI Systems? 75
3.2.3 Which Requirements Apply to the Training and Testing of High-Risk AI Systems with Special Categories of Personal Data? 77
3.2.4 What Requirements Apply to the Technical Documentation of High-Risk AI Systems? 78
3.2.5 What Requirements Apply to the Logging of High-Risk AI Systems? 81
3.2.6 Which Requirements Apply to the Transparency of High-Risk AI Systems? 82
3.2.7 What Requirements Apply to the Human Oversight of High-Risk AI Systems? 84
3.2.8 What Requirements Apply to the Accuracy, Robustness and Cybersecurity of High-Risk AI Systems? 86
3.3 What Obligations Apply to Providers of High-Risk AI Systems? 88
3.3.1 What Requirements Apply to the Quality Management System of a High-Risk AI Systems? 89
3.3.2 What Documents Must Providers of High-Risk AI Systems Keep? 91
3.3.3 What Requirements Apply to the EU Declaration of Conformity for High-Risk AI Systems? 91
3.3.4 What Requirements Apply to the CE Marking of a High-Risk AI System? 93
3.3.5 Which High-Risk AI Systems Must Be Registered by the Provider? 94
3.3.6 What Are Providers Obliged to Do if Their AI System in a Critical Use Case Is Exceptionally Not Considered High Risk? 96
3.3.7 What Monitoring Obligations Apply to Providers of High-Risk AI Systems? 96
3.3.8 To What Extent Are Providers of High-Risk AI Systems Obliged to Cooperate with National Supervisory Authorities? 97
3.3.9 When Must Providers of High-Risk AI Systems Take Corrective Actions and Inform Other Operators? 98
3.3.10 What Incidents Must Providers of High-Risk AI Systems Report to the Market Surveillance Authority? 99

3.3.11 How Must the Cooperation Between Providers of High-Risk AI Systems and Third Parties Be Contractually Organised? . . . 101
3.3.12 Are There Model Contracts for Cooperation Between Providers of High-Risk AI Systems and Third Parties? . . . 102
3.4 What Obligations Do Deployers of High-Risk AI Systems Have? . . . 103
3.4.1 What Technical and Organisational Measures Must Deployers of High-Risk AI Systems Take? . . . 104
3.4.2 What Human Oversight Requirements Must Deployers of High-Risk AI Systems Fulfil? . . . 105
3.4.3 How Do Deployers Have to Monitor the High-Risk AI System? . . . 106
3.4.4 Which Kind of Logs Must Deployers of High-Risk AI Systems Keep? . . . 107
3.4.5 What Additional Obligations Do Deployers Face if They Use a High-Risk AI System in the Workplace? . . . 107
3.4.6 Which Deployers Must Register High-Risk AI Systems Before Putting It into Service? . . . 108
3.4.7 What Additional Obligations Does the Deployer of a Post-remote Biometric Identification System Have? . . . 109
3.4.8 What Information Obligations Apply to Deployers of High-Risk AI Systems That Make Decisions Regarding Natural Persons? . . . 110
3.4.9 To What Extent Are Deployers of High-Risk AI Systems Obliged to Cooperate with National Competent Authorities? . . . 110
3.4.10 Which Deployers of High-Risk AI Systems Are Obliged to Carry Out a Fundamental Rights Impact Assessment? . . . 111
3.5 What Obligations Do Other Operators Have? . . . 112
3.5.1 What Obligations Apply to Manufacturers of Products That Are AI Systems or Contain AI Systems as Safety Components? . . . 113
3.5.2 What Obligations Do Importers of High-Risk AI Systems Have? . . . 113
3.5.3 What Obligations Apply to Distributors of High-Risk AI Systems? . . . 116
3.5.4 What Are the Obligations of Authorised Representatives of Providers of High-Risk AI Systems? . . . 118

4 Which AI Systems Are Subject to Specific Transparency Requirements? . . . 121
4.1 What Requirements Apply to Providers of AI Systems Directly Interacting with Humans? . . . 122

4.2 Which Requirements Apply to Providers of AI Systems That Generate Synthetic Content? . . . 123
4.3 What Requirements Apply to Deployers of Emotion Recognition Systems and Biometric Categorisation Systems? . . . 124
4.4 Which Requirements Apply to Deployers Whose AI Systems Generate Deep Fakes? . . . 125
4.5 Which Requirements Apply to Deployers Whose AI Systems Generate Texts for the Public? . . . 126
4.6 At What Point in Time Must the Transparency Requirements Be Met? . . . 126
4.7 What Guidance Does the AI Act Include for Providers and Deployers of AI Systems with Specific Transparency Requirements? . . . 126

5 Which Requirements Apply to GPAI Models? . . . 129
5.1 What Obligations Do Providers of GPAI Models Have? . . . 130
5.1.1 What Must the Technical Documentation of GPAI Models Contain? . . . 132
5.1.2 What Information Must Providers of GPAI Models Make Available to Downstream Providers of AI Systems? . . . 133
5.1.3 What Copyright Requirements Apply to GPAI Models? . . . 135
5.1.4 What Information on the Data Used for Training of a GPAI Model Must Be Made Available by the Provider? . . . 137
5.1.5 To What Extent Are Providers Obliged to Cooperate with Competent Authorities? . . . 137
5.2 What Additional Requirements Are There for GPAI Models with Systemic Risks? . . . 138
5.2.1 When Does a GPAI Model Pose a Systemic Risk? . . . 138
5.2.2 What Additional Obligations Apply to the Provider of a GPAI Model with a Systemic Risk? . . . 140
5.2.3 What Are the Requirements for the Categorisation Procedure for GPAI Models with Systemic Risk? . . . 142
5.3 What Special Rules Apply to Providers of GPAI Models with a Free and Open-Source Licence? . . . 143
5.4 How Can Codes of Practice and Harmonised Standards Facilitate Compliance for GPAI Models? . . . 144
5.5 What Requirements Apply to Other Operators with Regard to GPAI Models? . . . 146
5.5.1 What Are the Obligations of the Authorised Representative of the Provider of a GPAI Model? . . . 146
5.5.2 What Are the Rights and Obligations of a Downstream Provider That Integrates a GPAI Model into Its AI System? . . . 147
5.5.3 What Are the Obligations of Deployers, Distributors and Importers of GPAI Models? . . . 148

6 How Is the AI Act Implemented and Enforced? 151
6.1 What Requirements Apply to the Conformity Assessment Procedure Before a High-Risk AI System Can Be Made Available on the Market? 151
6.1.1 Which Conformity Assessment Procedure Applies to Which High-Risk AI System? 152
6.1.2 What Requirements Apply to an Internal Conformity Assessment? 154
6.1.3 What Requirements Apply to a Third-Party Conformity Assessment? 154
6.1.4 What Requirements Apply to the Conformity Assessment of AI Systems That Are (Safety Components of) Products Within the New Legislative Framework? 157
6.1.5 What High-Risk AI Systems Need Not Undergo a Conformity Assessment? 158
6.1.6 Which Changes to the AI System Require a Reassessment of Conformity? 159
6.2 How Is the AI Act Enforced After AI Systems and Models Have Been Placed on the Market or Put into Service? 160
6.2.1 Who Is Competent for Enforcing the AI Act? 160
6.2.2 Who Is Competent for Cross-Border Matters? 161
6.2.3 Which New Governance Bodies Will Be Created at EU Level? 162
6.2.4 What Tasks Do the Market Surveillance Authorities Have? 163
6.2.5 What Investigation Rights Do the Market Surveillance Authorities and the AI Office Have? 166
6.2.6 What Additional Powers Will Data Protection Authorities and Other Existing Authorities Receive Under the AI Act? 168
6.2.7 How Is the EU Database for AI Systems Set Up? 168
6.2.8 What Obligations Do Authorities Have Towards Operators? 169
6.2.9 What Sanctions Does the AI Act Provide for Violations of Its Provisions? 170
6.3 What Provisions Apply to the Testing of AI? 173
6.3.1 What Are AI Regulatory Sandboxes and What Goals Do They Serve? 174
6.3.2 What Is Testing in Real-World Conditions? 178

7 What Other Legislation Is Particularly Relevant with Regard to AI? 183
7.1 What Secondary Legislation and Other Tools to Supplement or Specify the AI Act Are Envisaged? 183

7.2 What Data Protection Regulations Apply to the Use of AI? 189
7.2.1 When Is the GDPR Applicable? 190
7.2.2 When Is Personal Data Processed During the Training and Use of AI? 191
7.2.3 What General Principles Apply to the Processing of Personal Data? 192
7.2.4 Which Legal Bases Does the GPDR Acknowledge for Processing Personal Data? 193
7.2.5 What Information Is the Controller Obliged to Provide? 196
7.2.6 What Rights Do Data Subjects Have? 197
7.2.7 What Requirements Apply to Automated Decisions by AI? 198
7.2.8 To Which Roles Are Obligations Under the GDPR Assigned? 201
7.2.9 What Are the Requirements for the Data Protection Organisation? 202
7.2.10 Which Requirements Apply to Data Transfers to Third Countries? 206
7.2.11 For Which Infringements Does the GDPR Provide for Sanctions and Compensation? 207
7.3 Which General Product Safety Requirements Must Be Observed? 209
7.4 What Rules Apply to the Liability for AI Applications? 210
7.4.1 What Does the Draft AI Liability Directive Provide for? 211
7.4.2 What Does the Product Liability Directive Provide for? 213
7.4.3 Which National Liability Rules Apply? 215
7.5 What International Laws and Framework Conditions Govern AI? 216
7.5.1 What International Agreements Are There? 216
7.5.2 What National Regulatory Approaches Exist Outside the EU? 218
7.6 What Technical Norms and Standards Cover AI? 224
7.6.1 Which ISO Standards Cover AI? 225
7.6.2 Which IEEE Standards Are Relevant? 226
7.6.3 What Harmonised Standards Help to Implement the AI Act? 226

List of Online Resources Used with Links 229



Scope and General Requirements

1

The AI Act forms part of the 'New Legislative Framework' for product safety legislation. The basics of this framework are explained at the beginning of this Chapter (see Sect. 1.1).

Thereafter, we will present the AI applications (directly or indirectly) regulated by the AI Act as well as the operators to which the AI Act applies (see Sects. 1.2 and 1.3). Subsequently, we will address actions that have a defined meaning under product safety law and to which the obligations of the operators are linked (see Sect. 1.4).

Finally, we will discuss the temporal scope of the AI Act (see Sect. 1.5) and provide insights on obligations that must be considered for all AI applications (see Sect. 1.6), as well as certain rights that the AI Act grants to third parties (see Sect. 1.7).

1.1 What Is the 'New Legislative Framework'?

Recital 9 (Consistency with the New Legislative Framework)

The AI Act is part of the 'New Legislative Framework' introduced in the EU in 2008. Thus, the AI Act is a **product safety law.** The New Legislative Framework is the EU's approach to harmonising product safety rules. Building on Regulation No. 765/2008/EC (on the accreditation of conformity assessment bodies) and Decision No. 768/2008/EC (on a common framework for the marketing of products), the EU has harmonised the structure of numerous regulations and directives of product safety. The underlying concept of the New Legislative Framework is a uniform approach to risk for the health and safety of natural persons. Thus, different safety aspects of the same product by various specific laws can be harmonised. As a key characteristic, the EU legal acts define requirements for market access and stipulate measures to ensure compliance with these requirements (see Sect. 7.6.3).

Important features of the New Legislative Framework are a pre-market conformity assessment procedure, the drawing-up of an EU Declaration of Conformity,

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_1

the affixation of a CE marking to compliant products and a uniform post-market surveillance in accordance with the requirements of the Market Surveillance Regulation (EU) 2019/1020.

Corresponding to the uniform conformity assessment procedures, all harmonisation legislation within the New Legislative Framework allocates similar obligations to certain economic operators (manufacturers, importers, distributors). However, it is to be noted that each legislative act may deviate from the basic principles of the New Legislative Framework with certain margins. For example, the roles of economic operators have been partially adapted for the AI Act. 'Manufacturers' of AI systems are referred to as providers. Similarly, the rules for importers of AI systems have their roots in the New Legislative Framework. While it may seem surprising to set up rules for importers of AI systems that can be supplied digitally, this can be explained by the New Legislative Framework. The AI Act does not only address the digital component of the system, but the system as a whole, including any physical components.

The AI Act's roots in the New Legislative Framework can also be observed in a central part: The definition of 'high-risk' AI systems. To an important extent, the definition of high-risk AI systems refers to other EU product safety legislation. AI systems are considered high-risk if the AI system is itself a product or is intended to be used as a safety component of a product falling within the scope of EU laws that are a part of the New Legislative Framework. Thus, if a product that uses AI is regulated by certain laws within the New Legislative Framework, the AI Act is automatically applicable (see Sect. 3.1.1.1) and the manufacturer of the product is deemed to be the provider of the AI system (see Sect. 3.5.1). On the other hand, the AI Act is not automatically applied to products not covered by the New Legislative Framework laws. Instead, the requirements for high-risk AI systems are incorporated into the applicable product safety law (see Sect. 3.1.1.2). The differentiation between products regulated within or outside of the New Legislative Framework can be explained by their compatibility with the AI Act. The structure and logic of legal acts outside the New Legislative Framework deviate more significantly from the AI Act. Thus, the AI Act cannot be applied to those products outside the New Legislative Framework directly without causing points of friction.

The central point of reference for product safety law is the so-called 'Blue Guide' authored by the European Commission. It was originally published in 2016 and updated in 2022. The Blue Guide summarises the common principles of EU legislation within the New Legislative Framework.

The Blue Guide 2022 can help to interpret many rules of the AI Act as long as the special features of AI regulation are considered. It should be emphasised, for example, that the AI Act is intended to protect fundamental rights in addition to safety and health, which is rather unusual for legislation within the New Legislative Framework. Therefore, some provisions of the AI Act, especially those with regard to transparency obligations and GPAI models, do not correspond to the New Legislative Framework.

Related Topics

Products that are or contain high-risk AI systems: Sect. 3.1.1.

The role of product manufacturers in the AI Act: Sect. 3.5.1.

Harmonised standards: Sect. 7.6.3. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), Section 1.2, p. 9 to 12.

1.2 Which Types of AI Does the AI Act Apply to?

Articles 2(1), 3(1), (63) and (66)

Recitals 12 (AI systems), 26 (Risk-based approach), 28 (Prohibited AI practices), 46 (High-risk AI systems), 97 (GPAI models), 99 (Generative AI models), 100 (GPAI systems).

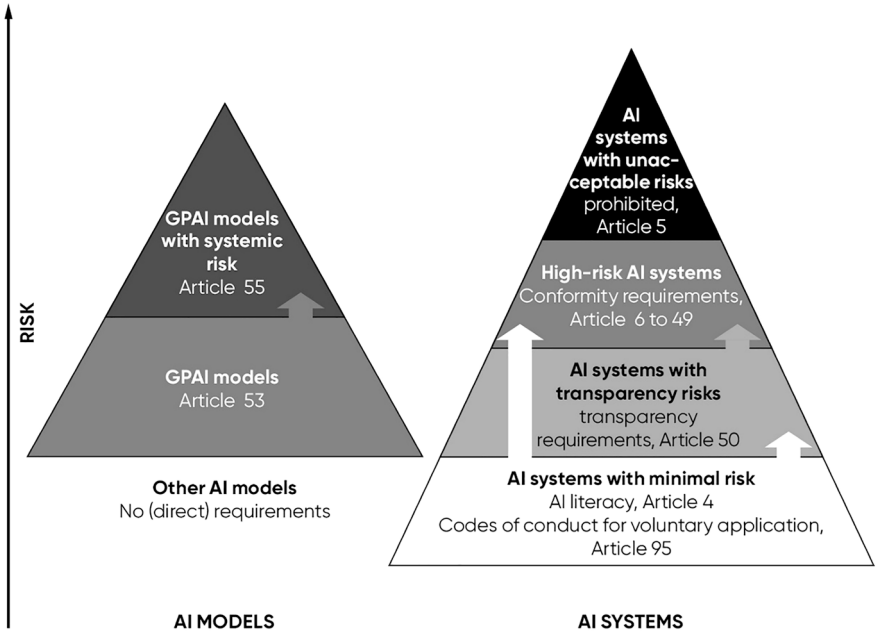


Fig. 1.1 Overview of the AI Act's risk-based approach

The AI Act applies to certain **AI systems and general-purpose AI models** (hereinafter referred to as GPAI models; see also Fig. 1.1.

The AI act addresses **AI systems** (see Sect. 1.2.1) in four risk-based categories:

- Prohibited AI practices (unacceptable risk; see Chap. 2),
- High-risk AI systems (see Chap. 3),
- AI systems with special transparency requirements (see Chap. 4),
- other AI systems (minimal risk).

General requirements apply to all AI systems, including those with minimal risk (see Sect. 1.6). The requirements of a lower risk category also apply to all higher risk categories. For example, high-risk AI systems must also fulfil the specific (lower risk) transparency requirements as far as these requirements are applicable.

The **risk-based approach** recognises that the use of AI is not dangerous per se. Therefore, there is no need to regulate the technology in general. Instead, the applicable rules depend on the specific use case of an AI system. The riskier it is, the stricter the obligations are. If the risks are minimal, there is only an obligation to promote so-called 'AI literacy' (i.e. training requirements); if the risks are unacceptable, the corresponding AI systems are largely banned. The most detailed provisions concern high-risk AI systems, for which a comprehensive set of rules on product safety and market access must be observed.

GPAI models (see Sect. 1.2.6) are a special category of AI models that can be used for a wide range of distinct tasks (see Chap. 4). GPAI models do not have a pre-defined use case and therefore do not fall directly into one of the aforementioned risk categories for AI systems. Nevertheless, GPAI models are subject to certain rules, as they can be particularly powerful part of a high-risk AI system. This is also reflected in the regulatory approach, which is primarily aimed at creating transparency and only provides for stricter obligations in the case of so-called systemic risks of the model. If GPAI models are integrated into AI systems which in turn can still serve a variety of purposes, these AI systems are referred to as a **GPAI system** (Article 3(66) of the AI Act). The same requirements are placed on GPAI systems as on all other AI systems, i.e. the applicable rules depend on the risk-based categorisation of each specific GPAI system.

Related Topics

General requirements for all AI systems: Sect. 1.6.

Prohibited AI practices: Sect. 1.2.2 and Chap. 2.

High-risk AI systems: Sect. 1.2.4 and Chap. 3.

Transparency requirements: Sect. 1.2.5 and Chap. 4.

GPAI models: Sect. 1.2.6 and Chap. 5. ◄

▶ **Further Information** *European Commission*, Artificial Intelligence – Questions and Answers (2023).

1.2.1 What Is an AI System?

Articles 3(1) and 96(1)(f)

Recitals 4 (Artificial intelligence), 12 (AI systems)

An AI application is considered an AI system within the meaning of the AI Act if it has the following five characteristics:

- The application is **machine-based**, i.e. it runs on one or more computers (Recital 12).
- It is designed to operate with varying degrees of **autonomy**, i.e. the application has some degree of independence of actions from human involvement and has the capabilities to operate without human intervention. The application must not be based on rules defined solely by humans to automatically execute operations (Recital 12).
- It may exhibit adaptiveness after deployment. This refers to a self-learning capability that allows the application to change during its use (Recital 12). This characteristic is not mandatory. Systems that are not self-learning can therefore still be AI systems. Self-learning systems, on the other hand, are usually AI systems.
- The application infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions for explicit or implicit objectives. The AI Act expressly states that basic data processing shall not be considered as an ability to infer. The **ability to infer** enables learning, reasoning or modelling. Inference refers to the process within an AI in which trained skills are applied to new data. Examples of inference techniques include machine learning, where a system learns from data how to achieve certain goals, and logic- or knowledge-based techniques, where the system infers how to solve a task from coded information or symbolic representations (Recital 12).
- The output can **influence** physical or virtual **environments**.

Software that is not based on AI often also fulfils many of these criteria. The **decisive criteria** for distinguishing AI systems from other (non-AI) software are the two characteristics of **autonomous operation and inferring results** from the input received. The concept of AI systems within the meaning of the AI Act is therefore very broad and could also include older AI technologies. The difficulties of demarcation can be clearly seen in the example of so-called **expert systems**. These are knowledge-based systems that can access a specific (expert) knowledge base and draw conclusions from this knowledge using an inference algorithm. These conclusions typically work on the basis of logical 'if-then' conclusions. Since, in addition to machine learning, logic- and knowledge-based approaches also exhibit inference within the meaning of the AI Act (see Recital 12), expert systems could also be

considered to be AI systems if they are operated with a sufficient degree of autonomy. However, the AI Act does not specify the exact requirements for when a system is 'designed to operate with varying degrees of autonomy'. It only states that systems that only execute pre-programmed rules should not be AI systems (Recital 12). Logic and knowledge-based systems (such as expert systems) typically only execute rules pre-programmed by humans. Hence, expert systems should not be considered as AI systems. Nevertheless, Recital 12 lists knowledge-based approaches as an example of inference capability. The definition of the AI Act is partially contradictive and leads to a certain degree of legal uncertainty.

The European Commission is authorised to further specify the definition of AI systems in the AI Act by means of guidelines (see Article 96(1)(f)).

In the case of high-risk AI systems, for which the AI Act provides for the most detailed obligations and requirements (see Chap. 3), the broad concept of AI systems is narrowed down. If AI systems do not pose a significant risk of harm, the requirements for high-risk AI systems do not apply to them (see Sect. 3.1.2.10). Therefore, AI systems that do not materially influence the outcome of decision-making are often only subject to the more general transparency requirements (see Chap. 4).

Related Topics

Requirements for high-risk AI systems: Chap. 3. ◀

▶ **Further Information** *Future of Privacy Forum*, The Spectrum of Artificial Intelligence – An Infographic Tool (2020); *High-Level Expert Group on AI*, A definition of AI (2018); *OECD.AI Policy Observatory*, What is AI? Can you make a clear distinction between AI and non-AI systems? (2024).

1.2.2 What Is an AI Model?

Recital 97 (GPAI models)

The AI Act does not explain directly what **AI models** are.

AI models are **not AI systems** and therefore (with the exception of GPAI models) do not fall under the scope of the AI Act. There are no general prohibitions for AI models and no transparency obligations. AI models cannot be high risk either. The obligations for operators of AI systems only apply indirectly if an AI model (which will typically be the case) is intended for integration into AI systems (whereby the actual requirements then only apply to the AI system).

However, the notion of 'AI model' is necessary to precisely define **GPAI models** and to distinguish them from GPAI systems (see Sect. 1.2.6).

The distinction between AI systems and AI models has considerable legal consequences (including with respect to liability) for operators, since the classification of

an AI application as an AI system or AI model determines the obligations an operator must fulfil. One approach to differentiate AI models from systems is to understand the AI models as necessary components of AI systems. Thus, AI models require the addition of further components, such as a user interface, to create an AI system (Recital 97). A user interface enables persons other than the developers to feed the (trained) AI model with input and obtain their output. An AI system is therefore the (analogue or digital) ready-to-use product that fulfils a specific purpose. AI models are the basis of many AI systems – but are not intended to be accessed directly by end-users without an appropriate interface.

Related Topics

AI systems: Sect. 1.2.1.

GPAI models: Sect. 1.2.6. ◀

1.2.3 Which AI Practices Are Prohibited?

Article 5

Recitals 26 (Risk-based approach), 28 (Prohibited AI practices), 29 (Manipulative techniques and exploitation of vulnerabilities), 30 (Prohibited biometric categorisation systems), 31 (Social scoring), 32 to 39 (Real-time biometric remote identification), 42 (Predictive policing and profiling), 43 (Facial recognition databases), 44 (Prohibited emotion recognition systems), 45 (Prohibitions under other EU laws)

The AI Act contains a list of **use cases** of AI systems that pose unacceptable risks to fundamental rights and are therefore prohibited. However, there are exceptions to these prohibitions (for more details on prohibited AI practices, see Chap. 2).

The list of prohibited AI practices in the AI Act is not exhaustive. AI practices can be prohibited also under other EU laws, in particular under data protection laws, non-discrimination laws, consumer protection laws or competition laws. These prohibitions by other EU legislation are not affected by the AI Act. In other words: If an activity is prohibited without the use of AI it is also prohibited with the use of AI.

Related Topics

Prohibited AI practices and exceptions: Chap. 2. ◀

1.2.4 What Is a High-Risk AI System?

Article 6(1) to (3), Annex I and III

Recitals 7 (Common rules for all high-risk AI systems), 46 (High-risk AI systems), 47 (AI safety components), 48 (Relevant fundamental rights risks), 50 (Products within the New Legislative Framework), 51 (Risk classification under other harmonisation legislation), 52 (Critical use cases), 53 (Exemptions from

high-risk categories), 54 (High-risk biometric AI systems), 55 (Critical infrastructure), 56 (Education), 57 (Employment and self-employment), 58 (Access to essential services), 59 (High-risk AI in law enforcement), 60 (Migration, asylum and border control management), 61 (Administration of justice and democratic processes), 62 (Influencing electoral behaviour), 63 (No legalisation effect for other legal acts)

High-risk AI systems are AI systems that are not prohibited but may have a significant harmful impact on the health, safety or fundamental rights of persons. The AI Act considers this condition to be fulfilled in **two use cases.** High-risk AI systems are therefore

- **Products or safety components of products** that are subject to conformity assessment under certain EU legislation (Article 6(1), Annex I; see in detail Sect. 3.1.1).
- Stand-alone AI systems that are intended to be used in **certain critical areas** (Annex III) (Article 6(2); see in detail Sect. 3.1.2). However, AI systems in critical use cases are not considered high-risk if they do not pose a significant risk to the fundamental rights of natural persons. This may be the case for AI systems only fulfilling subordinate or supporting tasks (Article 6(3); see Sect. 3.1.2.10).

Related Topics

Use cases and requirements for high-risk AI systems: Chap. 3. ◀

1.2.5 Which AI Systems Are Subject to Special Transparency Obligations?

Article 50

Recitals 120 (Interplay with Digital Services Act), 132 (AI systems that interact with humans), 133 (AI systems that generate large amounts of synthetic content), 134 (Disclosure obligations for deployers regarding deep fakes), 135 (Codes of practice for transparency obligations), 136 (Interplay with the Digital Services Act), 137 (Harmonisation with other transparency obligations)

There is no general definition of AI systems for which specific transparency obligations apply. There are, however, **certain use cases** in which the affected persons should be informed that content or actions are attributable to an AI system and not to a human being. The AI Act lists these use cases and provides for transparency obligations for each use case (detailed explanation in Chap. 4).

These transparency obligations apply to both high-risk and other AI systems. Transparency obligations derived from other EU or national law also remain in place.

Whether an AI system is high risk or not is irrelevant for these transparency obligations. It must be checked separately and additionally whether other rules of the AI Act apply to the AI system, i.e. whether the AI system is not prohibited and whether it is also to be categorised as a high-risk AI system.

Related Topics

Use cases and transparency requirements: Chap. 4. ◄

1.2.6 What Is a General-Purpose AI Model (GPAI Model)?

Article 3(63), (66) and (67)

Recitals 85 (Providers of GPAI systems), 97 (GPAI models), 98 (Thresholds for classifying GPAI), 99 (Generative AI models), 100 (GPAI systems), 110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission as GPAI model with systemic risks)

General-purpose AI models (GPAI models) are AI models (Article 3(63)) that

- display **significant generality,**
- are capable of competently performing a wide range of **distinct tasks**, and
- can be **integrated** into a variety of downstream systems or applications.

An AI model's performance is regarded as an indicator of a model's generality. If a model has more than one billion parameters, it shall be presumed that it displays 'significant generality' (Recital 98). What exactly constitutes a parameter depends on the method used by the respective AI model. Generally speaking, parameters are the values that AI models use to infer results from input data.

GPAI models are also conventionally referred to as foundation models, as these models can form **the basis of many different downstream AI applications.** Large generative AI models, such as *Large Language Models* (LLMs), are usually GPAI models. However, AI models that have been trained for use in a narrowly defined area (e.g. in the field of drug development or weather research) are often not GPAI models due to a lack of the required scope of applicability. AI models which do not fall within the scope of the GPAI provisions can only be indirectly regulated as component of an in-scope AI system.

GPAI models are different from **GPAI systems** (Article 3(66)). GPAI systems are AI systems that are based on GPAI models and can in turn fulfil a variety of purposes. Examples of GPAI systems are the *ChatGPT* and *Midjourney* applications, which are based on the *GPT* and *Midjourney* AI models.

Providers of GPAI models are, among others, required to disclose information that downstream providers of AI systems need in order to fulfil their AI Act obligations. Additional, stricter obligations apply for GPAI models if they present **systemic risks** (see Sect. 5.2.1).

Related Topics

AI models: Sect. 1.2.2.

Specifications for GPAI models: Chap. 5. ◄

▶ **Further Information** *European Commission*, Artificial Intelligence – Questions and Answers (2023), p. 3 and 4.

1.2.7 Which AI Applications Are Excluded from the Scope of the AI Act?

Article 2(2), (3), (6), (8) and (12)

Recitals 24 (Military, defence and national security), 25 (Research and development activities), 49 (Products outside the New Legislative Framework), 124 (Avoidance of duplication)

Under the following conditions, AI systems are excluded from the scope of the AI Act:

- AI systems used, placed on the market or put into service exclusively for **military, defence or national security** purposes (Article 2(3));
- AI systems and models developed and put into service exclusively for **scientific research and development** (Article 2(6));
- **Research, testing and development activities in** relation to AI systems or models before they are placed on the market and put into service, with the exception of testing in real-world conditions (Article 2(8));
- **Free and open-source AI systems** (Article 2(12)), unless they
  - are placed on the market or put into service as high-risk AI systems (see Chap. 3);
  - are subject to a prohibition under the AI Act (see Chap. 2) or
  - are subject to the specific transparency requirements under the AI Act (see Chap. 4).
  - This means that the exemption for open-source AI systems is rather narrow. Only free open-source AI systems that are permitted to be shared openly and that can be accessed, used, modified, and redistributed by the user free of charge are exempt from the scope of the AI Act.
- **High-risk AI systems that are products or safety components of products covered by EU harmonisation legislation outside the New Legislative Framework** (Article 2(2) in conjunction with Annex I, Section B; see Sect. 3.1.1.2). Although excluded from the scope of the AI Act, the requirements for high-risk AI systems apply indirectly. The harmonisation legislation that applies to these products is subject to amendments, incorporating the requirements of the AI Act regarding high-risk AI systems (Articles 102 to 109; see also Sect. 3.1.1.2). Aside from that, only the provisions on the evaluation of the AI Act by the European Commission (Article 112) and the provisions on AI regulatory sandboxes in relation to the requirements for high-risk AI systems (Article 57) apply directly to these high-risk AI systems.
- In addition, certain operators are excluded from the scope of the AI Act (see Sect. 1.3.11).

Related Topics

Exceptions to the scope of application for certain operators: Sect. 1.3.11.

High-risk AI systems that are related to products outside of the New Legislative Framework: Sect. 3.1.1.2.

New Legislative Framework: Sect. 1.1.

Testing in real-world conditions: Sect. 6.3.2. ◀

1.3 Which Operators Are Covered by the AI Act?

Articles 2(1)(a) to (f) and 3(3) to (11)

Recitals 21 (Level playing field), 22 (Applicability to third countries), 23 (Applicability to EU institutions and bodies), 83 (Operators along the value chain)

The personal scope of the AI Act includes operators and affected persons. Operators are providers (and their authorised representatives), deployers, importers, distributors and product manufacturers (Article 3(8); see also Fig. 1.2).

▶ **Further Information** *International Association of Privacy Professionals*, EU AI Act Compliance Matrix (2024).

1.3.1 Who Is a Provider?

Articles 3(3) and (23), 25(1) to (3)

Recitals 79 (Provider who has not designed or developed the AI system), 83 (Operators along the value chain), 84 (Quasi provider), 85 (Providers of GPAI systems), 86 (Relationship between quasi provider and former provider), 87 (Product manufacturer), 101 (Role of the provider in the supply chain of GPAI models), 128 (Substantial modification)

A provider is any natural or legal person that

- develops an AI system or a GPAI model or
- has an AI system or a GPAI model developed and places it on the market or puts the AI system into service under its own name or trademark (Article 3(3); for placing on the market and putting into service, see Sects. 1.4.1 and 1.4.2).

This definition is not clear and allows for several interpretations. On the one hand, 'provider' could mean that persons who have developed an AI system or GPAI model themselves would also have to place it on the market or put it into service in order to be considered providers. On the other hand, the notion can also be understood in such a way that the second part of the definition (placing on the market or putting into service) only refers to persons who have not developed the AI

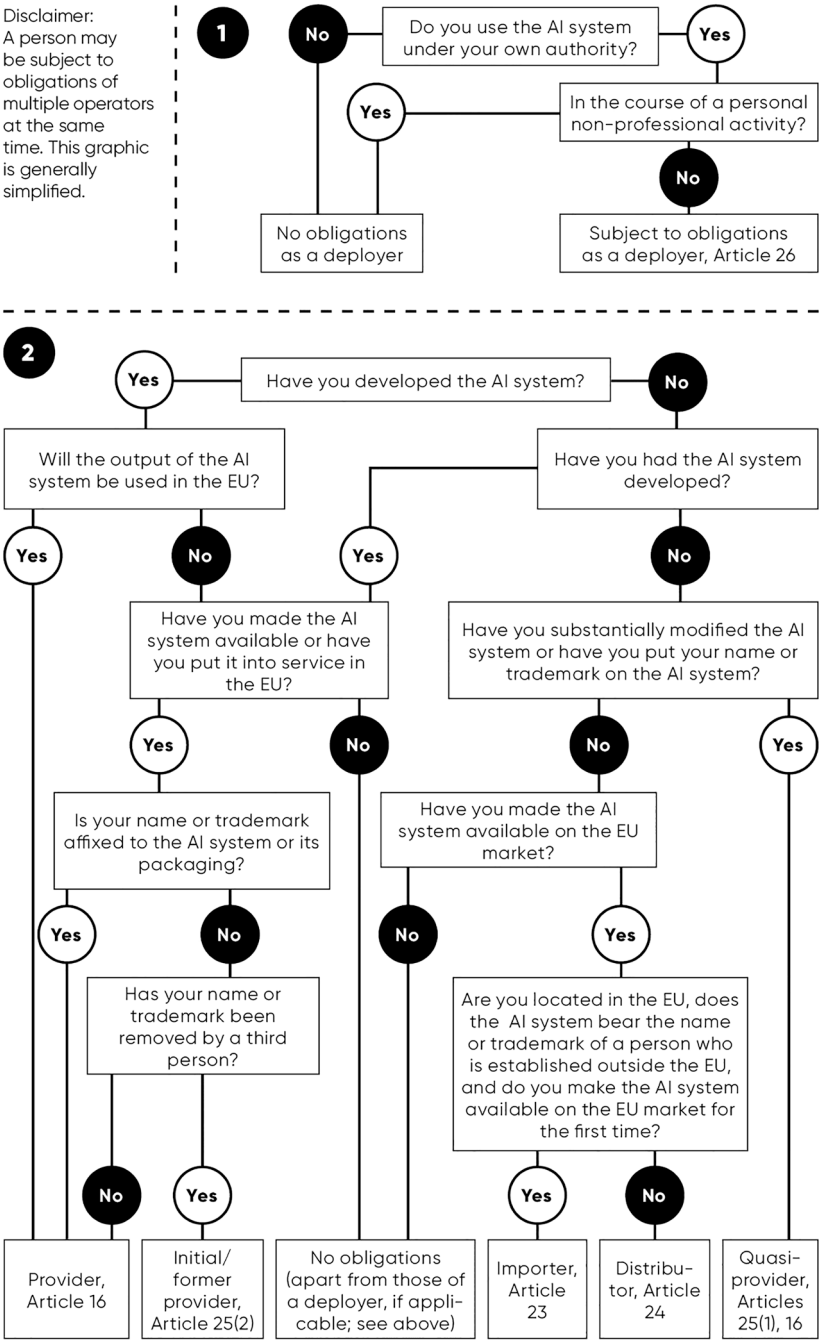


Fig. 1.2 Overview of operators of AI systems

system or GPAI model themselves but have had it developed. Only in these cases the definition of providers should be limited. The second interpretation is supported by the fact that the AI Act also explicitly applies to providers if only the output of their AI system is used in the EU (see Article 2(1)(c), see Sects. 1.3.9 and 1.3.10). Whether the AI system is previously made available on the EU market by this person is therefore irrelevant as long as the output is used in the EU. If this person was then not considered a provider because they did not make the AI system available in the EU, the provision on the scope would have no relevance.

A **trademark** is a distinctive sign or indicator that is used to identify that the AI system originates from a particular provider and to distinguish it from AI systems of other providers. Components of a trademark can be texts and graphic representations, e.g. a name, a word or a slogan, a logo, a picture or another representation. The AI Act does not require a trademark to be registered in the trademark register.

The AI Act does not directly specify which actions are considered to be part of the **development** of an AI system or a GPAI model. Anyone who significantly modifies an AI system (see Sect. 1.4.3) must also fulfil the obligations of a provider (see Sect. 1.3.7).

Authorities and public bodies can also be providers within the meaning of the AI Act. It is irrelevant whether the AI system is placed on the market or put into service for payment or free of charge. Providers of AI systems are equivalent to manufacturers of products in other areas of product safety law.

Distributors, importers, deployers or other third parties may also be considered **providers**, if they substantially modify an AI system or present themselves as providers (Article 25(1); for a more detailed explanation, see Sect. 1.3.7). The **initial provider** usually no longer is considered the provider of the AI system (Article 25(2)) but is obliged to cooperate with the new provider to ensure the conformity of the AI system.

If AI systems are related to products covered by EU product safety laws (Annex I), **the product manufacturer**, who has manufactured the product with AI features, may also be considered **a provider** under the AI Act (Article 25(3); for the requirements, see also Sect. 1.3.7).

Related Topics

Placing on the market: Sect. 1.4.1.

Making available on the market: Sect. 1.4.1.

Putting into service: Sect. 1.4.2.

Intended purpose: Sect. 1.4.2.

Substantial modification: Sect. 1.4.3.

High-risk AI systems: Sect. 1.2.4 and Chap. 3.

Quasi provider: Sect. 1.3.7.

Conformity assessment: Sect. 6.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 4.2.2, p. 57 (on trademarks in product safety law).

1.3.2 Who Is a Deployer?

Article 3(4)

Recital 13 (Deployer)

A deployer is anyone who **uses** an AI system **under their own authority**, unless the AI system is used in the course of a personal non-professional activity. If an AI system is used in the course of a purely personal non-professional activity, the AI Act does not apply (Article 2(10), see Sect. 1.3.11).

Therefore, anyone who uses an AI system commercially is a deployer under the AI Act. Deployers can also be public authorities and public bodies. In contrast, consumers who use AI systems are not deployers within the meaning of the AI Act. The AI Act deviates from other areas of product safety law, where the persons using a product are generally acknowledged as end-users. For other EU product safety legislation, both commercial and private users of products are regularly referred to as 'end-users' who are typically not subject to obligations. This is different under the AI Act, that differentiates between commercial and private users of AI systems. Commercial users are subject to obligations in order to minimise the risks of AI deployment (see Sects. 3.4 and 4.3 to 4.5). Hence, commercial users of AI systems are considered 'deployers' to distinguish them from private end-users that are not subject to obligations in the AI Act. This way, the AI Act also clarifies the difference between deployers under the AI Act and end users under other EU harmonisation legislation.

The AI Act does not include any explicit statements on the **distinction between personal non-professional activities** that are not subject to the AI Act and other activities to which the AI Act applies.

The AI Act also does not specify when an AI system is used **under someone's own authority.** This question is particularly important in contractual relationships. In employment relationships, it can be assumed that the employer uses the AI system under their own authority, while the employee does not. In other cases, it is likely to depend on who is in the position to decide on the conditions and circumstances of the use of the AI system. All relevant circumstances of the specific situation must be taken into account. This distinction is particularly challenging in the context of **SaaS** (*Software-as-a-Service*), where the provider makes AI-based software available to the user on the provider's server (or on a third party's server). Generally, the user has control over the use of the AI application, meaning that they are usually deemed as the deployer of the AI system. Thus, the SaaS provider is

also the provider of the AI system (if the AI system was developed by the SaaS provider or is distributed under its own name). However, the situation is different for AI platforms that allow users to create their own AI systems, e.g. by combining various elements (AI models, software modules, tools, etc.) and run them 'in the cloud' or on their own infrastructure.

There is no deployer for GPAI models, as an AI model cannot be used independently. If a GPAI model is integrated into a GPAI system, the general requirements mentioned above also apply to deployers of GPAI systems.

1.3.3 Who Is an Importer?

Article 3(6)

Recitals 83 (Operators along the value chain), 84 (Quasi provider)

An importer is anyone who

- is located or established in the EU and
- makes available on the EU market for the first time
- an AI system bearing the name or trademark of a natural or legal person established in a third country.

'Importer' is a known term in product safety law. 'Importers' are persons who place a product on the market in the EU for the first time. To determine if someone is an importer is straightforward for physical goods including AI elements, as the same principles apply as with other conventional physical products. However, the AI Act also covers AI systems that are only provided digitally as software. Hence, the traditional supply chain for physical products does not apply. This raises the question of whether a digital importer is also conceivable under the AI Act. At least in theory, the above-mentioned requirements could also be met if software is provided digitally.

There are no importers of **GPAI models,** as there are only obligations for importers of AI systems under the AI Act.

Related Topics

Making available on the market: Sect. 1.4.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.3, pp. 39–41.

1.3.4 Who Is a Distributor?

Article 3(7)

Recitals 83 (Operators along the value chain), 84 (Quasi provider)

A distributor is anyone who makes an AI system available on the market in the EU without being a provider or importer. This means that a distributor makes an AI system available on the market under the name or trademark of another person, after the same product has already been initially placed on the market.

There are no distributors for GPAI models, as there are only obligations for distributors of AI systems under the AI Act.

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.4, pp. 41–43.

1.3.5 Who Is the Product Manufacturer?

Article 25(3)

Recital 87 (Product manufacturer)

In certain cases, the product manufacturer can be considered the provider of an AI system (see Sect. 1.3.1).

The AI Act does not contain an own definition of who is the manufacturer of a product. Instead, the assessment will depend on whether a person is regarded as the manufacturer of a product under EU harmonisation legislation (see Sect. 3.1.1). Typically, the manufacturer is the person who is responsible for the design and manufacture of the product and places the product on the market under its own name or trademark.

The manufacturer of a product is considered to be the provider of a high-risk AI system if the product is an AI system or contains an AI system as a safety component (see Sect. 1.3.7).

Related Topics

Provider: Sect. 1.3.1.

Products that are high-risk AI systems: Sect. 3.1.1.

Quasi provider: Sect. 1.3.7.

Obligations for product manufacturers: Sect. 3.5.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.1, pp. 34–38 (on the manufacturer in product safety law).

1.3.6 Who Is an Authorised Representative Under the AI Act?

Article 3(5)

Recital 82 (Authorised representative)

An authorised representative is a person mandated by a non-EU provider who can be contacted by the competent authorities alongside or in place of the provider with regard to all obligations arising from the AI Act. The representative who has to be located or established in the EU is (together with the provider) responsible for the conformity of the AI application. The authorised representative must have received and accepted a written mandate from the provider that confers the necessary powers to represent the provider vis-à-vis other operators and authorities for the purposes of the AI Act.

Related Topics

Designation of the authorised representative: Sect. 1.3.10.

Duties of the authorised representative: Sects. 3.5.4 (High-risk AI systems) and 5.5.1 (GPAI models). ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.2, pp. 38–39.

1.3.7 Under What Circumstances Are Distributors, Importers, Deployers and Other Third Parties Considered Providers of High-Risk AI Systems?

Article 25

Recitals 79 (Provider who has not designed or developed the AI system), 83 (Operators along the value chain), 84 (Quasi provider), 85 (Providers of GPAI systems), 86 (Relationship between quasi provider and former provider), 87 (Product manufacturer)

Distributors, importers, deployers, and other parties involved in the AI value chain can, under certain circumstances, be **considered providers**, even though the AI system used has already been placed on the market by another provider (the so-called 'initial provider'). On the one hand, this concept is intended to ensure legal certainty. On the other hand, the AI Act intends to **distribute the provider obligations and obligations to cooperate fairly and appropriately** between the different parties of the AI value chain.

Distributors, importers, deployers or other third parties are **considered to be providers** (Article 25(1)) if they fulfil at least one of the following conditions:

- They **put their name** or **trademark** on a high-risk AI system that has already been placed on the market or put into service, without prejudice to any contractual agreement providing for a different allocation of obligations (point a);
- They make a **substantial modification** (see Sect. 1.4.3) to a high-risk AI system that has already been placed on the market or put into service in such a way that the AI system remains a high-risk AI system (point b).

- They modify the **intended purpose** (see Sect. 1.4.2) of an AI system (including a GPAI system) that has not been classified as high risk and has already been placed on the market or put into service in such a way that the AI system concerned becomes a high-risk AI system (point c).

If one of these conditions is met, there is a **change of roles and obligations.** Consequently, the provider who has initially placed the AI system on the market or put it into service is no longer considered to be the provider of the respective AI system (Article 25(2)). As a result of the substantial change, the new provider must usually also undergo a new conformity assessment procedure (see Sect. 6.1.6).

However, the **initial provider** is obliged to **cooperate** with the **new provider**. In this context, the initial provider shall provide the necessary information, technical access, and other assistance that can reasonably be expected, in particular with regard to compliance with the (renewed) conformity assessment, if necessary, for an additional fee. The intellectual property rights, confidential business information and trade secrets of the parties involved must be protected. By derogation, initial provider's are not obliged to cooperate with the new provider if the initial provider has clearly stated (e.g. in relevant terms and conditions) that its AI system is not to be changed into a high-risk AI system.

If **products fall** within the scope of certain **EU harmonisation legislation** (Annex I Section A, see Sect. 3.1.1.1), the product manufacturer shall be considered the provider of the high-risk AI system if the high-risk AI system is placed on the market or put into service under its name or trademark (Article 25(3)). In both cases, the **manufacturer** assumes the **responsibility for the conformity** of the AI system and is subject to the respective provider obligations of the AI Act (see Sect. 3.3).

Related Topics

Provider: Sect. 1.3.1.

Intended purpose of an AI system: Sect. 1.4.2.

Substantial modification: Sect. 1.4.3.

Products that are/contain high-risk AI systems: Sect. 3.1.1.1.

Provider obligations: Sect. 3.3.

Renewed conformity assessment procedure: Sect. 6.1.6. ◄

1.3.8 Can One Entity Take on the Roles of Several Operators at the Same Time?

Article 3(7)

Recital 83 (Operators along the value chain)

Being considered as an operator does not preclude a person from holding another additional role at the same time for the same AI system. The roles of the different operators are not mutually exclusive. It is possible that one person fulfils the requirements of several roles at the same time and must then also fulfil the obligations of several operators in parallel. For example, the AI Act states that an operator can be **both a distributor and an importer** at the same time (Recital 83). However, this example contradicts the notion of 'distributor' that expressly includes the requirement that only someone who is not an importer shall be a distributor (Article 3(7)). Moreover, the example does not provide for additional clarity, since the obligations of an importer largely overlap with the obligations of a distributor and only some special obligations are added, making the combination of both sets of obligations redundant (see Sects. 3.5.2 and 3.5.3). It therefore seems more likely that a person would only be considered an importer in relation to one AI system and a distributor in relation to another AI system.

The **importer or distributor** may also be **a deployer** of the AI system at the same time, if it also uses the AI system it has made available on the market under its authority.

In addition, a **provider** can **also** be the **deployer** of its AI system if it uses it itself.

Related Topics

Operators' obligations in high-risk AI systems: Sects. 3.3 to 3.5. ◀

1.3.9 What Is the Territorial Scope of the AI Act?

Article 2(1)

Recitals 21 (Level playing field), 22 (Applicability to third countries), 23 (Applicability to EU institutions and bodies)

There are various circumstances that lead to the territorial application of the AI Act:

- According to the **principle of establishment** the AI Act
  - applies to deployers of AI systems if they have their place of establishment in the EU or are located in the EU (Article 2(1)(b)). The AI Act does not clarify the requirements under which a deployer is deemed to be located in the EU. However, this should at least be the case if it has an establishment in the EU (see Recital 21). Such an establishment requires a fixed facility (e.g. an office) and the effective exercise of an activity in the EU; these requirements may already be met if there is a letterbox and an employee in the EU. The AI Act does not state expressly that the AI system must also be used in this

establishment in the EU, although this seems to be a reasonable restriction to its territorial scope.

- According to the **principle of destination,** the AI Act applies to
  - all **providers placing** an AI system or GPAI model on the EU market or putting an AI system into service in the EU (Article 2(1)(a));
  - all **providers and deployers** of AI systems if the output produced by their AI systems is used in the EU (Article 2(1)(c)).
    This aspect of the territorial scope of the AI Act is particularly unclear, as it could lead to a very broad scope of application (for more detail, see Sect. 1.3.10);
  - all **importers and distributors** making an AI system available on the market in the EU (Article 2(1)(d)); and
  - all **product manufacturers** who place an AI system on the market or put it into service together with their product and under their own name or trademark (Article 2(1)(e)).

In addition, the AI Act applies to **authorised representatives** mandated by a provider (Article 2(1)(f)) and in favour of **affected persons** located in the EU (Article 2(1)(g)). This latter aspect remains unclear. It is neither explained when a person is affected nor how the AI Act is intended to apply to these persons. It can best be understood from a functional perspective. The AI Act confers certain rights to persons affected by AI systems under certain conditions (see Sect. 1.7). Without an express provision on the scope of the AI Act, affected persons could probably not claim their rights. Hence, the extension of the scope to cover persons affected should be understood to mean that persons affected can exercise their rights under the AI Act.

The AI Act also applies to EU institutions, bodies, offices and agencies that are providers or deployers of AI systems.

Related Topics

Operators: Sect. 1.3.

Rights of data subjects: Sect. 1.7. ◀

1.3.10 What Requirements Apply to Companies Outside the EU?

Articles 2(1), 22(1), 54(1)

Recitals 21 (Level playing field), 22 (Applicability to third countries), 82 (Authorised representative)

According to the principle of destination, the AI Act applies to

- all providers outside the EU who place AI systems on the market or put them into service in the EU or who place GPAI models on the market in the EU.
- all providers and deployers of AI systems that have their place of establishment or are located outside the EU, if the output produced by their AI systems is used

in the EU. The latter aspect of the territorial scope of the AI Act is particularly unclear. In particular, the wording does not require the intent that the output is used in the EU. Thus, even a de facto use of the AI generated outcome against the will of the provider could trigger the AI Act. Such a broad scope of application would lead to noticeable challenges in determining when non-EU operators are subject to the AI Act. However, as illustrated in Recital 22, a wide territorial scope seems to be intended. Recital 22 provides the example of an operator established in the EU that has an AI-based service performed by an operator in a third country. Recital 22 calls for the application of the AI Act to the third-country operator in order to avoid the circumvention of the AI Act. However, at the same time the example suggests that in any case at least some link to the EU is required, e.g. because the performance of the task is initiated by an actor within the EU. Thus, the AI Act is not intended to cover all operators using or developing AI systems when the output is used in the EU. Consequently, the AI Act should only be applied to AI systems if the use of the output within the EU is foreseeable. Generally, this will only be the case when a contractual relationship exists with an operator in the EU. This position if further supported by the fact that Recital 22 refers to an otherwise imminent 'circumvention' of the AI Act.

In addition to all other requirements of the AI Act, providers without an establishment in the EU must **appoint** an **authorised representative** established in the EU before making their high-risk AI systems or GPAI models available on the EU market (Articles 22(1) and 54(1); see Sect. 1.3.6). This authorised representative must be appointed by written mandate before making the high-risk AI system or the GPAI model available on the EU market. However, if only the outputs of an AI system are used in the EU, there is no making available on the EU market. Therefore, the requirement to appoint an authorised representative does not apply to providers whose AI systems are only subject to the AI Act, because the output of the system is used within the EU.

Related Topics

Authorised representative: Sect. 1.3.6.

Territorial scope and principle of destination: Sect. 1.3.9.

Obligations of the authorised representative: Sects. 3.5.4 (High-risk AI systems) and 5.5.1 (GPAI models). ◀

1.3.11 Which Operators Are Excluded from the Scope of the AI Act?

Article 2(4) and (10)

Recitals 13 (Deployer), 22 (Applicability to third countries)

The AI Act does not apply to persons who use an AI system in the context of an **exclusively personal and non-professional activity** (see Sect. 1.3.2).

The AI Act also does not apply to

- **public authorities in a third country** outside the EU and
- **international organisations**, such as the UN,

insofar as these third countries or international organisations use the AI systems in the framework of international cooperation or agreements with the EU or its member states in the field of law enforcement and judicial cooperation and provide adequate safeguards to protect the fundamental rights and freedoms of individuals.

In addition, the AI Act also provides for exemptions from its scope for certain types of AI applications.

Related Topics

Exemptions of certain AI applications from the AI Act's scope: Sect. 1.2.7. ◄

1.3.12 What Special Provisions Apply to SMEs, Including Start-Ups?

Articles 11(1), 62, 95(4), 96(1), 99(1) and (6), 63(1) in conjunction with Article 2(3) Recommendation 2003/361/EC

Recitals 8 (Balancing innovation and protection of fundamental rights), 109 (Proportionality of compliance), 121 (Standardisation requests), 139 (Objectives of AI regulatory sandboxes), 143 (Facilitation for SMEs), 145 (AI on demand platform), 146 (Facilitated quality management system for micro-enterprises), 150 (Advisory forum), 168 (Sanctions)

The legislator expressly wants to minimise the burden on **small and medium-sized enterprises (SMEs),** which also include start-ups (Recital 143). At EU level, SMEs are defined in Commission Recommendation 2003/361 as companies whose staff and economic weight do not exceed the following **thresholds:**

- Medium-sized companies have up to 250 employees, an annual turnover of up to EUR 50 million and/or an annual balance sheet total of up to EUR 43 million;
- Small companies have up to 50 employees and a turnover and/or balance sheet total of up to EUR 10 million;
- Micro-enterprises have up to ten employees and a turnover and/or balance sheet total of up to EUR 2 million.

The organisational and financial effort that a company has to make to comply with the AI Act does not necessarily depend on its size. As a result, the **financial and organisational burden for SMEs** is usually higher in relation to their size than for

larger companies. The AI Act is intended to counteract this with a number of simplifications and thus promote the development of **start-ups and innovation in the EU**, in particular:

- SMEs that develop high-risk AI systems are allowed to provide the **technical documentation** (see Sect. 3.2.4) using a **simplified form** that the European Commission is developing for this purpose and that is intended to be tailored to the needs of SMEs (Article 11(1)). For the conformity assessment (see Sect. 6.1), this simplified form is recognised as an equivalent technical documentation and, if applicable, shall be accepted by the notified bodies.
- SMEs having a registered office or a branch in the EU are given **priority access to AI regulatory sandboxes** (see Sect. 6.3.1; Article 62(1)(a)).
- EU member states must provide **SME-specific training** on the AI Act and provide information on its application and use new or existing dedicated information channels to support SMEs in applying the AI Act (Article 62(1)(c) and (b)).
- EU member states should encourage the participation of SMEs in the **development of harmonised standards** (see Sect. 7.6.3; Article 62(1)(d)).
- The **fees for the conformity assessment** (see Sect. 6.1) must be reduced depending on the size of the company so that they are lower for SMEs (Article 62(2)).
- The **AI Office** (see Sect. 6.2.3) is to take a whole range of supporting measures (Article 62(3)) to help SMEs, but also other providers and deployers, to implement the AI Act:
  - Provision of standardised templates for the AI Act;
  - Establishment of a single information platform to provide easy-to-use information on the AI Act;
  - Realisation of information campaigns;
  - Evaluation and promotion of the exchange of best practices in public procurement procedures regarding AI systems.
- When **drawing up voluntary codes of conduct** for the application of high-risk obligations to low-risk AI systems (see Sect. 1.6.2), the special needs of SMEs should be taken into account (Article 95(4)).
- When drawing up **guidelines for the implementation of the AI Act,** the European Commission should pay particular attention to the needs of SMEs (Article 96(1), first sentence).
- When **imposing sanctions** (see Sect. 6.2.9), the interests of SMEs and their survival must be taken into account (Article 99(1)). Fines should be lower for SMEs. The framework for fines is generally based on a fixed lump sum or a percentage of the annual global turnover, whichever is higher. For SMEs, however, the lower value is the upper limit for fines (Article 99(6)).
- In addition, SMEs and start-ups must be considered in a balanced manner in the composition of the **advisory forum** that advises the AI Committee and the Commission (see Sect. 6.2.3; Article 67(2)).

Micro-enterprises (with fewer than 10 employees and an annual turnover of less than 2 million euros, see above) can implement the quality management system (see Sect. 3.3.1) in a simplified form, provided that the level of protection and the requirements of the AI Act are not undermined (Article 63). The European Commission provides guidelines on this.

In addition, existing institutions to promote research and innovation in Europe, such as the **AI on Demand platform** (available at aiod.eu), the **European Digital Innovation Hubs** (EDIH) and existing **Test and Experiment Facilities** (TEF) as well as the relevant **EU funding programmes** (such as Digital Europe and Horizon Europe) are intended to support SMEs in particular in building up AI-specific knowledge and expertise (Recital 145).

Related Topics

Voluntary codes of conduct: Sect. 1.6.2.

Requirements for high-risk AI systems: Sect. 3.2.

Provider obligations for high-risk AI systems: Sect. 3.3.

Conformity assessment procedure: Sect. 6.1.

Harmonised standards: Sect. 7.6.3. ◀

▶ **Further Information** *European Commission,* European Digital Innovation Hubs (2023), Commission launches AI innovation package (2024), Sectorial AI Testing and Experimentation Facilities under the Digital Europe Programme (2024).

1.4 Through What Actions Do Operators Trigger the Application of the AI Act?

Article 2(1), (9) to (12)

The AI Act applies to AI systems and GPAI models that have been placed on the market or put into service in the EU and, according to the very broad wording, also to AI systems whose output is used in the EU (see Sect. 1.3.10). In addition, the AI Act also applies to AI systems that were placed on the market or put into operation before the date of application of the AI Act, provided that these AI systems are substantially modified after the date of application (see Sect. 1.5.2). When an AI system is considered to have been placed on the market, put into service or substantially modified is described below.

Related Topics

Territorial scope of the AI Act: Sect. 1.3.9.

Requirements for companies outside the EU: Sect. 1.3.10.

Application of the AI Act to older AI systems in the event of a substantial modification: Sect. 1.5.2. ◀

1.4.1 When Is an AI Application Placed on the Market?

Article 3(9) and (10)

Recital 97 (GPAI models)

An AI system or GPAI model is placed on the market when it is made available on the EU market for the first time. Making available on the market means that the AI system or GPAI model is supplied for distribution or use on the EU market in the course of a commercial activity, whether in return for payment or free of charge.

In the case of physical products, such as self-driving cars, smart agricultural machinery or augmented reality glasses, making available on the market can be interpreted in the tradition of conventional product safety legislation by **physically supplying** the product, i.e. by handing the product over and thus transferring de facto control of the product. In the context of the AI Act, making available can also span a longer period of time if, for example, the AI model is not included in a product, but continuously connected to the product via the internet.

With regard to digital AI systems, such as AI chatbots, image generators or AI-based software for process optimisation, making available (as also described in Recital 97) takes place by granting access to the system, e.g. through downloads or via an application programming interface (API). Thus, digital AI systems can also be **supplied digitally**. Supplying the AI system digitally requires the provider to make the AI system accessible to its contracting party. Parallels can be drawn from the so-called Digital Content Directive (see Article 5(2)(a) and (b) of Directive (EU) 2019/770), which stipulates the conditions for the supply of digital content. According to the Digital Content Directive, the supply of digital content can be performed through making the content itself or any means suitable for accessing or downloading the content available or accessible to a recipient or to a physical or virtual facility of a recipient. However, digital AI systems can still be made available physically (e.g. on a data carrier).

For both physical and digital products, it does not matter whether the product is provided on a temporary or permanent basis, i.e. via a sale or as a service.

In other laws within the New Legislative Framework, a product is made available in the course of a **commercial activity** if the supply takes place in a business-related context. This does not necessarily require an intention to make a profit, but occasional supplies by charities and hobbyists should not be covered. As established under existing product safety legislation, the assessment of whether an activity is commercial should be based on the circumstances of each individual case. Criteria may include the regularity of the supplies, the characteristics of the AI system and the intentions of the operator.

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), points 2.2 and 2.3, pp. 19–21.

1.4.2 When Is an AI Application Put into Service?

Article 3(11) and (12)

An AI system is put into service when it is supplied in the EU for first use directly to the deployer, or for own use, in accordance with its intended purpose (Article 3(11)). This supply can take place physically or digitally (see Sect. 1.4.1).

The intended purpose is the use for which the provider has intended the AI system, including the specific circumstances and conditions of use as specified in the information supplied by the provider in the instructions for use, promotional or sales materials and statements as well as in the technical documentation (Article 3(12)). Particularly in the case of AI systems with multiple or undetermined uses, such as GPAI systems, the question arises as to how the intended use is to be distinguished from other possible yet unintended uses. Not all potential purposes of a GPAI System should be understood as intended purposes, but only those that the provider has already specified as fields of application. The notion of 'general purpose AI' refers to the objective capabilities, regardless of the provider's intentions. The intended purpose, in contrast, exclusively refers to the provider's subjective intentions. This distinction is also supported by the fact that a reasonably foreseeable misuse (see below) is not covered by the intended purpose. Accordingly, the intended purpose should not depend on the provider's knowledge as to how the AI system might be used, but only on the purposes that the provider has willingly assigned to the AI system. In practice, this distinction becomes relevant, e.g., if a GPAI system is used by a deployer in a high-risk use case (see Sect. 3.1.2) which the provider has not (expressly) intended the GPAI system to be used in. In such a case, the previous deployer who has changed the intended purpose could possibly be considered the provider of this new modified high-risk AI system (see Sect. 1.3.7).

A **reasonably foreseeable misuse** means the use of an AI system in a way that is not in accordance with its intended purpose, but which may result from reasonably foreseeable human behaviour or reasonably foreseeable interaction with other systems, including other AI systems (Article 3(13)). The foreseeability of a misuse will depend on how an average deployer is likely to use the AI system.

The reasonably foreseeable misuses are to be included in the risk management system (see Sect. 3.2.1) and in the instructions for use (see Sect. 3.2.6), but not when determining whether an AI system is put into service or whether it is considered a high-risk AI system based on its use case (see Sect. 3.1.2).

A GPAI model cannot be put into service independently. Only once a GPAI model has been integrated into an AI system, it can be put into service in accordance with the aforementioned requirements (Recital 97; for more details, see Sects. 1.2.2 and 1.2.6).

Related Topics

(Digital) supply: Sect. 1.4.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 2.6, pp. 23–26.

1.4.3 When Is an AI System Substantially Modified?

Articles 3(23), 43(4), 96(1)(f)

Recitals 84 (Quasi provider), 128 (Substantial modification)

An AI system is **substantially modified** if the AI system or its intended purpose is subsequently changed after the system has been placed on the market or put into service, in a way that was not foreseen or planned in the initial conformity assessment carried out by the provider. This triggers the requirement for a new conformity assessment (Article 3(23); see Sect. 6.1.6). Changes made autonomously by a self-learning AI system through its adaptability after being placed on the market are not considered to be substantial modifications if they were already taken into account in the initial conformity assessment (Article 43(4)). The European Commission is to issue guidelines to implement the requirements on substantial modifications (Article 96(1)(f)).

Related Topics

Becoming a provider due to substantially modifying an AI system: Sect. 1.3.1.

Conformity assessment after a substantial modification: Sect. 6.1.6. ◀

1.5 When Does the AI Act Apply?

1.5.1 When Does the Application of the AI Act Begin?

Article 113

Recitals 177 (Transitional arrangements), 178 (Voluntary early application), 179 (Date of application)

The AI Act entered into force on 1 August 2024 and applies in principle from 2 August 2026 (24 months from the date of its entry into force). As an EU regulation, it is directly applicable and does generally not require transposition into national law. By way of exception, the member states must still transpose some provisions (i.e. mainly those provisions regarding the powers of market surveillance authorities and sanctions) into national law.

Derogating from the 2 August 2026, some provisions of the AI Act will become applicable from different dates (see also Fig. 1.3):

- From 2 February 2025, the **prohibition of certain AI practices** will apply.
- From 2 August 2025,
  - the requirements for **notified bodies** and their notification will apply (Section 4 of Chapter III of the AI Act, Sect. 6.1.3.1);
  - the **obligations for GPAI models will** apply (Chapter V of the AI Act; see Chap. 5);
  - the provisions on **institutional governance at EU level will** apply (Chapter VII of the AI Act; see Sect. 6.2.3); and
  - the **provisions on sanctions will** apply (Chapter XII of the AI Act; see Sect. 6.2.9).
- From 2 August 2027, the **requirements for high-risk AI systems that are products** or safety components of such products and the corresponding obligations for operators will apply (see Chap. 3).

1.5.2 Does the AI Act Also Apply to AI Applications That Were Placed on the Market or Put into Service Before Its Entry into Force?

Article 111

Recitals 177 (Transitional arrangements), 178 (Voluntary early application), 179 (Date of application)

In principle, the AI Act does not apply to AI applications that were placed on the market or put into service before the AI Act entered into force. Only the prohibitions of certain AI practices also apply to AI systems that were placed on the market or put into service before the AI Act entered into force.

In addition, there are some cases in which the AI Act is exceptionally applied to AI systems and GPAI models even though they were placed on the market or put into service before the AI Act was applicable. These cases are as follows:

- Operators of **AI systems** that were placed on the market or put into service before 2 August 2026 have to comply with the requirements of the AI Act in the case of **significant changes** to their design (Article 111(2)). Significant changes should be understood as equivalent to the concept of substantial modification (Recital 177; see Sect. 1.4.3).
- Providers of **GPAI models** placed on the market before 2 August 2025 have to comply with the requirements from 2 August 2027 (Article 111(3)).

There are also two additional transitional rules for the public sector:

- If **high-risk AI systems are intended to be used by public authorities**, all providers and deployers of such systems must fulfil the requirements of the AI Act from 2 August 2030 at the latest (Article 111(2)).
- If AI systems are **components of certain European information systems** in the area of Freedom, Security and Justice (Annex X), e.g. the Schengen Information System, and were placed on the market or put into service before 2 August 2027,

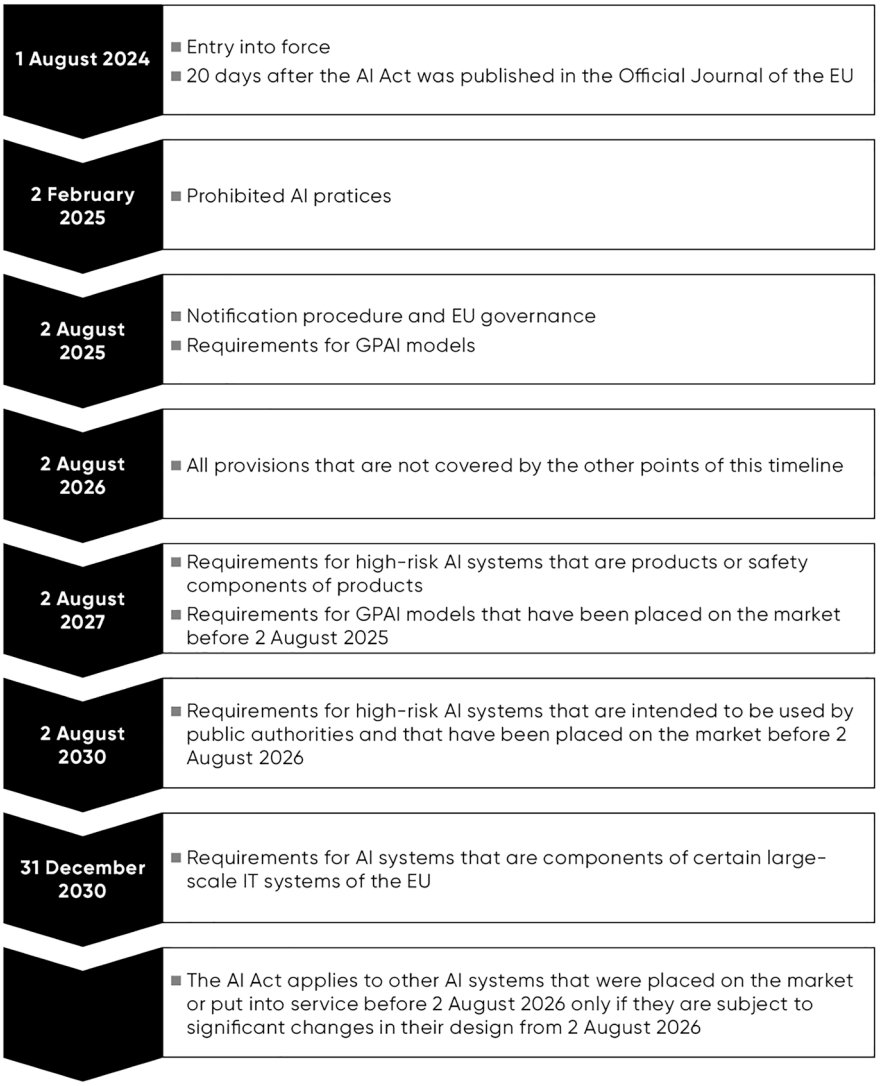


Fig. 1.3 Temporal scope

they have to comply with the requirements of the AI Act by 31 December 2030 (Article 111(1)).

1.6 What Are the General Minimum Requirements for All AI Systems?

Articles 4, 74(1) and 95

Recitals 20 (AI literacy), 26 (Risk-based approach), 27 (AI ethics guidelines), 156 (Market surveillance system), 165 (Codes of conduct for voluntary application), 166 (General product safety regulation as a safety net)

The AI Act generally follows a risk-based approach. The obligations of operators depend on the risk classification of their specific AI systems and the categorisation of the operator itself. For this reason, the AI Act **only contains limited general obligations** that apply to all AI systems (see Sect. 1.6.1). Providers of AI systems that are not high-risk can apply further provisions voluntarily (see Sect. 1.6.2).

In addition, the General Product Safety Regulation (GPSR; Regulation (EU) 2023/988) may also cover products that are related to AI systems and are not considered high-risk under the AI Act (Recital 166; see Sect. 1.6.3). However, AI systems are only subject to the GPSR if they are in scope. This requires, among other things, that they are intended or likely to be used by consumers under reasonably foreseeable conditions (see Sect. 7.3).

1.6.1 What Are the Requirements for Promoting AI Literacy?

Article 4

Recital 20 (AI literacy)

All providers and deployers of AI systems must promote AI literacy of persons dealing with AI. Therefore, these operators shall take measures to ensure—to the best extent possible—a sufficient level of competence of their staff and other persons dealing with the operation and use of AI systems on their behalf. The knowledge and skills of these persons and the context in which the AI systems are used must be considered. In addition, the users of the AI system should be taken into account, for example, whether the use of a system involves particularly vulnerable persons or groups of persons that are particularly prone to being discriminated against.

The exact scope of the AI literacy requirements remains uncertain. For AI systems that are not subject to any specific transparency obligations or considered high risk, the requirement is likely to be of a rather unspecific nature, i.e. basic trainings in dealing with AI might often be sufficient to comply with the requirement to promote AI literacy. With respect to minimal-risk AI systems (to whom no specific requirements apply), AI literacy will probably become relevant, for example, in the drafting and application of voluntary codes of conduct (see Sect. 1.6.2).

The AI Board (see Sect. 6.2.3), together with the European Commission, should support the promotion of AI literacy, for example through AI literacy tools (Recital 20). In any case, relevant operators should be interested in ensuring that their employees, freelancers and other service providers are sufficiently trained to use their AI systems as competently as possible and to avoid any harm. It is therefore advisable to check which persons will interact with AI systems and train them accordingly. General and role-specific privacy and security education is already familiar to many companies. Such existing training measures can be leveraged and extended to also cover AI literacy.

1.6.2 What Are Codes of Conduct for Voluntary Application?

Article 95

Recital 165 (codes of conduct for voluntary application)

In addition to the obligation to promote AI literacy, there are no mandatory requirements in the AI Act for operators developing, marketing or using AI models or AI systems with minimal risk, i.e. operators of AI systems that are neither prohibited nor considered high risk nor subject to specific transparency requirements. Providers and deployers of AI systems that are not considered high risk are only encouraged to apply specific requirements of the AI Act on a voluntary basis. To this end, **codes of conduct** are to be drawn up **for voluntary application** (Article 95). With these codes of conduct, providers and deployers can voluntarily commit themselves to apply the obligations for operators of high-risk AI systems to AI systems that are not considered high risk under the AI Act. Individual operators as well as organisations representing them, other stakeholders, and civil society organisations (e.g. universities) can draw up such codes. The AI Office (see Sect. 6.2.3) and the national authorities should promote and facilitate the establishment of such codes.

1.6.3 What General Safety Requirements Can Be Applicable to AI Systems?

Article 74(1)

Recital 166 (General Product Safety Regulation as a safety net)

All AI systems in scope of the AI Act (see Sect. 1.2.1) are considered as products within the meaning of the Market Surveillance Regulation (Article 74(1)). Consequently, market surveillance authorities may take action against AI systems even if they are neither high risk nor prohibited nor subject to specific transparency obligations. In this case, the market surveillance measures are not connected to breaches of the obligations under the AI Act, but depend on whether a specific AI system presents a risk to the health or safety or fundamental rights of individuals (Article 79(1)). For the market surveillance authorities to (be allowed to) take measures, an AI system must present such risks (for more details, see Sects. 6.2.4 and 6.2.4.3). The aim is to cover the potential case that an AI system is not subject to any obligations under the AI Act and nevertheless puts health, safety or fundamental rights of a person at risk. However, this scenario is unlikely and measures against AI systems that are not subject to specific requirements or obligations under the AI Act should be taken in exceptional circumstances only.

In addition, products related to AI systems may fall within the scope of the **General Product Safety Regulation** (EU) 2023/988 (Recital 166 of the AI Act; see Sect. 7.3). Stand-alone software, which is not embedded in a product (embedded software), does not fall into the scope of the General Product Safety Regulation.

Related Topics

Market surveillance: Sect. 6.2.

General Product Safety Regulation: Sect. 7.3. ◄

► **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022).

1.6.4 What Are the AI Ethics Guidelines?

Recital 27 (AI ethics guidelines)

The results of the 'Independent High-Level Expert Group on Artificial Intelligence' (AI HLEG), which was set up by the European Commission in 2017, can serve as an aid for the design of concepts to promote AI literacy and for the design of codes of conduct for voluntary application. Inter alia, the AI HLEG has published ethical guidelines for trustworthy AI and developed seven corresponding principles (human agency and oversight; technical robustness and safety; privacy and data governance; transparency; diversity, non-discrimination and fairness; societal and environmental well-being; accountability). These principles are **non-binding**. However, the AI Act takes them up as part of the obligations for risky AI use-cases and makes them into legally binding requirements. Thus, operators subject to obligations under the AI Act may use the ethic principles to better understand their obligations and the legislator's ratio behind the provisions of the AI Act. Operators not subject to obligations under the AI Act can take the principles into account voluntarily and at their own discretion.

In September 2024, the European Commission launched the so-called AI Pact, which calls upon companies to sign on to voluntary commitments anticipating core principles of the AI Act before its provisions become fully applicable. Signatories can choose, according to their role in the AI ecosystem, which commitments to pledge to, and are required to report on the implementation progress to the AI office.

Related Topics

International agreements: Sect. 7.5.1. ◄

► **Further Information** *High-Level Expert Group on AI*, Ethics guidelines for trustworthy AI (2019); *OECD*, Advancing accountability in AI: Governing and managing risks throughout the lifecycle for trustworthy AI (2023).

1.7 What Rights Does the AI Act Grant to Third Parties?

Articles 85, 86, 89(2) and 110

Recitals 9 (Consistency with the New Legislative Framework), 10 (Protection of personal data), 170 (Right to lodge a complaint), 171 (Right to an explanation)

Third party rights and legal remedies arise primarily from other legislation, in particular from data protection law (see Sects. 7.2.6 and 7.2.11) and from contractual agreements. These rights and legal remedies remain in place even after the AI Act has entered into force.

However, the AI Act grants (natural or legal) persons additional rights in three cases:

- Any natural or legal person has the **right to lodge a complaint** with the competent market surveillance authority (Article 85).
- Affected persons have a **right to obtain an explanation** from the deployer of a decision based on a high-risk AI system (Article 86).
- Downstream providers who have integrated a GPAI model into their AI system have the **right to lodge a reasoned complaint** with the AI Office (Article 89(2)).

Insofar as the requirements of the AI Act serve to protect third parties, these third parties may also have **claims** for compensation for damages resulting from violations of the AI Act under national civil law (see Sect. 7.4). These claims are not excluded by the AI Act. The AI Act even aims to facilitate the enforcement of such claims by allowing representative actions under Directive (EU) 2020/1828 with regard to claims arising from the violation of the AI Act (Article 110).

Related Topics

Rights of data subjects under the GDPR: Sects. 7.2.5, 7.2.6 and 7.2.11.

Liability requirements for AI: Sect. 7.4. ◀

▶ **Further Information** *European Commission*, Representative Actions Directive. EU law by topic – Consumer protection law (2023).

1.7.1 What Rights Apply in Case of a Suspected Breach of the AI Act?

Article 85

Recitals 170 (Right to lodge a complaint), 172 (Protection of whistleblowers)

Anyone who has reason to believe that obligations under the AI Act have been infringed may submit a complaint to the competent market surveillance authority. All natural and legal persons have the right to lodge a complaint, even if they are not affected by the infringement of the AI Act. The market surveillance authority must take the complaints into account when conducting market surveillance activities.

The scope of this right to lodge a complaint is unclear, in particular with regard to infringements of GPAI models. There are several arguments in favour of **limiting the right to lodge a complaint to infringements of** obligations and requirements applicable to **AI systems**. First, the fact that there are no market surveillance authorities for GPAI models speaks in favour of this restriction. If there are no competent 'market surveillance' authorities, there are no authorities that a complaint can be

submitted to. The AI Office exercises exclusive supervision over GPAI models without functioning as a market surveillance authority in this regard (see Sect. 6.2.1). Second, granting anyone and everyone the right to lodge a complaint should be restricted because otherwise the right of downstream providers to lodge a reasoned complaint (see Sect. 1.7.3) would have no specific function. The right for downstream providers to lodge a reasoned complaint serves no purpose if anyone can lodge an unreasoned complaint. Therefore, anyone's right to lodge a complaint should not apply if providers of GPAI models violated their obligations under the AI Act. Instead, the right for anyone to lodge a complaint should be limited to infringements of provisions of the AI Act that address AI systems.

Related Topics

Right of appeal for downstream providers: Sect. 1.7.3.

Competent market surveillance authority: Sect. 6.2.1.

Market surveillance procedures: Sect. 6.2.4. ◄

1.7.2 When Does the Right to an Explanation of an AI Based Decision Apply?

Article 86

Recital 171 (Right to an explanation)

In certain cases, persons subject to a decision which is taken on the basis of the output from a high-risk AI system have a right against the deployer to obtain an explanation of this decision. The deployer must then clearly and meaningfully explain the role of the **AI system in the decision-making process** and the **most important elements** of the decision taken.

The **prerequisites** for this right to an explanation are

- that the AI system can be used in a **critical use case** (Annex III, see Sect. 3.1.2) and
- that the decision produces **legal effects** or similarly affects that person in a way that has an adverse impact on their health, safety or fundamental rights**.** Similar conditions are also known from the General Data Protection Regulation, where decisions may not be taken on the sole basis of automated processing of personal data if these decisions have legal effects or similarly significantly affect the data subject (Article 22 of the GDPR, see Sect. 7.2.7).

There are three **limitations to** this right to explain an AI-based decision:

- In the area of **critical infrastructure** (see Sect. 3.1.2.2), there is generally no such right to an explanation.
- In addition, the right to an explanation does not apply to the extent that such right to explanation is otherwise provided for under EU law**.** In particular, the right to information in the case of decisions based solely on automated processing of

personal data must be taken into account here (Article 15(1)(h), Article 22 of the GDPR; see Sect. 7.2.7.2).
- Furthermore, the right to an explanation of a decision shall not apply if exceptions from, or restrictions to, the obligation of explanation arise from other EU law or EU member state law, for example due to confidentiality obligations or rights.

Related Topics

AI systems in critical use cases: Sect. 3.1.2.

Rules of the GDPR for automated decision-making: Sect. 7.2.7. ◄

1.7.3 What Rights Do Providers Who Integrate a GPAI Model into Their AI System Have?

Article 3(68) and Article 89(2)

Recitals 85 (Providers of GPAI systems), 101 (Role of the provider in the supply chain of GPAI models), 162 (Supervision over GPAI models)

If a GPAI model infringes the AI Act, downstream providers, who have integrated the GPAI model into their AI system, have the right to lodge a **reasoned complaint to the AI Office.** The complaint must contain at least the contact details of the provider of the GPAI model and the facts constituting the violation of the AI Act.

Related Topics

Requirements for GPAI models: Chap. 5.

Rights and obligations of Downstream providers: Sect. 5.5.2.

AI Office: Sect. 6.2.3. ◄



What AI Practices Are Prohibited?

2

Article 5(1)

Recitals 26 (Risk-based approach), 28 (Prohibited AI practices), 45 (Prohibitions under other EU laws)

The prohibitions on certain AI practices are the sharpest sword within the risk-based approach of the AI Act. Only AI systems that are **particularly harmful and abusive** are to be banned. According to the AI Act, these practices contradict the EU values of respect for human dignity, freedom, equality, democracy, the rule of law and fundamental rights.

The AI Act contains **eight prohibitions** on certain AI practices:

- subliminal or purposefully manipulative or misleading influences (see Sect. 2.1);
- exploitation of particular vulnerability or need for protection (see Sect. 2.2);
- social scoring (evaluation or classification of people based on their social behaviour for purposes unrelated to the recorded behaviour; see Sect. 2.3);
- predictive policing (predicting the likelihood that a person will commit a criminal offence based on profiling; see Sect. 2.4);
- untargeted scraping of facial images (creation/expansion of databases for facial recognition through the untargeted extraction of facial images from the internet or from surveillance footage; see Sect. 2.5);
- emotion recognition systems in the workplace and in educational institutions (see Sect. 2.6);
- biometric categorisation systems (see Sect. 2.7);
- 'real-time' remote biometric identification systems (see Sect. 2.8).

There are special **exceptions** to these general prohibitions in which the use of these AI practices is permitted. The European Commission is to issue guidelines that specify the prohibited AI practices (Article 96(1)(b)).

The list of prohibited AI practices in the AI Act is not exhaustive, i.e., AI practices may also be **prohibited under other laws.** The fact that an AI practice does not fall under the prohibitions of the AI Act does not necessarily mean that this AI practice is permitted under other laws.

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_2

In particular, the limited prohibition of decisions based solely on automated processing of personal data should be emphasised as a prohibition of AI practices outside the AI Act (Article 22 of the GDPR, see Sect. 7.2.7). In addition, general prohibitions (e.g. the prohibition of discrimination based on certain characteristics) also apply to the use of AI. What is prohibited without the use of AI is also prohibited with the use of AI.

2.1 What Requirements Apply to Subliminal, Manipulative and Deceptive Techniques?

Article 5(1)(a)

Recital 29 (Manipulative techniques and exploitation of vulnerabilities)

The first prohibition of the AI Act protects human autonomy and decision-making. Placing on the market, putting into service or using an AI system is prohibited

- if that system deploys subliminal techniques beyond a person's consciousness or purposefully manipulative or deceptive techniques,
- with the objective or effect of materially distorting the behaviour of a person or a group of persons,
- i. by appreciably impairing their ability to make an informed decision,
- ii. thereby causing them to take a decision that they would not have otherwise taken,
- iii. in a manner that causes or is reasonably likely to cause significant harm to that person, another person or a group of persons.

Three types of techniques are prohibited:

- Subliminal techniques;
- purposefully deceptive techniques; and
- purposefully manipulative techniques.

In each of the three cases, the person or group of persons concerned must suffer significant harm or be reasonably likely to suffer significant harm.

The scope of this prohibition is difficult to assess, as most of the characteristics are not precisely defined by the AI Act. However, other EU legal acts may provide indications on how the AI Act requirements need to be interpreted, as these laws already contain similar provisions. For example, Article 25 of the Digital Services Act (DSA) contains comparable requirements, as it, inter alia, prohibits providers of online platforms from deceiving or manipulating users through the design of online interfaces. There are also some conceptual parallels with the Unfair Commercial Practices Directive (UCP Directive (EC) 2005/29).

The requirements of the UCPD and the DSA also apply to AI systems and, thus, supplement the prohibitions of the AI Act.

Regardless of whether the technique used is subliminal or purposefully deceptive or manipulative, the technique must have the **objective or effect** of materially distorting the behaviour of a person or group of people. A person's behaviour is

considered to be materially distorted if the person's ability to make an informed decision is appreciably impaired and the person concerned is thereby induced to take a decision that they would not otherwise have taken. This understanding is in line with the definition of the UCPD, which defines a material distortion in a consumer's economic behaviour as a commercial practice to appreciably impair the consumer's ability to make an informed decision, thereby causing the consumer to take a transactional decision that they would not have taken otherwise (Article 2(e) UCPD).

In order to fall under this prohibition of the AI Act, an AI system must therefore limit the ability to make a free decision and impair it in such a way that the person concerned takes a decision that they would not otherwise have taken. The AI Act does not explicitly state how to determine if a person's ability to make a free decision is impaired, or if an objective or a subjective perspective should apply. From a subjective perspective, the only consideration is whether the AI system has actually succeeded in impairing the individual person's ability to make decisions. From an objective point of view, the AI system's capability to impair an average person's ability to make informed decisions suffices. There are two main arguments in favour of an **objective standard**: First, the exploitation of individual weaknesses is specifically prohibited (see Sect. 2.2). Second, even under the UCPD, significant influence is generally measured against the standard of the average consumer, who is reasonably well informed and reasonably observant and circumspect, taking into account social, cultural and linguistic factors (ECJ, judgement of 12 May 2011 – C-122/10, para. 22). It must therefore be assessed whether, from the perspective of an objective third party, an average person would have taken the same decision if the AI system had not been involved. Only if an average person had taken a different decision due to the effects of the AI system would their behaviour have been materially distorted.

Techniques of **subliminal influence** are beyond human perception. They use stimuli that cannot be perceived or reflected upon by human beings. However, it is highly controversial in psychology and neuroscience whether such stimuli can actually influence human behaviour. Therefore, it must be assessed carefully on a case-by-case basis whether an AI system can in fact subliminally influence a human. Although, in the future it is conceivable that AI systems could directly influence brain activity via an interface (e.g. via electrical impulses; see also Recital 29). In contrast to the other aspects of the prohibition described below, AI systems that use subliminal techniques are prohibited even if they are not deployed purposefully.

Any **purposefully deceptive technique** requires, first, that a deception is caused, i.e. that misconceptions are evoked in the person concerned and second, that this deception is purposeful. This requirement is not specified in the AI Act. In order to apply the AI Act coherently, the criteria regarding the intended purpose of an AI system (see Sect. 1.4.2) should also be used to assess whether a deception is purposeful. Hence, the provider of the AI system must have intended the AI system to be used to deceive humans.

In the DSA, in contrast to the AI Act, no intention is required for a deception to be prohibited (Article 25(1) DSA). Therefore, unintendedly deceptive AI interfaces that are not prohibited under the AI Act may still be prohibited under the DSA.

There is no established understanding to the notion of '**manipulative techniques'**. In the context of the prohibition discussed here, it should be understood to describe other forms of influence that are not deceptive in the aforementioned sense. This means that other AI techniques that materially distort a person's behaviour could potentially also be prohibited if they are intended to be used to materially distort an average person's ability to make decisions.

The person affected must be at risk of **significant harm** as a result of the AI techniques mentioned above. The prohibition applies to actual and likely harms equally, as long as the harms are significant. Significant harm includes significant adverse effects on physical and mental health and financial interests (Recital 29). The AI Act does not contain further criteria for determining when adverse effects are significant. If a health disadvantage requiring treatment is caused (e.g. an addiction), there should be significant harm in any case.

The use of **dark patterns** is typically considered to materially distort or impair—on purpose or in effect—a person's ability to make autonomous and informed choices or decisions (as explicitly stated in Recital 67 of the DSA). Thus, dark patterns are likely to be considered deceptive or manipulative techniques. The notion of 'dark pattern' refers to design elements that are intended to encourage people to behave in a certain way. For example, a chatbot deployed in the customer service interface of an online shop can be trained to repeatedly point out accessories with additional cost during the interaction with a customer and suggest that these accessories are necessary for the customer's needs. As a result, the customer is at risk of incurring additional costs. However, it should be highlighted that the AI Act leaves open when exactly a financial loss is considered as significant harm. In this example, the additional accessories may be reasonably priced, i.e. the customer could receive equal value for the price he paid. This argues against a significant harm. Due to the AI Act's ambiguity regarding significant harms, risk-averse providers may want to avoid an infringement of the prohibition. By providing the customer with very transparent information, operators can enable the customers to make informed decisions based on a broad knowledge base. thus minimise the risk of deception or manipulation.

The AI Act also addresses the use of subliminal, deceptive or otherwise manipulative AI techniques for **medical or psychological treatments**. These use cases of AI are not generally prohibited under the AI Act, even if they are subliminal or purposefully deceptive or manipulative. The lawfulness of such AI practices is governed by the applicable law and medical standards.

Similarly, the AI Act clarifies that the use of AI in advertising is not generally prohibited under the AI Act, provided that the advertising itself is permitted under applicable legislation (Recital 29).

2.2 Which Requirements Apply to the Exploitation of a Person's Vulnerability?

Article 5(1)(b)

Recital 29 (Manipulative techniques and exploitation of vulnerabilities)

The second prohibition of the AI Act also serves to protect human autonomy and freedom of decision-making. It is intended to prevent people from being disadvantaged due to their vulnerabilities.

It is prohibited to place on the market, put into service or use AI systems that exploit any **vulnerability** of a person or group of persons due to their age, disability or a particular social or economic situation with the objective or effect of materially distorting the behaviour of that person or a person belonging to that group in a manner that causes, or is reasonably likely to cause, significant harm to that person or another person. Vulnerable groups include, inter alia, people living in extreme poverty and ethnic or religious minorities (Recital 29). The decisive factor is that the specific person or group of persons is particularly prone to disadvantage due to their particular situation.

In order to be prohibited, an AI system has to exploit the vulnerability of a person or group of persons concerned in a manner that is at least reasonably likely to cause them significant harm.

The AI Act does not specify which specific social or economic situations are covered. AI systems should therefore generally not cause harmful discrimination based on a characteristic that distinguishes one group of people from others. In particular, discrimination based on gender, racial or ethnic origin, religion or belief and sexual orientation should be avoided. Positive discriminations (such as affirmative actions), which are based on the same characteristics but grant advantages to the groups concerned, are not covered by the AI Act, as long as they do not inflict any disadvantages but compensate for existing disadvantages.

Efforts to avoid discrimination can be taken into account as a mitigating factor when deciding on a fine under the AI Act (see Sect. 6.2.9.2). Thus, if a disadvantage becomes apparent in retrospect that was hardly, or not at all, foreseeable in advance, the fine should be lowered if not disregarded entirely.

2.3 Which Requirements Apply to Social Scoring?

Article 5(1)(c)

Recital 31 (Social scoring)

The third prohibition also serves to protect persons from being discriminated against, in this case from discrimination through so-called social scoring.

The evaluation and/or classification of a person or a group of persons based on **their social behaviour** or known, inferred or predicted **personal or personality characteristics** is prohibited for private and state operators, if

- it leads to discrimination in a social context **unrelated to the context in which the data was originally generated or collected** or
- it leads to a **detrimental or unfavourable treatment** of certain natural persons or groups of persons that is unjustified or disproportionate to their social behaviour or to the gravity of their behaviour.

The AI Act does not answer the question of when a disadvantage is still proportionate and therefore not prohibited. In that regard a **balancing of interests** is likely required**,** in which a legitimate interest in the use of the AI system must outweigh the interest of the affected person in not being placed in a detrimental position.

A particularly drastic example of social scoring is a social credit system in which socially desirable behaviour is awarded plus points, while socially disapproved behaviour is awarded minus points. The social credits then determine, for example, the prices of services or waiting times for visits to authorities.

Evaluating creditworthiness is unlikely to be prohibited as social scoring, since creditworthiness AI systems infer from information on the ability and willingness to pay the probability of fulfilment of a payment obligation. Therefore, a substantive link exists between the data collection and the potential disadvantages of a poor credit rating. The fact that credit scoring AI systems are not prohibited per se is also supported by the fact that they are (just) considered high-risk AI systems (see Sect. 3.1.2.5). However, if the AI system records and takes into account characteristics that are not directly related to individual creditworthiness (e.g. place of residence or name), a corresponding scoring AI system could potentially be prohibited.

Related Topics

High-risk AI systems for credit scoring: Sect. 3.1.2.5. ◄

2.4 Which Requirements Apply to Predictive Policing?

Article 5(1)(d), 3(52) AI Act in conjunction with Article 4(4) GDPR

Recitals 10 (Protection of personal data), 42 (Predictive policing and profiling)

The fourth prohibition of the AI Act is intended to protect the presumption of innocence. The notion '**predictive policing**' covers various approaches to predicting and preventing future criminal offences. This purpose is desirable in principle and therefore not every form of predictive policing is prohibited.

Only the assessment of a natural person in order to predict the risk of such person committing a criminal offence, based solely on profiling or on assessing their personality traits and characteristics, is prohibited. Profiling includes any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person's performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements (Article 3(52) of the AI Act in conjunction with Article 4(4) of the GDPR).

If profiling is exceptionally permitted under data protection law, the use of AI to predict the likelihood that a person will commit a criminal offence is nevertheless prohibited. This is to ensure that persons are only reasonably suspected of

committing a criminal offence if the suspicion is based on a human assessment of objective verifiable facts (Recital 42).

The prohibition therefore does not apply to AI systems used to support the human assessment of a person's involvement in a criminal activity that is based on **objective and verifiable facts** directly related to a criminal activity.

For example, AI-based software that infers that a certain person will rob a bank in the coming days from personal data, such as the school attended, place of residence, previous criminal offences and account balance, likely is prohibited. On the other hand, software that monitors payment transactions with foreign accounts for patterns that contain indications for money laundering or software that compares fingerprints from a crime scene with fingerprints from a database are not prohibited by the AI Act.

Related Topics

High-risk AI systems in law enforcement: Sect. 3.1.2.6. ◄

2.5 Which Requirements Apply to the Scraping of Facial Images?

Article 5(1)(e)

Recital 43 (Facial recognition databases)

The prohibition of certain AI systems in the context of scraping is intended to protect the right to privacy and prevent a feeling of mass surveillance. Scraping refers to techniques used to automatically read data from a large number of websites in an untargeted manner and transfer it to a database. This method is used to analyse data and is not generally prohibited. Only AI systems creating or expanding facial recognition databases through the **untargeted scraping of facial images from the internet** or CCTV footage are prohibited.

The prohibition is therefore specifically aimed at AI systems that build databases based on freely accessible images that can be used to identify people. The ban is very narrowly defined. For example, AI systems that use a specific image to compare it against a large number of image files on the internet are not prohibited.

2.6 Which Requirements Apply to Emotion Recognition in the Workplace and in Educational Institutions?

Article 3(34) and (39), Article 5(1)(f)

Recitals 14 (Biometric data), 18 (Emotion recognition systems), 44 (Prohibited emotion recognition systems)

The prohibition of certain emotion recognition systems is aimed at preventing discrimination. The AI Act assumes that AI technology used to identify or infer

emotions is scientifically controversial, meaning that its output can be unreliable and cannot always be generalised (Recital 44).

Emotion recognition systems are AI systems with the purpose of identifying or inferring emotions or intentions of natural persons based on their biometric data (Article 3(39); see Sect. 2.7).

Such AI systems are generally prohibited only in the **workplace and in education institutions.** This includes AI systems that detect emotions or intentions, e.g. happiness, sadness, anger, surprise, disgust, embarrassment, excitement, shame, contempt, satisfaction or amusement (Recital 18). This applies, for example, to AI systems that warn customer service agents that their tone of voice is too unfriendly.

In other areas of application, these systems are not prohibited by the AI Act. Emotion recognition systems are permitted even in the workplace and in educational institutions if they are introduced or placed on the market for **medical or safety reasons**, e.g. systems for recognising fatigue in professional pilots or drivers. However, this exception only applies with regard to the AI Act. If an emotion recognition system is prohibited under other legislation, it remains prohibited even though it is used for medical or safety purposes.

Related Topics

Biometric data: Sect. 2.7.

High-risk AI systems for emotion recognition: Sect. 3.1.2.1. ◀

2.7 Wh Requirements Apply to Biometric Categorization Systems?

Article 4(34) and (40), 5(1)(g)

Recitals 14 (Biometric data), 16 (Biometric categorisation), 30 (Prohibited biometric categorisation systems)

Biometric categorisation systems that **categorise** a person based on **biometric data** in order to infer or deduce their race, political opinions, trade union membership, religious or philosophical beliefs, sex life or sexual orientation are prohibited. Biometric data are personal data resulting from specific technical processing relating to the physical, physiological or behavioural characteristics of a natural person, such as facial images or fingerprints (Article 3(34)). This notion should be understood in the light of the GDPR (Recital 14). In contrast to the AI Act, the GDPR also requires that biometric data enable the unambiguous identification of the data subject, i.e. the concerned natural person (Article 4(14) GDPR). Biometric data within the meaning of the AI Act therefore also includes data that does not allow the affected person to be uniquely identified.

The prohibition does not apply to the **labelling or filtering of lawfully acquired biometric datasets**, such as images, based on biometric data, or categorising of biometric data in the area of law enforcement.

In addition, biometric categorisation is not prohibited if it is ancillary to another commercial service and strictly necessary for objective technical reasons (Article 4(40) and Recital 16). An example can be a filter for categorising facial or physical characteristics used on an online marketplace to preview the display of the product on the consumers themselves (Recital 16). The main service in this case is the sale of a product and the ancillary function of the biometric categorisation system is to allow the consumers to virtually try out the product on themselves and thus help them to make a purchase decision. Filters in social networks that categorise facial or body features to enable users to add or change images or videos may also be permitted as technical ancillary functions.

Related Topics

High-risk AI systems for biometric categorisation: Sect. 3.1.2.1. ◄

2.8 What Requirements Apply to Real-Time Remote Biometric Identification Systems?

Articles 3(34), (41) and (42), 5(1)(h) and (2) to (7)

Recitals 14 (Biometric data), 15 (Biometric identification), 17 (Remote biometric identification systems), 19 (Publicly accessible space), 32 (Risks of real-time biometric remote identification systems), 33 (Exceptions to the prohibition of real-time biometric remote identification systems), 34 (Safeguards if the exceptions apply), 35 (Authorisation requirement), 36 (Information obligations), 37 (Requirement for transposition into national law), 38 (Relationship with Article 10 of Directive (EU) 2016/680), 39 (Biometric identification systems with other purposes)

The AI Act only prohibits '**real-time' remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement**. A remote biometric identification system is an AI system that serves the purpose of identifying natural persons without their active involvement, typically at a distance through comparison of the biometric data (see Sect. 2.7) of a person with the biometric data contained in a reference database (Article 3(41)). In the case of a 'real-time' remote biometric identification system, the capturing of biometric data, the comparison and the identification occur without significant delay (Article 3(42)). It is not entirely clear when a person is considered to be 'actively involved' in the meaning of the AI Act. At the very least, persons who do not even know that they are being biometrically identified cannot be actively involved. However, persons who expressly consent to biometric identification are likely to be considered actively involved.

There is an **exception** to this prohibition under several conditions (Article 5(2) to (6)). 'Real-time' remote biometric identification in publicly accessible spaces for law enforcement purposes is therefore exceptionally permitted if it is used for the following purposes:

- the **targeted search** for missing persons or victims of certain criminal offences,

- the **prevention of specific, substantial and imminent serious threats** (e.g. terrorism) or
- conducting criminal investigation or prosecution or executing a criminal penalty against persons who have committed or are suspected of having **committed serious criminal offences** (in accordance with Annex II).

The exception is also safeguarded by **procedural requirements.** Protective measures must be taken and prior authorisation from a judicial authority or an independent administrative authority is required before each use. In addition, market surveillance and data protection authorities must be informed of each use. The exact requirements depend on the national legislation transposing these rules in the respective EU member state (Article 5(5)).

Related Topics

High-risk remote biometric identification systems: Sect. 3.1.2.1. ◄

2.9 What Prohibitions from Other Laws Must Be Observed?

Article 5(8)

Recital 45 (Prohibitions under other EU laws)

The AI Act does not affect prohibitions from other EU legislation. Further prohibitions on AI practices may arise, for example, from data protection law, non-discrimination law, consumer protection law and competition law. Especially, the (limited) prohibition of decision-making based solely on the automated processing of personal data is to be mentioned as a relevant rule with regard to AI applications (Article 22(1) of the GDPR; see Sect. 7.2.7).

Other prohibitions are not directed against automated practices with comparable clarity. Since all prohibitions that apply to human behaviour are generally prohibited with respect to automated systems, all practices that are prohibited without the use of AI are also prohibited with the use of AI.



Which Requirements Apply to High-Risk AI Systems?

3

The majority of the provisions of the AI Act concern high-risk AI systems. The following Chap. first describes the conditions under which an AI system is considered high risk within the meaning of the AI Act (see Sect. 3.1). This is followed by a description of the requirements high-risk AI systems have to comply with (see Sect. 3.2). Subsequently, the obligations of the various operators (see Sect. 1.3) of AI systems are presented (see Sects. 3.3–3.5).

3.1 Which AI Systems Are High-Risk AI Systems?

Article 6

Recitals 7 (Common rules for all high-risk AI systems), 26 (Risk-based approach), 46 (High-risk AI systems), 47 (AI safety components), 48 (Relevant fundamental rights risks), 50 (Products within the New Legislative Framework), 51 (Risk classification under other harmonisation legislation), 52 (Critical use cases), 53 (Exemptions from high-risk categories), 54 (High-risk biometric AI systems), 55 (Critical infrastructure), 56 (Education), 57 (Employment and self-employment), 58 (Access to essential services), 59 (High-risk AI in law enforcement), 60 (Migration, asylum and border control management), 61 (Administration of justice and democratic processes), 62 (Influencing electoral behaviour), 63 (No legalisation effect for other legal acts)

AI systems will be categorised as 'high-risk' if

- they are related to certain **products** that have to undergo a third-party conformity assessment under certain sector-specific EU harmonisation legislation (listed in Annex I; see Sect. 3.1.1) or
- if they are so-called **stand-alone high-risk AI systems** in certain critical use cases (listed in Annex III; see Sect. 3.1.2).

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_3

See also Fig. 3.1.

Guidelines to be provided by the European Commission shall facilitate the categorisation and provide a comprehensive list of examples of AI systems that are high risk and not high risk (Article 6(5)).

Related Topics

General concept of high-risk AI systems: Sect. 1.2.4. ◀

3.1.1 Which Products Are or Contain High-Risk AI Systems?

Article 6(1), Annex I

Recitals 9 (Consistency with the New Legislative Framework), 46 (High-risk AI systems), 47 (AI safety components), 49 (Products outside the New Legislative Framework), 50 (Products within the New Legislative Framework)

An AI system that is either a product or a safety component of a product is considered high-risk if it fulfils two conditions.

First, the **product** must be covered by the **EU harmonisation legislation** listed in Annex I of the AI Act. The AI Act takes into account certain sector-specific EU product safety legislation that has been issued by the EU in the form of regulations or directives (listed in detail in the following Sects. 3.1.1.1 and 3.1.1.2). A safety component in this sense is a component of a product or of an AI system that fulfils a safety function for that product or AI system, or where the failure or malfunction of such component endangers the health and safety of persons or property (Article 3(14)).

Second, the harmonisation legislation applicable to the afore-mentioned product must provide for a **third-party** conformity **assessment**, before placing it on the market or putting it into service (Article 6(1)). This refers to a mandatory procedure in which a body that is not the manufacturer of the product checks compliance with the requirements laid down in the applicable EU harmonisation legislation. Who carries out this conformity assessment depends on the applicable legal act. In product safety law it is common for products to undergo a conformity assessment by a **notified body** before they can be put into service or placed on the market.

Under most harmonisation legislation listed in Annex I, a third-party conformity assessment is mandatory if the manufacturer does not apply harmonised standards (see Sect. 7.6.3). Yet, if harmonised standards are applied to the product, a mere self-assessment is sufficient. In practice, product manufacturers can often choose whether they either apply harmonised standards or undergo a third-party assessment.

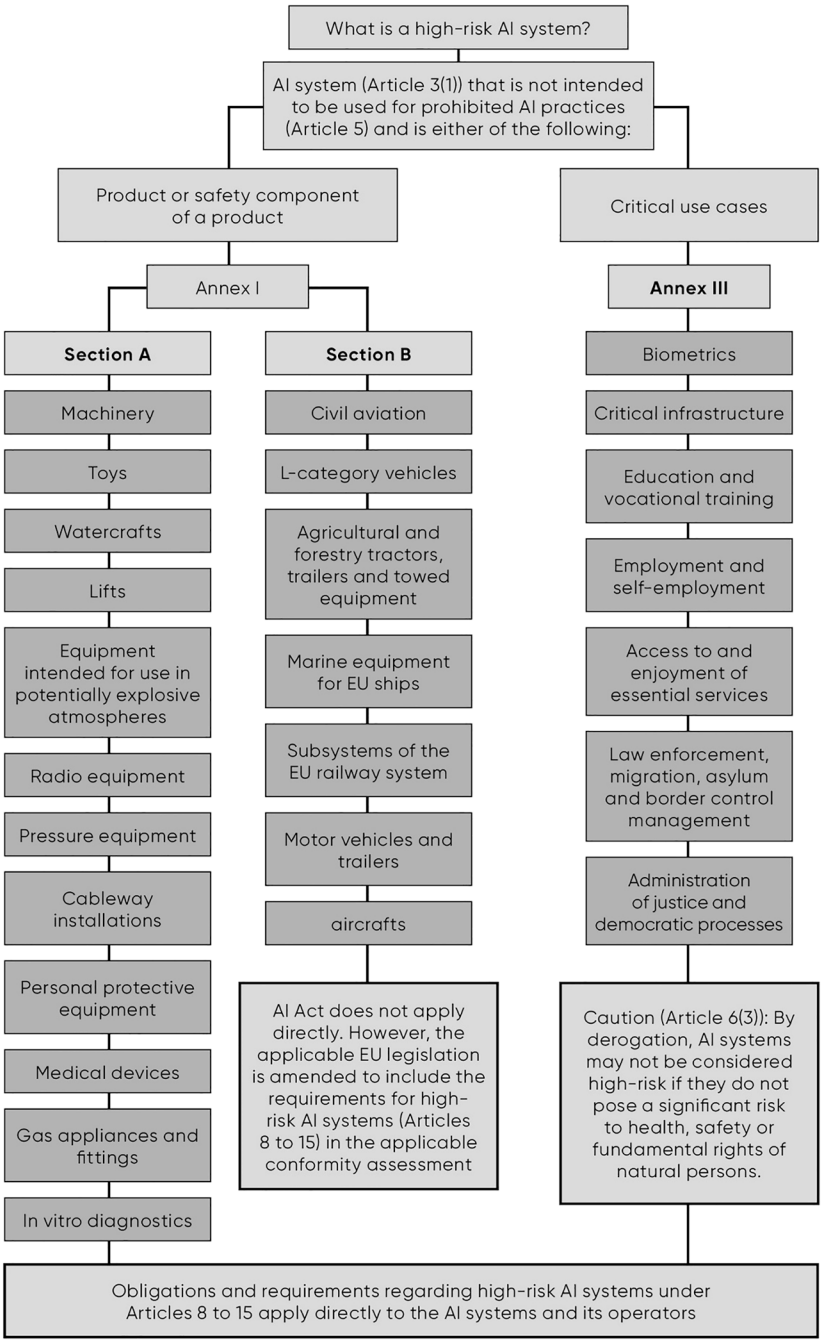


Fig. 3.1 Overview of high-risk AI systems

The European Commission considers that the option to apply harmonised standards to avoid a third-party assessment would be irrelevant for the classification of the product under the AI Act. Accordingly, AI systems connected to products listed in Annex I that do not have to undergo a third-party conformity assessment under harmonisation legislation because harmonised standards are applied would still be considered high risk under the AI Act.

The harmonisation legislation to which the AI Act refers in Annex I is listed in the following sub-sections.

Before looking at the harmonisation legislation itself, it is helpful to bear in mind that the AI Act distinguishes between **two categories of products.**

- For some products that fulfil safety requirements within the New Legislative Framework (see Sect. 1.1), the AI Act is **directly applicable** (Annex I Section A; see Sect. 3.1.1.1).
- Other products that are subject to safety requirements outside the New Legislative Framework (Annex I Section B; see Sect. 3.1.1.2) are excluded from the scope of the AI Act (see Sect. 1.2.7). However, the corresponding sector-specific harmonisation legislation is amended by the AI Act to include the **requirements for high-risk AI systems** (see Sect. 3.2) in the applicable conformity assessment procedure (Articles 102–109). The obligations of the specific operators under the AI Act do not apply to these products. The person responsible for compliance with the requirements for high-risk AI systems is not determined by the AI Act, but by the applicable harmonisation legislation that governs the conformity assessment.

Related Topics

New Legislative Framework: Sect. 1.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 5, pp. 70–94 (Conformity assessment); List of Notified Bodies (2024).

3.1.1.1 To Which Products Does the AI Act Apply Directly?

Article 6(1), Annex I

Recitals 9 (Consistency with the New Legislative Framework), 46 (High-risk AI systems), 47 (AI safety components), 50 (Products within the New Legislative Framework)

The AI Act is directly applicable to certain products within the New Legislative Framework (see Sect. 1.1; Annex I Section A), as far as they must undergo a third-party conformity assessment under the applicable harmonisation legislation. See also Table 3.1.

The quality management system (Article 17(2), see Sect. 3.3.1) and risk management system (Article 9(10), see Sect. 3.2.1) required under the AI Act can be

Table 3.1 Products to which the AI Act applies directly

Product	Applicable EU harmonisation legislation	Definition
Machinery	Directive 2006/42/EC	An assembly, fitted with or intended to be fitted with a drive system other than directly applied human or animal effort, consisting of linked parts or components, at least one of which moves, and which are joined together for a specific application (Article 2(2)(a))
Toys	Directive 2009/48/EC	Products that are designed or intended—whether or not exclusively—for use in play by children under 14 years of age (Article 2(1))
Watercrafts	Directive 2013/53/EU	• Recreational craft, i.e. any watercraft of any type, excluding personal watercraft, intended for sports and leisure purposes of hull length from 2.5 m to 24 m, regardless of the means of propulsion (Article 3(2)) • personal watercraft, i.e. a watercraft intended for sports and leisure purposes of less than 4 m in hull length which uses a propulsion engine having a water jet pump as its primary source of propulsion and designed to be operated by a person or persons sitting, standing or kneeling on, rather than within the confines of, a hull (Article 3(3))
Lifts	Directive 2014/33/EU	• lifting appliances serving specific levels, having a carrier moving along guides which are rigid and inclined at an angle of more than 15° to the horizontal, or • lifting appliances moving along a fixed course even where it does not move along rigid guides (Article 2(1))
Equipment and protective systems intended for use in potentially explosive atmospheres	Directive 2014/34/EU	Machines, apparatus, fixed or mobile devices, control components and instrumentation thereof and detection or prevention systems • which, separately or jointly, are intended for the generation, transfer, storage, measurement, control and conversion of energy and/or the processing of material and • which are capable of causing an explosion through their own potential sources of ignition and devices other than components of equipment • which are intended to halt incipient explosions immediately and/or to limit the effective range of an explosion and • which are separately made available on the market for use as autonomous systems. (Article 2(1) and (2))

(continued)

Table 3.1 (continued)

Product	Applicable EU harmonisation legislation	Definition
Radio equipment	Directive 2014/53/EU	• electrical or electronic product, which intentionally emits and/or receives radio waves for the purpose of radio communication and/or radiodetermination, or • an electrical or electronic product which must be completed with an accessory, such as antenna, so as to intentionally emit and/or receive radio waves for the purpose of radio communication and/or radiodetermination (Article 2(1)(1))
Pressure equipment and assemblies with a maximum permissible pressure of over 0.5 bar	Directive 2014/68/EU	Vessels, piping, safety accessories and pressure accessories, including, where applicable, elements attached to pressurised parts, such as flanges, nozzles, couplings, supports, lifting lugs (Article 2(1))
Cableway installations	Regulation (EU) 2016/424	A whole on-site system, • consisting of infrastructure and subsystems, • which is designed, constructed, assembled and put into service with the objective of transporting persons, • where the traction is provided by cables positioned along the line of travel. (Article 3(1))
Personal protective equipment	Regulation (EU) 2016/425	• Equipment designed and manufactured to be worn or held by a person for protection against one or more risks to their health or safety, • interchangeable components for equipment referred to in the first point which are essential for its protective function, and • connexion systems for equipment referred to in the first point – that are not held or worn by a person, – that are designed to connect that equipment to an external device or to a reliable anchorage point, – that are not designed to be permanently fixed and – that do not require fastening work before use. (Article 3(1))
Gas appliances and fittings	Regulation (EU) 2016/426	• appliances burning gaseous fuels used for cooking, refrigeration, air-conditioning, space heating, hot water production, lighting or washing, and also forced draught burners and heating bodies to be equipped with such burners • safety devices, controlling devices or regulating devices and sub-assemblies thereof, designed to be incorporated into an appliance or to be assembled to constitute an appliance (Article 2(1) and (2))

(continued)

Table 3.1 (continued)

Product	Applicable EU harmonisation legislation	Definition
Medical devices and their accessories	Regulation (EU) 2017/745	• articles intended by the manufacturer to be used, alone or in combination, for human beings for one or more of the specific medical purposes • articles which, whilst not being themselves medical devices, are intended to be used together with one or several particular medical device(s) to specifically enable the medical device(s) to be used in accordance with its/their intended purpose(s) or to specifically and directly assist the medical functionality of the medical device(s) in terms of its/their intended purpose(s) (Article 2(1) and (2))
In vitro diagnostics and their accessories	Regulation (EU) 2017/746	• reagents, reagent products, calibrators, control materials, kits, instruments, apparatus, pieces of equipment, software or systems, whether used alone or in combination, intended to be used in vitro for the examination of specimens, including blood and tissue donations, derived from the human body, solely or principally for the purpose of providing information on the condition of a human being • articles which, whilst not being themselves in vitro diagnostic medical devices, are intended to be used together with one or several particular in vitro diagnostic medical device(s) to specifically enable the in vitro diagnostic medical device(s) to be used in accordance with its/their intended purpose(s) or to specifically and directly assist the medical functionality of the in vitro diagnostic medical device(s) in terms of its/their intended purpose(s) (Article 2(2) and (4))

integrated into a quality or risk management system that is mandatory under applicable sector-specific EU harmonisation legislative mentioned above. Apart from this specific facilitation, all requirements for high-risk AI systems and obligations for operators under the AI Act apply as usual (see Sects. 3.2–3.5).

Related Topics

New Legislative Framework: Sect. 1.1. ◄

3.1.1.2 To Which Products Do the Requirements for High-Risk AI Systems Apply only Indirectly?

Article 6(1), Annex I

Recitals 46 (High-risk AI systems), 47 (AI safety components), 49 (Products outside the New Legislative Framework)

The AI Act is indirectly applicable to some products subject to a third-party conformity assessment procedure under EU harmonisation legislation outside the New

Table 3.2 Products to which the AI Act only applies indirectly

Product	Applicable EU harmonisation legislation
Civil aviation, including airports and related services (Although these are not labelled as 'products', they are subject to safety requirements that are checked by third parties; they are therefore covered by the reference in the AI Act)	Regulation (EC) No. 300/2008
Two- or three- wheel vehicles and quadricycles ('L-category vehicle')	Regulation (EU) No. 168/2013
Agricultural and forestry tractors (categories T and C) Trailers (category R) Interchangeable towed equipment (category S)	Regulation (EU) No. 167/2013
Marine equipment for ships flying the flag of an EU member state	Directive 2014/90/EU
Subsystems of the EU railway system	Directive (EU) 2016/797
Motor vehicles in categories M and N and trailers in category O	Regulation (EU) 2018/858
Safety systems for vehicles in categories M, N and O	Regulation (EU) 2019/2144
(Manned and unmanned) aircrafts (i.e. machines that can derive support in the atmosphere from the reactions of the air other than reactions of the air against the earth's surface), air traffic management and air navigation services	Regulation (EU) 2018/1139

Legislative Framework (see Sect. 1.1; Annex I Section B). They are largely excluded from the scope of application (see Sect. 1.2.7). Instead, the corresponding harmonisation legislation regulating these products is amended so that the requirements for high-risk AI systems (see Sect. 3.2) are **integrated into the existing sector-specific conformity assessment** (Articles 102–109).

This applies to the products displayed in Table 3.2.

Related Topics

Exemption from the scope of application for certain products: Sect. 1.2.7. New Legislative Framework: Sect. 1.1. ◀

3.1.2 Which 'Stand-Alone' AI Systems in Critical Use Cases Are Considered High-Risk?

Article 6(2), Annex III

Recitals 52 (Critical use cases), 53 (Exemptions from high-risk categories)

AI systems that are not a product or safety component of a product regulated by EU harmonisation legislation (as listed in Annex I) product or part thereof can also be considered high risk in so-called **'critical use cases'** (Annex III). They are then

also referred to as 'stand-alone' high-risk AI systems. The relevant critical use cases are listed by the AI Act and categorised into **eight areas**:

- biometrics;
- critical infrastructure;
- education and vocational training;
- employment, workers management and access to self-employment;
- access and enjoyment of essential private and public services and benefits;
- law enforcement;
- migration, asylum and border control management; and
- administration of justice and democratic processes.

The critical use cases in these areas are described in the following sections (see Sects. 3.1.2.1–3.1.2.8). The European Commission is to provide **guidelines on the practical implementation** of these use cases no later than 18 months after the AI Act enters into force, including examples of which AI systems are high risk and which AI systems are not high risk.

The European Commission may **add, modify or delete** use cases of stand-alone high-risk AI systems within these eight areas (see Sect. 3.1.2.9).

Stand-alone AI systems in critical use cases can also **exceptionally** be considered **non-high risk** if they do not pose a significant risk to fundamental rights (see Sect. 3.1.2.10).

The AI Act only categorises stand-alone AI systems in the aforementioned areas as high risk if they are permitted at all. AI systems that are prohibited by the AI Act (see Chap. 2) can therefore not be considered high risk.

Related Topics

Prohibited AI practices: Chap. 2.
Adaptation (in particular addition) of the critical use cases: Sect. 3.1.2.9.
Exceptions to the critical use cases: Sect. 3.1.2.10. ◄

3.1.2.1 Which Biometric AI Systems Are Considered High-Risk?

Article 3(34), (35), (36), (37), (39), (40) and (41), Annex III No. 1

Recitals 14 (Biometric data), 15 (Biometric identification), 17 (Remote biometric identification systems), 18 (Emotion recognition systems), 30 (Prohibited biometric categorisation systems), 44 (Prohibited emotion recognition systems), 54 (High-risk biometric AI systems)

In the area of biometrics, AI systems are considered high-risk for **three use cases.** These biometric AI systems process biometric data, i.e. personal data relating to the physical, physiological or behavioural characteristics of a natural person (for details, see Sect. 2.7). Some types of biometric AI systems are generally prohibited (Article 5; see Sects. 2.5–2.8). There are three use cases for high-risk biometric AI systems.

First, remote biometric identification systems are considered high risk. These are AI systems for the purpose of identifying natural persons, without their active involvement, typically at a distance by comparing their biometric data with a reference database (Article 3(41); for detail see Sect. 2.8).

High-risk remote biometric identification systems should not include biometric AI systems if they are intended to be used for **biometric verification** with the sole purpose to confirm that a specific natural person is the person he or she claims to be. This means that automated one-to-one verification of people's identity by comparing their biometric data to previously provided biometric data (Article 3(36)) is **not** considered **high risk**. One example of a (non-high-risk) biometric verification is the unlocking of a smartphone using biometric facial recognition software.

Second, AI systems are considered high risk if they are intended to be used for **biometric categorisation**, according to sensitive or protected attributes or characteristics based on inference of those attributes or characteristics. Biometric categorisation systems are AI systems that serve the purpose of assigning natural persons to specific categories on the basis of their biometric data, unless it is **ancillary to another commercial service** and strictly necessary for objective technical reasons (Article 3(40); see Sect. 2.7 as well).

Third, AI systems are considered high risk if they are intended to be used for **emotion recognition** (see Sect. 2.6 as well). Such AI systems use facial expressions to deduce or infer a person's emotions, for example, in order to identify suspicious persons in security checks. The reliability of such AI systems is controversial, particularly due to criticism of the scientific model of human emotions on which they are based.

Related Topics

Prohibited biometric AI systems: Sects. 2.5–2.8.
Data protection requirements for AI: Sect. 7.2. ◀

▶ **Further Information** *European Commission*, Artificial Intelligence – Questions and Answers (2023), pp. 5–7.

3.1.2.2 Which AI Systems Are Considered High-Risk in the Area of Critical Infrastructure?

Article 3(62) of the AI Act in conjunction with Article 2(4) of the CER Directive (EU) 2022/2557, Annex III No. 2 of the AI Act

Recital 55 AI Act (Critical infrastructure)

In the area of critical infrastructure, there is only one use case for 'stand-alone' high-risk AI systems. In this critical use case, high-risk AI systems are intended to be used as safety components (see Sect. 3.1.1) in the management and operation of **critical digital infrastructure, road traffic, or in the supply of water, gas, heat and electricity**. As safety components of critical infrastructure, AI systems are used to directly protect the physical integrity of critical infrastructure or

the health and safety of persons and property, but are not necessary for the functioning of the infrastructure facility (Recital 55). Examples include AI systems that measure the pressure on storage tanks or control the fire alarm for a cloud computing centre.

Critical infrastructure is to be understood very broadly and refers to any asset, facility, equipment, network or system or part of an asset, facility, equipment, network or system that is necessary for the provision of an essential service, which is crucial for the maintenance of vital societal functions, economic activities, public health and safety or the environment (Article 3(62) of the AI Act in conjunction with Article 2(4) of the CER Directive). Thereby, the AI Act explicitly refers to the definition in the EU CER Directive, which regulates the protection of critical infrastructure from physical disruption. It should be noted that not all sectors regulated by the CER Directive are also among the use cases of high-risk AI systems in critical infrastructure. The directly applicable legal acts that transpose the CER Directive into national law may also cover more sectors than the AI Act.

The Annex to the CER Directive lists examples of sectors, subsectors and categories of critical entities. These critical entities operate critical infrastructure (Article 6(2)(b) of the CER Directive). As the AI Act adopts the concept of critical infrastructure from the CER Directive, the examples in the Annex to the CER Directive provide an indication of which objects, installations, equipment, networks and systems can be considered critical infrastructure within the meaning of the AI Act. If AI systems are used as safety components in these entities, they will likely also be considered high-risk AI systems:

- critical digital infrastructure:
  - providers of internet exchange points (Article 6(18) of Directive (EU) 2022/2555);
  - DNS service providers (Article 6(20) of Directive 2022/2555);
  - top-level-domain (TLD) name registries (Article 6(21) of Directive (EU) 2022/2555);
  - providers of cloud computing services (Article 6(30) of Directive (EU) 2022/2555);
  - providers of data centre services (Article 6(31) of Directive (EU) 2022/2555);
  - providers of content delivery networks (Article 6(32) of Directive (EU) 2022/2555);
  - trust service providers (Article 3(19) of Regulation (EU) 910/2014);
  - providers of public electronic communications networks (Article 2(8) of Directive (EU) 2018/1972);
  - Providers of publicly available electronic communications services (Article 2(4) of Directive (EU) 2018/1972).
- road traffic:
  - road authorities responsible for traffic management control (Article 2(12) of Commission Delegated Regulation (EU) 2015/962);

  - operators of intelligent transport systems (Article 4(1) of Directive 2010/40/EU).
- supply of water:
  - suppliers of and distributors of 'water intended for human consumption' (Article 2(1)(a) of Directive (EU) 2020/2184);
  - Undertakings collecting, disposing of or treating urban, domestic or industrial waste water (Article 2(1) to (3) of Directive 91/271/EEC).
  - (Please note that it is unclear whether collecting and disposing waste water shall be considered as 'water supply' under the AI Act. On the one hand, waste water is not supplied, on the other hand the service of disposing waste water is being supplied. Therefore, it remains to be seen whether undertakings collecting, disposing of or treating waste water are covered as critical infrastructure under the AI Act.)
- supply of gas:
  - supply undertakings (Article 2(8) of Directive 2009/73/EC);
  - distribution system operators (Article 2(6) of Directive 2009/73/EC);
  - transmission system operators (Article 2(4) of Directive 2009/73/EC);
  - storage system operators (Article 2(10) of Directive 2009/73/EC);
  - LNG system operators (Article 2(12) of Directive 2009/73/EC);
  - natural gas undertakings (Article 2(1) of Directive 2009/73/EC);
  - operators of natural gas refining and treatment facilities.
- supply of heat:
  - operators of district heating (Article 2(19) of Directive (EU) 2018/2001).
  - It is unclear whether companies in the subsector of oil supply should also be included, as the wording of the AI Act ('heat supply') does not correspond to the CER Directive that distinguishes several sub-sectors within the energy sector. However, in order to offer a comprehensive overview, these companies are also listed here, as the wording of the AI Act is broad enough to potentially cover this subsector of the CER Directive as well:
    operators of oil transmission pipelines;
    operators of oil production, refining and treatment facilities, storage and transmission for the production, refining and processing of crude oil as well as oil storage facilities and oil pipelines;
    Central stockholding entities (Article 2(f) of Council Directive 2009/119/EC).
- supply of electricity:
  - Electricity undertakings while carrying out the function of 'supply' (Article 2(12) and (57) of Directive (EU) 2019/944);
  - distribution system operators (Article 2(29) of Directive (EU) 2019/944);
  - transmission system operators (Article 2(35) of Directive (EU) 2019/944);
  - producers (Article 2(38) of Directive (EU) 2019/944);
  - nominated electricity market operators (Article 2(8) of Regulation (EU) 2019/943)

– Market participants providing aggregation, demand response or energy storage services (Article 2(25) of Regulation (EU) 2019/943, Article 2(18), (20) and (59) of Directive (EU) 2019/944).
– This list is only exemplary. AI systems that are safety components in the management and operation of other sectors or sub-sectors of these sectors may also be considered high-risk.

Related Topics

Safety components: Sect. 1.2.4. ◀

▶ **Further Information** *European Commission*, Critical infrastructure resilience (2024).

3.1.2.3 Which AI Systems Are Considered High-Risk in the Area of Education and Vocational Training?

Annex III No. 3

Recital 56 (Education)

In principle, AI systems shall be used to promote high-quality digital education (Recital 56). However, certain decisions used in the area of education and vocational training are associated with greater risks, as they are often decisive for the course of a person's life and their future income. Thus, AI systems shall be particularly reliable in this area.

The area of education and vocational training includes educational and vocational training institutions at all levels. This includes at least the entire school career and all universities. Whether kindergartens and further education institutions are covered is not explicitly stated. As the AI Act expressly covers institutions at all levels and not just certain institutions such as schools and universities, a very broad understanding might apply. Other institutions such as kindergartens and further education institutions will therefore likely be covered, as they serve to educate people.

In education and vocational training, AI systems are generally considered to be high risk for the following use cases:

- AI systems that are intended to be used to **determine access or admission** to or to assign natural persons to educational and vocational training institutions at all levels (e.g. admission or aptitude tests at universities);
- AI systems that are intended to be used to **evaluate learning outcomes,** including when those outcomes are used to steer the learning process of natural persons in educational and vocational training institutions at all levels (e.g. examinations in schools and universities);
- AI systems that are intended to be used for the purpose of **assessing the appropriate level of education** that a person will receive or will be able to access, in the context of or within educational and vocational training institutions at all

levels (e.g. access test for limited university programmes assessed by an AI system only);
- AI systems that are intended to be used for **monitoring and detecting prohibited behaviour** of students during tests, in the context of or within educational and vocational training institutions at all levels (e.g. AI systems that evaluate the behaviour of students during a class test).

3.1.2.4 Which AI Systems Are Considered High-Risk in the Area of Employment and Self-employment?

Annex III, No. 4

Recital 57 (Employment and self-employment)

The AI Act considers certain AI systems used in the area of employment, workers management and access to self-employment to be high risk, since in the professional context numerous decisions are made that are decisive for a person's (economic) situation. That is why discriminatory decision-making patterns in AI systems are considered to have particularly far-reaching consequences.

The areas of employment, workers management and self-employment do not address only employees, but also self-employed persons, e.g. freelancers. As is usual in labour law, it is necessary to differentiate between employment and self-employment. Although the AI Act allocates both kinds of contractual relationships to the same area of high-risk use cases, it does not add all aspects of 'self-employment' to this high-risk area, but only the 'access to self-employment.'

The performance and termination of freelance contracts are not linked to access in the first place. Thus, 'access to self-employment' should be understood to only refer to the possibility of becoming self-employed. Following this interpretation, only decisions of authorities, bodies or agencies that can decide on whether an individual is admitted to self-employment would be covered by this area of high-risk use cases.

Even if one understood 'access to self-employment' to cover other aspects of self-employment despite the limitation to 'access', it is unlikely that every service contract would fall within the area of employment and access to self-employment. In any case, there should at least be a certain duration and a relationship of dependency, which must be comparable to that of a regular employment relationship.

In the area of employment and access to self-employment, AI systems are considered to be high risk, if they are

- intended to be used for the **recruitment or selection of natural persons**, in particular
  - to place targeted job advertisements,
  - to analyse and filter job applications and
  - to evaluate candidates;
- intended to be used
  - to make decisions affecting the **terms of work-related relationships, or the promotion or termination of** work-related contractual relationships,

- to **allocate tasks** based on individual behaviour or personal characteristics or traits, or
- to **monitor and evaluate the performance** and behaviour of persons in such relationships.

These use cases cover the entire life span of a contractual relationship. They can be categorised into two phases, with one phase being the time before a contract has been concluded and the other phase being the time in which the parties perform the contract. AI systems used before a contract is concluded are sometimes also called 'robo-recruiters'. An example of a high-risk use case before conclusion of a contract is a sourcing system that specifically identifies potential employees (or freelancers) with a suitable skills profile and contacts them for the purpose of concluding a contract. AI systems used to read, analyse and evaluate job applications automatically shall also be considered high risk. AI-systems conducting automated job interviews are not mentioned expressly as high-risk use cases. They are however likely to be considered high risk under the use case of 'analysing and filtering job applications' since applications are in fact also viewed and evaluated during automated job interviews. However, this use case is not explicitly listed as an example and could still be explicitly added in the future (for the addition of further critical use cases, see Sect. 3.1.2.9). Additionally, AI systems that autonomously decide on the conclusion of contracts based solely on the processing of personal data have to meet the requirements for automated decision-making under the GDPR (Article 22 GDPR; see Sect. 7.2.7).

After the conclusion of a contract, certain AI systems used to adjust the terms and monitor performances in the context of the contractual relationship can also be considered high risk. During this time, various types of information, e.g. working hours, workloads or performance indicators, can be recorded and analysed by AI systems. AI systems can optimise processes and distribute tasks according to this analysis in order to increase efficiency. Insofar as such AI systems evaluate the performance of individual persons and these evaluations are used, for example, to determine further career stages or to distribute tasks based on individual behaviour, characteristics or traits (without these being mere preparatory tasks, see below), these systems may be considered high risk.

Especially in the context of workers management, not all AI systems covered by the aforementioned use cases are considered high risk under any given circumstances. To acknowledge the potential benefits of AI in increasing efficiency and profitability as well as equal and fair treatment of employees, AI systems that only support or improve human decision-making shall not be considered high risk (see Sect. 3.1.2.10). In the area of employment and workers management, for example, there are AI systems that review HR decisions based on objective key figures (e.g. on performance) and can, for example, detect unconscious favouritism towards certain groups of people. AI systems can also take on preparatory tasks for a personnel assessment. In these cases, an AI system may be considered non-high risk even though it is used in the context of an employment relationship (see Sect. 3.1.2.10).

Related Topics

Possible amendments to the critical use cases: Sect. 3.1.2.9.
Exemptions from the critical use cases: Sect. 3.1.2.10. ◀

3.1.2.5 Which AI Systems Are Considered High-Risk in the Area of Essential Services?

Annex III No. 5

Recital 58 (Access to essential services)

The access to and enjoyment of certain 'essential services' is another area in which AI systems may be considered high risk. This area is intended to cover those services that are necessary for social participation and for a person's standard of living (Recital 58). The use cases in this critical area address relationships that are typically characterised by an imbalance of powers in which individuals are dependent on the provision of the service. There would be significant risks to their standard of living, health or property if these services were not provided.

In the area of essential services, AI systems are generally considered high risk if they are intended to be used:

- by public authorities or on behalf of public authorities
  - to evaluate the eligibility of natural persons for essential public assistance benefits and services, including healthcare services, as well as
  - to grant, reduce, revoke, or reclaim such benefits and services;

Examples include health services, social security benefits and social services that provide protection in cases such as maternity, illness, industrial accidents, dependency or old age and loss of employment and housing assistance (Recital 58);

- to evaluate the creditworthiness of natural persons or establish their credit score, with the exception of AI systems used to detect financial fraud. These services are essential as they determine access to financial resources or essential services, such as housing;
- for risk assessment and pricing in relation to natural persons in the case of **health and life insurance**; in this case too, the risks for the persons affected can be particularly high if AI systems have not been carefully developed.
- to evaluate and classify **emergency calls** by natural persons;
- to dispatch, or to establish priority in the dispatching of, emergency first response services, including by police, firefighters, and medical aid, as well as of emergency healthcare patient triage systems.
- It is important to note that all of these use cases only cover natural persons, i.e. human beings. If legal entities apply for public support or loans, AI-based checks are therefore not regarded as high-risk AI systems.

3.1.2.6 Which AI Systems Are Considered High-Risk in the Area of Law Enforcement?

Article 3(45) and (46), Annex III No. 6

Recitals 42 (Predictive policing and profiling), 59 (High-risk AI in law enforcement)

Law enforcement is a further area in which certain AI systems are considered high risk. In the AI Act, 'law enforcement' is defined to include all activities carried out by or on behalf of law enforcement authorities for the purposes of prevention, investigation, detection, or prosecution of criminal offences, or the execution of criminal penalties, including safeguarding against and preventing threats to public security (Article 3(46)). Law enforcement authorities are all public authorities competent for the purposes listed above and all agencies or bodies entrusted by member state law to exercise public authority and public powers for those purposes (Article 3(45)). This definition is still rather vague, as, for instance, the concepts of criminal offences and authorities vary between the EU member states.

Additional conclusions regarding the understanding of law enforcement in EU law can be drawn from data protection law. Data processing in law enforcement is excluded from the scope of the GDPR (Article 2(2) of the GDPR). Instead, Directive 2016/680 on data protection in the area of law enforcement (so-called LED) applies. The scope of the LED, as well as the exemption from the scope of the GDPR, correspond to the area of law enforcement under the AI Act. With regard to data protection law, all proceedings relating to administrative offences and all preventive measures against administrative offences are included in the area of law enforcement. However, the protection and defence against threats to public security shall only be included in the area of law enforcement within the meaning of the GDPR and the LED, if it relates to the prevention, investigation, detection or prosecution of criminal offences.

Therefore, 'criminal offences' under the AI Act can also include administrative offences. Administrative actions to prevent administrative offences are often subject to law enforcement proceedings. When administrative actions address threats to public safety, they are considered as law enforcement activities if this threat is also connected to an individual's criminal or administrative offence.

In data protection law, it is highly disputed whether **criminal court proceedings** fall within the scope of the LED, as national law often would refer to courts as 'authorities' when they perform their tasks as part of the judicial branch. If courts were to be understood as law enforcement authorities, court proceedings would be excluded from the GDPR and governed by the LED instead. Correspondingly, if courts were considered law enforcement authorities, AI systems used in criminal court proceedings would fall in the area of law enforcement under the AI Act. Thus, they would often be considered high-risk use cases. The better argument suggests to include court proceedings in the notion of law enforcement. In particular, courts are bound by the very procedural fundamental rights the AI Act is meant to protect, namely the right to a fair trial, the right of defence and the presumption of innocence (Recital 59).

It must be noted, though, that AI systems used in court proceedings may also be covered by the area of the administration of justice (see Sect. 3.1.2.8). Thus, even if criminal court proceedings would not be considered law enforcement, AI systems used therein might still be classified as high risk.

AI systems intended to be used for administrative proceedings by **tax and customs authorities** as well as by financial intelligence units (FIUs) carrying out administrative tasks under EU anti-money laundering law are considered not to be high risk (Recital 59).

On some occasions, the use of AI systems in the area of law enforcement as described above could be considered a **matter of national security** by an EU member state. In this case, the AI Act would not be applicable at all (see Sect. 1.2.7) and the AI systems would not be high risk.

High-risk AI systems are those used by or on behalf of law enforcement authorities or by EU institutions, bodies, offices or agencies in support of law enforcement authorities or on their behalf if they are intended to be used:

- to assess the risk of a natural person becoming the victim of criminal offences;
- as polygraphs or similar tools;
- to evaluate the reliability of evidence in the course of the investigation or prosecution of criminal offences;
- to assess the risk of a natural person offending or re-offending, insofar as this is not based solely on profiling (as defined in Article 3(4) of Directive (EU) 2016/680).
- (if the risk assessment is based solely on profiling, the AI system is generally prohibited, see Sect. 2.4);
- to assess personality traits and characteristics or past criminal behaviour of natural persons or groups;
- for the profiling of natural persons (as defined in Article 3(4) of Directive (EU) 2016/680) in the course of the detection, investigation or prosecution of criminal offences.

These high-risk use cases are largely descriptive and self-explanatory, except for the notion of 'polygraphs and similar tools.' Polygraphs are a specific type of so-called 'lie-detectors'. They can measure several physiological characteristics at the same time, e.g. blood pressure, pulse or perspiration. They are used to recognise significant physical activities in order to draw conclusions about the veracity and reliability of statements. Thus, AI systems should only be considered a similar tool to polygraphs if they provide similar functionality, i.e. if they are used to indicate the veracity and reliability of witnesses based on physical characteristics, such as brain activity.

▶ **Further Information** *Commission Nationale de l'Informatique et des Libertés (CNIL)*, "Law enforcement Directive": What Are We Talking About? (2021).

3.1.2.7 Which AI Systems Are Considered High-Risk in the Area of Migration, Asylum and Border Control Management?

Annex III No. 7

Recital 60 (Migration, asylum and border control management)

The area of migration, asylum and border control management is not explicitly defined in the AI Act. The terms used correspond to EU law that covers freedom of movement within the EU, the control of external borders, asylum, and immigration (see Article 3(2) of the Treaty on EU). Therefore, the critical area of migration, asylum and border control management should cover persons entering or leaving the EU temporarily or permanently as well as persons moving between different EU member states temporarily or permanently. This includes related previous and subsequent procedures connected to these movements, e.g. the issuing of visas or residence permits.

A key characteristic of migration, asylum and border control is the fact that persons in particularly vulnerable situations depend on the actions of the competent public authorities. Numerous fundamental rights and freedoms are affected by decisions taken in this area, e.g. the right to free movement and the right to protection of private life and personal data. Accuracy, transparency, and non-discrimination of decisions are therefore particularly important. Therefore, certain AI systems used to fulfil tasks with regard to migration, asylum and border control management are considered high risk.

The high-risk use cases in the area of migration, asylum and border control management include AI systems intended to be used by or on behalf of competent authorities or EU institutions, bodies, offices or agencies:

- as polygraphs or similar tools (see Sect. 3.1.2.6);
- to assess a risk posed by a natural person who intends to enter or who has entered the territory of an EU member state, including security risks, risks of irregular migration, or health risks;
- to assist competent public authorities for the examination of applications for asylum, visa or residence permits and for associated complaints with regard to the eligibility of the natural persons applying for a status, including related assessments of the reliability of evidence; or
- for the purpose of detecting, recognising or identifying natural persons, with the exception of the verification of travel documents.

▶ **Further Information** *European Parliament*, An area of freedom, security and justice: general aspects (2024).

3.1.2.8 Which AI Systems Are Considered High-Risk in the Area of Administration of Justice and Democratic Processes?

Annex III No. 8

Recitals 61 (Administration of justice and democratic processes), 62 (Influencing electoral behaviour)

The areas of administration of justice and democratic processes consist of two different parts. On the one hand, the administration of justice encompasses the entire judicial system and also bodies for alternative dispute resolution, insofar as their results are binding. On the other hand, democratic processes include at least elections and referenda and the preceding campaigns.

The two high-risk use cases the AI Act establishes in the critical area of administration of justice and democratic processes are the following:

- AI systems that are intended to be used by or on behalf of a judicial authority to assist researching and interpreting facts and the law and in applying the law to a concrete set of facts, or that are intended to be used in a similar way in alternative dispute resolution.
- This means, for example, that an AI system trained on the basis of a legal database to interpret the law is considered high risk if it is used to provide a judge with a complete draft judgement when deciding on a legal dispute. It must be stressed that not all AI systems used in the administration of justice are considered high risk. If an AI system fulfils certain conditions, especially if it only fulfils a narrow procedural task, it will not be considered high risk (for detail, see Sect. 3.1.2.10). In the administration of justice, AI systems not deemed high risk can, for example, enable judges to make annotations in and compare pleadings, highlight relevant passages in judgements, find certain information and present it in a structured manner or recognise deviations from previously issued court decisions. All of these examples do not compromise judicial independence but highlight that AI will play a key role in modernising the justice system and mitigating the workload of judges and other parties involved in the administration of justice. These potential benefits shall not be jeopardized by the AI Act. Regarding the administration of justice, it is expressly stated in the AI Act that purely administrative ancillary activities, such as the anonymisation or pseudonymisation of judgments and other documents or means of communication and administrative tasks, do not fall within the high-risk area (Recital 61).
- AI systems that are intended to be used for influencing the outcome of an election or referendum or the voting behaviour of natural persons in the exercise of their vote in elections or referenda. The AI Act does not provide any examples of AI systems it is intended to cover in the context of democratic processes, but it seems likely that, for instance, AI systems will be considered high risk if they are intended to be used to analyse population groups, determine their preferences and, on this basis, target election advertising with specific content.

- The classification of high-risk AI systems with regard to democratic processes expressly does not apply to AI systems whose output is not directly exposed to natural persons, such as tools for organising, optimising or structuring political campaigns in administrative or logistical terms.

3.1.2.9 Can the Critical Use Cases Be Amended in the Future?

Article 7

The AI Act does not provide a definite list of all use cases in which AI systems are considered high risk. Rather, the list in Annex III may be amended by the European Commission. **New use cases** within the eight critical areas (Annex III, see Sect. 3.1.2) can be **added** if they pose a risk of harm to health, safety, or fundamental rights at least equivalent to the use cases already defined (Article 7(1)). Use cases can also be **removed** if they no longer pose a significant risk and their deletion does not decrease the overall level of protection of the AI Act (Article 7(3)).

Before adding new use cases, the European Commission must examine whether these new AI use cases pose risks to fundamental rights equivalent to the previously recognised use cases.

As long as these new use cases have not yet been added by the European Commission, the AI system would not be considered high risk and would not have to comply with the requirements for high-risk AI systems. However, the competent market surveillance authority could still take corrective measures against this AI system, even though it does not violate any provisions under the AI Act. Market surveillance authorities may take action even against AI systems that comply with the applicable requirements of the AI act if these AI systems nevertheless present a risk to the health or safety of persons, to fundamental rights, or to other aspects of public interest protection (Article 82; see Sect. 6.2.4.1).

The AI Act contains a list of **criteria on how to assess risks to fundamental rights** with regard to use cases of high-risk AI systems. Before the European Commission amends the critical use cases, it must take into account the following **criteria** (Article 7(2)):

- intended purpose of the AI system;
- the extent to which the AI system is used or is likely to be used;
- the nature and amount of the data processed and used by the AI system, in particular whether special categories of personal data are processed (see Article 9 of the GDPR; also see Sect. 7.2.4.3);
- the extent to which the AI system acts autonomously and the possibility for a human to override a decision or recommendation that may lead to potential harm;
- the extent to which the use of the AI system has already caused harm to health and safety, has had an adverse impact on fundamental rights or has given rise to significant concerns about the likelihood of such harm or adverse impact; this can be demonstrated, for example, by reports or documented allegations submitted to national competent authorities;

- the potential extent of such harm or adverse impact, in particular in terms of its intensity and its ability to affect multiple persons or to disproportionately affect a particular group of persons;
- the extent to which persons who are (at least potentially) harmed are dependent on the outcome produced with the AI system; for instance, this refers to situations in which for practical or legal reasons it is not reasonably possible to opt-out from that outcome;
- the extent to which there is an imbalance of power, or the persons who are (at least potentially) harmed are in a vulnerable position in relation to the deployer of the AI system; in particular, a vulnerable position can result from status, authority, knowledge, economic or social circumstances, or age;
- the extent to which the outcome produced with the AI system is easily corrigible or reversible; it shall be taken into account what technical solutions are available to correct or reverse the outcome; however, outcomes having an adverse impact on health, safety or fundamental rights, shall not be considered to be easily corrigible or reversible;
- the magnitude and likelihood of benefit of the deployment of the AI system for individuals, groups, or society at large, including possible improvements in product safety; and
- the extent to which existing EU law provides for effective measures of redress in relation to the risks posed by the AI system (other than claims for damages) and for effective measures to prevent or substantially minimise those risks.

Related Topics

Market surveillance procedures: Sect. 6.2.4.1.
Corrective powers of market surveillance authorities: Sect. 6.2.9.3. ◀

3.1.2.10 When Are AI Systems in Critical Areas or Use Cases Not Considered High-Risk?

Article 6(3)

Recital 53 (Exemptions from high-risk categories)

Not all AI systems in critical use cases are considered high risk. According to Article 6(3), AI systems are exempted, if they **do not pose a significant risk** of harm to the health, safety or fundamental rights of natural persons. Hence, AI systems shall not be considered high risk if they do not significantly influence the outcome of human or automated decision-making. This clarification is highly relevant in practice, allowing the use of AI in important areas such as justice, education and in the workplace environment. The exemption strikes a balance between exploiting the benefits of digitalisation (e.g. in the context of justice or education modernisation) and avoiding specific risks inherent to the respective high-risk categories. However, the exemption does not apply to AI systems performing profiling (see Sect. 2.4) of natural persons.

In general, an AI system that falls within the high-risk areas defined in Annex III is not considered high risk if at least one of the following conditions is met:

- The AI system is intended to perform a **narrow procedural task**. For example, an AI system is not considered high risk if it converts unstructured data into structured data, categorises incoming documents or recognises duplicates.
- The AI system is intended to **improve the result** of a previously completed human activity. In this context, the AI system merely represents an 'additional layer' that complements a human activity. For example, when an AI system improves the language style or text of a previously drafted document.
- The AI system is intended to **detect decision-making patterns** or deviations from prior decision-making patterns and is not meant to replace or influence the previously completed human assessment, without appropriate human review. For example, an AI system is not considered high risk if it reviews a teacher's grading to alert to deviations from previous grading patterns.
- The AI system is intended to **perform a preparatory task** to an assessment relevant for the purposes of the use cases listed in Annex III. For example, AI systems are not high risk if they provide intelligent solutions for the processing of dossiers (documents, files, workflows), e.g. by indexing, searching, text and language processing, linking data to other data sources or translating texts.

The examples behind every condition are expressly included in the AI Act to illustrate the conditions under which AI systems are not considered high risk (Recital 53).

In all of these cases, it is crucial that the AI system does not decisively influence the decision or activity, which could create a significant risk of harm to health, safety or fundamental rights. These AI systems should only support the human decision or activity. Despite the use of AI, the decision and activity must therefore be determined by the will of the person using the AI system.

3.2 Which Requirements Apply to High-Risk AI Systems?

Article 8–15

Recitals 27 (AI ethics guidelines), 64 (Requirements for high-risk AI systems), 65 (Risk management system), 66 (Risk mitigation), 67 (Data quality and data governance), 68 (Access to high quality data), 69 (Principles of data processing and federated learning), 70 (Processing of special categories of personal data), 71 (Technical documentation and automatic logging), 72 (Instructions for use and transparency), 73 (Human oversight), 74 (Accuracy, robustness and cybersecurity), 75 (Technical robustness), 76 (Cybersecurity), 77 (Cyber resilience Act I), 78 (Cyber resilience Act II)

All high-risk AI systems must meet certain mandatory requirements to **mitigate** the **risks** and to establish a high level of **trustworthiness** (Recital 64). The intended purpose, the context of use, the state of the art, as well as the effectiveness and proportionality of applicable measures must always be taken into account when

assessing whether a high-risk AI system meets the relevant requirements of the AI Act.

Essentially, seven requirements apply to all high-risk AI systems:

- establishing a **risk management system** (Article 9; see Sect. 3.2.1);
- ensuring **data quality** and **data governance** (Article 10; see Sect. 3.2.2);
- drawing up a **technical documentation** (Article 11; see Sect. 3.2.4);
- **record-keeping** and **logging** (Article 12; see Sect. 3.2.5);
- transparency and provision of **information to deployers** (Article 13; see Sect. 3.2.6);
- enabling **human oversight** (Article 14; see Sect. 3.2.7) and
- ensuring appropriate **accuracy**, **robustness** and **cyber security** (Article 15; see Sect. 3.2.8).

The requirements for high-risk AI systems are based on the **ethical guidelines** of the independent **High-Level Expert Group on AI** (see Sect. 1.6). Although these ethical principles are non-binding, they have influenced the AI Act and can help to explain the intentions behind the various requirements for high-risk AI systems. The ethical guidelines can therefore help with the application and interpretation of the high-risk requirements and facilitate the compliant development of high-risk AI systems.

There is no general answer to the question who has to fulfil these requirements. It depends on the type of AI system which person is required to comply with the requirements for high-risk AI systems:

- If the AI Act is directly applicable to a high-risk AI system, its provider is obliged to fulfil the requirements (for the definition of provider, see Sect. 1.3.1; for the additional obligations of providers, see Sect. 3.3). This applies to 'stand-alone' high-risk AI systems in critical use cases (as listed in Annex III, e.g. AI systems in employment relationships or in law enforcement; see Sect. 3.1.2) and to high-risk AI systems that are products or safety components of products under legal acts within the so-called New Legislative Framework (see Sect. 1.1) (e.g. machines and toys; see Sect. 3.1.1.1).
- If the **AI Act is not directly applicable** to a product (e.g. motor vehicles and airplanes; see Sect. 3.1.1.2), the requirements for high-risk AI systems are incorporated into the regulatory act applicable to these products (Articles 102–109). The person responsible for the other conformity requirements for these products, i.e. typically the **manufacturer** of the product, is also responsible for fulfilling the requirements for high-risk AI systems.

In practice, the so-called **harmonised standards** developed by the European standardisation organisations (see Sect. 7.6.3) will be essential for implementing the requirements for high-risk AI systems in both cases. Harmonised standards further specify and shape the requirements for high-risk AI systems. AI systems that comply with harmonised standards are presumed to be in conformity with the requirements of the AI Act, provided that the European Commission has approved the respective standards. Providers of high-risk AI systems will, in many cases, follow the harmonised Standards in order to be able to demonstrate conformity as part of the **conformity assessment** (see Sect. 6.1) to be able to prove that the AI system fulfils the corresponding high-risk requirements.

Related Topics

Provider: Sect. 1.3.1.
Ethical principles of the High-Level Expert Group: Sect. 1.6.
Classification of high-risk AI systems: Sect. 3.1.
Obligations of providers: Sect. 3.3.
Technical standards: Sect. 7.6. ◀

▶ **Further Information** *AI Verify Foundation*, Model AI Governance Framework for Generative AI – Draft (2024); *The Alan Turing Institute*, Human Rights, Democracy, and the Rule of Law Assurance Framework for AI Systems (2021); *Bengio*, International Scientific Report on the Safety of Advanced AI – Interim Report (2024); *Bundesamt für Sicherheit in der Informationstechnik*, Generative AI models (2024); Transparency of AI Systems (2024); *Centre of Information Policy Leadership*, Building Accountable AI Programs (2024); *European Union Agency for Cybersecurity*, Artificial Intelligence and Cybersecurity Research (2023); *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022); *Galdon Clavell*, Checklist for AI Auditing (2024); *High-Level Expert Group on AI*, Ethics guidelines for trustworthy AI (2019); Assessment List for Trustworthy AI (2020); *International Association of Privacy Professionals*, EU AI Act Compliance Matrix (2024); *International Organization for Standardization*, Artificial Intelligence Management Standards (2024); *National Institute of Standards and Technology*, AI Risk Management Framework (2023); *OECD*, Advancing accountability in AI: Governing and managing risks throughout the lifecycle for trustworthy AI (2023); OECD Framework for the Classification of AI systems (2022); *OECD.AI Policy Observatory*; Catalogue of Tools & Metrics for Trustworthy AI (2024); Generative Artificial Intelligence Profile – Draft (2024); *UK AI Safety Institute*, Inspect – An open-source framework for large language model evaluations (2024).

3.2.1 Which Requirements Apply to the Risk Management System of High-Risk AI Systems?

Articles 3(2) and (13), 9

Recitals 65 (Risk management system), 66 (Risk mitigation)

A risk management system for high-risk AI systems shall be established, implemented, documented and maintained (Article 9(1)). The risk management system is the **central building block of AI governance** and is fundamental to ensuring a high level of protection of health, safety and fundamental rights, as required by the AI Act. The implementation of a risk management system is intended to ensure that the **overall risk of the AI system**, i.e. the combination of the probability of harm occurring and the severity of that harm (Article 3(2)) is reduced to an **acceptable level** (Article 9(5)). The requirements for risk management and mitigation are therefore a **core element of the AI Act**.

The risk management system shall take into account the risks that arise from the use in accordance with the **intended purpose** or from **reasonably foreseeable misuses** (see Sect. 1.4.2) and the risks arising from the **environment** within which the AI system operates.

The risk management system

- shall be run continuously **throughout the entire life cycle**, i.e. from planning to operation of the AI system,
- shall be subject to regular systematic **review and updating**,
- shall be supported by the provider's quality management system, as applicable (see Sect. 3.3.1),
- shall continuously incorporate **new findings** that arise during testing or operation, e.g. with regard to data quality (see Sect. 3.2.2), including findings from the **post-market monitoring system**, if applicable (see Sect. 3.3.7), and thus represents an **iterative process**,
- and
- shall be described in detail in **the technical documentation** (see Sect. 3.2.4).

High-risk AI systems must be tested with regard to their intended purpose at the latest before placing on the market or putting into service in order to determine the most appropriate and targeted risk management measures. The tests should be carried out during the development process and cover the entire life cycle of the system. This ensures that the high-risk AI system performs consistently for its intended purpose and that it fulfils the other requirements applicable to high-risk AI systems (see Sect. 3.2). Under certain conditions and in consultation with the competent authority, the testing can (additionally) be carried out under real-world conditions, i.e. in practical use (see Sect. 6.3.2).

A risk management system must include the **following steps** (Article 9(2)):

- the **identification and analysis** of the known and reasonably foreseeable **risks** that the high-risk AI system can pose to health, safety or fundamental rights when used in accordance with its intended purpose;
- the **estimation and evaluation of the risks** that may arise if the high-risk AI system is used in accordance with its intended purpose, or under conditions of reasonably foreseeable misuse;
- the evaluation of other potential risks, based on the analysis of data gathered from the **post-market monitoring system** (see Sect. 3.3.7); and
- the adoption of appropriate and targeted risk management measures designed to **address the identified risks**, which is the ultimate goal of implementing a risk management system.

The following circumstances shall be given due consideration in the context of risk mitigation:

- the **technical knowledge**, experience, education and training to be expected by the **deployer**,
- the **presumable context** in which the system is intended to be used,
- **foreseeable misuses**, insofar as they are based on 'easily foreseeable human behaviour' (see Sect. 1.4.2),
- **effects and possible interaction** resulting from the combined application of the requirements for high-risk AI systems (see Sects. 3.2.2–3.2.8). The effects of implementation and the specific risks in the areas of data governance, documentation, record-keeping and information obligations as well as in terms of human oversight, and accuracy, robustness and cybersecurity must therefore be considered and assessed. The aim is to minimise risks more effectively while ensuring an **appropriate balance in the implementation of risk management measures** (Article 9(4)).

The risk management measures must be designed in such a way that **any relevant residual risk** associated with each hazard, as well as the **overall residual risk** of the high-risk AI system, is assessed as **acceptable** (Article 9(5)). When determining the most appropriate risk management measures, it shall be ensured that

- risks identified and evaluated in the iterative process of the risk management system are eliminated or reduced, insofar as this is technically feasible;
- **mitigation and control measures** addressing risks that cannot be eliminated are implemented, where appropriate;
- sufficient information is provided to the **deployer** (see Sect. 3.2.6), and, where appropriate, training is provided to the deployer.

The identified risks should be described in the instructions for use (see Sect. 3.2.6) so that the deployer is aware of these risks and can take them into account when using the high-risk AI system. Deployer training need not be required on a regular basis to explain specific risks or to train deployers with regard to foreseeable misuses. However, providers may consider additional training measures to mitigate reasonably foreseeable misuses as necessary and appropriate (Recital 65).

Together with the quality management system (see Sect. 3.3.1) and the post-market monitoring system (see Sect. 3.3.7), the risk management system forms the **basic framework of the compliance processes for providers** of high-risk AI systems. The other requirements, such as data governance, technical documentation, and record-keeping obligations, are closely interwoven with risk and quality management and post-market monitoring, so that the implementation of a comprehensive, IT-supported system is almost mandatory in practice.

Acknowledged approaches to AI risk management include the **AI Risk Management Framework** of the US National Institute of Standards and Technology (**NIST**), the **OECD classification and risk management approaches** and the **ISO standard 42001 '**Artificial Intelligence Management System'. Another ISO standard, 42005 'AI Impact Assessment', is currently being finalised by the ISO member organisations (see Sect. 7.6).

Further specifications of the risk management systems for high-risk AI systems will be set out in the **harmonised standards** (see Sect. 7.6.3), which serve to demonstrate conformity and thus compliance with the requirements that the AI Act stipulates for risk management systems.

Related Topics

Reasonably foreseeable misuse: Sect. 1.4.2.
Requirements for data quality and data governance: Sect. 3.2.2.
Requirements for the technical documentation: Sect. 3.2.4.
Requirements for instructions for use: Sect. 3.2.6.
Provider's quality management system: Sect. 3.3.1.
Provider's post-market monitoring obligation: Sect. 3.3.7.
Testing in real-world conditions: Sect. 6.3.2.
Technical standards for AI: Sect. 7.6. ◀

3.2.2 Which Requirements Apply to Data Quality and Data Governance for High-Risk AI Systems?

Article 10

Recitals 66 (Risk mitigation), 67 (Data quality and data governance), 68 (Access to high-quality data), 69 (Principles of data processing and federated learning)

High quality data is essential for the successful development and implementation of AI systems especially if they are based on AI models that have been trained with data. Besides, high quality data is also fundamental for testing AI systems, even if they have not been trained with data, to assess that the AI systems are functioning as intended.

The requirements regarding **data quality and data governance** shall ensure that AI models and corresponding high-risk AI systems operate in a non-discriminatory manner. Inadequate, unbalanced, or incorrect data sets can potentially pose risks to health, safety or human rights and should therefore not be perpetuated in the use of a high-risk AI system. The requirements of the AI Act on data quality and data governance cover the handling of data and the required properties of data sets. In addition to safety aspects, they are intended to promote **data protection**, **data provenance** and thus the **transparency** of high-risk AI systems.

This transparency requirement for high-risk AI systems must not be confused with the transparency requirements for certain AI systems designated in Article 50. The latter are intended to ensure that users of certain AI systems, e.g. generative AI systems, are aware that they are interacting with AI (and not with another human) or reciprocate AI-generated content (deep fakes, texts; see Chap. 4).

If a high-risk AI system uses AI models that have been trained with data, special requirements regarding the data quality and data governance apply to the training, validation and testing data sets (Article 10(1)). For high-risk AI systems based on other techniques, the requirements only apply to the testing data sets (Article 10(6)). In general, training, validation and testing data must be subject to **data governance and data management procedures** that are **appropriate** in relation to the intended purpose of the high-risk AI system (Article 10(2)).

Those procedures shall concern in particular:

- the relevant **design choices**;
- the data collection processes and **the origin of the data**; where personal data is used, this also includes the original purpose of the data collection;
- the **data-preparation processing operations** (such as annotation, labelling, cleaning, updating, enrichment and aggregation of data);
- the formulation of assumptions, in particular with respect to the **information the data are supposed to measure and represent**;
- an **assessment** of the **availability**, **quantity** and **suitability** of the required data sets;
- an examination in view of **possible biases** that are likely to affect the **health** and **safety** of individuals, have a negative impact on **fundamental rights** or lead to

discrimination that is prohibited under EU law, in particular where data outputs influence inputs for future operations ('feedback loops');
- the appropriate **measures** to detect, prevent and mitigate any identified **biases**; and
- the **identification** of relevant **data gaps or shortcomings** that prevent compliance with the AI Act and measures to rectify them.

The **data sets** used for training, validation and testing must also have the following **properties**:

- They must be relevant, sufficiently representative, and, to the best extent possible, **free of errors and complete in view of the intended purpose** (Article 10(3)). With the restriction ('to the best extent possible'), the legislator has taken into account the fact that, especially when using large amounts of data to train AI models, it is rarely possible for large data sets to be completely error-free, even with the best efforts.
- The data sets must also have **appropriate statistical properties** at the level of individual data sets or in combination thereof, including, where applicable, in relation to the persons or groups of persons to whom the high-risk AI system is intended to be used (Article 10(3)).
- In addition, the data sets shall take into account any **specific** geographical, contextual, behavioural or functional **setting** under which the high-risk AI system is intended to be used, to the extent required by this intended purpose (Article 10(4)).

Training data influences the **functionality**, **safety** and **output quality** of an AI model and thus of a high-risk AI system that uses a corresponding AI model. Therefore, the data sets must be selected in such a way that they serve the intended purpose appropriately. Appropriate integrity checks should ensure that data sets used in training are neither manipulated themselves ('data poisoning') nor manipulated in such a manner that the AI model and its behaviour are subsequently changed ('model poisoning'). Other risks in relation to the data used are negative biases and drifts which arise when the data used to operate the AI system and the training data diverge. Test and key figures that map data quality can also be generated and retrieved automatically as part of **AI governance platforms**.

Further specifications for data governance and data management procedures to be implemented by AI system providers are still being developed for the purpose of **harmonised standards,** which serve to demonstrate conformity with data quality and data governance requirements (see Sect. 7.6.3). Here, the standardisation organisations should place particular emphasis on data generation and collection, data preparation processes, design choices and procedures for identifying and eliminating biases and potential discrimination through substitute data ('proxy discrimination') or other relevant data deficiencies.

Related Topics

Transparency requirements for certain AI systems: Chap. 4.
Technical standards: Sect. 7.6. ◀

3.2.3 Which Requirements Apply to the Training and Testing of High-Risk AI Systems with Special Categories of Personal Data?

Article 10(5)

Recital 70 (Processing of special categories of personal data)

Special categories of personal data may only be processed in exceptional cases and in compliance with strict requirements (Art. 9 of the GDPR; see Sect. 7.2.4.3). However, they may be used for the training of high-risk AI systems insofar as this is strictly **necessary to detect and correct biases** in connection with high-risk AI systems (Article 10(5)). Special categories of personal data are the following (Article 9 of the GDPR):

- data on racial and ethnic origin,
- data on political opinions,
- data on religious or philosophical beliefs,
- data on trade union membership,
- genetic data,
- biometric data for the purpose of uniquely identifying a natural person,
- health data, or
- data concerning the sex life or sexual orientation of a natural person.

When processing such sensitive data based on the exception provided by the AI Act, appropriate safeguards must be put in place to protect the fundamental rights and freedoms of natural persons, for example with regard to **data security** or through the **pseudonymisation** of personal data. The use of anonymised or synthetic data, i.e. data sets that artificially replicate the data of fictional natural persons, should also be considered.

When using special categories of personal data, the **requirements of general European data protection laws**, such as the General Data Protection Regulation (GDPR), Directive (EU) 2016/680 and Regulation (EU) 2018/1725, must be taken into account (see Sect. 7.2).

In addition, all of the **following conditions** must be met for the processing of special categories of personal data for training or testing purposes to be **exceptionally authorised** under the AI Act (Article 10(5)):

- The detection and correction of biases cannot be effectively fulfilled by processing other data, including **synthetic or anonymised data**.

- The special categories of personal data are subject to **technical limitations on their re-use**, and state-of-the-art security and privacy preserving measures, including pseudonymisation.
- The special categories of personal data are subject to appropriate **security measures** (including to ensure strict control and documentation of access, which may only be carried out by authorised persons with appropriate confidentiality obligations).
- The special categories of personal data will **not** be **transmitted, transferred or otherwise accessed** by third parties.
- The special categories of personal data will be **deleted** once the bias has been corrected or the end of the retention period for the personal data has been reached (whichever comes first). The AI Act does not clarify which retention periods it refers to. It is likely that this wording is intended to ensure compliance with the data protection principle of 'storage limitation' (see Sect. 7.2.3).
- The records of processing activities shall also include the **reasons why** the processing of special categories of personal data was **strictly necessary** to detect and correct biases, and why that objective could not be achieved with the processing of other data; all pursuant to the GDPR, Regulation (EU) 2018/1725 and Directive (EU) 2016/680.

3.2.4 What Requirements Apply to the Technical Documentation of High-Risk AI Systems?

Article 11

Recitals 66 (Risk mitigation), 71 (Technical documentation and automatic logging)

The technical aspects of every high-risk AI system shall be documented from the start of development and throughout its entire lifecycle. This serves to ensure **transparency** (explainability) and **controllability** of the AI system. The documentation serves as proof that the system complies with the requirements set out in the AI Act. On the one hand, it enables national competent authorities and notifying bodies to fulfil their corresponding inspection and investigation tasks. On the other hand, the technical documentation serves as a **self-assessment** of the provider regarding the functioning of the AI system and compliance with the requirements for high-risk AI systems. It supports the explainability of outputs generated by the AI system, the surveillance of the system during its operation and its **post-market monitoring** (see Sect. 3.3.7).

The technical documentation should contain **general information** about the characteristics, capabilities and limitations of the system, algorithms, data, training, validation and testing processes used, and the risk management system.

The technical documentation has to be (Article 11(1)):

- **drawn-up before** the AI system is placed on the market or put into service,
- kept **up to date**, and

- **written in a clear and comprehensible form** to assess how the AI system fulfils the requirements for high-risk AI systems (see Sect. 3.2).

For high-risk AI systems that are products or safety components of products already regulated by existing EU harmonisation legislation (for an overview, see Sect. 3.1.1), a single set of technical documentation shall be drawn up containing all the information required by both the AI Act and the relevant EU harmonisation legislation.

Small and medium-sized enterprises and start-ups (see Sect. 1.3.12) may use a simplified technical documentation that the European Commission will introduce. Notified bodies must accept this simplified form in the conformity assessment procedure.

The technical documentation shall contain the **following categories of information** (listed in Annex IV), insofar as they are relevant to the AI system in question:

- a **general description** of the high-risk AI system, including
  - its intended purpose, the name of the provider and the version of the system, reflecting its relation to previous versions;
  - how the AI system interacts with, or can be used to interact with, hardware or software (including other AI systems);
  - the versions of relevant software or firmware and any requirements related to version updates;
  - the description of all the forms in which the AI system is placed on the market or put into service, e.g. as embedded into hardware, for download or via an application programming interface (API);
  - the description of the hardware on which the high-risk AI system is intended to run;
  - where the AI system is a component of a product, photographs or illustrations showing external features, the marking and internal layout of that product;
  - a basic description of the user-interface provided to the deployer, and
  - the instructions for use for the deployer;
- a detailed **description of the elements** of the high-risk AI system **and of the development process**, including:
  - the methods and steps performed for the development of the AI system, including, where relevant, recourse to pre-trained systems or tools provided by third parties and how those were used, integrated or modified by the provider;
  - the design specifications of the system, namely
    the general logic of the AI system and of the algorithms;
    the key design choices including the rationale and assumptions made, including with regard to persons or groups of persons in respect of whom the system is intended to be used;
    the main classification choices;
    what the system is designed to optimise for, and the relevance of the different parameters;

the description of the expected output and output quality of the system;
the decisions about any possible trade-off made regarding the technical solutions adopted to comply with the requirements of the AI Act (see Sect. 3.2);

- the description of the system architecture explaining how software components build on or feed into each other and integrate into the overall processing; the computational resources used to develop, train, test and validate the AI system;
- where relevant, the data requirements in terms of datasheets describing the training methodologies and techniques and the training data sets used, including
  a general description of these data sets, information about their provenance, scope and main characteristics;
  how the data was obtained and selected;
  labelling procedures (e.g. for supervised learning), and
  data cleaning methodologies (e.g. outliers detection);
- assessment of the necessary measures of human oversight (see Sect. 3.2.7), and necessary technical measures to facilitate the interpretation of the outputs of the high-risk AI system by the deployers (see Sect. 3.2.6);
- where applicable, a detailed description of pre-determined changes to the high-risk AI system and its performance, and relevant information related to technical solutions adopted to ensure compliance with the requirements of the AI Act (see Sect. 3.2);
- information on the validation and test procedures used and their main characteristics; metrics used to measure accuracy, robustness and compliance with other relevant requirements of the AI Act (see Sect. 3.2) and potential discriminatory effects; test logs and all test reports, dated and signed by the responsible persons;
- information on the cybersecurity measures put in place;

- detailed **information on the monitoring, functioning and control of the high-risk AI system**, in particular with regard to
  - its capabilities and limitations in performance with respect to its intended purpose, including the degree of accuracy (overall and with respect to its application to specific individuals or groups of individuals);
  - the foreseeable unintended outcomes and sources of risks to health and safety, fundamental rights, and discrimination in view of its intended purpose;
  - necessary measures of human oversight (see Sect. 3.2.7) and technical measures put in place to facilitate the interpretation of the outputs of the high-risk AI system by the deployers (see Sect. 3.2.6), and
  - any specifications for input data;
- a description of the appropriateness of the **performance metrics** for the specific AI system;
- a detailed **description of the risk management system** (see Sect. 3.2.1);
- a **description of relevant changes** made by the provider to the high-risk AI system during its lifecycle;

- a **list** of all **harmonised standards** (see Sect. 7.6.3) applied in full or in part; if no harmonised standards have been applied, a detailed description of the solutions adopted to meet the requirements of the AI Act, including a list of other relevant standards and technical specifications applied;
- a **copy of the EU declaration of conformity** (see Sect. 3.3.3) and
- a detailed description of the **system for evaluating the performance** of the AI system after its placing on the market, including the post-market monitoring system (see Sect. 3.3.7).

Related Topics

Facilitated requirements for SMEs (incl. start-ups): Sect. 1.3.12.
Products that are or contain high-risk AI systems: Sect. 3.1.1.
EU declaration of conformity: Sect. 3.3.3.
Post-market monitoring obligation: Sect. 3.3.7. ◄

3.2.5 What Requirements Apply to the Logging of High-Risk AI Systems?

Article 12

Recitals 66 (Risk mitigation), 71 (Technical documentation and automatic logging)

High-risk AI systems shall include a logging feature that technically allows to **automatically record events during their lifecycle** (Article 12(1)). High-risk AI systems shall log all system events that indicate risks to health, safety, or fundamental rights and their realisation, and that can facilitate risk monitoring and mitigation measures by the provider (see Sects. 3.2.1 and 3.3.1), by deployers (see Sects. 3.4.1 and 3.4.2), or by market surveillance authorities (see Sect. 6.2).

The logging must be designed in such a way that the operation of the high-risk AI system is **traceable** to an extent appropriate to its intended purpose. To this end, at least the events that are relevant for the following purposes must be recorded (Article 12(2)):

- to identify situations that may result in the high-risk AI system presenting a **risk** to the health, safety, or fundamental rights of persons (see Sect. 6.2.4.1) or in a substantial modification of the AI system (see Sect. 1.4.3),
- to facilitate **post-marketing monitoring** (see Sect. 3.3.7) and
- to **monitor** the operation of the high-risk AI system **by the deployer** (see Sect. 3.4.2).

For high-risk AI systems that are intended to be used for the **remote biometric identification** of persons (see Sect. 3.1.2.1), the logging must include the following additional information (Article 12(3)):

- the period of each use of the high-risk AI system (date and time of the start and end of each use);
- the reference database with which the system compares the input data;
- the input data for which the search has led to a match;
- the identification of the natural persons involved in the mandatory verification of the results (see Sects. 3.2.7 and 3.4.7).

Further specifications regarding logging by AI systems are provided by **harmonised standards** (see Sect. 7.6.3), which serve to demonstrate conformity with the requirements that the AI Act places on logging by high-risk AI systems.

Related Topics

Significant changes to an AI system: Sect. 1.4.3.
Conformity assessment after substantial modification: Sect. 6.1.6.
High-risk remote biometric identification: Sect. 3.1.2.1.
Human oversight: Sects. 3.2.7 and 3.4.2.
Post-market monitoring: Sect. 3.3.7.
Risk management system: Sect. 3.2.1.
Quality management system: Sect. 3.3.1.
Supervisory and monitoring duties of the deployer: Sects. 3.4.1–3.4.2.
Administrative monitoring of compliance with the AI Act: Sect. 6.2.
Regulatory measures against AI systems presenting a risk: Sect. 6.2.4.1. ◀

3.2.6 Which Requirements Apply to the Transparency of High-Risk AI Systems?

Article 13
Recitals 66 (Risk mitigation), 72 (Instructions for use and transparency)

Since AI systems are considered particularly opaque and their decision-making processes are, indeed, not always easy to understand, high-risk AI systems shall be designed to be transparent and comprehensible. In this context, transparency is to be understood in the sense that the functioning of a high-risk AI system shall be understandable and explainable. This does not refer to transparency in the sense that a user recognises to interact with an AI system, as provided for in other provisions of the AI Act (see Chap. 4).

The transparency requirements for high-risk AI systems are intended to allow the deployer to use the system appropriately and in accordance with its intended purpose, to prevent misuse, to enable compliance with the requirements of the AI Act and ultimately to **reduce risks to safety, health, and fundamental rights** (Recital 72).

For these purposes, high-risk AI systems shall be designed and developed in a way to ensure that their operation is sufficiently transparent to enable deployers to interpret the systems output and use it appropriately (Article 13(1)). An

appropriate type and degree of transparency shall be ensured so that providers and deployers can comply with their relevant obligations (see Sects. 3.3 and 3.4). The knowledge and needs of the potential deployer, the intended purpose and the technical elements of the AI system used as well as the state of the art in terms of creating transparency in AI systems must be taken into account.

High-risk AI systems shall be accompanied by instructions for use in an appropriate digital format or otherwise. **Instructions for use** shall include concise, correct, clear and complete information that is relevant, accessible and comprehensible to deployers (Article 13(2)). They shall also inform deployers about intended and precluded uses in order to enable them to select the appropriate AI system for his respective purpose (Recital 72).

Instructions for use shall contain **at least the following information** (Article 13(3)):

- the **identity** and the **contact details of the provider** and, where applicable, of its authorised representative (regarding the requirement to appoint an authorised representative, see Sect. 1.3.10);
- the **characteristics, capabilities, and limitations of performance** of the high-risk AI system, including:
  - its intended purpose;
  - the level of accuracy, robustness and cyber security (see Sect. 3.2.8) and factors that can lead to their impairment;
  - any known or foreseeable circumstance that may lead to risks for health and safety or fundamental rights;
  - where applicable, the technical capabilities and characteristics of the high-risk AI system so that information can be provided that is relevant to explain its output;
  - when appropriate, its performance regarding specific persons or groups of persons on which the system is intended to be used;
  - when appropriate, specifications for the input data, or any other relevant information in terms of the training, validation and testing data sets used (see Sect. 3.2.2);
  - where applicable, further information that enables the interpretation and use of the system's output.
- any **changes** to the high-risk AI system or its performance that are **predetermined** at the moment of the initial conformity assessment;
- the measures to **ensure human oversight** (see Sect. 3.2.7), including technical measures taken to help deployers interpret the results of high-risk AI systems;
- the **computational and hardware resources needed**, the expected **lifetime** of the high-risk AI system and all necessary maintenance and care measures (including software updates), and
- where relevant, a description of the mechanisms included within the system to allow deployers to properly collect, store and interpret the **logs** created by the high-risk AI system (see Sect. 3.2.5).

If the high-risk AI system is based on an AI model, transparency with regard to the AI model can also contribute significantly to create transparency (explainability) regarding the high-risk AI system. Therefore, downstream providers of high-risk AI systems that incorporate **GPAI models** benefit from the transparency obligations that are applied to providers of GPAI models. The AI Act stipulates that providers of GPAI models have to provide relevant information and documentation to the downstream providers that implement the GPAI model in their AI system (Article 53, see Sect. 5.1.2). To this end, various AI model developers already offer fact-sheets, model cards or nutrition labels that provide information on training data and properties of AI models in varying degrees of detail. Corresponding data is often automatically compiled, processed and customised for different target groups (technical experts, auditors, users) as part of an **AI governance system**. Providers of high-risk AI systems can use the information that may already be provided to them by the developers of AI models to fulfil the transparency requirements for their high-risk AI system.

Further specifications regarding transparency and information are to be set out in **harmonised standards** (see Sect. 7.6.3), which serve to demonstrate conformity with the requirements set out in the AI Act.

Related Topics

Requirements for data quality and data governance: Sect. 3.2.2.
Automatic logging of the high-risk AI system: Sect. 3.2.5.
Provider obligations for high-risk AI systems: Sect. 3.3.
Operator obligations for high-risk AI systems: Sect. 3.4.
Appointment of an authorised representative in the EU: Sect. 3.5.4.
Information obligations of the provider of a GPAI model: Sect. 5.1.2. ◀

3.2.7 What Requirements Apply to the Human Oversight of High-Risk AI Systems?

Article 14

Recitals 66 (Risk mitigation), 73 (Human oversight)

The AI Act requires entitites to enable effective human oversight, both technically and organisationally. The AI Act's provisions on human oversight are both an expression and a prerequisite of the principles of human agency and oversight, as included in the ethics guidelines of the High-Level Expert Group on AI set up by the European Commission (see Sect. 1.6.4). Additionally, effective human oversight is necessary to enable corrective actions and harm minimisation. Ensuring human oversight is a core principle of the ethical application of AI and is therefore an integral part of global AI guidelines, principles, recommendations and international agreements (see Sect. 7.5.1).

The AI Act stipulates that high-risk AI systems must be designed and developed in such a way that they can be **effectively overseen** by humans for the period in

which they are used (Article 14(1)). To this end, suitable human-machine interfaces must be implemented in order to recognise malfunctions and to be able to intervene in the processes of a high-risk AI system in an appropriate manner.

Human oversight generally serves to **prevent or minimise risks to health, safety or fundamental rights** (Article 14(2)) when the high-risk AI system is used in accordance with its intended purpose or under circumstances of a reasonably foreseeable misuse (see Sect. 1.4.2). Human oversight is particularly important to mitigate risks that persist although the AI system complies with the other requirements set out by the AI Act.

Supervision and intervention options must be implemented before the high-risk AI system is placed on the market or put into service. The options must be **appropriate with regard to the risks, level of autonomy and context of use** of the high-risk AI system (Article 14(3)). Appropriate mechanisms can either be technically implemented into the AI system itself, where technically feasible, or implemented by the deployer. In many cases, a combination of provider-side (technical) and operator-side (technical or organisational) measures will ensure the necessary level of supervision.

The implemented mechanisms must enable the natural person to whom human oversight is assigned to (Article 14(4))

- to understand capabilities and limitations of the high-risk AI system and monitor **proper operation** and to detect and resolve anomalies, malfunctions and unexpected performance;
- to remain aware of the possible tendency to automatically rely or over-rely on the output produced by a high-risk AI system (**automation bias**);
- to **interpret the results** of the high-risk AI system **correctly,** taking into account the available interpretation tools and methods;
- to decide **not to use** the **high-risk AI system**, disregard, override or reverse the result of the high-risk AI system in any particular situation and
- to intervene in or **interrupt the operation of the system, e.g.** with a 'stop' button or a similar procedure that allows the system to come to a halt in a safe state.

Similar requirements already arise for some AI systems under the GDPR that contains requirements for automated decision-making based solely on the processing of personal data (see Sect. 7.2.7). If an automated decision is permitted under the GDPR, human intervention must be possible, the data subject must be able to present their own point of view and the decision must be contestable (i.e. reversible).

For high-risk AI systems that are intended to be used for the **biometric identification** of persons (see Sects. 3.1.2.1 and 3.4.7), the above-mentioned precautions must be designed in such a way that the deployer does not take any actions or decisions based solely on the identification result produced by the AI system. The identification must be verified and confirmed by at least two humans who have the necessary competence, training and authorisation (Article 14(5)). However, this four-eyes principle may be restricted for AI systems used in the areas of law enforcement, migration, border control or asylum.

Further specifications for ensuring human supervision are provided by **harmonised standards** (see Sect. 7.6.3), which serve to demonstrate conformity with the requirements set out in the AI Act in this area.

Related Topics

Reasonably foreseeable misuse: Sect. 1.4.2.
Biometric high-risk AI systems: Sect. 3.1.2.1.
Obligation for human oversight applicable to deployers: Sect. 3.4.2.
Obligations of deployers of post-remote biometric identification systems: Sect. 3.4.7.
Requirements for automated decision-making under the GDPR: Sect. 7.2.7.
International agreements on AI: Sect. 7.5.1.
Harmonised standards: Sect. 7.6.3. ◄

3.2.8 What Requirements Apply to the Accuracy, Robustness and Cybersecurity of High-Risk AI Systems?

Article 15

Recitals 66 (Risk mitigation), 74 (Accuracy, robustness and cybersecurity), 75 (Technical robustness), 76 (Cybersecurity), 77 (Cyber Resilience Act I), 78 (Cyber Resilience Act II), 122 (Presumption of conformity)

The AI Act sets out requirements for the accuracy, robustness and cybersecurity of high-risk AI systems in order to minimise risks and to prevent harms. Security measures against physical and digital attacks are intended to prevent AI systems from being manipulated and to ensure that high-risk AI systems deliver sufficiently precise and reliable results.

In the light of their **intended purpose** and the acknowledged **state of the art**, high-risk AI systems must be designed and developed to achieve an **appropriate level of accuracy, robustness and cybersecurity** and to function consistently in this respect throughout their lifecycle (Article 15(1)). The European Commission will encourage the development of benchmarks and performance metrics to measure accuracy and robustness (Article 15(2)).

Information on the accuracy of a high-risk AI system must be provided in the instructions for use of the system (see Sect. 3.2.6).

High-risk AI systems must be as **resilient** as possible regarding errors, faults and inconsistencies that may occur within the system or its operating environment and applies in particular to its interaction with humans or other systems (Article 15(4)). To ensure resilience both the provider and the deployers of high-risk AI systems must take appropriate technical and organisational measures. The resilience of a high-risk AI system must be taken into account and strengthened **throughout** its **lifecycle** in order to close possible protection gaps and ensure a high level of security. This can be underpinned by technical redundancies and corresponding IT security strategies.

For high-risk AI systems that continue to learn after development, **feedback loops** can perpetuate or amplify negative biases. If the outputs of high-risk AI systems that continue to learn are distorted, they will also influence the further development of the AI system as it uses its own outputs to learn on. Distortions in the output of high-risk AI systems that continue to learn are therefore particularly serious. Appropriate risk mitigation measures regarding feedback loops must therefore be taken as early as in the development of high-risk AI systems (Article 15(4)).

High-risk AI systems must also withstand attacks by third parties that aim to exploit system vulnerabilities and thus change system use, results or performance. Corresponding technical protective measures must be appropriate to the respective circumstances (e.g. intended use and environment) and risks. AI-specific attacks such as 'data poisoning' or 'model poisoning' (see Sect. 3.2.2) and other hostile attacks as well as weaknesses in the underlying IT infrastructure should be prevented or detected, responded to and resolved (Article 15(5)). In practice, operators will often test resilience and cybersecurity through 'red teaming', i.e. by simulating attacks by providers, users or third parties in order to uncover and remedy any security vulnerabilities.

In the future, high-risk AI systems that fall within the scope of the **Cyber Resilience Act** can demonstrate conformity with the cybersecurity requirements of the AI Act, by complying with the corresponding requirements of the Cyber Resilience Act (Recital 77). Besides, high-risk AI systems can also be presumed to comply with the cybersecurity requirements of the AI Act if they are certified under the Cybersecurity Act (Regulation (EU) 2019/881; not to be confused with the Cyber Resilience Act!) or a corresponding statement of conformity has been issued. This presumption requires that the AI Act's cybersecurity requirements are covered by the certification or statement of conformity (Article 42(2)).

Inspiration on how to provide for sufficient cybersecurity in AI systems can also be drawn from international approaches, as the **importance of safety in relation to AI systems** has also been recognised by national administrations inside and outside of the EU. For instance, the US federal government has founded the *Artificial Intelligence Safety Institute* under the leadership of the *National Institute of Standards and Technology (NIST).* The government of the United Kingdom has also set up an *AI Safety Institute* and has already provided an initial tool (called '*Inspect*') for testing AI models. The European Agency for Cybersecurity (ENISA) has already developed the *Multilayer Framework for Good Cybersecurity Practices for AI* in mid-2023. Finally, the German Federal Office for Information Security (BSI) published guidelines on the opportunities and risks of generative AI models in March 2024. During the second *AI Safety Summit*, which took place in Korea in May 2024, the *International Scientific Report on the Safety of Advanced AI* was published, which sets out various risks, measurement methods and safety measures (for references, see Sect. 3.1).

Further specifications regarding the accuracy, robustness and cybersecurity of AI systems are defined by **harmonised standards** (see Sect. 7.6.3), which serve to demonstrate conformity with the requirements set out in the AI Act in these areas.

Related Topics

Instructions for use of high-risk AI systems: Sect. 3.2.6.
Operator obligations for high-risk AI systems: Sect. 3.4.1.
Conformity assessment: Sect. 6.1. ◀

3.3 What Obligations Apply to Providers of High-Risk AI Systems?

Articles 16–21 and 25

Recitals 64 (Requirements for high-risk AI systems), 79 (Provider who has not designed or developed the AI system), 80 (Accessibility), 81 (Quality management system), 123 (Conformity assessment)

Providers (see Sect. 1.3.1) of high-risk AI systems are subject to extensive obligations under the AI Act, which are listed in Article 16. Essentially, the obligations of providers concern compliance with the requirements for high-risk AI systems (Articles 8–15, see Sect. 3.2). Additionally, providers are also obliged to have a **quality management system** (see Sect. 3.3.1), to ensure that the AI system undergoes the **conformity assessment procedure** (see Sect. 6.1) and to take **measures** if the AI system does not meet (or no longer meets) the requirements of the AI Act and, in extreme cases, to deactivate or recall it (see Sect. 3.3.9).

In detail, providers must

- ensure that the **requirements for high-risk AI systems** are met (see Sect. 3.1), and provide evidence of compliance with these requirements at the request of competent authorities;
- indicate their **name**, registered trade name or registered **trademark** and **contact address** on the high-risk AI system or, if that is not possible, on its packaging or in the accompanying documentation;
- have a **quality management system** in place (Article 17, see Sect. 3.3.1);
- keep the **technical documentation** and, when under their control, the automatically generated **logs** (Articles 18 and 19, see Sects. 3.2.4 and 3.2.5);
- ensure that the high-risk AI system undergoes the applicable **conformity assessment procedure** (Article 43, see Sect. 6.1), draw up a corresponding EU declaration of conformity (Article 47, see Sect. 3.3.3) and affix a CE marking (Article 48, see Sect. 3.3.4);
- **register** the high-risk AI system (Article 49, see Sect. 3.3.5);
- take the necessary **corrective actions** and provide the necessary information to other operators and to competent authorities (Article 20, see Sect. 3.3.9);
- observe the **accessibility requirements** of the Web Accessibility Directive (EU) 2016/2102 and of the European Accessibility Act (Directive (EU) 2019/882 on the accessibility requirements for products and services).

Below, each of these obligations is described in detail.

The obligations of the AI Act addressed to providers do not apply to providers of high-risk AI systems that are products or safety components of products covered by EU harmonisation legislation outside the New Legislative Framework (listed in Section B of Annex I; see Sects. 1.2.7 and 3.1.1.2). AI regulatory sandboxes are also only available for the development of products outside the New Legislative Framework as far as the requirements for high-risk AI systems in accordance with the AI Act have been incorporated into the applicable EU harmonisation legislation.

Related Topics

New Legislative Framework: Sect. 1.1.
Products (partially) excluded from the scope of the AI Act: Sect. 1.2.7.
Definition of providers: Sect. 1.3.1.
High-risk AI systems: Sect. 3.1.
Requirements for high-risk AI systems: Sect. 3.2.
Conformity assessment procedure: Sect. 6.1. ◀

3.3.1 What Requirements Apply to the Quality Management System of a High-Risk AI Systems?

Article 17

Recital 81 (Quality management system), 146 (Facilitated quality management system for micro-enterprises)

The provider of a high-risk AI system must set up a quality management system that implements the requirements of the AI Act and serves **quality assurance and quality control**. The quality management system incorporates **design considerations, organisational procedures and technical implementations** that shall ensure, describe and document compliance with the AI Act. The quality management system is connected to other systems that must be implemented under the AI Act, such the risk management system (see Sect. 3.2.1) or data governance (see Sect. 3.2.2). In practice, the quality management system can consist of several subsystems or be incorporated into a **comprehensive compliance approach** that covers data, AI models and systems.

The design and implementation of the quality management system shall be proportionate to the **size of the provider's organisation**. That means that smaller companies can set up a quality management system at a smaller scale and with less effort than bigger companies, as long as they ensure the level of protection that is required for their high-risk AI system to comply with the AI Act (Article 17(2)).

The quality management system is the **set of planned and systematically documented written policies, procedures and instructions** designed to ensure that the provider complies with his obligations under the AI Act (Article 17(1)). The quality management system must relate to essential provider obligations, such as the establishment of a **risk management system** (see Sect. 3.2.1), the **post-market**

monitoring system (Article 72, see Sect. 3.3.7) and the **procedures for reporting serious incidents** (Article 73, see Sect. 3.3.10).

In addition, the quality management system must also cover **the following aspects** (Article 17(1)):

- a **strategy for regulatory compliance**, also covering the conformity assessment procedure (see Sect. 3.3.3) and the management of modifications to the high-risk AI system;
- techniques, procedures and systematic actions for the **design, testing, development, quality control and quality assurance** of the high-risk AI system;
- **examination, test and validation procedures** to be carried out before, during and after the development of the high-risk AI system, as well as the frequency with which they have to be carried out;
- the **technical specifications and standards** to be applied, if the relevant harmonised standards are not fully applied or do not cover all relevant requirements, the means to ensure conformity with the requirements for high-risk AI systems (see Sect. 3.2);
- systems and procedures for **data management**, including data acquisition, data collection, data analysis, data labelling, data storage, data filtration, data mining, data aggregation, data retention and any other operation relating to the data that is performed before and for the purposes of the placing on the market or putting into service of the high-risk AI system;
- the handling of **communication with relevant authorities, notified bodies**, other **operators**, **customers** or other interested parties;
- systems and procedures for **record-keeping** of all relevant documentation and information;
- **resource management**, including measures with regard to security of supply, and
- the **responsibilities of management and other personnel** in relation to all aspects listed.

To **avoid duplications**, the AI quality management system may be integrated into another quality management system that is required by other EU harmonisation legislation (Article 17(3)). For **financial institutions,** large parts of the requirements regarding the quality management system are deemed to be fulfilled if the corresponding provisions of EU financial services law are complied with (Article 17(4)). Public authorities have the option to adopt or implement rules of a quality management system that has been set up at national or regional level, provided that the AI-specific requirements are addressed there (Recital 81).

Related Topics

Risk management system: Sect. 3.2.1.
Data governance requirements: Sect. 3.2.2.

Post-market monitoring system: Sect. 3.3.7.
Serious incidents reporting: Sect. 3.3.10.
Conformity assessment procedure: Sect. 6.1. ◀

3.3.2 What Documents Must Providers of High-Risk AI Systems Keep?

Articles 18, 19

Providers of high-risk AI systems shall keep the following documentation at the disposal of the competent authorities for a period of 10 years after the high-risk AI system has been placed on the market or put into service (Article 18):

- the **technical documentation** (see Sect. 3.2.4);
- the documentation concerning the **quality management system** (see Sect. 3.3.1);
- the documentation on any **changes approved** by notified bodies (see Sect. 6.1.3.1);
- the decisions and any other **documents issued by the notified bodies**, and
- the **EU declaration of conformity** (see Sect. 3.3.3).

Providers of high-risk AI systems must also keep the **logs** automatically generated by their high-risk AI systems (see Sect. 3.2.5) to the extent these logs are under their control (Article 19). The logs must be kept for a **period appropriate** to the **intended purpose** of the high-risk AI system, which must be **at least 6 months.** However, this only applies if other laws, in particular on the protection of personal data (see Sect. 7.1), do not provide otherwise.

Related Topics

Technical documentation: Sect. 3.2.4.
Logging by high-risk AI system: Sect. 3.2.5.
Quality management system: Sect. 3.3.1.
Conformity assessment procedure: Sect. 6.1.
Inspection rights of the surveillance authorities: Sect. 6.2.5. ◀

3.3.3 What Requirements Apply to the EU Declaration of Conformity for High-Risk AI Systems?

Article 47, Annex V

Recitals 123 (Conformity assessment), 124 (Avoidance of duplication), 125 (Notified bodies), 126 (Requirements for notified bodies), 127 (Notified bodies in third countries), 128 (Substantial modification), 129 (CE marking), 130 (Exemptions from the conformity procedure)

For every high-risk AI system, providers must issue an **EU declaration of conformity**, which confirms that the system in question fulfils the AI Act's requirements on high-risk AI systems. In this way, providers also assume responsibility in a formalised, externally manifested manner regarding the compliance of their high-risk AI system (see Sect. 3.2; Article 47(2)).

The declaration of conformity must be written, machine-readable, physical or electronically signed and kept **up to date.** It must be kept at the disposal of the national competent authorities for a period of 10 years after the AI system has been placed on the market or put into service, and a copy of the declaration of conformity must be submitted upon request.

If high-risk AI systems are still subject to other EU harmonisation legislation (see Sect. 3.1.1.1), a single EU declaration of conformity is issued that contains all the necessary information (e.g. for an AI system that is a safety component of a machine, the EU declaration of conformity also contains the information required by the Machinery Directive).

The declaration of conformity must at least include the following **categories of information** (Annex V):

- the **name and type of the AI system**, other unambiguous reference to identify and trace the AI system;
- the **name and address of the provider** and, if mandated, of their authorised representative;
- a statement that the EU declaration of conformity is issued under the sole responsibility of the provider;
- assurance that the **high-risk AI system complies with the AI Act** and, where applicable, other legislation that also requires the issuing of an EU declaration of conformity;
- if personal data is processed, a statement that the AI system complies with **the requirements of the GDPR** and other EU data protection laws (see Sect. 7.2);
- references to any relevant **harmonised standards** used (see Sect. 7.6.3) or any other common specifications in relation to which conformity is declared;
- where applicable, the **name** and **identification number of the notified body**, a description of the conformity assessment procedure carried out and identification number of the certificate issued;
- **a signature**, the **place** and **date of issue** of the declaration, the **name** and **function** of the **signatory** and an indication of for whom or on whose behalf this person has signed.

The declaration of conformity shall be provided in, or **translated** into, a language accepted by the national competent authorities of the member states in which the high-risk AI system is made available. The declaration of conformity shall be easily understandable for the competent authorities. This condition is fulfilled with a translation into the respective national language of the national authorities. As some authorities also accept an English version, the declaration of conformity may not have to be translated into all EU languages if an AI system is widely used in the EU.

The European Commission is authorised to update the list of required contents of the declaration of conformity and to add new mandatory contents if this becomes necessary due to technical progress. A model declaration of conformity can be found in Annex III of Decision 768/2008 EC on a common framework for the marketing of products.

Related Topics

Products that are/contain high-risk AI systems: Sect. 3.1.1.
Requirements for high-risk AI systems: Sect. 3.2.
Data protection requirements: Sect. 7.2.
Harmonised standards: Sect. 7.6.3. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 4.4, p. 62–64; *International Standardisation Organisation*, Standard 17050 Conformity assessment – Supplier's declaration of conformity (2004).

3.3.4 What Requirements Apply to the CE Marking of a High-Risk AI System?

Article 48

Recital 129 (CE marking)

In addition to the EU declaration of conformity (see Sect. 3.3.3), high-risk AI systems must also be provided with a **CE marking** after conformity assessment. The marking indicates that the system meets the requirements that the AI Act sets up for high-risk AI systems and that the AI system is therefore not subject to any restrictions within the EU internal market. If high-risk AI systems are also covered by another EU harmonisation legislation that also requires **CE marking**, the CE marking means that the high-risk AI system also fulfils the **requirements of** this **other legislation** (see Sect. 3.1.1.1; e.g. CE marking on a toy with AI features means that this toy fulfils the requirements of the Toy Safety Directive and the AI Act).

If possible, the CE marking must be affixed to the AI system physically. If the high-risk AI system is provided digitally, for example via an interface or as software as a service, **digital CE marking** can be used, if the marking is **easily accessible** via the interface from which the AI system is accessed or via a machine-readable code or other electronic means (Article 48(2)).

The CE marking must be affixed **visibly, legibly and indelibly** to the system or, if not otherwise possible, to the packaging or accompanying documents. If a conformity assessment procedure has been carried out with the involvement of a notified body, its identification number must also be indicated. This also applies to advertising materials in which reference is made to the conformity of the system. The general requirements applicable to CE marking (Article 30 of Regulation (EC) 765/2008) must be observed.

Related Topics

Products that are/contain high-risk AI systems: Sect. 3.1.1.
EU declaration of conformity: Sect. 3.3.3. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), Section 4.5.1, p. 64–69.

3.3.5 Which High-Risk AI Systems Must Be Registered by the Provider?

Articles 49, 71, Annex VIII
Recital 131 (Registration obligation)

Stand-alone high-risk AI systems used in critical use cases (listed in Annex III; see Sect. 3.1.2) must be registered **before they are placed on the market or put into service** (Article 49). The provider or, if applicable, their authorised representative (see Sects. 1.3.6 and 3.5.4) must register themselves and the respective AI system in an **EU database** operated by the European Commission in cooperation with the member states (see Sect. 6.2.7). This serves the purpose of **transparency** with regard to the following questions:

- What types of stand-alone AI systems are there in each critical use case?
- How many of these AI systems are offered or operated in the EU?

To this end, the registration is also an important control mechanism for the AI Office and for the national market surveillance authorities. Deployers or consumers can also use the database to find out which high-risk AI systems are operated in the critical areas and, if applicable, whether a particular system has been registered as a high-risk AI system in a critical use case in accordance with the AI Act.

The **information to be provided** by the provider at the time of registration shall include at least the following (Section A of Annex VIII):

- the name, address and contact details of the provider and, if applicable, of their authorised representative and/or the person that submitted the information for registration on behalf of the provider;
- the AI system trade name and any additional unambiguous reference that enables to identify and trace the AI system;
- a description of the intended purpose of the AI system (see Sect. 1.4.2) and the components and functions supported through the AI system;
- a basic and concise description of the information used by the system (data, inputs) and its operating logic;

- the status of the AI system (on the market/in service; no longer on the market/in service; recalled);
- all EU member states in which the AI system has been placed on the market, put into service or made available;
- a basic and concise description of the information used by the system (data, inputs) and its operating logic;
- the type, number and expiry date of the certificate issued by the notified body, a scanned copy of this certificate, and the name or identification number of that notified body, where applicable;
- a copy of the EU declaration of conformity (see Sect. 3.3.3);
- the electronic Instructions for use
- (not applicable to stand-alone high-risk AI systems in the areas of law enforcement or migration, asylum and border control as referred to in No. 1, 6 and 7 of Annex III);
- voluntarily a URL address for additional information.

Due to their criticality and national importance, high-risk AI systems that are used as safety components in the management and operation of **critical infrastructure** (as referred to in No. 2 of Annex III; see Sect. 3.1.2.2) must not be registered in the EU database (Article 49(1)), but in a database **at national level** (Article 49(5)).

Even if an **AI system** is **not** considered **high risk** because it does not pose a significant risk to health, safety or fundamental rights (see Sect. 3.1.2.10), the provider must register the AI system in question in the EU database anyways (Article 49(2); see Sect. 3.3.6). However, the registration of non-high-risk AI systems must contain less information (as listed in Section B of Annex VIII).

Specific registration requirements apply to stand-alone high-risk AI systems (including biometric high-risk AI systems) that are used in the areas of law enforcement, migration, asylum and border control management. They must be registered in a **secure, non-public part of the** aforementioned **EU database,** which is accessible only to the European Commission and national authorities (Article 49(4)). The registration must contain less information than the documentation of other AI systems (Article 49(4)).

In addition, certain deployers of high-risk AI systems must also register in the database (see Sect. 3.4.5).

Related Topics

Quasi providers: Sect. 1.3.7.
High-risk AI systems in critical use cases: Sect. 3.1.2.
EU declaration of conformity: Sect. 3.3.3.
Deployers' obligation to register: Sect. 3.4.5.
Structure of the EU database: Sect. 6.2.7. ◄

3.3.6 What Are Providers Obliged to Do if Their AI System in a Critical Use Case Is Exceptionally Not Considered High Risk?

Articles 6(3), (4) and 49(2), Annex VIII

Recitals 53 (Exemptions from high-risk categories), 131 (Registration obligation)

If an AI system in a critical use case (Annex III, see Sect. 3.1.2) is exceptionally not considered high risk because it does not pose a significant risk to health, safety or fundamental rights, the provider shall document their assessment, in particular with regard to the criteria their assessment was based on (see Sect. 3.1.2.10). In this case, the provider is subject to the obligation to **register** the AI system in the **EU database** anyways (see Sect. 3.3.5). The provider shall submit the **documentation of the assessment** to the national competent authorities upon request.

Related Topics

High-risk AI systems in critical use cases (and exceptions): Sect. 3.1.2.
Provider's obligation to register: Sect. 3.3.5.
EU database: Sect. 6.2.7. ◀

3.3.7 What Monitoring Obligations Apply to Providers of High-Risk AI Systems?

Article 72

Recitals 155 (Post-market monitoring), 158 (Consistency with financial services legal acts)

Providers must set up and document a system to monitor their high-risk AI system after it has been placed on the market or put into service (so-called 'post-market monitoring'; Article 72(1)). The post-market monitoring is a vital source of information regarding the use of the AI system and its characteristics. The information obtained through the post-market monitoring enables timely, appropriate, and targeted **corrective measures** (see Sect. 3.3.9) and it can also help to **improve the design** and development processes of future AI systems. Because the information will also be used for risk assessments, the post-market monitoring system must be integrated into the **risk management system** (see Sect. 3.2.1).

The **post-market monitoring system** must include all activities that are carried out by providers of AI systems to collect and review experience gained from the use of AI systems they place on the market or put into service to identify any need to immediately apply any necessary corrective or preventive action (Article 3(25)). The provider must take into account the type of AI technology implemented and the risks of the high-risk AI system.

The Post-market monitoring system must

- actively and systematically **collect relevant data on the performance** of the high-risk AI system throughout its lifecycle that may be provided by deployers or collected from other sources (with the exception of sensitive operational data from law enforcement authorities),
- **actively and systematically document and analyse** the data throughout the lifecycle of the AI system to ensure ongoing **compliance with the requirements for high-risk AI systems** (see Sect. 3.2);
- include, where appropriate, an **analysis of the interaction with other AI systems** and, where applicable, with other devices and software, and
- are based on an appropriate **post-marketing monitoring plan**, which is part of the technical documentation (see Sect. 3.2.4).

The European Commission will publish a **template** of a post-marketing monitoring plan and a list of the elements to be included in the plan by means of an implementing act by 2 February 2026 (Art. 72(3)).

If high-risk AI systems are products or safety components of products covered by EU harmonisation legislation within the New Legislative Framework (as listed in Section A of Annex I; see Sect. 3.1.1.1), the establishment of a post-market monitoring system and a corresponding plan may already be required on the **basis of the applicable harmonisation legislation**. Providers can choose to integrate both monitoring systems, provided that at least an equivalent level of protection is achieved. This simplification is intended to ensure consistency, avoid duplications, and minimise additional burdens on providers. The same applies to the use of **stand-alone high-risk AI systems by financial institutions** that are used as part of an essential service (i.e. to evaluate creditworthiness in particular; see Sect. 3.1.2.5). Providers can choose to integrate the post-market monitoring system and other systems required under EU financial services law with regard to internal governance, arrangements, or processes, provided that the requirements of the AI Act are also covered.

Related Topics

High-risk AI systems that are (safety components of) products: Sect. 3.1.1.
High-risk AI systems in critical use cases: Sect. 3.1.2.
Requirements for high-risk AI systems: Sect. 3.2.
Quality management system: Sect. 3.3.1. ◀

3.3.8 To What Extent Are Providers of High-Risk AI Systems Obliged to Cooperate with National Supervisory Authorities?

Article 21

Providers of high-risk AI systems must, upon reasoned request by a competent authority, such as a national market surveillance authority, **provide all information**

and documentation necessary to demonstrate the conformity of the high-risk AI system with the requirements of the AI Act. The authority must reason the request for information so that the provider is able to **understand** the **reason for the request and, if applicable, the scope of the request**. A request can be reasoned, for example, if the competent market surveillance authority or the notified body wants to investigate further on a **risk to the health, safety or fundamental rights of persons** that the provider has previously reported to them (see Sect. 3.3.9). Providers must submit the information and documentation in an official language of the EU institutions which the requesting authority has indicated and can easily understand.

Providers may also have to grant access to the logs automatically generated by the high-risk AI system at the reasoned request of a competent authority (see Sect. 3.2.5). However, this only applies to the extent these logs are under the providers' control.

It must be noted that all measures taken by market surveillance authorities, including requests, are subject to procedural requirements and safeguards, such as the principle of proportionality (see Sects. 6.2.5 and 6.2.8). Authorities may only request data that is strictly necessary for the assessment of the risks posed by AI systems and for the exercise of their powers in accordance with the AI Act and the Regulation on market surveillance and product conformity (EU) 2019/1020 (Article 78(2)).

If a competent authority receives information due to the provider's obligation to cooperate, this information is subject to **confidentiality** requirements (Article 78, see Sect. 6.2.8).

Related Topics

Logging by high-risk AI systems: Sect. 3.2.5.
Obligation to report significant risks: Sect. 3.3.9.
Investigative rights of surveillance authorities: Sect. 6.2.5.
Procedural obligations of authorities: Sect. 6.2.8. ◀

3.3.9 When Must Providers of High-Risk AI Systems Take Corrective Actions and Inform Other Operators?

Articles 3(16) and (17) and 20

If providers of high-risk AI systems (have reason to) consider that a high-risk AI system they have placed on the market or put into service does not comply (or no longer complies) with the requirements of the AI Act, they must

- take immediate **corrective action** to bring that system into conformity, or
- **withdraw**, **disable** or **recall** the high-risk AI system, as appropriate (Article 20(1)).

A **recall** is any measure that aims to return the AI system to the provider if it has already been made available to deployers. In the alternative a recall can also aim at

taking the AI system out of service or disabling its use (Article 3(16)). A **withdrawal** is a measure that aims to prevent an AI system in the supply chain from being made available on the market (Article 3(17)). Providers shall inform distributors and, where applicable, deployers, authorised representatives and importers of the affected high-risk AI systems of the measures taken.

When providers decide on how (and especially how fast) to respond to a lack of conformity, they shall take into account the risk posed by the deviation from the requirements of the AI Act. A minor and short-time deviation can usually be corrected with software updates, while serious malfunctions of AI systems that serve as safety components of specially regulated products (see Sect. 3.1.1.1) can demand more drastic actions, such as an immediate recall or withdrawal of the product or an immediate deactivation of the AI system.

If providers become aware of a **risk to the health, safety or fundamental rights of individuals** posed by their high-risk AI systems, they must

- immediately **investigate the causes** (if applicable, together with the relevant deployer) and
- **inform** the competent **market surveillance authorities**, and
- where applicable, **inform** the **notified body** that issued a certificate for the high-risk AI system that poses the risk (see Sect. 6.1.3).

In particular, the information must also include details on the type of non-conformity and the relevant corrective actions already taken. The competent authority monitors the Provider's corrective actions in a separate procedure (see Sect. 6.2.4.1).

Related Topics

Products that are/contain high-risk AI systems: Sect. 3.1.1.
Requirements for high-risk AI systems: Sect. 3.2.5.
Operator's obligation to report AI systems that harbour a Risk: Sect. 3.4.2.
Authority procedures for AI systems that harbour a Risk: Sect. 6.2.4.1. ◀

3.3.10 What Incidents Must Providers of High-Risk AI Systems Report to the Market Surveillance Authority?

Article 3(49) and (61), Article 73

Recital 155 (Post-market monitoring)

Providers of high-risk AI systems placed on the EU market must **report serious incidents** to the market surveillance authorities of the member states where the incident occurred (Article 73(1)).

The notion of **'serious incident'** refers to an incident or malfunction of an AI system that directly or indirectly has any of the following consequences (Article 3(49)):

- the **death** of a person **or serious harm** to a person's health;
- a serious and irreversible **disruption** of the management or operation **of critical infrastructure** (see Sect. 3.1.2.2);
- the infringement of obligations under EU law intended to protect **fundamental rights,** or
- serious harm to **property or** the **environment**.

Different **deadlines** apply for the notification:

- In general, a report should be made **immediately** after the provider has established the causal link between the AI system and the serious incident or the reasonable likelihood of such a link, but, in any event, no later than **15 days** after the provider, or, where applicable, the deployer, becomes aware of the serious incident (Article 73(2)). The reporting period must take into account the severity of the serious incident, but also the complexity of the circumstances of the investigation and the determination of causality.
- In the event of a **widespread infringement** or a serious and irreversible **disruption of critical infrastructure,** the notification should be made **immediately,** but no later than **2 days** after becoming aware of the incident (Article 73(3)). Again, the period in which the report must be submitted, will only start once the provider has established a causal link or at least the reasonable likelihood of a causal link between the AI system and the serious incident.
- The notion of 'widespread infringement' (Article 3(61)) means any act or omission contrary to EU law protecting the interest of individuals, if this act or omission has harmed or is likely to harm the collective interests of individuals and
  - these individuals reside in at least two EU member states other than the member state in which
    the act/omission originated or took place,
    the provider or, where applicable, its authorised representative (see Sects. 1.3.6 and 3.5.4) is located or established or
    the deployer is established (if the deployer committed the infringement); or
  - the act/omission has common features, including the same unlawful practice or the same interest being infringed, and is occurring concurrently, committed by the same operator, in at least three EU member states.
- The **death of a person** must be reported **immediately** after the provider or deployer has established, or as soon as it suspects, a **causal link** between the high-risk AI system and the death of a person, but no later than **10 days** thereafter (Article 73(4)).

Providers or deployers may submit an **incomplete initial report** if this is necessary to ensure timely reporting. The initial report must then be followed by a complete report (Article 73(5)).

If high-risk AI systems are (safety components of) devices covered by the Medical Devices Regulation (EU) 2017/745 or by the Regulation (EU) 2017/746 on in vitro diagnostic medical devices (Article 73(10), see also Sect. 3.1.1.1), only breaches of EU law that protects fundamental rights must be reported under the AI Act. The same restriction applies to stand-alone high-risk AI systems in critical use cases (as listed in Annex III, see Sect. 3.1.2), if they are subject to equivalent reporting obligations under other EU legislation (Article 73(9)). For example, safety incidents for critical facilities under the CER Directive (EU) 2022/2557 do not have to be reported according to the AI Act because Art. 15 CER Directive implements a similar reporting duty. If, for example, an AI disrupts a water supply plant it is integrated into, the CER Directive already requires reporting to the competent authority, because the safety of critical infrastructure is affected. An additional report to the market surveillance authority only is required if the disruption violates an obligation intended to protect fundamental rights, e.g. obligations under the GDPR.

Following the reporting, providers must immediately investigate the serious incident, if necessary, in cooperation with the competent authorities and notified bodies (Article 73(10)). The investigation shall include a **risk assessment** of the incident and **corrective measures**. However, providers shall not make any changes to the AI system that may jeopardise a **subsequent official investigation**, unless the competent authority has been informed in advance (Article 73(6)).

Market surveillance authorities are obliged to take **measures to** eliminate the risk posed by the AI system or, as a last resort, to recall it or withdraw it from the market within 7 days of receiving the notification (Article 73(8), Article 19 Regulation (EU) 2019/1020). Competent authorities shall also notify the European Commission of any serious infringement (Article 73(11), Article 20 Regulation (EU) 2019/1020). The market surveillance authorities must also inform national public authorities or bodies protecting fundamental rights (see Sect. 6.2.6) about all serious incidents that infringe EU law protecting fundamental rights.

Related Topics

Authorised representative: Sects. 1.3.6 and 3.5.4.
Products that are/contain high-risk AI systems: Sect. 3.1.1.
High-risk AI systems in critical use cases: Sect. 3.1.2.
Authorities for the protection of fundamental rights: Sect. 6.2.6. ◀

3.3.11 How Must the Cooperation Between Providers of High-Risk AI Systems and Third Parties Be Contractually Organised?

Articles 25(4), 51–56
Recitals 88 (Cooperation agreements), 89 (Free and open-source components)

Providers of high-risk AI systems often work with a wide variety of **third parties** who offer **tools**, **components** or **services** that are needed to develop and offer complex AI systems. This includes the training, testing and evaluation of models, integration into software or other aspects of model development (Recital 88). Specific requirements with respect to components for AI systems apply to providers of GPAI models (Articles 51–56, see Chap. 5).

The AI Act presumes that the provider itself cannot explain all aspects of such third-party contents in detail. This could consequently lead to a lack of knowledge that results in the provider of a high-risk AI system not fulfilling its obligations under the AI Act to the best extent possible. For instance, a provider may not foresee how two third-party tools will interact, which could lead to biased outputs. For reasons of **legal certainty** and **transparency,** providers and third parties must agree in writing (verbal agreement is insufficient, but **a digital text** should fulfil this requirement) how the third party supports the provider in fulfilling its obligations under the AI Act (Article 25(4)).

This may involve the provision of information (e.g. on training data), technical access (e.g. to development platforms) or other support services (e.g. in the context of 'red teaming' or other attack tests). However, the obligation does not apply if third parties offer services to the public under a **free and open-source licence**. Special rules also apply to GPAI models that are made available under free and open-source licences (see Sect. 5.3).

Related Topics

Requirements for GPAI models: Chap. 5. ◄

3.3.12 Are There Model Contracts for Cooperation Between Providers of High-Risk AI Systems and Third Parties?

Article 25(4)

Recital 90 (Model contract terms)

The AI Office may draw up model terms for contracts between providers of high-risk AI systems and third parties that supply tools, components or services used for or integrated into high-risk AI systems. The model terms can be used **on a** purely **voluntary basis** and therefore constitute **recommendations** (at most). They are intended to facilitate cooperation between different actors in the AI value chain and may also inspire contract terms that are individually negotiated. Sector-specific necessities and circumstances as well as special business cases should also be taken into account by the AI Office when drawing up model terms. The AI Office publishes the model contract terms **to be used free of charge** and in an easy-to-use electronic format.

3.4 What Obligations Do Deployers of High-Risk AI Systems Have?

Articles 26, 27

Recitals 13 (Deployer), 91 (Obligations of deployers), 92 (Deployment at the workplace), 93 (Risks of use)

The **deployers** (see Sect. 1.3.2) **of high-risk AI systems** are the operators that are closest to the day-to-day use of the AI systems. They can directly evaluate and influence the **system's behaviour in its practical use.** Due to their knowledge of the specific deployment of the AI system, they can recognise risks that the provider could not foresee during the development phase and during the conformity assessment. Therefore, the AI Act imposes specified obligations on deployers of high-risk AI systems in order to **minimise risks** and to protect the health, safety and fundamental rights of individuals. Deployers must respect the **intended purpose** of the AI system, as defined by the provider (see Sect. 1.4.2), as well as the instructions for use (see Sect. 3.2.6).

In addition to requirements that may arise from other applicable law, deployers of high-risk AI systems have **special obligations** under the AI Act (Article 26). Essentially, this means that deployers have to:

- implement **technical and organisational measures** to ensure that the AI system is operated in accordance with the instructions for use and to facilitate the other obligations applicable to deployers;
- ensure **human oversight** by competent and trained individuals;
- provide relevant and sufficiently representative **input data**, in so far as this is subject to the deployer's control;
- **monitor** the operation of the high-risk AI system;
- **inform** providers, importers, distributors and market surveillance authorities about **risks to the health, safety or fundamental rights** of individuals and about serious incidents;
- **suspend the use of the system** if they have reason to consider that the AI system poses risks to the health or safety or fundamental rights of individuals;
- keep the **automatically generated logs**;
- inform **workers' representatives** and affected **workers** when AI systems are used at the workplace;
- **register themselves** in the EU database if they are public authorities or EU institutions;
- comply with special requirements when using AI systems for **remote biometric identification**;
- **inform affected persons** about the use of a high-risk AI system in the context of a decision affecting an individual, and
- **cooperate** with the competent authorities.

In limited cases of application, the deployer is also obliged to carry out a **fundamental rights impact assessment** (Article 27).

Deployers can make use of the information provided by the provider (see Sect. 3.2.6) to fulfil their obligations.

Besides the obligations under the AI Act that are described in the following subsections, further obligations may arise from other laws, such as the obligation to carry out a **data protection impact assessment** under the GDPR (see Sect. 7.2.9.5).

Related Topics

Transparency requirements for high-risk AI systems: Sect. 3.2.6.
Data protection impact assessment: Sect. 7.2.9.5. ◀

3.4.1 What Technical and Organisational Measures Must Deployers of High-Risk AI Systems Take?

Article 26(1), (3)–(6)

Recital 91 (Obligations of deployers)

Deployers of high-risk AI systems must implement **appropriate technical and organisational measures** to ensure that they use the system in accordance with the accompanying **instructions for use** (see Sect. 3.2.6; Article 26(1)). This serves to mitigate expected risks and to avoid unexpected risks. All risks that can reasonably be foreseen have to be included in the risk assessment and, consequently, in the instructions for use. Therefore, the risks posed by an AI system are assessed to be acceptable, if the deployer adheres to the instructions for use.

Therefore, the AI system cannot be used for a different (possibly high-risk) purpose (or for the same purpose but in a different way of application) which may lead to risks for which the system was not designed. It should be noted that deployers who change the intended purpose or deviate from the intended purpose may have to fulfil the obligations of a provider themselves (see Sect. 1.3.7).

The technical and organisational measures should include the following aspects in particular:

- the provision of relevant and sufficiently representative **input data** (Article 26(4)),
- the **monitoring** of the operation of the system, **informing about risks** to health, safety or fundamental rights and the possible **suspension of the use** of the system (Article 26(5); see Sects. 3.4.2 and 3.4.3) and
- the keeping of automatically generated **logs** (Article 26(6); see Sect. 3.4.4).

The AI Act does not specify in more detail when the technical and organisational measures to be taken by the deployer are 'appropriate' within the meaning of its provisions. However, deployers can refer to the principles known from the areas of **data protection** and **IT security** and use these for guidance. Besides, all obligations to implement technical and organisational measures that apply to the deployer under data protection, IT security or other laws remain unaffected by the GDPR (Article 26(3)).

Related Topics

Logging by high-risk AI system: Sect. 3.2.5.
Instructions for use: Sect. 3.2.6.
Provider fiction: Sect. 1.3.7.

Technical and organisational measures in accordance with the GDPR: Sect. 7.2.9.1. ◀

3.4.2 What Human Oversight Requirements Must Deployers of High-Risk AI Systems Fulfil?

Article 14, 26(2)
Recitals 73 (Human oversight), 91 (Obligations of deployers)

The deployers must delegate the **supervision of the high-risk AI system to natural persons** who have the necessary competence, training, authority, and support. This obligation will require deployers to delegate the necessary powers to the persons overseeing AI.

Accordingly, the principle of human oversight also applies to deployers of high-risk AI systems. The deployer's obligation to use human supervision corresponds to the requirement for high-risk AI systems to enable human oversight (see Sect. 3.2.7). The deployers must ensure human oversight in day-to-day business. Providers are only obliged to design high-risk AI systems in such a way that deployers can take the necessary measures (see Sect. 3.2.7). The measures taken by the provider must be **appropriate** in relation to the **risks, the degree of autonomy and the context of use** of the high-risk AI system. They must allow the overseeing persons to

- decide **not to use** the **high-risk AI system**, to disregard, override or reverse the output of the high-risk AI system, or
- intervene in or **interrupt the operation of the system, e.g.** with a 'stop' button or a similar procedure that allows the system to come to a standstill in a safe state.

While the providers must implement these measures on a technical level when developing the high-risk AI system, the deployer must ensure these measures on an organisational level when using the high-risk AI system (see Article 14(4)). The obligations of providers and deployers must complement each other in order to ensure effective human oversight (see also Article 14(2)). The obligation of providers to enable human oversight would be ineffective if the deployers had no obligation to implement human oversight in the actual use of the high-risk AI system.

The natural persons exercising human oversight must have the necessary competence in dealing with the high-risk AI system (including AI literacy, see Sect. 1.6.1). Supervisors should be trained separately, if necessary (see also Recital 91). Thereby the general requirement for AI literacy training (see Sect. 1.6.1) is concretised for deployers of high-risk AI systems. Specific indications of when supervisors are

sufficiently competent and trained to exercise human oversight can be derived from the requirements for enabling human oversight (see Sect. 3.2.7). Accordingly, the responsible persons must be able (Article 14(4))

- to understand the capabilities and limitations of the high-risk AI system and **monitor proper operation** and detect and resolve anomalies, malfunctions and unexpected performance;
- to **remain aware of** the possible tendency to automatically rely or over-rely on the outcome produced by a high-risk AI system (**automation bias**);
- to **correctly interpret** the **outputs** of the high-risk AI system, taking into account the available interpretation tools and methods.

However, this does not mean that a single person must be permanently responsible for monitoring the system. Deployers of high-risk AI systems will often distribute corresponding tasks across various specialist and management levels within the company as part of an AI governance or compliance system. In addition, technical tools are often used to support monitoring activities, e.g. to recognise a function of the AI system that deviates from the norm and, if necessary, to interrupt the operation until a human approves the continuation of the system. The technical and organisational design of human monitoring must always be risk-based.

Related Topics

Human supervision: Sect. 3.2.7.
Technical and organisational measures of the deployer: Sects. 3.4.1–3.4.4. ◀

3.4.3 How Do Deployers Have to Monitor the High-Risk AI System?

Article 26(5)
Recital 91 (Obligations of deployers)

Deployers must monitor the operation of the high-risk AI system, paying particular attention to the **instructions for use**. If deployers have reason to believe that the use of the high-risk AI system in accordance with the instructions for use poses a **risk to the health, safety or fundamental rights of persons** (Article 79(1)), they must immediately inform the provider or distributor and the relevant market surveillance authorities and suspend the use of the system. The Provider must then take appropriate corrective measures (see Sect. 3.3.9).

If deployers identify a **serious incident** (see Sect. 3.3.10), they must immediately inform first the provider and then the importer or distributor and the relevant market surveillance authorities (Article 26(5)). If the deployer is unable to contact the provider, she must step in for the provider by investigating the causes and submitting a **qualified report to the market surveillance authorities** (regarding the provider's obligation to report, see Sect. 3.3.10).

In practice, monitoring will on the one hand be **automated** by appropriate **AI governance systems** that contain the relevant tolerance values, detect deviations (such as drifts, which arise when the data used to operate the AI system and the training data diverge) independently, monitor the AI system and notify the deployer of identified risks and deviations. On the other hand, deployers must also ensure **human oversight** of the system (see Sect. 3.4.2).

Related Topics

Instructions for use: Sect. 3.2.6.
Provider obligations in the case of risks to persons: Sect. 3.3.9.
Provider obligations in the event of serious incidents: Sect. 3.3.10.
Deployer obligation to enable human oversight: Sect. 3.4.2. ◀

3.4.4 Which Kind of Logs Must Deployers of High-Risk AI Systems Keep?

Article 26(6)
Recital 91 (Obligations of deployers)

All logs automatically generated by the high-risk AI system (see Sect. 3.2.5) must be kept by the deployer for an **appropriate period of time,** at least **6 months.** This obligation only applies to the extent that the logs are under the deployer's control. The deployer must take appropriate technical and organisational measures, for example to provide access only to authorised persons, to ensure availability or to securely delete the data.

Related Topics

Logging by high-risk AI system: Sect. 3.2.5. ◀

3.4.5 What Additional Obligations Do Deployers Face if They Use a High-Risk AI System in the Workplace?

Article 26(7)
Recital 92 (Deployment at the workplace)

Deployers who are employers must inform workers' representatives and the employees concerned that they will be subject to the use of a high-risk AI system. The other information requirements under EU and national labour law must be taken into account.

Further obligations of the employer to inform and consult employees or their representatives regarding the putting into service or use of AI systems remain unaffected by the AI Act and are governed by the provisions of the applicable labour law (Recital 92).

Related Topics

High-risk AI systems in employment: Sect. 3.1.2.4.
Deployer's information obligations for high-risk AI systems: Sect. 3.4.8.
Information obligations under the GDPR: Sect. 7.2.5. ◀

3.4.6 Which Deployers Must Register High-Risk AI Systems Before Putting It into Service?

Articles 26(8), 49(3), 71(3), Section C of Annex VIII
Recitals 91 (Obligations of deployers), 131 (Registration obligation)

Only deployers who are **public authorities or EU institutions, bodies, offices and agencies, or persons acting on their behalf,** are required to register themselves in the EU database (see Sect. 6.2.7) before putting into service or using a stand-alone high-risk AI system used in a critical use case (as listed in Annex III, see Sect. 3.1.2). As part of the registration process, they must select the specific high-risk AI system to be used that has to be registered by the provider beforehand (see Sect. 3.3.5).

Other deployers are entitled to register themselves voluntarily in the database (Recital 131).

Deployers must provide the following information in the database and keep it up to date (Article 71(3), Section C of Annex VIII):

- the name, address and **contact details** of the deployer and the person carrying out the registration on behalf of the deployer;
- the **URL** of the entry of the **AI system** in the EU database by its provider;
- a summary of the results of the **fundamental rights impact assessment** carried out (see Sect. 3.4.8) and
- where applicable, a summary of the **data protection impact assessment** carried out (see Sect. 7.2.9.5).

Deployers of AI systems intended to be used as safety components in the management and operation of critical digital infrastructure, road traffic, or the supply of water, gas, heat or electricity are **exempted from the obligation to register** themselves in the EU database (Article 49(3)).

Deployers shall check **before use** whether the high-risk AI system has been **registered** in the EU database by the provider or distributor. If this is not (yet) the case, they must refrain from using this system for the time being and inform the relevant provider or distributor about the pending registration.

Related Topics

High-risk AI systems in critical use cases: Sect. 3.1.2.
Provider's obligation to register: Sect. 3.3.5.

Fundamental rights impact assessment: Sect. 3.4.9.
EU database: Sect. 6.2.7.
Data protection impact assessment: Sect. 7.2.9.5. ◄

3.4.7 What Additional Obligations Does the Deployer of a Post-remote Biometric Identification System Have?

Article 26(10)

Recitals 94 (Biometric identification for law enforcement purposes), 95 (Post-remote biometric identification)

If a post-remote biometric identification system is operated in the context of law enforcement, strict obligations apply. This is due to the **intrusive nature** of these systems and the fact that the prohibition and **strict exceptions for the use of real-time remote biometric identification** should not be undermined (Recital 95; see Sect. 2.8).

Post-remote biometric identification systems include all biometric remote identification systems that are not biometric real-time remote identification systems (see Sect. 2.8).

Post-remote biometric identification systems shall only be used in a targeted manner in the context of an investigation to **search for a person** suspected or convicted of committing a **criminal offence**, to prevent an actual and foreseeable **risk of a criminal offence** or to search for a specific **missing person.** Any use must be limited to what is **strictly necessary** for the investigation of a specific **criminal offence.**

Authorisation for use must be obtained in advance or without undue delay, but at the latest within 48 h, from a **judicial authority** or an administrative authority whose decision is binding and subject to judicial review. The AI Act does not clarify when the 48-hour period for subsequent authorisation of use begins. As the authorisation should be obtained as soon as possible, the period will probably be considered to run from the beginning of the use of the remote biometric identification system. An **exemption** from the authorisation requirement applies if the system is used to initially identify a potential suspect based on objective and verifiable facts that are directly linked to the criminal offence.

Deployers must also document the use of post-remote biometric identification systems and submit **annual reports** on their use to the relevant market surveillance authorities and national data protection authorities, although specific sensitive operational data does not have to be disclosed.

The AI Act does not set out any specific requirements for the use of AI systems for post-remote biometric identification in other use cases than law enforcement. However, in addition to the requirements of the AI Act, **other relevant legal requirements**, in particular from the GDPR and the Law Enforcement Directive (EU) 2016/680, must be observed in any case. The member states can also issue additional**, stricter national regulations** regarding post-remote biometric identification systems in law enforcement.

Related Topics

Prohibition of real-time remote biometric identification systems: Sect. 2.8.
Biometric high-risk AI systems: Sect. 3.1.2.1.
Data protection requirements for the use of AI: Sect. 7.2. ◄

3.4.8 What Information Obligations Apply to Deployers of High-Risk AI Systems That Make Decisions Regarding Natural Persons?

Article 26(11)
Recital 91 (Obligations of deployers)

Deployers of high-risk AI systems in critical use cases (as listed in Annex III, see Sect. 3.1.2) that **make decisions about individuals** or provide support for such decisions shall inform the individuals that they are subject to the use of such a system. In addition, affected persons may also have a right to an explanation of the decision (see Sect. 1.7.2). However, this right to an explanation is not identical in terms of content and must therefore be considered separately from the obligation to provide information.

As **personal data** is regularly processed in this context, the corresponding provisions under EU data protection law, i.e. under the GDPR and the Law Enforcement Directive (Directive (EU) 2016/680), must also be observed.

In particular, the **requirements for automated decision-making** set up by the GDPR must be taken into account (see Sect. 7.2.7).

Related Topics

Right to an explanation of an AI-based decision: Sect. 1.7.2.
High-risk AI systems in critical use cases: Sect. 3.1.2.
Specific transparency obligations for deployers of all AI systems: Sects. 4.3–4.5.
Information obligations under the GDPR: Sect. 7.2.5.
GDPR provisions on automated decision-making: Sect. 7.2.7. ◄

3.4.9 To What Extent Are Deployers of High-Risk AI Systems Obliged to Cooperate with National Competent Authorities?

Article 26(12)
Recital 91 (Obligations of deployers)

Deployers must cooperate with the national competent authorities in all measures taken by those authorities in relation to the high-risk AI system in order to

implement the AI Act. In doing so, the respective **risk** posed by the operation of the AI system and the principle of **proportionality** must be taken into account. The powers of the market surveillance authorities are set out in the AI Act and the Market Surveillance Regulation (see Sect. 6.2.5). National competent authorities must also observe obligations towards deployers (e.g. to treat information confidentially; see Sect. 6.2.8).

Related Topics

Investigation rights of the supervisory authorities: Sect. 6.2.5.
Obligations of the authorities towards the operators: Sect. 6.2.8. ◀

3.4.10 Which Deployers of High-Risk AI Systems Are Obliged to Carry Out a Fundamental Rights Impact Assessment?

Article 27
Recital 96 (Fundamental rights impact assessment)

Deployers of high-risk AI systems must carry out a fundamental rights impact assessment (Article 27(1)) in the following cases:

- the deployer is a **body governed by public law;**
- the deployer is a **private entity** that provides **public services** (e.g. in the areas of education, health care, social services, housing and administration of justice);
- the deployer uses a stand-alone high-risk AI system for **credit scoring and creditworthiness assessment of** natural persons (Annex III No. 5(b)) or
- the deployer uses a stand-alone high-risk AI system for **risk assessment** and **pricing** of **health and life insurance** (Annex III No. 5(c)).

The obligation applies only to deployers of stand-alone high-risk AI **systems in critical use cases** (as listed Annex III, see Sect. 3.1.2), except for AI systems that are used as safety components of critical digital infrastructure, road traffic or the supply of water, gas, heat or electricity (Annex III No. 2, see Sect. 3.1.2.2).

The fundamental rights impact assessment is intended to analyse the **effects** that the use of a high-risk AI system may have **on fundamental rights** before putting it into service and to identify any **measures to minimise the risks.** The AI Office will develop a **template** for a questionnaire and an automated tool to facilitate the fundamental rights impact assessment.

The fundamental rights impact assessment must include at least the following elements (Article 27(1)):

- a description of the deployer's **processes** in which the AI system will be used;
- a description of the **period of time** and **frequency of** use of the AI system;

- the **categories of natural persons** and groups of persons who could be affected by the use;
- the **risks of harm** for the identified categories of persons or groups of persons;
- the implementation of **human oversight measures** according to the instructions for use, and
- the measures to be taken if the identified risks of harm occur (as well as for **risk avoidance**), including arrangements for internal corporate governance and complaints mechanisms.

Deployers, in particular in the public sector, may involve representatives of groups of people who may be affected by the AI system or independent **experts** and civil society organisations in the assessment (Recital 96).

The fundamental rights impact assessment only needs to be carried out **before** the deployer **uses** the high-risk AI system for the **first time**. For subsequent uses, the deployer can simply refer to previously conducted impact assessments in **similar use cases**. If, during the use of the high-risk AI system, the deployer considers that changes occur in relation to the elements to be assessed (see above), it shall carry out a new impact assessment (Article 27(2)).

The deployer shall **inform the competent market surveillance authority of the results of the risk assessment** after it has been carried out. If a high-risk AI system is placed on the market or put into service before the conformity assessment procedure has been completed for exceptional reasons (see Sect. 6.1.5), deployers may be exempt from the notification obligation (Article 27(3)).

If the use of a high-risk AI system also requires a **data protection impact assessment** to be carried out (e.g. in accordance with Article 35 GDPR, see Sect. 7.2.9.5), this can be **complemented** by the elements of the fundamental rights impact assessment that are also required (Article 27(4)).

Related Topics

High-risk AI systems in critical use cases: Sect. 3.1.2.
Data protection impact assessment: Sect. 7.2.9.5. ◀

3.5 What Obligations Do Other Operators Have?

In addition to the provider and deployer of a high-risk AI system, other operators along the AI value chain (e.g. distributors and importers) also have certain obligations, which are outlined below.

3.5.1 What Obligations Apply to Manufacturers of Products That Are AI Systems or Contain AI Systems as Safety Components?

Article 25(3)

Recitals 83 (Operators along the value chain), 84 (Quasi provider)

If an AI system is a safety component of a product covered by EU harmonisation legislation (as listed in Section A of Annex I; see Sect. 3.1.1.1) and

- placed on the market together with the product under the name or trademark of the product manufacturer, or
- is put into service under the name or trademark of the product manufacturer after the product has been placed on the market,

the product manufacturer (see Sect. 1.3.5) assumes responsibility for the conformity of the AI system with the AI Act and is subject to the **obligations of the provider** (see Sect. 3.3).

Related Topics

Definition of the manufacturer: Sect. 1.3.5.
Obligations of the provider: Sect. 3.3. ◀

3.5.2 What Obligations Do Importers of High-Risk AI Systems Have?

Article 23

Recital 83 (Operators along the value chain)

Importers (see Sect. 1.3.3) must comply with various obligations (Article 23):

- **verification obligations** for imported high-risk AI systems prior to Placing on the market;
- **reporting obligations** for special Risks;
- **labelling obligations**;
- the obligation for safe **storage** and **transport**;
- the obligation to **retain documents** that prove the conformity of the system and
- the obligation to **cooperate** with the competent supervisory authority.

Each of these obligations is explained in detail in the following sub-sections.

Importers can also be treated as providers under certain circumstances and must fulfil the corresponding provider obligations (see Sect. 1.3.7).

Related Topics

Definition of importer: Sect. 1.3.3.
Quasi provider: Sect. 1.3.7.
Distributor's obligation to take corrective action: Sect. 3.5.3.2. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.3, p. 39–41.

3.5.2.1 What Do Importers of High-Risk AI Systems Need to Check Before Placing the System on the Market?

Article 23(1) and (2)

Importers must ensure that the high-risk AI system complies with the requirements of the AI Act before placing a high-risk AI system on the market. To this end, they shall **verify** (Article 23(1)) that the provider has

- carried out a **conformity assessment procedure** (see Sect. 6.1),
- drawn up the necessary **technical documentation** (see Sect. 3.2.4),
- affixed the required **CE marking** (see Sect. 3.3.4),
- drawn up the necessary **EU declaration of conformity** (see Sect. 3.3.3),
- attached the **instructions for use** (see Sect. 3.2.6), and
- has appointed an **authorised representative** (see Sect. 1.3.10).

The high-risk AI system **must not be placed on the market** if the importer considers or has reasonable grounds to believe that the system

- **does not meet the requirements** of the AI Act for high-risk AI systems (see Sect. 3.2),
- is **falsified**, or
- accompanied by a **falsified documentation**.

In such cases, the importer may only place the system on the market after it has been brought into conformity (Article 23(2)).

Related Topics

Authorised representative: Sect. 1.3.6.
Obligation to appoint an authorised representative: Sect. 1.3.10.
Requirements for high-risk AI systems: Sect. 3.2.
Obligations of the provider of a high-risk AI system: Sect. 3.3.
Conformity assessment procedure: Sect. 6.1. ◀

3.5.2.2 How Must Importers Label High-Risk AI Systems They Place on the Market?

Article 23(3)

Importers must indicate their **contact information**, i.e. their name, registered trade name or registered trademark, and the address at which they can be contacted on the high-risk AI system itself and, where applicable, on the packaging or in the accompanying documentation.

3.5.2.3 How Must Importers Store and Transport High-Risk AI Systems That They Place on the Market?

Article 23(4)

Insofar as this is relevant for AI systems at all, importers must ensure that storage and transport conditions do **not jeopardize** the conformity of the high-risk AI **system.** However, this only applies as long as the high-risk AI system is under the importer's responsibility.

3.5.2.4 What Documents Must Importers of High-Risk AI Systems Keep?

Article 23(5)

For a period of **10 years** after the AI system has been placed on the market or put into service, importers must keep

- the **instructions for use** (see Sect. 3.2.6),
- the **EU declaration of conformity** (see Sect. 3.3.3), and
- where applicable, a copy of the certificate issued by the **notified body** (see Sect. 6.1.3.2).

Related Topics

Instructions for use: Sect. 3.2.6.
EU declaration of conformity: Sect. 3.3.3.
Conformity assessment procedure by a notified body: Sect. 6.1.3.2. ◀

3.5.2.5 To What Extent Must Importers of High-Risk AI Systems Cooperate with National Competent Authorities?

Article 23(2), (6) and (7)

Importers shall cooperate with the national competent authorities when the authorities take **measures** in relation to the relevant high-risk AI system, in particular when these serve to **minimise risks** (Article 23(7)). They shall also provide, upon a reasoned request, all information and documentation necessary to **demonstrate the compliance** of the high-risk AI system (Article 23(6)). This includes the documents to be kept by the importer and the technical documentation (see Sect. 3.2.4). The information must be presented in a language that can be understood easily by the authorities.

If the AI system poses a **risk to health, safety or fundamental rights**, the importer shall inform the provider of the system, the market surveillance authorities, the provider and its authorised representative (Article 23(2)). The provider must then take appropriate corrective actions (see Sect. 3.3.9). Market surveillance authorities shall initiate appropriate procedures following notification by the importer (see Sect. 6.2.4.1).

Related Topics

Technical documentation: Sect. 3.2.4.
Corrective action by the provider: Sect. 3.3.9.
Surveillance measures regarding AI systems that pose a risk: Sect. 6.2.4.1. ◀

3.5.3 What Obligations Apply to Distributors of High-Risk AI Systems?

Article 24
Recital 83 (Operators along the value chain)
Distributors (see on the term Sect. 1.3.4) are subject to

- **verification obligations** for high-risk AI systems before making them available on the market,
- **reporting obligations** for risks,
- the obligation for safe **storage** and **transport**,
- **monitoring** and **correction obligations**, and
- the obligation **to cooperate** with the competent **supervisory authorities**.

If distributors also act as importers (see Sect. 1.3.3), they should also be subject to the corresponding obligations of an importer (Recital 83; see Sect. 1.3.7). Under certain circumstances (see Sect. 1.3.7), distributors also have the obligations of a provider of high-risk AI systems (see Sect. 3.3).

Related Topics

Distributor: Sect. 1.3.4.
Importer: Sect. 1.3.3.
Quasi provider: Sect. 1.3.7.
Obligations of the provider of a high-risk AI system: Sect. 3.3.
Obligations of the importer of a high-risk AI system: Sect. 3.5.2. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 3.4, p. 41–43.

3.5.3.1 What Do Distributors Need to Verify When Making a High-Risk AI System Available on the Market?

Article 24(1) and (2)

Before distributors make a high-risk AI system available on the EU market, they must verify that

- the high-risk AI system bears the required **CE marking** (see Sect. 3.3.4),
- the high-risk AI system is accompanied by the necessary **EU declaration of conformity** (see Sect. 3.3.3) and the **instructions for use** (see Sect. 3.2.6), and
- the provider and, where applicable, the importer of the AI system have fulfilled their **labelling obligations** (see Sects. 3.3 and 3.5.2.2), and
- the provider has set up a **quality management system** (see Sect. 3.3.1).

If a distributor has reason to believe that the system does not comply with the requirements for high-risk AI systems, it must not make the system available on the market until the system has been **brought into conformity** with the requirements of the AI Act (Article 24(2)).

If the high-risk AI system also poses a **risk to health or safety or fundamental rights,** the distributor shall inform the provider or importer of the system (Article 24(2)).

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.
Obligations of the provider of a high-risk AI system: Sect. 3.3.
Importer's labelling obligation: Sect. 3.5.2.2. ◀

3.5.3.2 When Do Distributors of High-Risk AI Systems Need to Take Corrective Action?

Article 24(4)

If, distributors have reason to believe that a high-risk AI system that was made available on the market **does not comply** (or no longer complies) with the requirements of the AI Act, it must take the necessary **corrective action** to bring the AI system into conformity or, if the risks are sufficiently high, to withdraw or recall the AI system. Alternatively, distributors may also ensure that the provider, the importer, or any other relevant operator, as appropriate, takes the necessary corrective action (Article 24(4)).

If distributors become aware that the high-risk AI system poses a **risk to health, safety or fundamental rights** after it has been made available on the market, they must immediately inform the provider or the importer of the AI system. In addition, distributors must **inform** the **national competent authorities of the member states** in which they have made the system available. In doing so, they shall indicate the extent to which the AI system deviates from the requirements of the AI Act and what corrective measures have been taken (Article 24(4)). The provider must then take appropriate corrective measures (see Sect. 3.3.9). Market surveillance

authorities shall initiate an appropriate procedure following notification by the distributor (see Sect. 6.2.4.1).

Related Topics

Corrective action by the provider: Sect. 3.3.9.
Surveillance measures regarding AI systems that pose a risk: Sect. 6.2.4.1. ◀

3.5.3.3 How Should Distributors Store and Transport High-Risk AI Systems?

Article 24(3)

Insofar as this is relevant for AI systems at all, distributors must organise storage and transport conditions in such a way that the conformity of the **high-risk AI system** is **not jeopardized. T**his only applies as long as the high-risk AI system is under the distributor's responsibility.

3.5.3.4 To What Extent Do Distributors of High-Risk AI Systems Have to Cooperate with National Supervisory Authorities?

Article 24(5) and (6)

Distributors shall cooperate with the national competent authorities when the authorities take **measures** in relation to the relevant high-risk AI system, in particular when these serve to **mitigate or reduce risks** (Article 24(6)). They shall also, upon reasoned request, provide all information and documentation necessary to **demonstrate the compliance** of the high-risk AI system (Article 24(5)).

If the AI system poses a **risk to health, safety or fundamental rights** (Article 79(1)), the distributor shall inform the provider or importer of the system as well as the competent authorities (see Sect. 3.5.3.2).

Related Topics

Corrective action by the provider: Sect. 3.3.9.
Corrective action by the distributor: Sect. 3.5.3.2.
Surveillance measures regarding AI systems that pose a risk: Sect. 6.2.4.1. ◀

3.5.4 What Are the Obligations of Authorised Representatives of Providers of High-Risk AI Systems?

Article 22

Recital 82 (Authorised representative)

Before making a high-risk AI system available on the EU market, providers not established in the EU must designate an authorised representative established in the EU (Article 22(1), see Sect. 1.3.10). This authorised representative must perform some of the provider's tasks and be available to the competent authorities as a contact person in addition to, or instead of, the provider. The purpose of this provision

is to ensure that there is a contact person in the EU for every high-risk AI system, so that the enforcement of the AI Act is facilitated and harmonised for all providers (Recital 82).

The authorised representative's tasks must be set out in a **written mandate** (Article 22(2)). A copy of the mandate must be made available to the market surveillance authorities on request and in an official EU language specified by the competent authority (Article 22(3)).

The mandate must at least enable the authorised representative to perform **the following tasks** (Article 22(3)):

- **to verify** that the EU declaration of conformity and the technical documentation for the high-risk AI system have been drawn up and whether the provider has carried out an appropriate **conformity assessment procedure;**
- to keep at the disposal of the competent authorities for a period of 10 years after the high-risk AI system has been placed on the market or put into service of the high-risk AI system:
  - the contact details of the provider of the AI system,
  - the **EU declaration of conformity** (see Sect. 3.3.3),
  - the **technical documentation** (see Sect. 3.2.4), and
  - the certificate issued by a notified body, where applicable (see Sect. 6.1.3.2);
- to provide all the information and documentation, including automatically generated logs (see Sect. 3.2.5), to the competent authorities upon a reasoned request,
- **to cooperate with the competent authorities** in any action the authorities take in relation to a high-risk AI system, in particular to reduce and to mitigate risks (see Sect. 6.2.4), and
- comply with the **registration obligations** (see Sect. 3.3.5) or, if the provider carries out the registration, verify that the designation of the authorised representative and its contact details in the database are correct.

The authorised representative must **terminate the mandate** if it has reason to believe that the provider is acting contrary to its obligations under the AI Act. In this case, the authorised representative shall immediately **inform** the market surveillance authority concerned (and any notified body involved) about the termination of the mandate and the reasons for it (Article 22(4)).

Related Topics

Obligation to appoint an authorised representative: Sect. 1.3.10.
Requirements for high-risk AI systems: Sect. 3.2.
Obligations of the provider of a high-risk AI system: Sect. 3.3.
Conformity assessment procedure: Sect. 6.1.
Market surveillance procedures: Sect. 6.2.4. ◀

Which AI Systems Are Subject to Specific Transparency Requirements?

4

Article 50

Recitals 26 (Risk-based approach), 120 (Interplay with Digital Services Act), 133 (AI systems that generate large amounts of synthetic content), 136 (Interplay with Digital Services Act), 134 (Disclosure obligations for deployers regarding deep fakes), 137 (Harmonisation with other transparency obligations)

The AI Act contains certain transparency obligations for AI systems, regardless of whether these AI systems are considered high risk or not. These transparency obligations apply, if the AI system in question is used in a certain way that is covered by the transparency obligations.

The transparency obligations assume certain cases where it must be disclosed that actions are carried out, or content is generated, by AI systems. The transparency obligations do not concern the functionality and internal processes of an AI system. They are solely intended to clarify when content stems from AI systems. Other transparency requirements that cover the internal functioning, i.e. the explainability of the processes within an AI system, only apply to high-risk AI systems (see Sect. 3.2.6).

The transparency obligations that apply to certain categories of AI systems, regardless of their other risk attribution, are divided into five cases. In each case, either providers or deployers of the AI system covered have information and transparency obligations, the content of which depends on the specific use case.

These **cases with special transparency obligations** are the following:

- providers of AI systems intended for direct interaction with natural persons,
- providers of AI systems that generate synthetic audio, image, video or text content,
- deployers of emotion recognition systems and biometric categorisation systems,
- deployers of AI systems that generate deep fakes,
- deployers of AI systems that generate or manipulate texts that are published to inform the public about matters of public interest.

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_4

In the following Sections, each transparency obligation is described in detail.

It must be noted, though, that in any case it must be assessed whether the AI system is a prohibited AI system, first, e.g. because it is intended to be used in a prohibited practice in the area of manipulative or deceptive techniques, emotion recognition or biometrics (see Chap. 2). Additionally, the AI system may be subject to **further obligations** under the AI Act or other legal acts. The obligations of providers and deployers of high-risk AI systems must be observed (see Sects. 3.2, 3.3 and 3.4). An AI system can be subject to both the requirements for high-risk AI systems and the transparency obligations. There may also be additional information obligations, for example under data protection or consumer protection law.

Related Topics

Prohibited AI practices: Chap. 2.

High-risk AI systems: Chap. 3. ◄

4.1 What Requirements Apply to Providers of AI Systems Directly Interacting with Humans?

Article 50(1)

Recital 132 (AI systems that interact with humans)

If an AI system is intended to directly interact with humans, providers must ensure in the design and development stage that the AI system will be sufficiently transparent (recognisable) in its future use. This requirement does not apply to deployers. However, deployers may still have to comply with other transparency obligations, especially those regarding deep fakes (see Sects. 4.3 to 4.5 for all transparency obligations that apply to deployers).

The purpose of the transparency provision is for humans to know whether they are interacting with another human or with an AI system. The transparency obligation should therefore only apply to AI systems whose application simulates direct interaction with a human (e.g. chatbots). Only if there is a risk of confusion in this regard, the natural persons concerned must be informed about the interaction with an AI system.

The transparency requirement does not apply to constellations in which, from the point of view of a reasonably informed, attentive and understanding person, it is obvious from the circumstances and context of use that they interact with an AI system. This will be the case for many chatbots. Here, it is often obvious from the name ('XY bot') and the design of the application (e.g. through predefined questions and topics that the user can select to interact with the chatbot) that the user interacts with an AI system and not with a human. If AI systems fulfil tasks that a human obviously cannot perform in the same way, for example at the same speed, it is obvious to an informed person that they are interacting with AI systems, so that generally no additional transparency notice will be required. This is the case, for

example, with real-time translation software. When translating complex texts in the blink of an eye, it is obvious to an informed person that a human cannot have produced these results, as in these cases a human would not be able to capture the input, carry out the work and write down the results with comparable speed.

The transparency obligation for AI systems directly interacting with humans does not apply to AI systems authorised by law to detect, prevent, investigate or prosecute criminal offences if appropriate safeguards are in place to protect the rights and freedoms of third parties. Systems that are available to the public to report a criminal offence must in turn fulfil the transparency requirement.

4.2 Which Requirements Apply to Providers of AI Systems That Generate Synthetic Content?

Article 50(2)

Recitals 120 (Interplay with Digital Services Act), 133 (AI systems that generate large amounts of synthetic content)

Synthetic content generated or manipulated by AI systems must be recognisable as such and labelled accordingly. The provider of such AI systems must ensure that the synthetic content is recognisable. If synthetic content is a deep fake or if synthetic content is intended to inform about matters of public interest, the deployer of the AI system also has certain transparency obligations (see Sects. 4.4 and 4.5).

This obligation covers AI systems that generate synthetic **audio, image, video or text content**. The AI Act **does not** contain an **explicit definition** of what content is synthetic. The purpose of the transparency requirement is to distinguish synthetic content from content that is generated by humans and is authentic (Recital 133). This suggests that 'synthetic content' means artificially created or altered content. However, it should also be taken into account that this transparency requirement is intended to minimise 'new risks of misinformation and manipulation at scale, fraud, impersonation and consumer deception' (Recital 133). As these risks do not usually arise from everyday applications, the very broad wording should be understood restrictively. AI systems that perform a supporting function or do not significantly change the input data provided by the deployer or its semantics are explicitly not covered. Synthetic content is therefore **only content that is significantly changed** by an AI system. Due to the very narrow purpose of the regulation, changes should only be considered significant if they change the original meaning of the content. For example, a photo whose background has been completely supplemented by an AI will probably be synthetic. If, on the other hand, an AI system has only corrected the colours so that they appear stronger overall or has controlled the focus of the camera so that the photo is as sharp as possible, these images are not synthetic, as the significance of the content was not changed at all. It could even be deceptive if pictures were labelled as 'generated by AI' when in reality only minor changes were made by AI without altering the significance of the picture. For example, texts are synthetic if they are created by specific prompts using a generative AI system. If, on

the other hand, only a grammar check is carried out by AI, the text is not significantly changed and is therefore not synthetic.

Providers of AI systems that generate synthetic content must ensure that the results of the AI system are **labelled** in a machine-readable format **and** are **recognisable as artificially generated or manipulated.** The technical labelling should be as effective, interoperable, robust and reliable as possible in accordance with the state of the art. The general proportionality, the respective risk posed by the AI system, e.g. with regard to a particular potential for fraudulent activities or consumer deception, as well as the implementation costs of any labelling measures must be taken into account. It is crucial that the **origin of the content** is **traceable.** The requirements are therefore formulated in a technology-neutral manner. According to the AI Act, examples of currently available technologies include watermarks, metadata identification, logging methods and fingerprints. For example, the Coalition for Content Provenance and Authenticity (C2PA), in which numerous well-known digital companies have joined forces, is currently developing new technical specifications for the traceability of digital content.

The transparency obligation does not apply to AI systems that are authorised by law to detect, prevent, investigate and prosecute criminal offences.

► **Further Information** *European Parliament*, Briefing: Generative AI and watermarking (2023).

4.3 What Requirements Apply to Deployers of Emotion Recognition Systems and Biometric Categorisation Systems?

Article 3(39) and (40), 50(3)

Recitals 14 (Biometric data), 16 (Biometric categorisation), 18 (Emotion recognition systems)

For certain AI systems that process biometric data, the AI Act contains an obligation to inform the persons concerned. This information obligation applies to emotion recognition systems (see Sect. 2.6) and biometric categorisation systems (see Sect. 2.7). In both cases, it must be noted that some of these systems are already subject to prohibitions under the AI Act. If emotion recognition systems and biometric categorisation systems do not fall under the prohibition, **deployers** must inform the persons concerned about the use of the systems. The providers of these AI systems have no additional transparency obligations only because of the fact that their AI system can recognise emotions or categorise humans based on biometric data. However, they may still have to comply with the specific transparency obligations that apply to providers (see Sects. 4.1 and 4.2).

This obligation does not apply to AI systems authorised by law to detect, prevent and investigate criminal offences if appropriate safeguards are in place to protect the rights and freedoms of third parties.

Related Topics

(Prohibited) emotion recognition systems: Sect. 2.6.

(Prohibited) Biometric categorisation systems: Sect. 2.7.

Biometric high-risk AI systems: Sect. 3.1.2.1. ◄

4.4 Which Requirements Apply to Deployers Whose AI Systems Generate Deep Fakes?

Article 3(60), 50(4)

120 (Interplay with the Digital Services Act), 133 (AI systems that generate large amounts of synthetic content), 134 (Disclosure obligations for deployers regarding deep fakes)

In addition to the obligations of **providers** whose AI systems generate synthetic content (see Sect. 4.1), **deployers** of such AI systems also have transparency obligations if the content generated is considered as deep fake.

AI systems create deep fakes if they generate or manipulate image, audio or video content in such a way that the content resembles existing persons, objects, places, entities, or events and would falsely appear to a person to be authentic or truthful (Article 3(60)). This requirement is vague, as it depends on the diligence of the viewer whether artificial content falsely appears to be authentic. Particularly inattentive persons are much easier to deceive than attentive observers. The AI Act does not expressly specify its criteria in this regard. Since the transparency obligation regarding deep fakes is intended to counter the spread of misinformation, it should only be taken into account here whether a reasonably informed, attentive and circumspect natural person would mistakenly believe the content to be genuine. If only individual, inattentive persons mistakenly believe content to be genuine, this does not lead to a general dissemination of false information and therefore need not constitute a deep fake within the meaning of the AI Act.

Deployers of AI systems that generate deep fakes must disclose that the content has been artificially generated or manipulated. Unlike providers of such AI systems (see Sect. 4.1), deployers do not have to label the content as AI-generated in a machine-readable form. Thus, the disclosure obligation for deployers is easy to fulfil. Hence, it may be advisable for risk-averse deployers to assume a deep fake in cases of doubt, where content is not obviously artificially generated and may appear to be realistic.

The disclosure obligation for deployers does not apply to AI systems authorised by law to detect, prevent, investigate and prosecute criminal offences.

If deep fakes are used in recognisably artistic, creative, satirical, fictional or analogue works or programmes, only the presence of deep fakes must be disclosed in an appropriate manner. To ensure that the presentation or enjoyment of the work is not impaired, it is not necessary to label each and every deep fake individually.

4.5 Which Requirements Apply to Deployers Whose AI Systems Generate Texts for the Public?

Article 50(4)

120 (interaction with Digital Services Act), 134 (Disclosure obligations for deployers regarding deep fakes)

There are also additional transparency obligations for **deployers** of AI systems that generate or manipulate texts which is published with the purpose to inform the public about matters of public interest. This obligation does not apply to providers of these AI systems. Providers only have to comply with the specific transparency obligations applicable to providers (see Sects. 4.1 and 4.2).

AI systems that generate texts without human review are covered if these texts concern matters of public interest and are made accessible to an undefined group of people. For example. this will apply to AI-generated texts that are published on the internet without further human review and editorial responsibility. Deployers of such AI systems must disclose that the text has been artificially generated or manipulated.

This obligation does not apply to AI systems authorised by law to detect, prevent, investigate and prosecute criminal offences. Besides, the obligation does not apply if the AI-generated content is controlled by a human or if a natural or legal person has editorial responsibility for the publication. This exception is intended to cover cases where an AI-generated text has been reviewed or editorially controlled by a human prior to its publication and a specific natural or legal person takes responsibility for it (Recital 134).

4.6 At What Point in Time Must the Transparency Requirements Be Met?

Article 50(5)

The information must be provided to the concerned person at the latest at the time of the first interaction with or exposure to the AI system or AI-generated content.

4.7 What Guidance Does the AI Act Include for Providers and Deployers of AI Systems with Specific Transparency Requirements?

Articles 50(7), 96(1)(d)

Recital 135 (Codes of practice for transparency obligations)

Guidelines issued by the European Commission shall specify how the transparency obligations are to be implemented in practice (Article 96(1)(d)).

With regard to detecting and labelling artificially created or manipulated content (see Sects. 4.2, 4.4 and 4.5), the AI Office (see Sect. 6.2.3) shall facilitate and

encourage the drawing-up of codes of practice by relevant stakeholders. Such codes of practice can be approved by the European Commission. If the European Commission does not consider the codes of practice to be appropriate, it may issue its own guidelines for the implementation of the labelling requirements (Article 50(7)).

Related Topics

AI Office: Sect. 6.2.3. ◄



Which Requirements Apply to GPAI Models?

5

Articles 3(63), 51 to 56

Recitals 97 (GPAI models), 98 (Thresholds for classifying GPAI), 99 (Generative AI models), 100 (GPAI systems), 101 (Role of the provider in the supply chain of GPAI models), 102 (Free and open-source GPAI models), 103 (Monetisation), 104 (Exemptions from transparency obligations), 105 (Text and data mining), 106 (Extraterritoriality), 107 (Transparency of training data), 108 (Monitoring copyright compliance), 109 (Proportionality of compliance), 110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 114 (Obligations regarding systemic risks), 115 (Reporting of serious incidents), 116 (Codes of practice), 117 (Presumption of conformity)

GPAI models (see Sect. 1.2.6), such as large **generative AI models** ('genAI') and large language models ('LLMs'), are subject to special provisions of the AI Act. AI models can be implemented for a variety of different possible use cases, but they are not in themselves AI systems (Recital 97). Thus, they cannot be considered as high risk under the AI Act. If they are subjected to further fine-tuning or supplemented with user interfaces, they can also be used in high-risk AI systems.

The AI Act distinguishes between **two** risk-based **categories of GPAI models** that are subject to the AI Act: GPAI models with systemic risks and regular GPAI models (without systemic risks).

Essentially, all GPAI models are subject to **documentation** and **information obligations** (also with regard to the data used for model training), as well as the obligation to implement a system to protect the **copyrights** of third parties.

GPAI models with systemic risks are subject to additional obligations in order to increase transparency, recognise risks, prevent damage and increase cyber security. GPAI models with systemic risks are considered to be riskier due to their capacities or reach. These can materialise through misuse or lack of reliability of the model and can lead to discrimination, disinformation or jeopardize the security of

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_5

AI systems (Recital 110). They must therefore also be reported to the European Commission (see Sect. 5.2.3).

Free and open-source GPAI models, on the other hand, are considered less risky due to their particular transparency. They are particularly important for research and development (Recital 102), which is why some facilitations apply to them, provided they do not pose a systemic risk.

The obligations laid down for GPAI models do not apply when an own model that does not pose systemic risks is used for purely internal processes that are not essential for providing a product or a service to third parties and the rights of natural persons are not affected (Recital 97). However, this exemption does not apply to GPAI models that pose systemic risks. In any case, the implementation of the obligations concerning GPAI models must be appropriate and proportionate (Recital 109).

▶ **Further Information** *AI Verify Foundation*, Model AI Governance Framework for Generative AI – Draft (2024); *The Alan Turing Institute*, Human Rights, Democracy, and the Rule of Law Assurance Framework for AI Systems (2021); *Bengio*, International Scientific Report on the Safety of Advanced AI – Interim Report (2024); *Bundesamt für Sicherheit in der Informationstechnik*, Generative AI models (2024); *Centre of Information Policy Leadership*, Building Accountable AI Programs (2024); *European Union Agency for Cybersecurity*, Artificial Intelligence and Cybersecurity Research (2023); *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022); *Galdon Clavell*, Checklist for AI Auditing (2024); *High-Level Expert Group on AI*, Ethics guidelines for trustworthy AI (2019); Assessment List for Trustworthy AI (2020); *International Association of Privacy Professionals*, EU AI Act Compliance Matrix (2024); *International Organization for Standardization*, Artificial Intelligence Management Standards (2024); *National Institute of Standards and Technology*, AI Risk Management Framework (2023); *OECD*, Advancing accountability in AI: Governing and managing risks throughout the lifecycle for trustworthy AI (2023); OECD Framework for the Classification of AI systems (2022) ; *OECD.AI Policy Observatory*; Catalogue of Tools & Metrics for Trustworthy AI (2024); Generative Artificial Intelligence Profile – Draft (2024); *UK AI Safety Institute*, Inspect – An open-source framework for large language model evaluations (2024).

5.1 What Obligations Do Providers of GPAI Models Have?

Articles 3(3) and 53

Recitals 97 (GPAI models), 101 (Role of the provider in the supply chain of GPAI models), 104 (Exemptions from transparency obligations), 105 (Text and data

mining), 106 (Extraterritoriality), 107 (Transparency of training data), 108 (Monitoring copyright compliance), 109 (Proportionality of compliance)

The **provider** (Sect. 1.3.1) of a GPAI model is anyone who

- develops the GPAI model or
- has it developed and places it on the market under its own name or trademark (Article 3(3)).

GPAI models can be placed on the market in different ways, e.g. through software libraries, application programming interfaces ('APIs'), as a direct download or as a physical copy (Recital 97).

Providers of GPAI models play an **important role in the AI value chain** (Recital 101). Downstream providers who integrate GPAI models into their AI systems must be familiar with the technical characteristics of the GPAI model. This is also necessary in order to fulfil their own obligations (e.g. requirements for high-risk AI systems, see Sects. 3.2 and 3.3).

Providers of GPAI models must fulfil the following four obligations (Article 53(1)):

- They draw up and keep up-to-date the **technical documentation** of the model (including its training and testing process and the results of its evaluation), which must be made available to the **AI Office and the national competent authorities** upon request.
- They draw up, keep up-to-date and make available **information and documentation to providers of AI systems** who intend to integrate the GPAI model into their AI systems.
- They implement a **copyright compliance strategy.**
- They draw up and make publicly available a **sufficiently detailed summary** about the content used to train the AI model, according to a template provided by the AI Office.

In the following sub-sections, these obligations for providers of GPAI models are described in detail.

For providers of GPAI models that are placed on the market under a free and open-source licence, there are some simplifications (see Sect. 5.3), provided they do not pose a systemic risk.

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.

Obligations of the provider of a high-risk AI system: Sect. 3.3.

Facilitations for free and open-source GPAI models: Sect. 5.3. ◀

5.1.1 What Must the Technical Documentation of GPAI Models Contain?

Article 53(1)(a) and (6), Annex XI

Recital 101 (Role of the provider in the supply chain of GPAI models)

The technical documentation of a GPAI model, which must be provided to the AI Office and the national competent authorities upon request (Article 53(1)(a)), must contain at least the elements listed in **Annex XI.** Providers of AI models that are made available under a free and **open-source licence** and that do not present systemic risk are, however, are exempt from the obligation to draw up a technical documentation if they comply with the relevant requirements (see below Sect. 5.3).

Annex XI specifies **general information** that must be provided by all providers (Section 1) and **additional information** that must be provided **for models with an** inherent **systemic risk** (Section 2).

The general technical documentation must contain at least the following information:

- a **general description of the GPAI model**, including
  - the tasks that the model is intended to fulfil and the type and nature of the AI systems in which it can be integrated,
  - the applicable policies for acceptable use,
  - the date of release (not specified by the AI Act; probably the date on which the GPAI model was finalised, or the first making available on the market) and the methods of distribution,
  - the architecture and number of parameters (i.e. the specific functioning of the GPAI model; relevant parameters can include the requirements for categorising GPAI models and those relevant for categorising systemic risks; see Sects. 1.2.6 and 5.2.1),
  - the modality (e.g. text, image) and the format of inputs and outputs, and
  - the licence (i.e. the contractual terms of use) under which the model is offered.
- a **detailed description of the elements of the model** and relevant **information of the process for the development**, including
  - the technical means required to integrate the GPAI model into AI systems (instructions for use, IT infrastructure, tools),
  - the design specifications of the model and training process, including training methodologies and techniques, the key design choices including the rationale and assumptions made,
  - where applicable, information on the data used for training, testing and validation, including the type and provenance of data and curation methods (e.g. cleaning, filtering, etc.), the number of data points, their scope and their main characteristics; where applicable, how the data were obtained and selected, and any other measures taken to detect whether data sources are unsuitable and methods used to detect identifiable biases,

- the computational resources used to train the model (for example, number of floating-point operations), training time, and other relevant details related to training, and
- the known or estimated energy consumption of the model.

The European Commission may amend the list of necessary elements for the technical documentation of a GPAI model through a delegated act (Article 53(6)).

Providers of GPAI models **with systemic risks** must provide additional information in the technical documentation (see Sect. 5.2.2). Providers of GPAI models that are provided under a **free and open-source licence** and that do not present systemic risks are exempt from the obligation to provide technical documentation if they comply with the relevant requirements (see Sect. 5.3).

Related Topics

Additional elements of the technical documentation for GPAI models with systemic risks: Sect. 5.2.2.

Facilitation for providers of free and open-source GPAI models: Sect. 5.3.

Competent authorities: Sect. 6.2.1.

AI Office: Sect. 6.2.3. ◀

5.1.2 What Information Must Providers of GPAI Models Make Available to Downstream Providers of AI Systems?

Articles 3(68), 53(1)(b), Annex XII

Recital 101 (Role of the provider in the supply chain of GPAI models)

Providers of GPAI models must make information available to downstream providers who intend to integrate the GPAI model into their AI system (Article 3(68); see also Sect. 5.5.2). This information must enable the provider to **implement** the GPAI system into its AI model professionally and safely, especially with regard to high-risk AI systems. The information to be provided should enable downstream providers of AI systems to have a good **understanding of the capabilities and limitations** of the GPAI model and to fulfil their obligations under the AI Act.

Providers of GPAI models that are provided under a free and **open-source licence** and that do not pose a systemic risk are exempt from the obligation to provide information to downstream providers if they comply with the relevant requirements (see Sect. 5.3).

According to Annex XII, the provider of a GPAI model must make available the following information, which in parts resembles the information that has to be included in the technical documentation (see Sect. 5.1.1):

- a general description of the GPAI model, including
  - the tasks that the model is intended to perform and the type and nature of AI systems into which it can be integrated,
  - the applicable policies of acceptable use,
  - the date of release and the methods of distribution,
  - if applicable, an indication of how the GPAI model interacts with hardware or software that is not part of the model itself, or how it can be used for such interaction,
  - if applicable, the versions of relevant software related to the use of the GPAI model (e.g. if the GPAI model only works with a current version of a specific operating software),
  - the architecture and the number of parameters,
  - the modality (e.g. text, image) and format of inputs and outputs;
  - the licence for the model; and
- a description of the elements of the GPAI model and of the process for its development, including
  - the technical means (e.g. instructions for use, infrastructure, tools) required to integrate the GPAI model into AI systems;
  - the modality (e.g. text, image, etc.) and format of the inputs and outputs and their maximum size (e.g. length of the context window or the number of tokens that the model can process), and
  - where applicable, information on the data used for training, testing and validation, including the type and provenance of the data and the curation methods.

Information on the modality and format of inputs and outputs should be included both in the general description of the GPAI model and in the description of its components and its development process. There is likely to be some overlap in the content of both parts of the information provided to downstream providers (for example, in relation to the modalities of inputs and outputs). While the general description of the GPAI model emphasises key characteristics, the description of the components and the development process should contain more detailed information (e.g. on the maximum size of the output).

Providers of GPAI models that are provided under a **free and open-source licence** and that do not pose a systemic risk are exempt from the obligation to provide information to downstream providers (see Sect. 5.3).

Related Topics

Facilitation for providers of free and open-source GPAI models: Sect. 5.3.

Rights and obligations of downstream providers: Sect. 5.5.2. ◀

5.1.3 What Copyright Requirements Apply to GPAI Models?

Article 53(1)(c); Article 2(2) DSM Directive (EU) 2019/790

Recitals 105 (Text and data mining), 106 (Extraterritoriality), 108 (Monitoring copyright compliance)

Providers of GPAI models must comply with **EU copyright law.** This is not only a requirement of the AI Act, but also an obligation under the relevant international agreements, EU directives and their implementation in the national law of the EU member states. Therefore, the provisions of the AI Act described below apply to providers of GPAI models in addition to the general copyright law. Providers of other AI models that are not GPAI models must still ensure compliance with copyright law when developing their AI models.

The AI Act contains two additional provisions on copyright protection that providers of GPAI models must comply with. First, providers must develop a strategy for complying with EU copyright law (see below) and, second, providers must provide information on the test and training datasets used (see Sect. 5.1.4).

The legislator intended the AI Act's provisions on copyright to particularly address the training AI models. The training of AI models often requires large data sets that are subject to copyrights and related rights. When using this kind of legally attributed and protected data, **the rights holders' content** must be **protected**. This need for protection is particularly eminent for **text and data mining,** which is used to create training datasets that represent text or images, for example. Text and data mining is any automated analytical technique aimed at analysing text and data in digital form in order to generate information which includes but is not limited to patterns, trends and correlations (Article 2(2) of the Directive (EU) 2019/790 on copyright in the Digital Single Market, 'DSM Directive'). Text and data mining is generally permitted under the **DSM Directive** (Article 4 DSM Directive). However, this does not apply if the respective rights holders have expressly **reserved the use of their works**, i.e. if they 'opted out' from the use of their content for text and data mining. This must be done in an appropriate manner (Article 4(3) of the DSM Directive), for example by machine-readable means in the case of content made publicly available online. The reservation does not apply if the text and data mining is carried out for scientific research purposes.

The AI Act requires providers of GPAI models to **put in place** a **policy to comply with copyright** and related rights (Article 53(1)(c)). In particular, this policy must ensure that providers identify and comply with expressed reservations of rights regarding the use for text and data mining as set out in the DSM Directive. Therefore, the provider must implement a data clearance process as part of data governance in order to gain clarity about the **origin of the data sets used** for model training and to ensure that they are authorised to use the data. This can also help to fulfil the transparency obligation for GPAI models (see Sect. 5.1.4).

According to the **principle of destination** (see Sects. 1.3.9 and 1.3.10), the obligation to set up a copyright compliance policy appears to apply to all providers that place GPAI models on the market in the EU, i.e. also to those providers that do not have an establishment within the EU. The AI Act presumes that it would not matter

in which territory the copyright-relevant acts underpinning the training of those GPAI models take place (Recital 106). This conflicts with the **principle of territoriality** in copyright law that stipulates that the copyright law of the country in which a particular act of use or infringement takes place applies. Resulting from the requirement to set up a policy on copyright compliance, the AI Act is intended to subject providers outside the EU to EU copyright law, even though it does not apply to them. However, the AI Act cannot extend the scope of application of EU copyright law. The legislators' 'hidden' attempt in Recital 106 to extend EU copyright law to the training of GPAI models outside the EU is therefore more likely to be seen as a political demand with regard to the creation of a 'level playing field'.

This is underlined as well by an additional point of friction between the requirements of the AI Act and EU copyright law. To put it plainly, there is no 'EU copyright law'. To the extent that there are harmonised copyright provisions at EU level at all, these have so far been issued in the form of directives. Since directives are not directly applicable, the provisions are implemented in each member state by a separate legal act with national characteristics that often max out the margins of transposition. Therefore, it will hardly be possible to set up a single uniform policy on copyright compliance for the entire EU. The AI Act only addresses the reservation of use for text and data mining and does not specify any other requirements that the policy must take into account. For companies that train their GPAI model in the EU, this is a comparatively easy task to solve, as they have to comply with the applicable national copyright law when developing a GPAI model anyway. For them, the copyright law of the country that is applicable to the training anyway is a good orientation to put a policy into place.

Companies outside the EU are potentially caught between the AI Act's principle of destination and the copyright principle of territoriality. If both principles of application were to apply, providers would possibly have to comply with EU copyright law in addition to the copyright law that applies at the location of the training activity. This is likely to cause considerable difficulties because the various national regulations are not harmonised and will contradict each other at least in part. In such situations, the country of origin's copyright law takes primacy as laid out in Art. 5 of the Berne Convention and other international copyright agreements. According to this principle, the scope of protection and the legal remedies available to the authors to protect their rights are determined exclusively by the legal provisions of the country in which protection is claimed. It is therefore difficult to justify a reasonable, extraterritorial extension of EU copyright law to countries outside the EU.

Related Topics

Territorial scope of the AI Act: Sect. 1.3.9.

Application of the AI Act to companies outside the EU: Sect. 1.3.10.

Transparency obligation for GPAI models: Sect. 5.1.4. ◀

5.1.4 What Information on the Data Used for Training of a GPAI Model Must Be Made Available by the Provider?

Article 53(1)(d)

Recital 107 (Transparency of training data)

Providers of GPAI models must create **transparency** by providing information about the data sets used for model training. This should enable downstream providers who integrate the GPAI model into an AI system to better assess the risks and legality of the data sets used (e.g. with regard to compliance with copyright law and data protection law) as well as to assess what performance they can expect of the AI model.

The AI model is an essential building block of an AI system (see Sect. 1.2.2). Information regarding the training data used is particularly important for **providers of high-risk AI systems** in order to fulfil their data governance obligations (see Sect. 3.2.2) and risk management (see Sect. 3.2.1) in order to fulfil their obligations.

Providers of GPAI models are therefore obliged to, draw up and make publicly available a **sufficiently detailed summary** about the content used for the training of the GPAI model, according to a **template provided** by the AI Office.

Business secrets and confidential information need not be made public, as their protection must be taken into account (Recital 107). The summary should be **generally comprehensive in its scope instead of technically detailed** to facilitate parties with legitimate interests (such as rights holders) to exercise and enforce their rights from EU law. For example, the most important data collections (e.g. comprehensive publicly accessible data sets or archive content that is not publicly accessible) can be listed. Overall, a '**narrative explanation** should be provided, which also gives copyright holders an insight into the possible use of protected works. The AI Office is to provide a '**simple and effective' template** for the summary (Recital 107).

Related Topics

AI models: Sect. 1.2.2.

Obligations of the provider of a high-risk AI model: Sect. 3.2. ◀

5.1.5 To What Extent Are Providers Obliged to Cooperate with Competent Authorities?

Article 53(3)

109 (Proportionality of compliance), 110 (Systemic risks), 114 (Obligations regarding systemic risks), 115 (Reporting of serious incidents)

Providers of GPAI models should cooperate with the national competent authorities and the European Commission in the **exercise of their competences and powers**, if and to the extent **necessary** for the supervision of AI systems and GPAI models under the AI Act. The nature and extent of the exercise of the powers of the

national authorities and the European Commission and thus also the necessary cooperation on the part of the provider are regularly characterised by the potential risk posed by the AI model and the **principle of proportionality.**

This general obligation to cooperate is supplemented by additional reporting obligations for providers of GPAI models with systematic risks (see Sect. 5.2.2).

5.2 What Additional Requirements Are There for GPAI Models with Systemic Risks?

Articles 51, 52 and 55

Recitals 110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 114 (Obligations regarding systemic risks)

The risk-based approach of the AI Act is not only applied to AI systems, but also to GPAI models. The AI Act provides for additional, stricter obligations for providers of GPAI models that pose a so-called systemic risk. The obligations regarding GPAI models with systemic risks apply in addition to the general obligations for GPAI models (see Sect. 5.1).

The criteria used to assess whether a GPAI model poses a systemic risk and the provider's obligations resulting from the categorisation are presented below.

Related Topics

Risk-based approach to AI systems: Sect. 1.1.

General obligations for providers of GPAI models: Sect. 5.1. ◀

5.2.1 When Does a GPAI Model Pose a Systemic Risk?

Article 3(65) and (67), 51, Annex XIII

Recitals 110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 114 (Obligations regarding systemic risks)

A GPAI model may present a so-called systemic risk. A risk is systemic (Article 3(65)) if

- it is specific to the **high-impact capabilities** of GPAI models,
- having a **significant impact** on the EU market
- due to their **reach**, or due to actual or reasonably foreseeable **negative effects on** public health, safety, public security, **fundamental rights** or the society as a whole
- that can be **propagated at scale** across the value chain.

This notion is difficult to handle as it is quite vague and requires much interpretation. Therefore, the criteria set up for classifying GPAI models with systemic risks are likely to be more important in practice. GPAI models shall be classified as posing a systemic risk, if it meets any of the following conditions (Article 51(1)):

- It has **high impact capabilities** that are assessed using appropriate technical tools and methodologies, including indicators and benchmarks.
- It is **designated by the European Commission**, taking into account certain criteria (Annex XIII, see below). The decision on designating a GPAI model as posing systemic risks can be taken on the Commission's **own initiative** or on the basis of a qualified warning from the Scientific Panel (see Sect. 6.2.3) that the GPAI model has capabilities or an impact equivalent to those of a high impact model.

In both cases, the notion of 'high-impact capabilities' should cover capabilities that match or exceed those of the **most advanced GPAI models** (Article 3(64)). The most advanced GPAI models are also known as 'frontier models', although this notion is not used within the AI Act.

A GPAI model is presumed to have high-impact capabilities if the cumulative amount of computation used for its training exceeds 10^{25} floating point operations (Article 51(2)). Floating point operations include all mathematical operations or assignments involving floating-point numbers, which are subset of the real numbers typically represented on computers by an integer of fixed precision scaled by an integer exponent of a fixed base (Article 3(67)). The cumulative number of floating-point operations (shortened as 'FLOPs' in a previous draft of the AI Act) should not be confused with the unit of measurement FLOPS (floating point operations per second), which is used to measure the speed of computing. In addition to the amount of computation used for training, the European Commission can define **other indicators and benchmarks** which, if exceeded, trigger the legal presumption of high-impact capabilities (Article 51(3)).

If a GPAI model is considered to have high-impact capabilities according to the criteria set out above, it will be categorised as posing a systemic risk in a formal procedure (see Sect. 5.2.3). During the procedure, the provider of the GPAI model can rebut the presumption by **demonstrating** that **there is no systemic risk** despite the high impact capabilities (see below Sect. 5.2.3).

Alternatively, the **European Commission** can categorise a **GPAI model** as posing a **systemic risk.** The following indicators must be taken into account when deciding on whether a GPAI model should be categorised as GPAI model with a systemic risk (Annex XIII):

- the number of parameters of the model (for relevant parameters, see first the requirements for systematic risk in this Section and second the requirements for classification as a GPAI model, Sect. 1.2.6),
- the quality or size of the data set, for example measured through tokens,

- the amount of computation used to train the model, measured in floating-point operations or indicated by a combination of other variables, such as estimated training cost, estimated time required for training or estimated energy consumption for training,
- the input and output modalities of the model, e.g. text-to-text (as in LLMs), text-to-image (such as AI models that generate images), multimodality, and state-of-the-art thresholds for determining high-impact capabilities for each modality, and the specific type of inputs and outputs (e.g. biological sequences, such as DNA, as input data in a medical GPAI model),
- the benchmarks and evaluations of the model's capabilities, including considering the number of tasks without additional training, the adaptability to learn new, different tasks, the degree of autonomy and scalability, and the tools it has access to, and
- the number of registered (commercial and other) end-users in the EU.

Even if a GPAI model has been trained with less than 10^{25} floating-point operations, it can therefore be classified by the European Commission as a GPAI model with systemic risk, provided that the corresponding classification criteria are met and a comparable risk justifies the classification.

The aforementioned classification criteria (Annex XIII) can be adapted by the European Commission by means of a delegated act (Article 51(3)).

Related Topics

GPAI model: Sect. 1.2.6.

Scientific panel: Sect. 6.2.3. ◀

5.2.2 What Additional Obligations Apply to the Provider of a GPAI Model with a Systemic Risk?

Article 53(1)(a) in conjunction with Section 2 of Annex XI; Article 55

110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 114 (Obligations regarding systemic risks)

In addition to the general rules that apply to all providers of GPAI models (see Sect. 5.1), providers whose GPAI models pose **systemic risks** (see Sect. 5.2.1) must **also** comply with the following obligations (Article 55(1)):

- They must evaluate the **GPAI model** in accordance with standardised protocols and tools that reflecting the state of the art, including conducting and documenting **adversarial testing** (e.g. through red teaming) for the GPAI model in order to identify and mitigate systemic risks,

- They must **assess and mitigate** potential **systemic risks** at EU level, including their sources, that may arise from the development, the placing on the market, or the use of the GPAI model with systemic risk;
- They must keep track of and document **serious incidents** (see Sect. 3.3.10). Additionally, providers must immediately inform the AI Office and, where appropriate, the national competent authorities about serious incidents and possible corrective actions to address these incidents.
- They must ensure an adequate level of **cybersecurity** protection for the GPAI model with systemic risk and its physical infrastructure.

In addition to the general requirements (see Sect. 5.1.1), the **technical documentation** of a GPAI model with systemic risk must also contain the following **additional elements** (Article 53(1)(a), Section 2 of Annex XI):

- a detailed **description of the evaluation strategies** (see above, first bullet point), including evaluation results, based on available public evaluation protocols and tools or otherwise of other evaluation methodologies. The evaluation strategies include evaluation criteria and metrics as well as the methodology used to identify limitations in the performance of the system;
- where applicable, a detailed description of the measures taken to conduct internal or external **adversarial testing** (for example, red teaming), **model adaptations**, including alignment and fine tuning, and
- where applicable, a detailed description of the **system architecture** explaining how software components build or feed into each other and integrate into the overall processing.
- Providers of GPAI models with systemic risk may, where appropriate, rely on **harmonised standards** and on **codes of practice** to demonstrate compliance with the additional obligations for providers of AI models with systemic Risk (Article 55(2); see Sect. 5.4).

Related Topics

Serious incidents: Sect. 3.3.10.

General obligations for providers of GPAI models: Sect. 5.1.

Harmonised standards and codes of practice for GPAI models: Sect. 5.4. ◀

▶ **Further Information** *AI Verify Foundation*, Model AI Governance Framework for Generative AI – Draft (2024); *Bundesamt für Sicherheit in der Informationstechnik*, Generative AI models (2024); *International Organization for Standardization*, Artificial Intelligence Management Standards (2024); *OECD.AI Policy Observatory*; Catalogue of Tools &

Metrics for Trustworthy AI (2024); *National Institute of Standards and Technology*, Generative Artificial Intelligence Profile – Draft (2024); *UK AI Safety Institute*, Inspect – An open-source framework for large language model evaluations (2024).

5.2.3 What Are the Requirements for the Categorisation Procedure for GPAI Models with Systemic Risk?

Article 52, Annex XIII

110 (Systemic risks), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission)

Providers of GPAI models **must notify the European Commission** if their model meets the conditions of high impact capabilities and therefore qualifies as a GPAI model with systemic risk (Article 52(1); see Sect. 5.2.1). This notification must be made without delay and in any event within two weeks after the conditions are met or after it is known that the conditions will be met. The provider must also provide the information that demonstrates the high-impact capability of the GPAI model.

If the **European Commission** is not notified accordingly, it can without further ado decide to **designate** the GPAI system as posing a **systemic risk** (see Sect. 5.2.1).

When providers notify the European Commission of high-impact capabilities, they may at the same time present sufficiently substantiated arguments to demonstrate that the GPAI model exceptionally does not present a systemic risk, despite its high-impact capabilities (Article 52(2)). The European Commission then has to decide on the provider's arguments. If the European Commission does not agree with the provider's arguments for their GPAI model not to be categorised as posing systemic risk, it rejects the **arguments**. The GPAI model is then deemed to pose systemic risk (Article 52(3)).

The classification as a GPAI model with systemic risk need not be based on a notification by the provider. Alternatively, the **European Commission** can designate a GPAI model to pose systemic risk on its own initiative or on the basis of a qualified warning issued by the Scientific Panel (see Sect. 6.2.3; Article 52(4)). The designation must be based on an assessment of the model in accordance with the **criteria set out** in **Annex XIII**, which may be further developed by the European Commission over time and adapted to the state of the art (see Sect. 5.2.1). If a GPAI model is designated to pose systemic risk, the provider may request the European Commission to **re-assess** the designated model based on the criteria set out in Annex XIII (see Sect. 5.2.1). The request for reassessment must contain 'objective, detailed and new reasons that have arisen since the designation decision' (Article 52(5)). Although it is not stated expressly in the AI Act, the same must also apply to reasons that the European Commission did not take into account in its initial assessment before it designated the GPAI model as presenting systemic risk. The application for reassessment can be submitted **at the earliest six months** after the European Commission's initial decision. However, this deadline cannot apply if the European

Commission has overlooked significant reasons in its assessment. In the event of an unsuccessful reassessment by the European Commission, the provider may submit a further request for reassessment at the earliest after a further six months.

If the European Commission changes the assessment criteria, it must automatically check whether the previous classifications are still justified and, **if necessary, downgrade** them if they do no longer pose a systemic risk due to the updated assessment criteria.

The European Commission also publishes and keeps up to date a **list of GPAI models that have been identified as posing a systemic risk** (Article 52(6)).

Related Topics

Criteria for the assessment of systemic risk: Sect. 5.2.1.

Scientific panel: Sect. 6.2.3. ◄

5.3 What Special Rules Apply to Providers of GPAI Models with a Free and Open-Source Licence?

Articles 53(2), 54(6)

102 (Free and open-source GPAI models), 103 (Monetisation), 104 (Exemptions from transparency obligations)

Free and open-source **GPAI models** are typically transparent by default. Their **source code** is **accessible**, their documentation is regularly extensive and they usually involve a broad developer community. As they can be freely redistributed, modified and further developed, they make a particular contribution to **research and innovation in the** field of artificial intelligence and to a diverse AI ecosystem (Recital 102).

For this reason, providers of GPAI models that are available under a free and open-source licence are **exempt from** the obligation to provide a **technical documentation** for the AI Office and national competent authorities (see Sect. 5.1.1) and from the obligation to provide **information to downstream providers** (see Sect. 5.1.2; Article 53(2)). Providers of GPAI models that are made available under a free and open-source licence are also exempt from the obligation to appoint an **authorised representative** that generally applies to non-European providers (Article 54(6)). For these exemptions, it is irrelevant how the AI model is supplied.

However, the **providers are only exempt from the requirements regarding technical documentation and information of downstream providers** if

- the free and open-source licence allows for the **access**, **use**, **modification** and **distribution** of the GPAI model,
- the **model parameters**, including weights, the information on the **model architecture,** and the information on **model usage** are made publicly available; and
- the GPAI model does **not present systemic risks**.

A licence is only considered free if it is provided free of charge. However, any other form of monetisation, which is common in the open-source sector and necessary for the further development of the offerings and support of the open-source community, does not jeopardise the exemption. Contrary to the legislative intention, which is only reflected in the legally non-binding Recitals (Recital 103), there is much to suggest that technical support or other services in connection with the GPAI model can be offered for a fee. Ultimately, the decisive factor should be that the model (including its parameters) has been made available in a free and open-source manner so that downstream providers can test and use it without needing further documentation.

For GPAI models that pose **systemic risk**, the corresponding documentation requirements (see Sects. 5.1.1 and 5.2.2) must be complied with, even if they are provided under a free and open-source licence.

Even if a GPAI model is provided under a free and open-source license, it is not always obvious which **data sets** were used **for training** and fine-tuning. Hence, providers of free and open-source GPAI models must still create a **summary on training data used** for these models (see Sect. 5.1.4). Moreover, providers of free and open-source GPAI models need to set up a policy for compliance with **copyright law**, in particular with regard to the reservation of the right to text and data mining (see Sect. 5.1.3).

Related Topics

General obligations for providers of GPAI models: Sect. 5.1.

Criteria for the assessment of systematic risk: Sect. 5.2.1. ◀

5.4 How Can Codes of Practice and Harmonised Standards Facilitate Compliance for GPAI Models?

Articles 53(4), 55(2) and 56

Recitals 116 (Codes of practice), 117 (Presumption of conformity)

Codes of practice that concretise the requirements of the AI Act for providers of GPAI models will be **highly relevant** in practice to comply with the provisions of the AI Act. It is not mandatory to implement codes of practice, yet it will facilitate compliance. Providers of GPAI models can demonstrate that they fulfil their obligations as providers more easily if they apply the approved codes of practice. This is particularly important for providers of GPAI models with systemic risk (see Sect. 5.2.3).

Providers can rely on approved codes of practice to demonstrate the conformity of their GPAI models until **harmonised standards** are **published.** Harmonized standard function the same as codes of practice and differ only in how they are drawn up. Whilst codes of practice are drawn up by stakeholders, especially by providers of GPAI models themselves, harmonised standards are developed by the

European standardisation organisations (see Sect. 7.6.3). Apart from this difference, they are like codes of practice. Harmonised standards also specify the requirements for GPAI models and provide a presumption of conformity if they are complied with.

Additionally, compliance with the codes of practice or with harmonised standards facilitates the **conformity assessment by downstream providers** of high-risk AI systems that integrate GPAI models into their AI systems. Providers of GPAI models that do not apply codes of practice or harmonised standards may also demonstrate compliance with the requirements for GPAI models through **appropriate alternative procedures** to be assessed by the European Commission (Articles 53(4), 55(2)).

The AI Office encourages and facilitates the development of codes of practice, also taking into account **international approaches**, in order to contribute to the proper application of the AI Act (Article 56(1)). The codes of practice must be **available by 2 May 2025**. If codes of practice cannot be finalised by this date, the Commission may instead issue detailed specifications by means of an implementing act (Article 56(9)).

The AI Office and the AI Board should ensure that the **codes of practice** at least cover the general **obligations of providers of GPAI models** (Article 53, see Sect. 5.1) and the specific obligations regarding GPAI models with systemic risk (Article 55, see Sect. 5.2.2). The following aspects should also be taken into account (Article 56(2)):

- the means to ensure that the **information** to be provided by the model provider is kept up to date in light of market and technological developments;
- the adequate level of detail to summarise the **content** used for the **training**;
- the identification of the type and nature of **systemic risks** and, where appropriate, their causes, and
- the measures, procedures and modalities for the assessment and **management of the systemic risks**, including documentation thereof. They must be proportionate to the risks, take into consideration their severity and probability and take into account the specific challenges of tackling those risks in light of the possible ways in which the risks may emerge and materialise along the AI value chain.

The AI Office may invite **all providers of GPAI models** and relevant national competent authorities to participate in the development of codes of conduct. It may involve civil society organisations, industry, academia and other relevant **stakeholders** (such as downstream providers (see Sect. 5.5.1) and independent experts) to support the development of the guidelines (Article 56(4)). Among other things, this is intended to ensure that the needs and interests of all interested parties, including affected persons, are taken into due account.

In particular, the codes of practice should clearly set out specific **objectives**, **commitments** and **measures**, which—where possible—are backed up with key performance indicators ('KPIs'). This is not only intended to promote feasibility and target monitoring for providers. It also serves to **inform the AI Office**, to which the **providers** should regularly **report** on the implementation of the commitments

and measures taken, also by means of performance indicators (Article 56(5)). The **AI Office** and the **AI Board** regularly **monitor and evaluate** the realisation of the objectives of the code of practice by the parties involved and their contribution to the proper application of the AI Act.

Related Topics

Obligations for providers of GPAI models: Sect. 5.1.

Obligations for providers of GPAI models with systematic risk: Sect. 5.2.2.

New EU bodies: Sect. 6.2.3.

Harmonised standards: Sect. 7.6.3. ◄

5.5 What Requirements Apply to Other Operators with Regard to GPAI Models?

With regard to the requirements for GPAI models, the AI Act primarily places obligations on providers. However, there are also some requirements that affect other operators, which are described in the following sub-sections.

5.5.1 What Are the Obligations of the Authorised Representative of the Provider of a GPAI Model?

Article 54

Providers not established in the EU must appoint an authorised representative established in the EU before placing a GPAI model on the market (Article 54(1); see already Sect. 1.3.10). This authorised representative must perform the **provider's tasks,** which are defined in a written mandate. The mandate must enable the authorised representative to act as a **contact person for the AI Office and the competent authorities** in addition to, or instead of, the provider in all matters related to ensuring compliance with the AI Act (Article 54(4)). Providers of **free and open-source GPAI models** that do not present systemic risk (Article 54(6), see Sect. 5.3) are **exempt** from the obligation to appoint an authorised representative.

The mandate must at least empower the authorised representative to (Article 54(3)):

- verify that the provider has fulfilled all his obligations under the AI Act (see Sect. 5.1),
- keep a copy of the technical documentation (see Sect. 5.1.1) at the disposal of the AI Office and the national competent authorities as well as the contact details of the provider of the GPAI model,

- provide all information and documentation required to demonstrate compliance with the obligations for GPAI models to the AI Office, upon a reasoned request, and
- cooperate with the AI Office and the competent authorities, upon a reasoned request, in any action they take in relation to the GPAI model, or an AI system based on it.

The authorised representative must **terminate** the **contractual relationship** if it has reason to believe that the provider acts contrary to its obligations under the AI Act. In this case, the authorised representative shall immediately **inform** the AI Office of the termination and the reasons for it (Article 54(5)).

Related Topics

Authorised representative: Sect. 1.3.6.

Obligations for companies outside the EU: Sect. 1.3.10.

Authorised representative of the provider of a high-risk AI system: Sect. 3.5.4.

Obligations of the provider of a GPAI model: Sect. 5.1.

Additional provider obligations regarding systemic risks: Sect. 5.2.2. ◀

5.5.2 What Are the Rights and Obligations of a Downstream Provider That Integrates a GPAI Model into Its AI System?

Article 3(68)

Recital 100 (GPAI systems)

A provider of an AI system in which one or more GPAI models are integrated is a downstream provider (Article 3(68)). It literally follows the provider of the GPAI model 'downstream' in the AI value chain.

The **obligations** of a downstream provider of an AI system, who may also be the provider of the AI model, are based on how the AI system is classified according to the risk-based approach of the AI Act. The AI system must not be prohibited (Article 5, see Chap. 2). If the AI system is high risk (Article 6, see Sect. 3.1), the downstream provider must fulfil all the obligations of a provider of high-risk AI systems (Article 16, see Sect. 3.3). If the AI system is not classified as high risk, its provider may still have to only fulfil the transparency obligations under the AI Act (see Chap. 4).

Providers of GPAI models should provide downstream providers with **sufficient information and documentation** regarding the GPAI model, especially when it comes to models with systemic risk (see Sects. 5.1.2 and 5.2.2). This is to ensure

that downstream providers can fulfil their obligations under the AI Act if their AI system is based on a GPAI model (Recital 101).

Downstream providers also have the **right to lodge a reasoned complaint** with the AI Office if they believe that the GPAI model they have integrated in their AI system violates the AI Act (Article 89(2), see Sect. 1.7.3).

Related Topics

Right to lodge a complaint with the AI Office: Sect. 1.7.3.

Prohibited AI practices: Chap. 2.

Requirements for high-risk AI systems: Chap. 3.

Transparency requirements for AI systems: Chap. 4.

Obligations of the provider of a GPAI model: Sect. 5.1.

Additional obligations of the provider regarding systematic risks: Sect. 5.2.2. ◀

5.5.3 What Are the Obligations of Deployers, Distributors and Importers of GPAI Models?

Articles 2(1)(b) and (d) and 3(4), (6) and (7)

The AI Act **does not** impose **any obligations on** deployers, distributors and importers of GPAI models. The AI Act **does not apply** to them, as the AI Act only applies to deployers, importers and distributors of AI systems (Article 2(1)(b) and (d)). The definitions of deployers, importers and distributors also refer only to AI systems and not to GPAI models (Article 3(4), (6) and (7)). There are also **no protection gaps** in this respect, as providers or, where applicable, their authorised representatives (see Sects. 5.1 and 5.5.1) can always be held responsible for complying with the requirements that the AI Act places on GPAI models. The 'operation' of an AI model always takes place by means of an AI system—for which special obligations may be specified regarding deployers, distributors or importers (especially in the case of high-risk AI systems, see Sects. 3.4 and 3.5).

Related Topics

Deployers: Sect. 1.3.2.

Importers: Sect. 1.3.3.

Distributors: Sect. 1.3.4.

Obligations for deployers of high-risk AI systems: Sect. 3.4.

Obligations for other operators of high-risk AI systems: Sect. 3.5.

Transparency obligations for deployers of certain AI systems: Sects. 4.3 to 4.5.

Obligations for providers of GPAI models: Sect. 5.1.

Obligations of the authorised representative for GPAI models: Sect. 5.5.1. ◀



How Is the AI Act Implemented and Enforced?

6

The AI Act contains a comprehensive enforcement regime, which essentially consists of two parts. Firstly, high-risk AI systems are tested in a conformity assessment procedure before being placed on the market or put into service (see Sect. 6.1). Secondly, all AI systems and GPAI models are monitored by surveillance authorities, particularly after they have been made available on the market (see Sect. 6.2). To further facilitate and promote compliance with the AI Act, the AI Act also contains additional requirements to test AI systems under real-world conditions before they are put into service or placed on the market (see Sect. 6.3).

This structure corresponds to the concept of the New Legal Framework (see Sect. 1.1). Initially, compliance with the requirements of the AI Act should be ensured as independently as possible (in the conformity assessment procedure by the provider itself or by a non-governmental notified body). The state market surveillance authorities only intervene if significant risks from an AI system are subsequently identified.

In the following sub-sections, the various aspects of how compliance with the requirements of the AI Act is to be ensured are described in detail.

Related Topics

New Legislative Framework: Sect. 1.1. ◄

6.1 What Requirements Apply to the Conformity Assessment Procedure Before a High-Risk AI System Can Be Made Available on the Market?

Article 43(1)–(3), Annex VI and VII

Recitals 123 (Conformity assessment), 124 (Avoidance of duplication), 125 (Notified bodies)

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_6

Providers of high-risk AI systems must prove that the **high-risk AI system fulfils the requirements of the AI Act** (see Sect. 3.2). This is demonstrated through a conformity assessment procedure. For this purpose, the AI Act provides for **three different procedures**, which are based on the respective purpose of the AI system (Article 43; see the following Sect. 6.1.1).

After successfully completing the conformity assessment procedure, providers of the high-risk AI systems issue a **EU declaration of conformity** (see Sect. 3.3.3), which must be sent to the national competent authorities upon request. The system must bear a **CE marking** (see Sect. 3.3.4) and, in some cases, be registered in an **EU database** (see Sect. 3.3.5).

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.
EU declaration of conformity: Sect. 3.3.3.
CE marking: Sect. 3.3.4.
Registration in the EU database: Sect. 3.3.5. ◄

6.1.1 Which Conformity Assessment Procedure Applies to Which High-Risk AI System?

Article 43(1), (2) and (6), Annex III
Recitals 123 (Conformity assessment), 125 (Notified bodies)

There are three different conformity assessment procedures for high-risk AI systems, each of which applies to one of the following three case groups:

- Case 1: Ppoducts or safety components of products within the New Legislative Framework (as listed in Section A of Annex I),
- Case 2: stand-alone high-risk AI systems, except for biometric high-risk AI systems,
- Case 3: stand-alone high-risk biometric AI systems.

The procedure to be applied in each of these three cases is described below.

Case 1: Products with harmonised safety requirements or safety components of such products within the New Legislative Framework (as listed in Section A of Annex I, see Sect. 3.1.1.1) must comply with the conformity assessment procedures to which they are subject under the applicable harmonisation legislation (Article 43(3)).

As part of the conformity assessment procedure that applies under other harmonisation legislation, the manufacturer or a notified body must also verify compliance with the requirements for high-risk AI systems. For instance, a smart robot will likely already be subject to a third-party conformity assessment under the Machinery Directive. The third party must then include in its assessment under the Machinery Directive whether the smart robot also complies with the AI Act.

Case 2: Stand-alone high-risk AI systems in critical use cases (with the exception of biometrics; as listed in No. 2–8 of Annex III) are checked for compliance with the requirements for high-risk AI systems as part of the internal (self-)control of the provider (see Sect. 3.2) **without the involvement of third party conformity assessment bodies** (Article 43(2)).

The critical areas where compliance of stand-alone high-risk AI systems can be demonstrated through an internal control are:

- critical infrastructure (see Sect. 3.1.2.2)
- education and vocational training (see Sect. 3.1.2.3),
- employment, workers' management and access to self-employment (see Sect. 3.1.2.4),
- access to and enjoyment of essential private and public services and benefits (see Sect. 3.1.2.5),
- law enforcement (see Sect. 3.1.2.6),
- migration, asylum and border control management (see Sect. 3.1.2.7), and
- administration of justice and democratic processes (see Sect. 3.1.2.8).

Case 3: Stand-alone high-risk biometric AI systems (No. 1 of Annex III; see Sect. 3.1.2.1) can only be checked for conformity with the AI Act as part of an internal control if corresponding **harmonised standards** or common specifications (see Sect. 7.6.3) are available and fully applied (Article 43(1)). The provider will then have a **right to choose** whether to involve a third party in the conformity assessment**.** It can either apply harmonised standards or common specifications, as applicable (see Sect. 7.6.3), and carry out an internal conformity assessment on this basis (see Sect. 6.1.2). Or it can have a conformity assessment carried out by a third party, i.e. by a notified body (see Sect. 6.1.3). If there are no harmonised standards and no common specifications or if the provider does not (fully) apply the existing standards or specifications, the conformity assessment procedure with the involvement of a notified body is mandatory.

In future, these stricter requirements that have the provider choose between applying harmonised standards or involving a notified body may also apply to high-risk AI systems in other critical areas (see above). By means of a delegated act, the European Commission can amend the AI Act so that high-risk AI systems from other critical areas must also undergo a third-party conformity assessment if no harmonised standards or common specifications are applied (Article 43(6)).

Related Topics

Products within the New Legislative Framework that are/contain high-risk AI systems: Sect. 3.1.1.1.

Stand-alone high-risk AI systems in critical use cases: Sect. 3.1.2.

Requirements for high-risk AI systems: Sect. 3.2.

New Legislative Framework: Sect. 1.1. ◄

6.1.2 What Requirements Apply to an Internal Conformity Assessment?

Article 43, Annex VI

Recital 123 (Conformity assessment)

As part of a conformity assessment under internal control, the provider has to

- verify that the established **quality management system** fulfils the requirements of the AI Act (see Sect. 3.3.1),
- examine the information contained in the **technical documentation** (see Sect. 3.2.4) to assess whether the system complies with the essential requirements for high-risk AI systems (see Sect. 3.2), and
- verify that the **design and development** process of the AI system and its **post-market monitoring** (see Sect. 3.3.7) are consistent with the technical documentation.

The European Commission may update the scope and content of the provider's inspection obligations in the future in the light of technical progress (Article 43(5)).

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.
Quality management system: Sect. 3.3.1.
Post-market monitoring system: Sect. 3.3.7. ◀

6.1.3 What Requirements Apply to a Third-Party Conformity Assessment?

Articles 28–39, 43; Annex VII

Recitals 123 (Conformity assessment), 124 (Avoidance of duplication), 125 (Notified bodies)

The second case to demonstrate conformity of a high-risk AI system is the conformity assessment procedure involving a notified body.

6.1.3.1 What Are Notified Bodies?

Article 28–39

Recitals 123 (Conformity assessment), 124 (Avoidance of duplication), 125 (Notified bodies), 126 (Requirements for notified bodies), 127 (Notified bodies in third countries)

Notified bodies are conformity assessment bodies and carry out conformity assessment activities (see Annex VII) including testing, certification and inspection, where the conformity procedure requires the involvement of notified **conformity assessment bodies.**

They are private entities that are assessed by government bodies (the so-called 'notifying authorities' of the EU member states), deemed competent to carry out conformity assessment procedures and 'notified' accordingly (Article 30; hence the notion 'notified body'). The AI Act sets out detailed provisions on how the notification procedure takes place (Articles 28–39). The mandatory **state inspection of conformity assessment bodies** (Article 30) ensures that notified bodies comply with the legal requirements, including with regard to organisational structure, resources, independence and professional competence.

Providers who choose or have to follow a conformity procedure involving third parties can choose any notified body at their own discretion. By derogation, the competent market surveillance authority (see Sect. 6.2.1) assumes the function of the notified body with respect to AI systems that are intended to be put into service by law enforcement, immigration or asylum authorities or by EU institutions, bodies, offices or agencies.

Conformity assessment bodies outside the EU can also be chosen under certain circumstances if an agreement has been concluded with the EU and they fulfil the relevant requirements placed on notified bodies (Article 39).

Related Topics

Competent market surveillance authorities: Sect. 6.2.1. ◀

6.1.3.2 How Is the Conformity Assessment Carried Out with the Involvement of a Notified Body?

Article 43, Annex VII

Recitals 125 (Notified bodies), 126 (Requirements for notified bodies), 127 (Notified bodies in third countries)

The notified body inspects the **quality management system** (see Sect. 3.3.1) and the **technical documentation** (see Sect. 3.2.4). Afterwards, the provider receives a notification of the reasoned assessment decision and, where applicable, an EU technical documentation assessment certificate (Annex VII, points 3.2 and 4.6) and, where applicable, an EU certificate of conformity (Article 44(1); see also Sect. 3.3.3). If the AI system does not fulfil the requirements of the AI Act for high-risk AI systems, the notified body refuses to issue an EU technical documentation assessment certificate and informs the provider of the reasons thereof (Annex VII, point 4.6).

In detail, the procedure should be as follows:

First, the **provider** (or, if applicable, its authorised representative; see Sects. 1.3.6 and 1.3.10) submits an **application** to a notified body for the assessment of the quality management system and for the assessment of the technical documentation (Annex VII, points 3.1 and 4.2). This application includes

- the **name and address** of the provider and, if applicable, of the authorised representative;
- a **list and the technical documentation for each AI system** covered by the same quality management system,
- **documentation on the quality management system** covering all aspects required by the AI Act,
- a description of the **procedures** in place to ensure that the quality management system remains adequate and effective;
- a written declaration that the same application has not been submitted to any other notified body.
- the **technical documentation** for the AI system for which the conformity assessment shall be carried out by the notified body.

Based on the information provided in the provider's application, the notified body then carries out an **assessment to determine** whether the requirements for high-risk AI systems (see Sect. 3.2) and the requirements for a quality management system (see Sect. 3.3.1) are met.

As part of the inspection of the technical documentation, the notified body

- shall be granted full **access to the training, validation and testing data sets used**, if appropriate and only to the extent necessary for the assessment (Annex VII, point 4.3),
- may **require** further **evidence or tests** to enable a proper assessment of the conformity of the AI system with the requirements for high-risk AI systems (Annex VII, point 4.4), and
- shall, upon reasoned request, be granted **access to the training and trained models** of the AI system, including its relevant parameters, if this is necessary to assess the conformity and all other reasonable means have been exhausted and have proven to be insufficient (Annex VII, point 4.5).

If the AI system does not fulfil the **requirements relating to the training data used**, the AI system must be re-trained before the provider can apply again for a new conformity assessment. The notified body must explain why the data set used does not fulfil the requirements of the AI Act (Annex VII, point 4.6, paragraph 5).

After completing the conformity assessment procedure, the provider must **continue to implement and maintain** the quality management system so that it continues to function adequately and efficiently (Annex VII, point 3.3). Any intended changes to the approved quality management system or the list of AI systems covered by the same quality management system must be communicated to and examined by the notified body in order to determine whether a reassessment is required (Annex VII, point 3.4, see Sect. 6.1.6). The approved quality management system shall **be monitored by the notified body** after completing the conformity assessment procedure to ensure that the provider continues to comply with the terms and conditions of the approved quality management system (Annex VII, point 5.1). For this purpose, the provider must grant the notified body access to its premises and

provide the necessary information (Annex VII, point 5.2). The notified body shall also carry out **periodic audits** of the provider to monitor the quality management system (Annex VII, point 5.3).

In future, the **requirements** applicable to the third-party conformity assessment procedure may **be updated** by the European Commission in the light of technical progress (Article 43(5)).

Related Topics

Authorised representative: Sect. 1.3.6
Obligation to appoint an authorised representative: Sect. 1.3.10.
Technical documentation: Sect. 3.2.4.
Requirements for high-risk AI systems: Sect. 3.2.
Quality management system: Sect. 3.3.1.
Conditions that require a new conformity assessment: Sect. 6.1.6. ◀

6.1.4 What Requirements Apply to the Conformity Assessment of AI Systems That Are (Safety Components of) Products Within the New Legislative Framework?

Article 43(3), Annex VII

Recitals 123 (Conformity assessment), 124 (Avoidance of duplication)

If AI systems are **products** or safety components of products covered by **harmonisation legislation** within the New Legislative Framework (Annex I Section A; see Sect. 3.1.1.1), the conformity assessment procedure under the AI Act does not apply. Instead, the manufacturer of the product shall apply the **conformity assessment procedure required by the applicable harmonisation legislation** (Article 43(3)). The **requirements of the AI Act** for high-risk AI systems (see Sect. 3.2) are **included** in the conformity assessment procedure under the applicable legal act.

Certain provisions of the AI Act on third-party conformity assessment (see Sect. 6.1.3.2), apply accordingly to the procedure to which the product is subject under the applicable harmonisation act, since these provisions concern special features of AI systems and attribute additional inspection rights and obligations to the notified body. In detail, the notified body may, as part of the examination of the technical documentation of the product:

- require unrestricted **access to the training, validation and test data sets used to** the extent necessary for the assessment (Annex VII, point 4.3);
- **require** further **evidence or tests** to enable a proper assessment of the conformity of the product with the requirements for high-risk AI systems (Annex VII, point 4.4), and

- require, upon reasoned request, that it receives **access to the training models and trained models of the** product, including its relevant parameters, as a final means of conformity assessment (Annex VII, point 4.5).

If the product does not fulfil the **requirements for the training data used,** the product must be re-trained before the manufacturer can apply for a new conformity assessment. In the notification of the assessment decision, the notified body must explain why the data used did not meet the requirements of the AI Act (Annex VII, Section 4.6, paragraph 5).

Conformity assessment bodies that have been notified in accordance with the relevant harmonisation legislation are **responsible** and authorised to carry out the assessment with respect to products that are or include AI systems.

If manufacturers are legally entitled to dispense with a conformity assessment by notified bodies, they may only make use of this if they have **harmonised standards** or Common specifications (see Sect. 7.6.3) that cover the requirements for high-risk AI systems (Article 43(3)).

Related Topics

Products within the New Legislative Framework that are/include high-risk AI systems: Sect. 3.1.1.1.

Requirements for high-risk AI systems: Sect. 3.2.

Third-party conformity assessment for AI systems that are not products: Sect. 6.1.3.2.

New Legislative Framework: Sect. 1.1.

Harmonised standards and common specifications: Sect. 7.6.3. ◀

6.1.5 What High-Risk AI Systems Need Not Undergo a Conformity Assessment?

Article 46

Recital 130 (Exemptions from the conformity procedure)

In narrowly defined exceptions, any market surveillance authority (see Sect. 6.2.1) may, upon duly justified request, authorise the placing on the market or putting into service of specific high-risk AI systems in the territory of the member state concerned for one of the following **exceptional reasons**:

- **public safety**,
- protection of **life and health of persons**,
- **environmental protection** or
- protection of **key industrial and infrastructural assets**.

The authorisation is **limited** to the duration of the ordinary conformity assessment procedure and expires upon completion of this procedure. The ordinary conformity assessment procedure should be completed without delay (Article 46(1)).

An exceptional authorisation must only be granted if the market surveillance authority concludes that the high-risk AI system complies with the requirements for high-risk AI systems (see Sect. 3.2; Article 46(3)). Market surveillance authorities must inform the European Commission and the other EU member states of all authorisations they have granted.

The authorisation must be **withdrawn** if the European Commission considers the authorisation to be unlawful (e.g. due to objections from another member state; Article 46(4) and (5)).

Law enforcement authorities or civil protection authorities may **deploy** a specific high-risk AI system **without** the authorisation of the market surveillance authority**,** provided that such authorisation is requested immediately during or after deployment (Article 46(2)). This exception only applies

- in duly justified situations of urgency for **exceptional reasons of public security**, or
- in cases of **specific, substantial and imminent threats to the life or physical safety** of natural persons.

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.
Competent market surveillance authority: Sect. 6.2.1. ◄

6.1.6 Which Changes to the AI System Require a Reassessment of Conformity?

Articles 25(2), 43(4)

Recital 128 (Substantial modification)

High-risk AI systems that have already been subject to a conformity assessment procedure only need to be reassessed if they are **substantially modified** (see Sect. 1.4.3). It is irrelevant, whether the unmodified AI system also continues to be placed on the market or continues to be used by the previous deployer. The reassessment only regards the modified version that is considered a new (high-risk) AI system.

It should be noted that the person who makes a significant change to a high-risk AI system is considered a **new provider** of the new high-risk AI system (see Sect. 1.3.7). Accordingly, a person who previously only used or traded a high-risk AI system may become a provider if they change the system's intended purpose. After any substantial modification, the new provider must carry out a new conformity assessment procedure without having been involved in the initial conformity assessment of the unmodified AI system. Therefore, the **initial provider** is obliged to

'**cooperate closely**' with the new provider in complying with the requirements of the AI Act (Article 25(2)). However, the principle of proportionality must be observed here. In addition, the previous provider should be able to demand appropriate remuneration for its additional services. This obligation to cooperate may not apply at all, e.g., if the initial provider has clearly stated that its AI system must not be converted into a high-risk AI system.

Related Topics

Substantial modification: Sect. 1.4.3.
Quasi provider: Sect. 1.3.7. ◄

6.2 How Is the AI Act Enforced After AI Systems and Models Have Been Placed on the Market or Put into Service?

Articles 64–71, Articles 74–84, Articles 88–94, Articles 99–101

The numerous provisions regarding the enforcement of the AI Act through various supervisory authorities take up a large part of the AI Act.

In the following sub-sections, the competences of the administrative authorities (Sects. 6.2.1 and 6.2.2), the new EU bodies for AI governance (Sect. 6.2.3), the tasks, procedures and powers of the surveillance authorities (Sects. 6.2.4–6.2.8) as well as the fines and other sanctions under the AI Act (Sect. 6.2.9) are displayed.

6.2.1 Who Is Competent for Enforcing the AI Act?

Articles 70, 74, 75 and 88

Recitals 108 (Monitoring copyright compliance), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 141 (Testing in real-world conditions), 153 (Designation of national authorities), 154 (Principles for national enforcement), 156 (Market surveillance system), 158 (Consistency with financial services legal acts), 159 (Market surveillance for high-risk biometric AI systems), 161 (Supervision over certain GPAI systems), 162 (Supervision over GPAI models)

The AI Act's public enforcement system corresponds to the New Legislative Framework. The AI Act is enforced in two stages:

- **before placing on the market or putting into service**: conformity assessment procedure for high-risk AI systems (see Sect. 6.1) and
- **after placing on the market or putting into service**: market surveillance in accordance with the Market Surveillance Regulation for all AI systems (see below).

At least one market surveillance authority shall be established or designated by each EU member state (Article 70(1)). The **national market surveillance authorities** are in principle **competent for the enforcement vis-a-vis all operators of all AI systems**. By way of derogation, other authorities are responsible for the following AI systems:

- For AI systems that are products or components of products under EU harmonisation legislation (as listed in Section A of Annex I; see Sect. 3.1.1.1), the market surveillance authorities that supervise these products in accordance with the applicable harmonisation legislation remain competent for surveillance of these products also if they are or include AI systems (Article 74(3)).
- For AI systems placed on the market, put into service, or used by financial institutions, the relevant national authority responsible for financial supervision of those institutions assumes the tasks of the market surveillance authority (Article 74(6)).
- For high-risk AI systems used in the areas of law enforcement (see Sect. 3.1.2.6), migration, asylum and border control (see Sect. 3.1.2.7), as well as justice and democracy (see Sect. 3.1.2.8), the national data protection officers are responsible for market surveillance (Article 74(8)). They are also responsible if biometrics are used in these areas (see Sect. 3.1.2.1)
- For EU institutions, bodies, offices and agencies (with the exception of the Court of Justice of the EU acting in its judicial capacity), the European Data Protection Supervisor assumes the tasks of the market surveillance authority (Article 70(9)).
- For AI systems based on a GPAI model and developed by the same provider as the GPAI model, the AI Office acts as market surveillance authority (Article 75(1)).

The **AI Office** is responsible for enforcing the AI Act with regard to providers of GPAI **models** (Article 88(1)). However, the supervision of GPAI models is not 'market surveillance' within the meaning of the AI Act.

Related Topics

AI Office: Sect. 6.2.3.
Procedures of market surveillance authorities: Sect. 6.2.4.
Investigation rights of market surveillance authorities: Sect. 6.2.4.3.
Other measures taken by market surveillance authorities: Sect. 6.2.9.3. ◀

6.2.2 Who Is Competent for Cross-Border Matters?

Articles 74(11) and 81

Recitals 157 (Risks for fundamental rights and safeguard procedure), 160 (Joint activities)

There is no uniform competence for AI systems that are provided in several member states. Each national market surveillance authority is responsible in the

respective member state. If high-risk AI systems pose serious risks in two or more member states, market surveillance authorities and the European Commission (through the AI Office) may carry out joint actions (Article 74(11)). If a market surveillance authority finds that a deficiency in an AI system also affects other member states, it must inform the competent authorities in these other member states (Article 79(3)).

The so-called **safeguard procedure** applies if the market surveillance authority of one member state objects to a measure taken by the market surveillance authority of another member state or if the European Commission finds the measure taken by a market surveillance authority to be contrary to EU law (Article 81). The reasons of this assessment must be communicated to the European Commission, which then examines the measure taken. If the Commission considers the measure to be contrary to EU law after the examination, the measure must be withdrawn by the competent market surveillance authority. However, if the measure is justified, all member states are obliged to take appropriate measures to reduce the corresponding risk in their area of competence.

Related Topics

Market surveillance procedures: Sect. 6.2.4. ◄

6.2.3 Which New Governance Bodies Will Be Created at EU Level?

Articles 3(47) and 64 to 68

Recitals 108 (Monitoring copyright compliance), 111 (Classification of systemic risks), 112 (Procedure for determining systemic risks), 113 (Designation by the European Commission), 116 (Codes of practice), 117 (Presumption of conformity), 121 (Standardisation requests), 148 (Governance framework and AI Office), 149 (AI Board), 150 (Advisory forum), 151 (Scientific panel), 152 (EU support structures), 161 (Supervision over certain GPAI systems), 162 (Supervision over GPAI models), 163 (Supervisory function of the scientific panel), 164 (Supervisory powers of the AI Office), 173 (Amendments to the conditions for categorising high-risk AI systems)

The **European AI Office** is part of the European Commission and is intended to contribute to the implementation, monitoring and supervision of AI systems (Article 64). It was established by a Commission decision in January 2024. The AI Office is the supervisory authority for GPAI (see Sect. 6.2.1) and is tasked with developing and promoting codes of conduct, codes of practice and standardised templates, as well as promoting coordination and the exchange of information within the EU. To this end, it has numerous individual competences. It also provides the secretariat for the AI Board.

The **European Board on Artificial Intelligence** ('AI Board') is composed of one representative from each member state and advises and supports the European

Commission and the member states in order to facilitate the harmonised and effective application and enforcement of the AI Act (Articles 65 and 66). It serves as a platform for coordination and exchange between national competent authorities, including on best practices. In addition, the AI Board advises the AI Office on its activities and issues corresponding opinions.

The **advisory forum** advises the AI Board and the AI Office (Article 67). It is made up of various stakeholders, inter alia from industry, civil society and academia.

The **scientific panel** of independent experts is composed of scientifically and technically qualified experts and is intended to support the AI Office in its monitoring activities (Article 68). It plays a central role in the monitoring of GPAIs by contributing to their assessment and warning of systemic risks (Article 90). The scientific panel also acts as a pool of experts for the member states, which can call in experts from the scientific panel (possibly for a fee).

Related Topics

Market surveillance by the AI Office: Sect. 6.2.1.
Systemic risks (for GPAI): Sect. 5.2.
AI Office: Commission Decision of 24 January 2024 establishing the European AI Office, C/2024/1459. ◀

6.2.4 What Tasks Do the Market Surveillance Authorities Have?

Article 74(1) AI Act in conjunction with Article 14(4)(f) Market Surveillance Regulation, Articles 79–83 AI Act

Recitals 9 (Consistency with the New Legislative Framework), 156 (Market surveillance system), 164 (supervisory powers of the AI Office)

Market surveillance authorities monitor compliance with the AI Act. Their market surveillance activities can be either active or reactive. In active market surveillance, the market surveillance authorities act without a concrete suspicion of infringement; in reactive market surveillance, the market surveillance authorities act on the basis of a concrete suspicion, possibly based on an external request or complaint. A number of procedures are provided for market surveillance activities which are described below. The procedures do not apply to high-risk AI systems that are products or safety components of products covered by other EU harmonisation legislation (see Sect. 3.1.1). Instead, the relevant sector-specific supervisory procedures that are provided for in the applicable EU harmonisation legislation are to be applied (Article 74(4)).

Related Topics

Right to lodge a complaint: Sect. 1.7.1.
Products that are or contain AI systems: Sect. 3.1.1.
New Legislative Framework: Sect. 1.1. ◀

▶ **Further Information** *European Commission*, Good Practices for Market Surveillance (2017), The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 7, pp. 104–126.

6.2.4.1 What Risks Trigger a Market Surveillance Authority to Check the Conformity of an AI System?

Articles 79, 81 and 82

Recital 157 (Risks for fundamental rights and safeguard procedure)

Where a market surveillance authority has sufficient reason to consider an AI system to present a **risk to the health or safety, or to fundamental rights, of persons**, it shall evaluate that AI system in respect of its compliance with the AI Act. Authorities designated to supervise or enforce EU law for the protection of fundamental rights, such as data protection authorities and equality bodies, must be involved in market surveillance procedures regarding risks to fundamental rights (Article 79(2); see Sect. 6.2.6). All operators, including providers (see Sect. 3.3.9), deployers (see Sect. 3.4.3), importers (see Sect. 3.5.2.5) and distributors (see Sect. 3.5.3.4), must inform the market surveillance authority if they consider an AI system to pose a risk to the health or safety, or to fundamental rights, of persons.

The market surveillance authority then requests the operators to take the necessary **corrective measures** to bring the AI system (back) into conformity with the AI Act (Article 79(4)). The possible measures go as far as to obliging operators to withdraw or recall the AI system from the market as a last resort. Even if a high-risk AI system fulfils all requirements of the AI Act, the market surveillance authority can still require the operator to take corrective action if the high-risk AI system poses a risk to health and safety, to fundamental rights, or the public interest (Article 82).

If the operators fail to take appropriate corrective actions, the market surveillance authority is empowered to take appropriate **provisional measures** (Article 79(5)). If a market surveillance authority in another member state or the European Commission itself doubts the legality of such provisional measure, the Commission may re-examine this provisional measure under the **safeguard procedure** (Article 81).

Related Topics

Operators' obligations in high-risk AI systems: Sects. 3.3–3.5.
Safeguard procedure: Sect. 6.2.2.
Authorities protecting fundamental rights: Sect. 6.2.6. ◀

6.2.4.2 When Does Formal Non-compliance Trigger Market Surveillance Actions?

Article 83

The market surveillance authorities also take action if an AI system does not pose any material risks but does not comply with the AI Act formally. If a market surveillance authority makes any of the following findings, it shall require the provider to bring the AI system back into compliance with the AI Act:

- The CE marking has not been affixed (correctly).
- The EU declaration of conformity has not been drawn up (correctly).
- The registration in the EU database (see Sect. 6.2.7) has not been carried out.
- No authorised representative has been appointed.
- The technical documentation is not available.

If the providers fail to comply with the request to bring its AI system back into conformity, the market surveillance authority may restrict or prohibit the high-risk AI system being made available on the market. In addition, the operators who have violated their corresponding obligations may be fined (Article 99(4)).

Related Topics

Fines: Sect. 6.2.9.1.
CE marking: Sects. 3.3.4 (for providers) and 3.5.2.2 (for importers).
EU declaration of conformity: Sect. 3.3.3 (for providers).
Registration in the EU database: Sects. 3.3.5 (for providers) and 3.4.6 (for deployers).
Obligation to appoint an authorised representative: Sect. 1.3.10 (for providers outside the EU).
Technical documentation: Sects. 3.2.4 (for providers) and 3.5.2.4 (for importers). ◀

6.2.4.3 What Measures Does the Market Surveillance Authority Take if It Considers an AI System High Risk Although It Was Classified by the Provider as Not High Risk?

Article 80

Recital 53 (Exemptions from high-risk categories)

In way of derogation, providers of AI systems can deviate from the categories of stand-alone high-risk AI systems (as listed in Annex III) and demonstrate that their AI system is not high risk (see Sect. 3.1.2.10). If the market surveillance authority has reason to doubt this demonstration, it can carry out a review. If it finds that the AI system is indeed high risk, despite the provider's own assessment, it will request the provider to take appropriate corrective actions. In addition, a fine may be imposed if the provider has intentionally misclassified its AI system or if it fails to bring the AI system back into conformity within the prescribed period (Article 99(4)(a)).

Related Topics

High-risk AI systems: Chap. 3.
Fines: Sect. 6.2.9.1. ◀

6.2.5 What Investigation Rights Do the Market Surveillance Authorities and the AI Office Have?

Articles 21, 74 and 75 in conjunction with Article 14(2) and (4) Market Surveillance Regulation, Article 89

Recitals 156 (Market surveillance system), 159 (Market surveillance for high-risk biometric AI systems), 164 (Supervisory powers of the AI Office)

The market surveillance authorities are mainly empowered with investigation rights by means of a reference to the **Market Surveillance Regulation**. The Market Surveillance Regulation applies to all AI systems covered by the AI Act. This means that the market surveillance authorities competent for supervising AI systems have all powers transferred to market surveillance authorities by the Market Surveillance Regulation (Article 74(1)).

Market surveillance authorities are obliged to exercise their powers efficiently and effectively and in accordance with the principle of proportionality, to the extent that such exercise relates to the subject matter and the purpose of the measures and the nature and the overall (actual or potential) harm resulting from non-compliance (Article 14(2) of the Market Surveillance Regulation). There are also some procedural safeguards in favour of the operators against whom measures are directed. Market surveillance authorities must therefore exercise their powers **in a risk-based manner** (Recital 21 of the Market Surveillance Regulation).

The individual powers for the supervision of AI systems are defined by law and are presented below.

A competent market surveillance authority must, upon a reasoned request,

- receive **all information and documentation** (Sect. 3.3.8) required to demonstrate the compliance of a high-risk AI system with the AI Act (Article 21(1) of the AI Act).
- be granted access to the **logs automatically generated** by a high-risk AI (Sect. 3.2.5; Article 21(2) of the AI Act), and
- be granted access to the **source code** of a high-risk AI system if the other investigative powers are not sufficient and this is necessary to check compliance (Article 74(13) of the AI Act).

Market surveillance authorities may also require operators to **submit**

- relevant documents, technical specifications, data or information (in particular the technical documentation, see Sect. 3.2.4) on the **conformity and technical aspects** of the AI system (Article 14(4)(a) of the Market Surveillance Regulation);
- relevant **information on the supply chain**, on the details of the **distribution network**, on the **quantities of AI systems on the market** and on other AI systems having the same technical characteristics as the AI system in question, where relevant for conformity with the applicable requirements (Article 14(4)(b) of the Market Surveillance Regulation);
- request relevant information necessary to identify the **owner of a website** if the information in question is related to the subject matter of the investigation; for example, if a risky AI system is provided through that website (Article 14(4)(c) of the Market Surveillance Regulation).

Market surveillance authorities may also

- carry out **unannounced** on-site or remote **inspections** and checks of AI systems (Article 14(4)(d) of the Market Surveillance Regulation; Article 74(5));
- **enter** any **premises, land or means of transport** used by the operator for purposes related to its trade, business, craft or profession in order to detect non-compliances and to obtain evidence (Article 14(4)(e) of the Market Surveillance Regulation);
- start **own-initiative investigations** to identify and bring non-compliances to an end (Article 14(4)(f) of the Market Surveillance Regulation);
- acquire and inspect **samples** of the AI system, even under a cover identity or remotely, and to **reverse engineer** these samples (Article 14(4)(j) of the Market Surveillance Regulation, Article 74(5)), and
- where relevant and limited to the extent necessary to fulfil the tasks, also remotely, access the documentation and the **training, validation and test data sets** used (Sect. 3.2.2; Article 74(12)).

The AI Office has the same powers in relation to **GPAI systems,** provided that the provider of the GPAI system is also the provider of the GPAI model (Article 75(1); for the competence of the AI Office, see Sect. 6.2.1).

When it comes to the **supervision of GPAI models,** the AI Office is not a market surveillance authority within the meaning of the Market Surveillance Regulation. Therefore, the AI Office does not have the aforementioned powers of a market surveillance authority for this area of its responsibility. When supervising GPAI models, the AI Office is authorised to take all necessary measures to monitor the effective implementation and compliance with the AI Act (Article 89(1)). For the purposes of investigations, the AI Office may require the provider to submit documentation and any additional information necessary to assess the provider's compliance with the AI Act (Article 91(1)). The AI Office may also require the provider to provide technically appropriate access to a GPAI model (Article 92(3)).

Related Topics

Obligations of market surveillance authorities towards operators: Sect. 6.2.8.
Other powers of market surveillance authorities: Sect. 6.2.9.3.
Obligations to cooperate with authorities: Sects. 3.3.8 (Provider); 3.4.9 (Deployer), 3.5.2.5 (Importer), 3.5.3.4 (Distributors), 3.5.4 (Authorised representatives). ◀

6.2.6 What Additional Powers Will Data Protection Authorities and Other Existing Authorities Receive Under the AI Act?

Article 77
Recital 157 (Risks for fundamental rights and safeguard procedure)
Existing authorities that supervise or enforce **EU law protecting fundamental rights**, including the right to non-discrimination, will be granted additional powers under the AI Act. These authorities include, in particular, data protection authorities and equality bodies established under EU law.
These authorities are authorised to **request and inspect** all **documentation** created or maintained on the basis of the AI Act in an accessible language and format, insofar as this is necessary for the effective performance of their duties. They may request further inspections and tests by the market surveillance authorities and will be informed and involved by the market surveillance authorities in measures taken against risks to fundamental rights.
Besides, the competent data protection authorities are also responsible as market surveillance authorities with respect to AI systems that are used for certain state tasks (see Sect. 6.2.1).

Related Topics

Competent market surveillance authority: Sect. 6.2.1. ◀

6.2.7 How Is the EU Database for AI Systems Set Up?

Articles 49, 60 and 71
Recitals 131 (Registration obligation), 141 (Testing in real-world conditions)
The European Commission shall set up and maintain a central EU database for all stand-alone AI systems in critical use cases (as listed in Annex III, see Sect. 3.1.2).
The following entries can be found in the database:

- Providers must register their stand-alone high-risk AI systems (see Sect. 3.3.5).
- Providers must also register AI systems in critical use cases if they are not considered high-risk because of an exception (see Sects. 3.1.2.10 and 3.3.6).

- Deployers who are public authorities, institutions or other public bodies must also register in the database (see Sect. 3.4.6).
- In addition, tests of AI systems outside AI regulatory sandboxes must be registered in the database (see Sect. 6.3.2.1).

The database consists of a public and a non-public part (see Sect. 3.3.5). The public part must be accessible and publicly available in a user-friendly manner and the entries must be easy to navigate and machine-readable (Article 71(4)). The non-public part can only be accessed by market surveillance authorities and the European Commission, unless the provider has consented for making the information publicly accessible (Article 71(4)).

Related Topics

Registration obligations for providers: Sects. 3.3.5 and 3.3.6.
Registration obligation for deployers: Sect. 3.4.6.
Obligation to register real-world testing: Sect. 6.3.2.1. ◀

6.2.8 What Obligations Do Authorities Have Towards Operators?

Article 78; Article 74(1) AI Act in conjunction with Article 18 Market Surveillance Regulation; Article 94 AI Act in conjunction with Article 18 Market Surveillance Regulation

Recital 167 (Confidentiality)

The European Commission, the market surveillance authorities and the notified bodies, as well as any other natural or legal persons involved in the application and enforcement of the AI Act, are obliged to respect the **confidentiality** of the information and data under their control in carrying out their tasks and activities. In particular, intellectual property rights and business secrets, public and national security interests and classified information as well as the conduct of criminal or administrative proceedings must be protected.

They are required to only request data that is absolutely necessary and to delete it as soon as it is no longer required. They are also obliged to ensure an appropriate level of cyber security.

In addition, the national market surveillance authorities and the AI Office, as far as applicable, have some procedural obligations under the Market Surveillance Regulation:

- They must state the exact legal basis for their measures (Article 18(1) Market Surveillance Regulation).
- They must notify their measures, decisions or orders to the operator concerned without delay (Article 18(2) Market Surveillance Regulation).

- They must give the operator concerned an opportunity to be heard within a reasonable period of time before a measure, decision or order is taken; via exception, this opportunity may be granted retrospectively if necessary (Article 18(3) Market Surveillance Regulation).

Related Topics

Competent market surveillance authorities: Sect. 6.2.1.
Notified bodies: Sect. 6.1.3.1. ◄

6.2.9 What Sanctions Does the AI Act Provide for Violations of Its Provisions?

Articles 99, 100, 101, Article 74(1) AI Act in conjunction with Article 14(4)(i) Market Surveillance Regulation

Recitals 168 (Sanctions), 169 (Sanctions for GPAI models)

The AI Act contains provisions on fines that the EU member states must implement in national laws (Article 99). In principle, fines may only be imposed on the basis of these national laws. The market surveillance authorities are then responsible for imposing fines in individual cases (Article 74(1) AI Act in conjunction with Article 14(4)(i) Market Surveillance Regulation). The AI Act sets out a framework for various infringements. Within this framework the market surveillance authorities determine the actual fine at their discretion. In order to determine how high a fine should be, the AI Act contains a list of circumstances to be taken into account.

For GPAI models, the AI Act already contains binding rules on the fines that the European Commission may impose as the competent supervisory authority. An implementing act is to contain more specific requirements (Article 101(6)).

The AI Act also transfers further powers for market surveillance authorities to respond to infringements. Moreover, the EU member states can lay down additional sanctions for infringements of the AI Act in national laws, whereby double penalties are prohibited.

6.2.9.1 What Fines Can Be Imposed?

Articles 99, 100 and 101

Recitals 168 (Sanctions), 169 (Sanctions for GPAI models)

The framework for the amount of the fines depends on which provision of the AI Act an operator violates (see Fig. 6.1). The framework is based on a monetary amount or a percentage of worldwide annual turnover, whichever is higher. For SMEs and start-ups, the lower value limits the amount of possible fines.

If an AI system does not comply with the provisions on **prohibited AI practices** (Chap. 2), fines of up to EUR 35 million or, in the case of undertakings, up to 7% of the total worldwide annual turnover may be imposed.

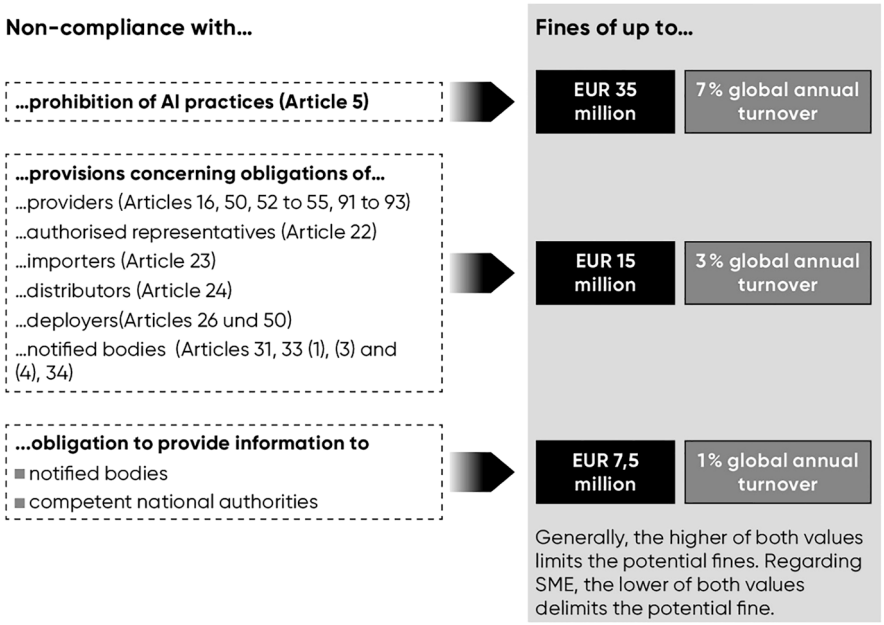


Fig. 6.1 Overview of fines

For violations of the **obligations of operators regarding high-risk AI systems** (Sects. 1.3.10, 3.3–3.5) and **GPAI models** (Sect. 1.3.10 and Chap. 5) and for violations of **transparency obligations** (Chap. 4) fines of up to EUR 15 million or, in the case of undertakings, up to 3% of their total worldwide annual turnover may be imposed.

If **incorrect, incomplete or misleading information** is provided to notified bodies or national competent authorities in response to their request for information, fines of up to EUR 7.5 million or, in the case of undertakings, up to 1% of the total worldwide annual turnover may be imposed.

For EU bodies, the AI Act contains its own framework of fines, which provides for fines of up to EUR 1.5 million for violations of the prohibited AI practices and up to EUR 750,000 for other violations of the AI Act (Article 100).

Related Topics

Prohibited AI practices: Chap. 2.
Operators' obligations regarding high-risk AI systems: Sects. 3.3–3.5.
Operators' obligations regarding GPAI models: Chap. 5.
Transparency obligations: Chap. 4.
Investigation rights: Sect. 6.2.5.
Notified bodies: Sect. 6.1.3.1. ◀

6.2.9.2 How Is the Amount of the Fine Determined?

Article 99(7)

When determining whether and to what extent fines are imposed, **all relevant circumstances** of the individual case must be taken into account, including:

- the nature, gravity and duration of the infringement and its consequences,
- whether the same operator has already been fined by other market surveillance authorities of one or more member states for the same infringement,
- whether the same operator has already been fined by other authorities for the same act/omission under other EU law or national law,
- the size, annual turnover and market share of the operator who committed the offence,
- the financial benefits gained or losses avoided as a result of the infringement,
- the degree of cooperation with the national competent authorities in identifying and eliminating the infringement and in mitigating and containing the consequences,
- the intentional or negligent nature of the breach and the degree of responsibility of the operator, taking into account the technical and organisational measures taken by the operator, and
- all measures taken by the operator to mitigate the harm suffered by the affected persons.

6.2.9.3 What Other Supervisory Measures Are Threatened?

Article 74(1) AI Act in conjunction with Articles 14–16 Market Surveillance Regulation, Article 99 AI Act

Recitals 9 (Consistency with the New Legislative Framework), 10 (Protection of personal data), 170 (Right to lodge a complaint)

The AI Act regulates the powers of the market surveillance authorities with a reference to the Market Surveillance Regulation (Article 74(1); see also Sect. 6.2.5). When exercising these powers, the principle of proportionality applies, meaning that the authority must exercise its powers on a risk-based basis (see Sect. 6.2.5). If an AI system does not fulfil the requirements of the AI Act, the market surveillance authorities are authorised

- to order the operators to take appropriate action to bring the non-compliance to an end or to eliminate a risk, including to withdraw or recall the AI system from the market (Article 14(4)(g), 16(3)(c) Market Surveillance Regulation),
- to require the removal of content from a website or other online interface that refers to the AI systems concerned or to require the explicit display of a warning to end users accessing the online interface (Article 14(4)(k)(i) Market Surveillance Regulation),
- to require information society service providers to restrict access to the online interface if the operators have not complied with the request to remove the content or to display a warning (Article 14(4)(k)(ii) of the Market Surveillance Regulation), or

- require an operator to destroy the AI system or otherwise render it unusable (Articles 14(4)(g), 16(3)(d) Market Surveillance Regulation).

Member states may also confer additional powers to their market surveillance authorities, including the power to recover the costs of a measure taken against the operator (Article 15 Market Surveillance Regulation).

When exercising their powers, market surveillance authorities must comply with their obligations towards operators (see Sect. 6.2.8).

In addition, the member states may lay down further sanctions such as warnings in national law (Article 99(1)). Sanctions under other legal acts are also not excluded by the AI Act. It is also to be expected that affected persons who suffer damage as a result of violations of the AI Act may be able to assert claims for damages under civil law (see Sect. 7.4).

Related Topics

Obligations of the market surveillance authority towards operators: Sect. 6.2.8. Investigative powers of market surveillance authorities: Sect. 6.2.5. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), point 7, pp. 104–126.

6.3 What Provisions Apply to the Testing of AI?

Articles 57 to 61

Recitals 138 (Establishment of AI regulatory sandboxes), 139 (Objectives of AI regulatory sandboxes), 140 (Further processing of personal data in AI regulatory sandboxes), 141 (Testing in real-world conditions)

Testing AI models and systems is fundamental **to AI governance** and to **the risk and quality management systems** that the AI Act prescribes for high-risk AI systems (see Sects. 3.2.1 and 3.3.1).

Testing and development activities are excluded from the scope of the AI Act as long as the AI system is not yet placed on the market or put into service (Article 2(8); see Sect. 1.2.7). The AI Act does not set out any requirements for testing within the sphere of the developer, as this internal testing does not pose risk for external persons (other relevant legal requirements, for example on data protection [see Sect. 7.2], must still be taken into account).

If the AI system is intended to be placed on the market or put into service in the EU, it is advisable to take the applicable requirements of the AI Act into account during the development and testing of the AI system. For instance, if the AI system will be classified as a high-risk AI system, (see Sect. 3.1) the conformity requirements (see Sect. 3.2) should be included already in the design, development and testing stage. This applies in particular to the technical documentation, the selection

of training, test and validation data as well as the risk and quality management systems. The earlier compliance with the AI Act is integrated into the development of an AI system, the easier it will be to comply with the requirements of the AI Act.

The same applies to providers of **GPAI models** (see Chap. 5), which may be tested before they are placed on the market or integrated into an AI system. Providers of GPAI models that involve **systemic risk** must even carry out **model assessments and attack tests** (see Sect. 5.2.2) to identify and mitigate corresponding risks.

While internal testing activities are not subject to the AI Act, AI systems can also be tested in **real-world conditions** before they have undergone a conformity assessment (see Sect. 6.1.5). For this purpose, the AI Act includes a number of requirements, in particular to protect the affected persons (see Sect. 6.3.2). Additionally, the AI Act provides for the introduction of AI regulatory sandboxes, which offer a **controlled testing environment** for the development phase of high-risk AI systems and are intended to support providers in legally compliant development (see Sect. 6.3.1).

Related Topics

Exemption from the scope of the AI Act for development: Sect. 1.2.7.
Requirements for high-risk AI systems: Chap. 3.
Requirements for GPAI models: Chap. 5.
Exemption from the conformity assessment procedure: Sect. 6.1.5.
Data protection regulations: Sect. 7.2. ◀

▶ **Further Information** *Bengio*, International Scientific Report on the Safety of Advanced AI – Interim Report (2024); *Bundesamt für Sicherheit in der Informationstechnik*, Generative AI models (2024); *Centre of Information Policy Leadership*, Building Accountable AI Programs (2024); *High-Level Expert Group on AI*, Ethics guidelines for trustworthy AI (2019); Assessment List for Trustworthy AI (2020); *National Institute of Standards and Technology*, AI Risk Management Framework (2023); Generative Artificial Intelligence Profile – Draft (2024); *UK AI Safety Institute*, Inspect – An open-source framework for large language model evaluations (2024).

6.3.1 What Are AI Regulatory Sandboxes and What Goals Do They Serve?

Articles 3(54) and (55), 57 to 59

Recitals 138 (Establishment of AI regulatory sandboxes), 139 (Objectives of AI regulatory sandboxes), 140 (Further processing of personal data in AI regulatory sandboxes)

Under the AI Act, AI regulatory sandboxes are meant to offer a **safe and controlled framework** to develop, train, validate and—if necessary—test AI systems under real-world conditions before they are placed on the market or put into service (Article 3(55) and Article 57(5); with regard to real-world testing in AI regulatory sandboxes, see Sect. 6.3.2.2). AI regulatory sandboxes must be set up by competent authorities and made available to (future) providers of AI systems for use under regulatory supervision for a limited period of time. To participate in a regulatory sandbox (future) providers must agree with the competent authority on a **sandbox plan**. This agreement must describe the objectives, conditions, timeframe, methodology and requirements for the activities that the provider will carry out within the AI regulatory sandbox (Article 3(54)).

Governments around the world had already fostered the development of test frameworks before the AI Act entered into force. Some EU member states have already set up regulatory sandboxes in various areas, often linked to specific economic sectors. For instance, the German federal government is preparing, among other things, a law on regulatory sandboxes to create an overarching framework and standards. The AI Act is intended to take up the **existing structures** and harmonise them with the requirements of the AI Act.

The EU expects great benefits from the regulatory sandboxes being established. The regulatory sandboxes are intended to foster **innovation in the EU** by

- creating a controlled environment and
- enabling providers, authorities and other stakeholders in the AI ecosystem to collaborate regarding a high-risk AI system before placing it on the market or putting it into service.

AI regulatory sandboxes serve multiple objectives. Their establishment requires financial, organisational and human resources, most of which must be provided by the member states.

In practice, it must be proven whether the providers of high-risk AI systems see **added value in supervised development** in AI regulatory sandboxes or prefer in-house development.

AI regulatory sandboxes shall contribute to the following **objectives** (Article 57(9)):

- to improve **legal certainty** to achieve compliance with the AI Act and other applicable legislation,
- to promote the exchange of **best practices** through cooperation with the authorities involved in the AI regulatory sandboxes,
- to foster **innovation and competitiveness**,
- to facilitate the development of an **AI ecosystem**,
- to contribute to evidence-based regulatory learning, including with a view to a **future adaptation of the AI regulatory framework**, and
- to facilitate and accelerate the **access of AI systems to the EU market**, in particular for small and medium-sized enterprises and start-ups (see Sect. 1.3.12).

Within the AI regulatory sandboxes, risks, in particular with regard to fundamental rights, health, and safety, shall be identified and appropriate **tests and risk mitigation measures** shall be developed (Article 57(6)). Furthermore, the competent authorities shall provide (future) providers with guidance on how to fulfil the requirements and obligations arising from the AI Act (Article 57(7)).

Related Topics

Measures to promote SMEs and start-ups: Sect. 1.3.12.
Testing in real-world conditions in the AI regulatory sandbox: Sect. 6.3.2.2. ◀

6.3.1.1 What Are the Benefits of Participating in AI Regulatory Sandboxes?

Article 57

139 (Objectives of the AI regulatory sandboxes)

Providers shall receive support in the AI regulatory sandboxes by providing a **controlled environment to develop, test, and validate** AI systems for a limited period of time before their AI system is placed on the market or put into service. Participating in a regulatory sandbox is intended to facilitate the identification and minimisation of risks (see Sect. 6.3.1). Furthermore, cooperation with competent authorities within the regulatory sandboxes is also intended to facilitate the conformity assessment procedure (see Sect. 6.1). Since market surveillance authorities can be consulted as early as in the development stage, the result of the subsequent conformity assessment should be more predictable, and the procedure itself can be completed faster.

Upon request, the competent authority shall provide the (future) provider of the tested AI system with **written proof** of the testing and risk mitigation measures successfully carried out in the regulatory sandbox. In addition, the competent authority shall submit an **exit report** detailing the activities carried out in the sandbox, their results and learning outcomes. Providers may use these documents to demonstrate compliance with the AI Act during the **conformity assessment procedure** or relevant market surveillance measures (see Sect. 6.2.5). The evidence and final reports issued by the national authorities are intended to **speed up conformity assessment procedures** and must be **positively taken into account** by market surveillance authorities and notified bodies (Article 57(7)).

Finally, the market surveillance authorities must **not impose administrative fines** for infringements of the AI Act if the provider

- observes its agreed sandbox plan and the terms and conditions for its participation in the sandbox and
- follows in good faith the guidance given by the national competent authority (Article 57(12)).

Related Topics

Compliance assessment procedures for high-risk AI systems: Sect. 6.1.
Investigation rights of the market surveillance authorities: Sect. 6.2.5. ◀

6.3.1.2 How and by Whom Are AI Regulatory Sandboxes Established?

Article 57, 58

Recital 138 (Establishment of AI regulatory sandboxes)

The EU plans to make AI regulatory sandboxes available to all (future) providers who wish to participate. Each **member state** must ensure that their national competent authorities set up at least one AI regulatory sandbox at national level which is operational by 2 August 2026. As an option, pre-existing regulatory sandboxes or similar institutions can be turned into AI regulatory sandboxes under the AI Act if they are adjusted to comply with the requirements of the AI Act with respect to regulatory sandboxes (Article 57(1)). Additional regulatory sandboxes may also be set up jointly by national competent authorities of two or more member states, provided that national (and ultimately EU-wide) coverage is guaranteed. Moreover, regulatory sandboxes can also be set up at regional or local level—and again, also jointly with the national competent authorities of other member states (Article 57(2)). The **European Data Protection Supervisor** may set up a real-world laboratory for EU institutions, bodies, offices and agencies (Article 57(3)). A publicly accessible **list of all planned and existing** AI regulatory **sandboxes** will be published and updated by the AI Office (Article 57(15)).

The AI Act sets out a detailed **framework for the establishment and operation of AI regulatory sandboxes**. Among other things, the AI Act stipulates that the national competent authorities must provide AI regulatory sandboxes with sufficient resources to fulfil their tasks effectively and in a timely manner. Besides, national competent authorities must cooperate with other relevant authorities when setting up sandbox, e.g. with the national data protection authorities. AI regulatory sandboxes should also facilitate cooperation between authorities, including cross-border cooperation. The national competent **authorities shall report** annually to the AI Office and the AI Board on the **implementation and findings** in relation to the AI regulatory sandboxes.

More specific conditions regarding the establishment, development, implementation, operation and supervision of AI regulatory sandboxes shall be laid down by the European Commission through implementing acts (Article 58(1)). These implementing acts shall cover the following areas:

- the **eligibility and selection criteria** for participation in the AI regulatory sandbox,
- procedures for the application, participation, monitoring, exiting from and termination of the AI regulatory sandbox, including the sandbox plan and exit report, and
- the terms and conditions applicable to **participants**.

In addition, the AI Act sets up a framework of provisions on what the implementing Acts must ensure (Article 58(2)). For example, the sandboxes should be open to all providers (but give priority to small and medium-sized enterprises, for which participation is free of charge) and involve other relevant actors, such as notified bodies, standardisation organisations, or researchers, in order to foster cooperation between the private and public sectors.

6.3.1.3 Can Personal Data That Has Been Collected for Other Purposes Be Further Processed in AI Regulatory Sandboxes?

Article 59

Recital 140 (Further processing of personal data in AI regulatory sandboxes)

Personal data lawfully **collected for other purposes** may be processed for the development, training and testing of AI systems in regulatory sandboxes under a number of conditions (Article 59(1)). The first condition is that the data processing must be **necessary** for the development of an AI system that serves to safeguard a **substantial public interest,** for example public safety and health, environmental protection, the resilience of critical infrastructure or public administration.

Second, special **security and protection measures** must be taken for the rights and freedoms of the data subjects. Personal data that has already been collected may only be passed on in compliance with the GDPR (see Sect. 7.2). Personal data that has only been 'generated' (i.e. collected or generated by aggregation of data sets) in the context of a regulatory sandbox must not be used outside the regulatory sandbox. In addition, the processing of personal data in the regulatory sandboxes must not result in any measures or decisions that have a **negative impact on the data subjects.**

Related Topics

Data protection requirements for AI: Sect. 7.2. ◄

6.3.2 What Is Testing in Real-World Conditions?

Articles 3(57), 60 and 61

Recital 141 (Testing in real-world conditions)

Testing in real-world conditions is

- the **temporary testing** of a (high-risk) AI system for its intended purpose,
- which takes place **in real-world conditions outside a laboratory** or otherwise simulated environment,
- to gather reliable and robust data and **to assess and verify the conformity of** the AI system with the requirements of the AI Act (Article 3(57)).

Testing in real-world conditions is **not considered placing** the AI system **on the market or putting** it **into service**, provided that all requirements of the AI Act for such tests are met. AI systems can be tested in real-world conditions both inside and outside AI regulatory sandboxes.

6.3.2.1 What Requirements Apply to Testing in Real-World Conditions Outside of Regulatory Sandboxes?

Articles 3(58), 60, 61 and 76

Recital 141 (Testing in real-world conditions)

Providers may **also test** stand-alone high-risk AI **systems in critical use cases** (as listed in Annex III, see Sect. 3.1.2) **outside of regulatory sandboxes** under 'real' conditions **in practice** before placing these systems on the market or putting them into service (Article 60(1)). High-risk AI systems that are products or safety components of products (see Sect. 3.1.1) must not be tested under real-world conditions outside of regulatory sandboxes.

Testing under real-world conditions is intended to accelerate the development and market entry of high-risk AI systems in the EU (Recital 141). Providers can also conduct tests in collaboration with (future) deployers if they follow the conditions set out in the AI Act. Testing under real-world conditions is limited to a **maximum duration of 6 months**, must be based on a **real-world testing plan** that has to be assessed and approved by the competent market surveillance authority. Moreover, the testing in real-world conditions requires the subjects (i.e. participating humans, Article 3(58)) to give their **informed consent**. All activities with respect to real-world testing must be closely monitored by the market surveillance authorities.

The AI Act sets out the **following requirements** for lawful testing in real-world conditions (Article 60(4)), which shall be further specified by the European Commission by means of implementing acts:

- The (future) provider has drawn up a real-world **testing plan** (see Sect. 6.3.2.3) and submitted it to the market surveillance authority (see Sect. 6.2.1) in the member state where testing in real-world conditions is to take place.
- The testing and the testing plan have been approved by the **market surveillance authority; approval** is deemed to have been granted after 30 days without a response if the applicable national law permits such tacit approval.
- The **testing** has to be registered in the EU database (see Sect. 6.2.7); high-risk AI systems in the areas of law enforcement, migration, asylum and border control and critical infrastructure will be registered in the non-public part of the database for confidentiality reasons.
- The (future) provider carrying out the testing in real-world conditions must be **established in the EU** or must have appointed an **authorised representative** established in the EU (see Sect. 1.3.10).
- The **data** collected and processed for the testing will only be **transferred** to **third countries** if appropriate and applicable safeguards are in place in accordance with EU law—in particular, the data protection requirements in Articles 44–49 of the GDPR (see Sect. 7.2.10) as well as the requirements for data trans-

fers under Article 32 Data Act and Article 31 Data Governance Act must be observed.
- The testing ends when its testing purpose is achieved, or after a period of **6 months** if the purpose is not achieved earlier. After 6 months the testing can be **extended** by a further 6 months, provided that the provider informs the market surveillance authority in advance and explains why such an extension is necessary.
- Appropriate **safeguards** must have been put in place for subjects who belong to vulnerable groups due to their age or disability.
- If providers **cooperate with (future) deployers** on the testing, the deployers have to be informed about all aspects of the test relevant to their participation, and have to receive the instructions for use of the AI system (see Sect. 3.2.6). Besides, all participating operators must have agreed on their roles and responsibilities to fulfil the legal requirements.
- All **subjects** must have given their **informed consent** to the testing. If obtaining consent would prevent the AI system from being tested in the area of law enforcement, informed consent is not required but negative effects on the subjects must be prevented and **personal data** must be **deleted** after the testing has been carried out.
- The **testing process** is **effectively overseen** by persons who are appropriately qualified in the relevant field and have the necessary ability, training and authorisation in this respect.
- The AI system's predictions, recommendations or decisions can effectively be **reversed** and **disregarded.**

As displayed before, freely-given **informed consent** must be obtained from all subjects prior to their participation in real-world testing (Article 61(1)). To this end, participants must be informed in advance of the essential aspects of the test, e.g. the objective, duration and conditions, possible inconveniences, their rights and the possibility of cancelling or disregarding the output of the AI system. The consent must be dated and documented and a copy made available to the participants (Article 61(2)).

Participation in the test can be cancelled at any time by **withdrawing** their informed consent. The subject can then demand the immediate and permanent deletion of their personal data without any disadvantages for them. The cancellation does not have to be justified. Withdrawal of informed consent does not affect the legality or validity of activities already carried out before consent is withdrawn (Article 60(5)).

During testing, **serious incidents** causing death or serious injury to a person, serious and irreversible disruption to the management or operation of critical infrastructure, violation of fundamental rights or serious harm to property or the environment must **be reported** (Article 60(7); see Sect. 3.3.10). In such cases, the provider shall take immediate measures to limit the damage, including suspending or cancelling testing and recalling the high-risk AI system. The competent market surveillance authorities must be notified about mitigating measures taken (Article 60(8)).

The **authorities** also have general **control and monitoring powers** and the possibility to request information from providers, conduct unannounced investigations and to check on the conduction of the real-world testing (Articles 60(6), 76—the reference to Article 75 in Article 60(6) is probably an editorial error; see Sect. 6.2.4.3).

Related Topics

Appointment of an authorised representative: Sect. 1.3.10.
High-risk AI systems: Sect. 3.1.
Instructions for use: Sect. 3.2.6.
Reporting procedure regarding serious incidents: Sect. 3.3.10.
Competent market surveillance authority: Sect. 6.2.1.
EU database: Sect. 6.2.7. ◀

6.3.2.2 What Requirements Apply to Testing in Real-World Conditions Within Regulatory Sandboxes?

Articles 57(5), 58(4)

Testing in real-world conditions can also be carried out in AI regulatory sandboxes (Article 57(5)). The national competent authorities and the operators (see Sect. 1.3) that are involved in testing shall specifically agree on the **terms and conditions for real-world testing** in a regulatory sandbox and, in particular, on appropriate **safeguards** for fundamental rights, health and safety (Article 58(4)).

6.3.2.3 What Elements Must the Plan for Testing in Real-World Conditions Include?

Article 3(53), Article 60(1)

The real-world testing plan shall describe the **objectives**, **methodology**, geographical, population and temporal **scope**, **monitoring**, organisation and **conduct** of testing in real-world conditions (Article 3(53)). More detailed elements shall be specified by the European Commission by means of implementing acts (Article 60(1)).



What Other Legislation Is Particularly Relevant with Regard to AI?

7

7.1 What Secondary Legislation and Other Tools to Supplement or Specify the AI Act Are Envisaged?

Many provisions and requirements of the AI Act shall be specified and supplemented by secondary legislation. All secondary acts provided for in the AI Act are summarised in Table 7.1. For each act, the following information is included in a separate column:

- the legal provision whose requirements can be specified, supplemented, or amended by a secondary act,
- a short summary of the content that can be specified or changed,
- the legal form of the act (as an indicator of how binding the provisions of the secondary acts are),
- the legal basis on which the authorisation to amend/specify a provision of the AI Act arises,
- the responsible actor who can carry out the change/concretisation and
- if applicable, an implementation deadline within which the concretisation must take place.

With regard to legal forms, please note the following: Delegated acts will amend the content of certain parts of the AI Act, i.e., they will change the actual contents of the AI Act. **Implementing acts** can only specify certain parts of the AI Act, but the basic rule of the AI Act remains the same. However, implementing acts are still legally binding. **Standardisation mandates** are intended to lead to the development of harmonised standards (see Sect. 7.6.3), which can then facilitate compliance with the requirements of the AI Act. **Guidelines reflect** the European Commission's non-binding legal opinion, but are also taken into account, particularly in the case of fines, and are therefore important for the interpretation of the respective requirements. Other acts are non-binding but—depending on the specific

© The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7_7

Table 7.1 Overview of supplementary and specifying provisions with respect to the AI Act

Provision of the AI Act that is changed/ specified	Content	Legal form	Legal basis	Responsible actor	Deadline
Articles 2(2), (5), (7) and (9); Article 6(1), Annex I	Detailed information on the relationship between the AI Act and other legal acts	Guidelines	Article 96(1)(e)	EU Commission	/
Article 3(1)	Application of the definition of an AI system	Guidelines	Article 96(1)(f)	EU Commission	/
Article 3(23), Article 25(1)(b)	Practical implementation of the provisions on substantial modifications	Guidelines	Article 96(1)(c)	EU Commission	/
Article 5	Prohibited AI practices	Guidelines	Article 96(1)(b)	EU Commission	/
Article 5(1)(h), (2), and (3)	Use of real-time remote identification systems	National law	Article 5(5)	EU member state	/
Article 6(1)–(3)	Implementation of the categorisation of high-risk AI systems with examples of AI systems that are or are not high risk	Guidelines	Article 6(5)	EU Commission after consultation with AI Board	2 Feb 2026
Article 6(2), Annex III	Amendments to critical use cases for stand-alone high-risk AI systems	Delegated acts	Article 7(1)–(3)	EU Commission	/
Article 6(3)	Amendments to criteria according to which AI systems are not high risk in critical use cases (Annex III)	Delegated act	Article 6(6)–(8)	EU Commission	/
Articles 8–15, 25	Application of the requirements for high-risk AI systems and obligations of the operators	Guidelines	Article 96(1)(a)	EU Commission	/

Articles 8–15	Specification of the requirements for high-risk AI systems	Standardisation requests	Article 40(2)	EU Commission in consultation with the AI Board, stakeholders and the advisory forum	Without undue delay
		Harmonised standards	Article 40(1), Regulation (EU) No 1025/2012	European standardisation organisations	
		Implementing act if standardisation request has not been accepted or not fulfilled (in accordance with the request)	Article 41(1)	EU Commission in consultation with advisory forum	/
Article 11(1), Annex IV	Simplified form of technical documentation of high-risk AI systems by SMEs	Simplified form	Article 11(1)	EU Commission	/
Article 11(1), Annex IV	Amendment of the minimum information for technical documentation for high-risk AI systems	Delegated acts	Article 11(3)	EU Commission	/
Article 15(1)	Technical aspects of measuring accuracy and robustness of high-risk AI systems	Benchmarks and measurement methodologies	Article 15(2)	Relevant stakeholders and organisations (incl. metrology and benchmarking authorities), supported by the Commission	/
Article 17	Simplified implementation of the quality management system by micro-enterprises (<10 employees and <2 million annual turnover)	Guidelines	Article 63(1)	EU Commission	/
Article 25(4)	Contracts between providers of high-risk AI systems and third parties providing tools or components	Voluntary model terms for contracts	Article 25(4)	AI Office	/

(continued)

Table 7.1 (continued)

Provision of the AI Act that is changed/ specified	Content	Legal form	Legal basis	Responsible actor	Deadline
Article 27	Implementation of the fundamental rights impact assessment by deployers of high-risk AI systems	Template for a questionnaire	Article 27(5)	AI Office	
Article 43(1), Annexes VI and VII	Amendment of the minimum requirements for the conformity assessment in the light of technical progress	Delegated act	Article 43(5)	EU Commission	/
Article 43(1) and (2)	Amendment of which conformity assessment procedure applies to which kind of high-risk AI systems in critical use cases	Delegated act	Article 43(6)	EU Commission	/
Article 47(2), Annex V	Updating the contents of the EU declaration of conformity	Delegated act	Article 47(5)	EU Commission	/
Article 50	Practical implementation of the transparency obligations	Guidelines	Article 96(1)(d)	EU Commission	/
Article 50(2) and (4)	Implementation of the obligations to detect and label artificially generated or manipulated content	Codes of practice, possibly generally applicable through implementing acts	Article 50(7)	Stakeholders and AI Office (codes of practice) EU Commission (implementing act)	/
Article 51(1) and (2)	Amendment of thresholds, supplement of benchmarks and indicators for determining GPAI models with systemic risk	Delegated act	Article 51(3)	EU Commission	/
Article 52(4), Annex XIII	Adjustment of the conditions under which the EU Commission may designate a GPAI model with Systemic risk as such	Delegated act	Article 52(4)	EU Commission	/

Articles 53–55	Specification of obligations for GPAI models	Standardisation requests	Article 40(2)	EU Commission in consultation with the AI Board, stakeholders and the advisory format	as applicable
		Harmonised standards	Article 40(1), Regulation (EU) No. 1025/2012	European standardisation organisations	
		Implementing act if standardisation mandate not accepted or not fulfilled (in accordance with the mandate)	Article 41(1)	EU Commission in consultation with advisory forum	/
Article 53(1)(a), Annex XI	Specification of the measurement and calculation methodologies for technical documentation of GPAI models	Delegated act	Article 53(5)	EU Commission	/
Article 53(1)(a) and (b), Annexes XI and XII	Amendment of the minimum content for technical documentation and transparency information for GPAI models	Delegated act	Article 53(6)	EU Commission	/
Article 53(1)(d)	Summary of the content used to train a GPAI model	Template	Article 53(1)(d)	AI Office	/
Articles 53 and 55	Implementation of the obligations for GPAI models	Codes of practice, possibly generally applicable through implementing acts	Article 56	Stakeholders and AI Office (codes of practice) EU Commission (implementing act)	2 May 2025
		Implementing act, if no adequate code of practice was finalised in time	Article 56(9)	EU Commission	2 Aug 2025

(continued)

Table 7.1 (continued)

Provision of the AI Act that is changed/ specified	Content	Legal form	Legal basis	Responsible actor	Deadline
Article 57	Detailed rules on AI regulatory sandboxes	Implementing act	Article 58(1)	EU Commission	/
Article 60, Article 3(53)	Detailed rules on real-world testing plans	Implementing act	Article 60(1)	EU Commission	/
/	All areas covered by the AI Act	Standardised templates for SMEs	Article 62(3)	AI Office on request of the AI Board	/
Article 68	Detailed provisions on the establishment of the scientific panel	Implementing act	Article 68(1)	EU Commission	/
Article 72(1) and (3)	Template for the post-market monitoring plan and a list of elements to be included in the plan	Implementing act	Article 72(3)	EU Commission	2 Feb 2026
Article 97 paragraph 1	Revocation of the EU Commission's competence to adopt delegated acts	Resolution	Article 97(3)	EU Parliament and EU Council	/
Article 99	Rules on sanctions and other enforcement measures	National law	Article 99(1)	EU member states	2 Aug 2025
Article 101(1)	Regulations and procedural safeguards for fines against providers of GPAI models	Implementing act	Article 101(6)	EU Commission	/

regulation—can have a similar effect to guidelines, i.e., they must be taken into account in particular when deciding whether and to what extent fines are to be imposed in the event of an infringement. For example, if a simplified form from the European Commission is intended to facilitate compliance with the AI Act for small companies, small companies will generally not have to fear a fine if they do not provide information that is required under the AI Act but was not requested on the form (unless they act in bad faith).

7.2 What Data Protection Regulations Apply to the Use of AI?

Article 2(7) AI Act

Recitals 9 (Consistency with the New Legal Framework), 10 (Protection of personal data), 39 (Biometric data with other purposes), 42 (Predictive policing and profiling), 45 (Prohibitions under other EU laws), 67 (Data quality and data governance), 69 (Principles of data processing and federated learning), 141 (Testing in real-world conditions).

EU data protection law remains applicable alongside the AI Act (Article 2(7) AI Act). From a business perspective, the General Data Protection Regulation (GDPR) is of central importance, as the use and training of AI often involves the processing of personal data, which is primarily regulated by the GDPR. If an AI processes personal data, all principles for the processing of personal data must therefore be complied with. This applies to both the development and the use of the AI.

Most of the obligations under the GDPR apply to the so-called 'controller', who determines the purposes and means of data processing (Article 4(7) GDPR; see Sect. 7.2.8).

▶ **Further Information** *Der Hamburgische Beauftragte für Datenschutz und Informationssicherheit*, Large Language Models and Personal Data (2024); European Data Protection Board, Report of the work undertaken by the ChatGPT Taskforce (2024); *Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder (DSK)*, Orientierungshilfe: Künstliche Intelligenz und Datenschutz (2024); *Agencia Española de Protección de Datos (AEPD)*, Adecuación al RGPD de tratamientos que incorporan Inteligencia Artificial. Una introducción (2020); *Commission Nationale de l'Informatique et des Libertés (CNIL)*, IA: comment être en conformité avec le RGPD? (2022), Guide d'auto-évaluation pour les systèmes d'intelligence artificielle (IA) (2022); *Information Commissioner's Office (ICO)*,

Guidance on AI and data protection (2023); *Galdon Clavell*, Checklist for AI Auditing (2024).

7.2.1 When Is the GDPR Applicable?

Articles 2, 3 and 4(1) and (2) GDPR, Article 10(5)(a) AI Act
Recitals 14–21, 27 GDPR

The GDPR generally applies to the processing of **personal data** by automated means (Article 2(1) GDPR). It therefore applies to training and development as well as to the use of AI systems, insofar as personal data is processed.

Personal data means any information relating to an identified or identifiable natural person ('data subject'; Article 4(1) GDPR). An **identifiable** natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier. This means that not only direct identifiers such as name or credit card number are covered, but also any information that, together with other information, enables the assignment to a person. **Processing** refers comprehensively to any operation in connection with personal data, such as collection, storage or use (Article 4(2) GDPR). The GDPR does not recognise a minimum time limit for the storage period, meaning that mere temporary storage, for example in RAM, is sufficient in principle.

However, the GDPR **does not apply to non-personal data**, i.e. any information that does not allow the identification of a natural person. The 'principles of data protection' (i.e. the entire GDPR) should therefore not apply to 'anonymous information, i.e. information that does not relate to an identified or identifiable natural person or personal data that has been anonymised in such a way that the data subject cannot or can no longer be identified' (Recital 26 GDPR). To determine when data is considered anonymised and therefore non-personal data, all means should be taken into account that are reasonably likely to be used by the controller or another person to directly or indirectly identify the natural person (Recital 26 GDPR). Regarding what means are reasonably likely to be used to identify the natural person, all objective factors, such as the costs of identification and the time required for this as well as the technology available at the time of processing and technological developments should be taken into account (Recital 26 GDPR). The GDPR therefore chooses a relative perspective, which allows for data to be 're-identified' at a later point in time than the relevant processing due to better de-anonymisation techniques.

Anonymisation plays a particularly important role in the training of AI. As far as possible, developers should try to anonymise all data that is considered to be personal data before training AI. This also applies to the processing of special categories of personal data in order to recognise and correct bias. Special categories of personal data can only be used if anonymised data is not sufficient for this purpose (Article 10(5)(a) AI Act; see Sects. 3.2.2 and 3.2.3). Even if anonymisation is not completely successful and the GDPR therefore continues to apply, efforts to impede identification of data subjects make it easier to justify the data processing (see Sect. 7.2.4).

The GDPR applies territorially if one of the following two conditions is met (Article 3 GDPR):

- On the one hand, the GDPR applies if personal data is processed in the context of the activities of an establishment of a controller or processor in the EU, regardless of whether the processing takes place in the EU or not.
- On the other hand, the GDPR applies if personal data of data subjects located in the EU are processed, even if the controller or processor is not established in the EU, where the data processing is related to
  - the offering of goods or services to data subjects in the EU, regardless of whether a payment is to be made by those data subjects; or
  - the monitoring of their behaviour as far as their behaviour takes place in the EU.

Especially due to the principle of destination (displayed as the second condition for territorial applicability), the GDPR has a considerable effect on providers in third countries outside the EU. When the principle of destination applies, non-EU providers must also appoint a GDPR representative within the EU (Article 27 GDPR). This parallels obligation of providers who are not established in the EU to appoint an authorised representative under the AI Act (see Sect. 1.3.10).

Related Topics

Appointment of an authorised representatives under the AI Act: Sect. 1.3.10.

Principle of destination (in the context of the AI Act): Sect. 1.3.9.

Data quality requirements in the AI Act: Sect. 3.2.2.

Legal basis for data processing: Sect. 7.2.4. ◀

7.2.2 When Is Personal Data Processed During the Training and Use of AI?

When data sets containing personal data are used in AI training within the territorial scope of the GDPR, the GDPR also applies, as the training of AI necessarily requires the (intermediate) storage of the data. A data set may also contain personal data if the attributes can only be assigned to data subjects by using unique identifiers, such as user IDs or browser IDs, as long as the controller can actually assign the attributes.

When AI systems are used, personal data may be processed in particular with regard to the user of the AI system. Persons using AI systems may expressly provide personal data concerning themselves or third parties (e.g. by entering names in a prompt). Even if the input does not contain any clear identifiers (such as names or

telephone numbers), a personal reference can result from the context of the information provided. Personal data is also processed if the user's user data is stored in such a way that it can be assigned to individual users (e.g. by storing a user ID in the metadata).

7.2.3 What General Principles Apply to the Processing of Personal Data?

Article 5 GDPR

Recital 39 GDPR

The GDPR sets out the following general principles for the processing of personal data (Article 5 GDPR).

Legality and Transparency
Personal data must be processed lawfully, fairly and transparent. This principle is particularly expressed in the requirement of a legal basis for processing (Articles 6 and 9 GDPR; see Sect. 7.2.4) and the information obligations (Articles 13 and 14 GDPR; see Sect. 7.2.5).

Purpose Limitation
Personal data must be collected for specified, explicit and legitimate purposes and must not be further processed in a manner incompatible with those purposes. The principle of purpose limitation contrasts the concept of big data, where stored data is constantly recombined in order to draw new conclusions. Especially if personal data collected by another controller is used to train AI, it can be complicated to specify the exact purpose of use for the AI training at the time of collection.

Data Minimisation
Personal data must be adequate, relevant, and limited to what is necessary for the purposes of the processing. In this respect, the controller always has to question whether the personal reference of data is necessary, especially when training AI.

Accuracy
Personal data must be accurate and, where necessary, kept up to date. Every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which it is processed, are erased or rectified without delay. This is expressed in particular by the separately regulated rights to rectification and erasure (Articles 16 and 17 GDPR; see Sect. 7.2.6). Regarding data accuracy, a particular challenge of AI systems are so-called hallucinations. This means that the outputs generated by an AI system may not correspond to reality, even though the AI system outputs them as such, for example historical data or a person's birthday. This raises the question of the extent to which hallucinating AI systems are in line with the principle of data accuracy.

Storage Limitation
Personal data must be stored in a form which permits the identification of data subjects for no longer than is necessary for the purposes for which the data are processed. In addition to the principle of data minimisation, the principle of storage limitation ensures that personal data is not retained after the actual purpose of processing has ceased to exist.

Integrity and Confidentiality
Personal data must be processed in a manner that ensures appropriate security of the personal data against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures. Regarding high-risk AI systems, this criterion overlaps, at least to a certain extent, with the requirement of appropriate cybersecurity in the AI Act (see Sect. 3.2.8).

Accountability
The controller is responsible for compliance with all of the aforementioned principles of data protection and must be able to demonstrate compliance with them (Article 5(2) GDPR).

Related Topics

Legal basis for processing: Sect. 7.2.4.

Obligation to provide information: Sect. 7.2.5.

Cybersecurity requirements in the AI Act: Sect. 3.2.8. ◀

7.2.4 Which Legal Bases Does the GPDR Acknowledge for Processing Personal Data?

Article 6 GDPR
Recitals 10, 32, 39–50 GDPR
In order to be lawful, any processing of personal data requires a legal basis. The GDPR lists the following grounds that can justify to process personal data (Article 6(1) GDPR):

- consent of the data subject,
- performance of contractual obligations,
- performance of legal obligations,
- protection of vital interests of a natural person,
- performance of a task in the public interest, and
- necessary for a legitimate interest of the controller or a third party.

In the following assessment, training and the use of AI will be considered separately, as they involve different processing steps each of which needs a legal basis.

7.2.4.1 Which Legal Bases May Apply to the Training of AI?

Articles 4(11) and 7(3) GDPR
Recitals 32 and 33 GDPR

Consent
If processing is to be based on the consent of the data subject, consent must be freely given, specific, informed and unambiguous (Article 4(11) GDPR). Therefore, every individual data subject has to state its consent separately. Afterwards, data subjects can withdraw their consent at any time (Article 7(3) GDPR). In principle, the training of AI can be based on the consent of data subjects. However, in view of the high legal requirements for consent and the constant legal uncertainty caused by a possible withdrawal, there are important reasons against using consent as legal basis to train AI with personal data.

Performance of a Contract
The processing is also lawful if it is necessary for the performance of a contract to which the data subject is party or, at the request of the data subject, for the preparation before entering into a contract. Only the parties' primary obligations, i.e. those obligations that form the core of the contract, are necessary for performance of the contract. The training of AI will only very rarely constitute a primary obligation of either party, which means that this legal basis is also unlikely to justify the processing of personal data to train AI.

Performance of Legal Obligations
Processing is also lawful if it is necessary to perform legal obligations to which the controller is subject. However, it is unlikely that AI has to be trained with personal data to perform legal obligations.

Protection of Vital Interests
In rare occasions, the processing of personal data to train an AI model can be justified if it is necessary to protect vital interests of a person.

Performance of Public Tasks
In contrast, public tasks that justify the training of AI may apply more often. For example, AI may be fine-tuned with personal data to facilitate the performance of regulatory tasks, such as granting public assistance or services.

Legitimate Interest
The most relevant legal basis for AI training is likely to be the exercise of overriding legitimate interests. Accordingly, any legitimate interest of the controller can justify the processing of personal data for AI training, provided that the processing is necessary for the interest and the interest in the processing outweighs the rights, freedoms and interests of the data subjects. Appropriate protective measures, in particular comprehensive pseudonymisation of the data used, can make a significant contribution to ensure that the controller's interests outweigh the data subjects' interests.

It must be ensured on a case-by-case basis that

- the controller has a legitimate interest,
- the data processing is necessary to fulfil the legitimate interest (i.e. there is no equally suitable milder means to achieve the purpose) and
- the interests of the data subject against the processing do not override the controller's legitimate interest.

▶ **Further Information** *European Data Protection Board,* Guidelines 1/2024 on processing of personal data based on Article 6(1)(f) GDPR (2024).

7.2.4.2 Which Legal Bases May Apply to the Use of AI?

In contrast to AI training, data subjects will often consent to the processing of personal data for the use of AI. Data subjects will often have a direct interest in a service that is based on AI, making consent a more viable legal basis regarding the processing of personal data for the use of AI. Personal data can also be processed directly to perform the contractual obligation to allow the use of an AI system. Hence, it is also easier to base processing on the ground of performing a contractual obligation.

Nevertheless, the controller must ensure that the conditions regarding consent are met even in the case of mass processing of personal data, or ensure that the use of AI is necessary for the fulfilment of primary obligations. This applies in particular when it comes to the data of third parties, i.e. not the user.

The legal basis of exercising legitimate interests is also likely to be highly relevant for the use of AI due to its flexibility. In contrast to consent and contract performance, it allows, in particular, the processing of personal data of third-party data subjects who are not directly involved in the use of the AI system (such as information about third parties who are part of a prompt).

The other legal bases (see Sect. 7.2.4.1) will rarely be applicable to the use of AI, for the same reasons as were already explained with regard to the training of AI.

7.2.4.3 When May Special Categories of Personal Data Be Processed?

Article 9 GDPR; Article 10(5) AI Act

Recitals 51 to 56 GDPR; Recital 70 AI Act (Processing of special categories of personal data)

The GDPR defines special categories of personal data (Article 9(1) GDPR; see Sect. 3.2.3). The processing of special categories of personal data is generally prohibited but allowed under additional conditions (Article 9(2) GDPR). The AI Act contains an additional legal basis to allow the processing of special categories of personal data in exceptional cases to detect and correct discriminatory biases in high-risk AI systems (Article 10(5) AI Act in conjunction with Article 9(2)(g) GDPR; see Sect. 3.2.3).

Besides this specific legal basis in the AI Act, the GDPR contains several other legal grounds for the lawful processing of special categories of personal data.

Regarding the training and use of AI with special categories of personal data, the following legal bases come into consideration (Article 9(2) GDPR):

- consent of the data subject, whereby essentially the same problems exist here as with consent to the processing of other personal data (see Sects. 7.2.4.1 and 7.2.4.2),
- the processing of data that has obviously been made public, although it is questionable in some cases to what extent this includes information available on social networks,
- the processing necessary for the purposes of preventive health care, medical diagnosis, care or treatment in the health or social sector and the management of systems and services in the health or social sector in accordance with EU or EU member state law, and
- the processing necessary for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with EU or EU member state law.

Unlike with other personal data, it is not possible to base the processing of special categories of personal data on the protection of an overriding legitimate interest (see Sect. 7.2.4.1). Thus, especially with regard to AI training with special categories of data (which is relevant for health data in particular), it must be carefully examined on which basis the processing can be based in the context of the training where consent does not prove to be an adequate legal basis (see above).

Related Topics

Additional legal basis for AI training under the AI Act: Sect. 3.2.3.

Legal bases for processing other categories of personal data: Sects. 7.2.4.1 and 7.2.4.2. ◀

7.2.5 What Information Is the Controller Obliged to Provide?

Articles 13 and 14 GDPR
Recitals 60 to 62 GDPR

The controller is obliged to provide information to the data subject whose personal data is being processed. On the one hand, there are obligations to provide information to data subjects whose data the controller has collected directly from the data subject (Article 13 of the GDPR) and, on the other hand, to data subjects whose data the controller has not collected directly from the data subject (Article 14 of the GDPR). In the case of AI training, the latter may be the case, for example, with purchased data sets that contain personal data with which an AI is to be trained. In the case of the use of AI, data processing may occur, for example, if information is part of a user prompt.

These information obligations can be fulfilled by creating a privacy policy. In general, the privacy policy must be made available to those persons whose data are processed, which is particularly difficult in the case of mass processing of data of data subjects with whom the controller has no contact. Responding to these practical challenges, the GDPR allows for simplifications to the information obligation if providing the information proves impossible or would require a disproportionate effort (Article 14(5)(b) GDPR).

7.2.6 What Rights Do Data Subjects Have?

Articles 15 to 21 GDPR

Recitals 39, 63, 64 to 70 GDPR

Data subjects are entitled to certain rights (Articles 15 to 21 of the GDPR).

They can request information from the controller about the personal data processed, including the provision of a copy of all personal data processed (Article 15 GDPR).

They can also request the rectification (Article 16 GDPR) and erasure (Article 17 GDPR) of personal data. The latter applies in particular if the purpose of the processing no longer applies or if there is no (longer a) legal basis for the processing.

They can also request the restriction of processing while certain checks are carried out by the controller in connection with the GDPR, such as checking the accuracy of personal data, or a dispute arises between the data subject and the controller because the latter does not comply with the data subject's request (Article 18 GDPR).

Furthermore, data subjects have the right to receive the personal data concerning them, which they have provided to a controller, in a structured, commonly used and machine-readable format or to have the data transmitted directly to another controller (so-called 'right to data portability', Article 20 GDPR).

In addition, data subjects have the right to object to the processing of personal data concerning them on the basis of a legitimate interest (see Sect. 7.2.4) on grounds relating to their particular situation (Article 21 GDPR). In the case of direct marketing, this is also possible without the presentation of special reasons (Article 21(2) GDPR).

When AI systems are used, it should often be possible to assign personal data to a specific data subject via a unique user ID, which is stored together with a user prompt, for example. This should also make it possible to fulfil the rights of data subject described above. On the other hand, the implementation of data subject rights when training AI poses challenges for data controllers. Because masses of data from different sources are brought together for training, it is sometimes almost impossible to determine which data can be assigned to which persons. This is all the more true if identifiers such as the user ID are deleted for the training.

This can be remedied by an exception, according to which the rights of data subjects under the GDPR are excluded if the controller is no longer able to identify the data subject without additional information (Article 11(1) GDPR). However,

this exception does not apply if the data subject provides additional information that enables them to be identified.

Related Topics

Obligation to provide information: Sect. 7.2.5. ◄

7.2.7 What Requirements Apply to Automated Decisions by AI?

Article 22 GDPR

Recitals 15, 71, 72 GDPR

The GDPR generally prohibits decisions based solely on the automated processing of personal data and provides for certain exceptions (Article 22 GDPR).

7.2.7.1 When Is Automated Decision-Making Prohibited?

Article 22 GDPR

Recitals 15, 71, 72 GDPR

The data subject shall have the right not to be subject to a decision based solely on automated processing which produces legal effects concerning them or similarly significantly affects them (Article 22 GDPR). Despite the wording to the contrary ('has the right'), this is not a claim to be asserted, but rather a directly applicable prohibition that does not need to be asserted.

The provisions of the AI Act on human oversight also have a similar protective function (see Sect. 3.2.7), as it is intended to ensure that humans are not directly and uncontrollably exposed to the results of high-risk AI systems.

A **decision is based exclusively on automated processing** if a human being no longer has a significant influence on the decision, i.e. the decision has to be 'predetermined' in an automated manner and no person may be responsible for the decision. A human is considered to have significant influence, meaning the decision is not based solely on automated processing, if they review—and can deviate from—the automated decision. It is crucial that the human supervisor is given actual room for judgement that is not linked to criteria that already result from the automated decision. The term 'decision' is to be understood broadly and basically means any process that can be of a purely economic or social nature.

In particular, the use of AI to make certain decisions is likely to fall under the concept of a decision based on automated processing within the meaning of the GDPR, insofar as the AI processes personal data, for example if user prompts contain personal data.

The decision must have a **legal effect** on the data subject or **significantly affect** them **in a similar way** in order to fall under the prohibition of the GDPR. A legal effect is always to be assumed if the legal position of the person concerned is changed in any way, for example if a right, an obligation or a legal relationship is established or cancelled or a right is infringed. It can be assumed that only negative legal effects are covered. The data subject is similarly significantly affected if the decision has a lasting negative impact on the economic or personal development of

the person concerned. When exactly an affect is to be regarded as significant depends on the individual case.

Related Topics

Human oversight of high-risk AI systems: Sect. 3.2.7.

Human oversight as a principle of the AI ethics guidelines: Sect. 1.6.4. ◀

7.2.7.2 What Exceptions Exist to the Prohibition of Automated Decision-Making?

Articles 13–15 and 22 GDPR; Articles 10(3) and 86 AI Act

Recitals 15, 60–64, 71 and 72 GDPR

The GDPR provides for **three exceptions** in which automated decision-making is permitted (Article 22(2) GDPR).

An automated decision is permitted if the decision is necessary for the conclusion or performance of a contract between the data subject and the controller. This includes, in particular, mass or time-critical contracts that could not be concluded if they were to be reviewed by a human. This exception is also likely to cover numerous scenarios in which AI systems are used to enable the conclusion of contracts, for example in credit scoring as a prerequisite for granting a loan or determining the interest rate (on the prohibition of social scoring in creditworthiness assessments, see also Sect. 2.3; on the critical use case of credit scoring by AI systems, see Sect. 3.1.2.5).

Furthermore, an automated decision may be permitted on the basis of an EU legal act or a law of a member state to which the data controller is subject if the legal act contains appropriate measures to safeguard the rights and freedoms as well as the legitimate interests of the data subject.

Finally, an automated decision may be authorised on the basis of the express consent of the data subject. In this respect, the point of reference for consent is not only the data processing, but also the automated decision with legal effect or similar and significant impairment. The requirements for consent to the processing of personal data (see Sect. 7.2.4) apply in this respect. Consent must be voluntary, specific, informed and unambiguous. The scope of the required information can be determined, among other things, with the help of the existing information obligations for the controller (Articles 13 and 14 GDPR, see Sect. 7.2.5).

Regarding automated decision-making, the GDPR requires the controller to inform the data subject in advance of the so-called 'logic involved' and the scope and intended effects of the processing for the data subject (Article 13(2)(f) and Article 14(2)(g) GDPR). In addition, the data subject also has the right to request access to the same information (Article 15(1)(h) GDPR).

The AI Act also grants the person affected by an AI based decision to receive an explanation of the decisions (Article 86(1) AI Act; see Sect. 1.7.2). However, this right under the AI Act only applies if and insofar as there is no right under the GDPR or another legal basis (Article 86(3) AI Act). Thus, the AI Act does not

provide for a right to an explanation regarding automated decision-making, as covered by the GDPR.

What exactly the term 'logic involved' means, i.e. how detailed the decision-making algorithm has to be explained under the GDPR, has not yet been conclusively clarified. However, the information should at least contain sufficient information to be able to present one's own point of view and challenge the decision, as the GDPR grants data subjects these rights (Article 22(3) GDPR).

All three exceptions to the prohibition of automated decision-making require the controller to take appropriate measures to safeguard the rights and freedoms as well as the legitimate interests of the data subject (Article 22(3) GDPR). This should include at least the right to obtain human intervention on the part of the controller, to express one's point of view and to contest the decision.

Therefore, the GDPR provides for three-steps to replace an automated decision by a human decision in individual cases. First, the data subject can challenge the decision taken. Second, the data subject explains their point of view and, third, the data subject has the right to have the decision reviewed by a human. This also serves the objective of not allowing exclusively automated decision-making without the possibility of human intervention. The rules of the GPDR therefore also correspond to the requirement of the AI Act regarding human oversight (see Sect. 3.2.7). In this respect, the AI Act even provides expressly that it must be possible to disregard or reverse decisions and outputs of high-risk AI systems.

In addition to the measures mentioned, the GDPR provides for the specific information of the data subject and grants them a right to an explanation of the decision taken following an appropriate assessment (Recital 71 GDPR).

Furthermore, the GDPR specifies requirements that the controller should ensure for fair and transparent processing (Recital 71 GDPR). For example, in the case of profiling (i.e., decision-making based on behavioural profiles, see Sect. 2.4), the controller should use suitable mathematical or statistical methods. Furthermore, the controller should take technical and organisational measures to ensure, in particular, that factors that lead to inaccurate personal data are corrected and that the risk of errors is generally minimised. These requirements are reminiscent of the requirement of data accuracy under the AI Act (Article 10(3) AI Act, see Sect. 3.2.2). In addition, the controller should prevent discriminatory decisions. This requirement is similar to the requirement of sufficiently representative data (Article 10(3) AI Act; see Sect. 3.2.2).

Related Topics

Prohibited social scoring: Sect. 2.3.

Profiling (and its prohibited use for predictive policing): Sect. 2.4.

Human oversight of high-risk AI systems: Sect. 3.2.7.

Consent to the processing of personal data: Sect. 7.2.4.

Obligation to provide information: Sect. 7.2.5. ◄

7.2.8 To Which Roles Are Obligations Under the GDPR Assigned?

Both when using and training AI, the question arises as to what role the individual operators play in terms of data protection (for information on the operators, see Sect. 1.3). Numerous operators are often involved in the use or training of AI solutions. Without being able to cover the entire range of constellations, the following case shall exemplify possible scenarios: A company may use an AI solution in the sense of a deployer under the AI Act (see Sect. 1.3.2), whilst another company develops the very AI solution as a provider within the meaning of the AI Act (see Sect. 1.3.1) and provides the infrastructure required to operate it. Besides, one company may provide personal data to another company that uses these data for AI training.

Related Topics

Operators under the AI Act: Sect. 1.3. ◄

7.2.8.1 What Is an Independent Controller?

Article 4(7) GDPR

Recital 79 GDPR

Operators can act as independent controllers if they determine the means and purposes of processing on their own. In the case of a data transfer between two companies, each company often determines the purposes of the transfer separately without a joint determination.

7.2.8.2 What Are Joint Controllers?

Article 26 GDPR

Recital 79 GDPR

The GDPR also assumes that there are joint controllers. Joint controllers are two (or more) data controllers who jointly determine the purposes and means of processing.

They must specify in an agreement who assumes which obligations under the GDPR internally and make the essence of this agreement available to the data subjects (Article 26(1) GDPR). Externally, however, data subjects can assert all their rights against each individual controller (Article 26(3) GDPR).

The internal allocation of tasks only plays a role internally, e.g. for a possible internal compensation of damages.

7.2.8.3 What Is a Processor?

Article 28 GDPR

Recital 81 GDPR

In addition to the role of the controller, who determines the purposes and means of processing, the GDPR also contains rules regarding the processor, who processes personal data on behalf of the controller, i.e. who does not pursue their own purposes with the processing (Article 28 GDPR). The processing by a processor must be based on a contract in which, in particular, the subject matter, duration, nature and purpose of the processing as well as the categories of personal data and data subjects are defined (Article 28(3) GDPR).

Using an AI solution on the cloud infrastructure of another company (such as in the case of Microsoft Copilot) often involves processing by a processor. However, close attention must be paid to whether the company offering the AI solution (also) processes the personal data for its own purposes. In particular, the personal data may often be used by this company to train the AI. If this is the case, the assignment of roles under the GDPR must be examined carefully.

7.2.9 What Are the Requirements for the Data Protection Organisation?

Articles 24–36 GDPR

Recitals 13 and 74–96 GDPR

The GDPR contains a whole series of organisational obligations that are intended to ensure compliance with the substantive requirements of the GDPR that are presented above.

7.2.9.1 What Technical and Organisational Measures Must the Controller Take?

Articles 5, 24 and 32 GDPR

Recitals 74 to 79 and 83 GDPR

The controller must implement appropriate technical and organisational measures to ensure and demonstrate compliance with the requirements of the GDPR (Articles 24 and 32 GDPR). Such measures serve in particular to ensure compliance with the principles of processing (Article 5 GDPR; see Sect. 7.2.3) and may relate, for example, to the transparency, purpose limitation and confidentiality of data processing as well as the availability and integrity of data or accountability of the processor. They include, among other things, pseudonymisation and encryption, the ability to quickly restore personal data and regular evaluation procedures with regard to the technical and organisational measures taken (Article 32(1) GDPR). When developing high-risk AI systems, these measures may overlap with the data quality requirements under the AI Act (see Sect. 3.2.2). When using a high-risk AI system, the AI Act contains additional requirements for technical and organisational measures to be taken by the deployer (see Sect. 3.4.1).

Related Topics

Data quality requirements under the AI Act: Sect. 3.2.2.

Technical and organisational measures of the deployer: Sect. 3.4.1.

Principles of processing: Sect. 7.2.3. ◄

7.2.9.2 What Are 'Privacy by Design' and 'Privacy by Default'?

Article 25 GDPR

Recitals 78 GDPR; 69 AI Act (Principles of data processing and federated learning)

The controller must ensure that the data protection principles (see Sect. 7.2.3) are complied with as effectively as possible, including even the stage when the means for processing are determined. This means, the design of the processing shall already minimise the risks for data subjects, for example by processing all personal data pseudonymously (so-called 'privacy by design'; Article 25(1) GDPR). The requirement of privacy by design specifies the general obligation to take technical and organisational measures for data protection (see Sect. 7.2.9.1).

Furthermore, the controller is obliged to ensure that by default only the personal data that is necessary for the purpose of processing is processed (so-called 'privacy by default'; Article 25(2) GDPR).

Recital 69 of the AI Act explicitly includes both of these principles and describes how a controller could implement privacy by design and by default when training AI. The measure described can be implemented through federated learning, for example. That means that AI models are trained with data that is stored on different devices (decentralised) without these being merged on a server where the data could hardly be assigned to data subjects. Only the respective training results are brought together and coordinated in order to train the AI model. In this respect, federated learning poses lower risks for the people concerned since the processing is decentralised.

Related Topics

Principles of processing in the GDPR: Sect. 7.2.3.

General technical and organisational requirements of the GDPR: Sect. 7.2.9.1. ◄

▶ **Further Information** *Heinrich Hertz Institute*, Research Topics: Federated Learning (2024).

7.2.9.3 What Requirements Apply to the Record of Processing Activities?

Article 30 GDPR

Recitals 13 and 82 GDPR

As a rule, every controller must keep a record of all processing activities (Article 30(1) GDPR). The purposes and processed categories of personal data and data

subjects of all processing activities as well as recipients to whom personal data has been or will be disclosed must be listed. Every processor is also subject to a similar obligation (Article 30(2) GDPR).

7.2.9.4 How Must Data Breaches Be Reported?

Articles 33 and 34 GDPR

Recitals 85–88 GDPR

When a data breach occurs, the controller shall notify the breach to the competent supervisory authority without undue delay and, where feasible, not later than 72 h after having become aware of the breach (Article 33(1) GDPR). The notification shall contain at least information on the nature of the personal data breach, including the categories and approximate number of data subjects affected by the breach, the name and contact details of its data protection officer, a description of the likely consequences of the breach and a description of the measures taken or proposed to be taken by the controller to address the breach and mitigate its effects (Article 33(3) GDPR).

In addition, the controller must inform data subjects affected by the data breach without undue delay whether the data breach is likely to result in a high risk to their rights and freedoms (Article 34(1) GDPR). The individual notification may be replaced by a public announcement if the former would involve a disproportionate effort (Article 34(3)(c) GDPR). This may be particularly relevant in the case of data breaches in the context of AI training, where personal data from a wide variety of sources is merged.

▶ **Further Information** *European Data Protection Board*, Guidelines 9/2022 on personal data breach notification under GDPR, Version 2.0 (2023).

7.2.9.5 When Should a Data Protection Impact Assessment Be Carried Out?

Article 35 GDPR; Article 27(4) AI Act

Recitals 75, 84, 89 to 93 GDPR

In particular, if AI is used for applications that involve a high risk to the rights of data subjects (this should often be the case for high-risk AI application scenarios), the controller should carry out a data protection impact assessment in advance and, in particular, assess the proportionality of the processing operations and the risks for data subjects (Article 35(1) GDPR). The AI Act provides for a comparable impact assessment for deployers of high-risk AI systems that are, or act on behalf of, public authorities, among others (see Sect. 3.4.10). The fundamental rights impact assessment under the AI Act is intended to supplement the data protection impact assessment (Article 27(4) GDPR).

7.2.9.6 When Must a Data Protection Officer Be Designated?

Articles 37–39 GDPR

Recital 97 GDPR

Both controllers and processors must designate a data protection officer if either

- the processing is carried out by a public authority or public body, or
- the core activities of the controller or processor consist of processing operations which require regular and systematic monitoring of data subjects on a large scale by virtue of their nature, scope and/or purpose, or
- the core activities of the controller or processor consist of extensive processing of special categories of personal data (see Sect. 7.2.4.3) or personal data relating to criminal convictions and offences.

Further cases in which a data protection officer must be appointed can be added by the EU member states.

In other cases, controllers, processors or associations of several operators may voluntarily appoint a data protection officer (Article 37(4) GDPR).

The data protection officer must be sufficiently qualified (Article 37(5) GDPR). They may be appointed internally as an employee or externally as a service provider (Article 37(6) GDPR).

The GDPR contains a number of provisions on how the data protection officer must be integrated into the organisation of the controller or processor. Among other things, they must be involved in the protection of personal data at an early stage, have sufficient resources and access authorisations, and act independently (Article 38(1) to (3) GDPR). They are the contact person for data subjects when exercising their rights under the GDPR (Article 38(4) GDPR; regarding data subject rights, see Sect. 7.2.6).

Furthermore, the GDPR also clarifies what tasks the data protection officer must fulfil at least (Article 39 GDPR). Among other things, the data protection officer must inform and advise the organisation of the controller or processor with regard to data protection obligations, monitor compliance with these obligations, assist with the data protection impact assessment if necessary (see Sect. 7.2.9.5), and cooperate with the data protection supervisory authority.

Related Topics

Processing of special categories of personal data: Sect. 7.2.4.3.

Data protection impact assessment: Sect. 7.2.9.5. ◀

▶ **Further Information** *Article 29 Working Party*, Guidelines on Data Protection Officers (2017).

7.2.9.7 When Must a Representative Be Appointed in the EU?

Article 27 GDPR

Recital 80 GDPR

Controllers and processors who are not established in the EU and to whom the GDPR applies based on the principle of destination (see Sect. 7.2.1), must generally appoint a representative in the EU. Exemptions apply to public authorities and public bodies and to cases where personal data is processed only occasionally and special categories of personal data (see Sect. 7.2.4.3) are not processed on a large scale. In addition to the controller or processor or in their place, the representative is the contact point for data protection supervisory authorities and data subjects in all matters relating to the obligations arising from the GDPR.

Providers without an establishment in the EU also have a similar obligation under the AI Act, which requires them to appoint an authorised representative in the EU as a contact point (see Sect. 1.3.10).

Related Topics

Authorised representative under the AI Act: Sect. 1.3.6.

Obligation to appoint an authorised representative: Sect. 1.3.10.

Application of the GDPR to operators outside the EU: Sect. 7.2.1.

Processing of special categories of personal data: Sect. 7.2.4.3. ◄

7.2.10 Which Requirements Apply to Data Transfers to Third Countries?

Articles 44 to 49 GDPR

Recitals 101 to 115 GDPR

Any transfer of personal data by a controller or processor to a third country (i.e. a country outside the EU/European Economic Area) or to an international organisation is only permitted under certain conditions (Articles 44 to 49 GDPR).

Data Transfers on the Basis of an Adequacy Decision

A transfer of personal data to a third country or an international organisation can be based on a so-called adequacy decision (Article 45 GDPR). In an adequacy decision, the European Commission decides that a third country, a territory, or one or more specific sectors within a third country or an international organisation offers an adequate level of protection so that personal data can be transferred without further safeguards or guarantees.

The adequacy decisions for transfers to the USA which have been declared invalid by the ECJ on several occasions have become particularly famous. The so-called 'Data Privacy Framework' (the successor to the 'Privacy Shield') that currently applies to data transfers between the EU and the USA is also based on an adequacy decision. US companies can (self-)certify their compliance with the

relevant data protection requirements and then base the transfer of data between the EU and the USA on this.

Further adequacy decisions currently exist for Andorra, Argentina, the Faroe Islands, Guernsey, Isle of Man, Israel (partial), Japan, Jersey, Canada (restricted to commercial organisations), New Zealand, Switzerland, South Korea, Uruguay, and the United Kingdom.

Data Transfers Subject to Appropriate Safeguards
In the absence of an adequacy decision for a third country or an international organisation, a transfer is only permitted if the controller or processor has provided appropriate safeguards and if enforceable rights and effective legal remedies are available to the data subjects (Article 46(1) GDPR).

The standard data protection clauses (Article 46(2)(c) GDPR) are of paramount importance as safeguards. In 2021, the European Commission adopted Standard Contractual Clauses (SCCs), which controllers and processors can use to justify transfers to third countries for which there is no adequacy decision. However, it is not sufficient to simply incorporate the SCCs in a contract with a third country party. By concluding the SCCs, controllers or processors must also ensure an appropriate level of protection (e.g. with the help of a transfer impact assessment).

Data Transfer due to Exceptions in Individual Cases
In addition, under certain conditions, it is possible to transfer personal data to a third country or an international organisation without an adequacy decision or appropriate safeguards (Article 49 GDPR). Although the GDPR does not explicitly stipulate this, data transfers should only be based on the exceptions in individual cases, meaning that it is rather difficult to base mass transfers on the exceptions.

▶ **Further Information** *European Commission*, Adequacy decisions. How the EU determines if a non-EU country has an adequate level of data protection (2024).

7.2.11 For Which Infringements Does the GDPR Provide for Sanctions and Compensation?

Articles 58, 82 to 84 GDPR

Recitals 122, 129, 131 and 148 to 153 GDPR

In the event of infringements, the GDPR provides for fines similar to those of the AI Act (see Sect. 6.2.9.1).

For example, breaches of the obligations of controllers and processors (Articles 8, 11, 25 to 39, 42 and 43 GDPR; see Sect. 7.2.8) may result in fines of up to EUR 10 million or, in the case of undertakings, up to 2% of total worldwide annual turnover (Article 83(4)(a) GDPR). In the event of breaches of the principles of processing, including the conditions for consent (Articles 5, 6, 7 and 9 GDPR, see Sects. 7.2.3 and 7.2.4), the rights of data subjects (Articles 12 to 22 GDPR, see

Sects. 7.2.5–7.2.7) or the requirements for transfers to third countries (Articles 44 to 49 GDPR; see Sect. 7.2.10) are subject to fines of up to EUR 20 million or, in the case of undertakings, up to 4% of their total worldwide annual turnover (Article 83(5)(a) to (c) GDPR).

In addition, other provisions of the GDPR and national data protection laws are also subject to sanctions (Article 83(4)(b) and (c) and (5)(d) and (e) and (6) GDPR).

The GDPR contains—again similar to the AI Act (see Sect. 6.2.9.2)—a catalogue of circumstances that must be taken into account when deciding whether and to what extent a fine will be imposed (Article 83(2) GDPR).

In addition, the data protection authorities also have further investigative and remedial powers, e.g. to carry out investigations or to prohibit certain processing operations (Article 58(1) and (2) GDPR).

In contrast to the AI Act, the GDPR also contains a separate basis for claims for damages (Article 82(1) GDPR). This claim extends to all material or immaterial damage caused by infringing the GDPR and is directed against the controller or the processor.

The EU member states can also stipulate further sanctions in national law (Article 84 GDPR).

Related Topics

Sanctions in the AI Act: Sect. 6.2.9.

Principles of processing: Sect. 7.2.3.

Legal basis for processing: Sect. 7.2.4.

Duty to provide information: Sect. 7.2.5.

Rights of data subjects: Sect. 7.2.6.

Prohibition of automated individual case decisions: Sect. 7.2.7.

Controller and processor: Sect. 7.2.8. ◀

▶ **Further Information** Assessment of fines: Article 29 Working Party, Guidelines on the application and setting of fines under Regulation

2016/679; European Data Protection Board, Guidelines 04/2022 for the calculation of fines under the GDPR.

7.3 Which General Product Safety Requirements Must Be Observed?

Recital 166 AI Act (General Product Safety Regulation as a safety net)

The GPSR (**General Product Safety Regulation** (EU 2023/988)) shall apply to products related to AI systems (Recital 166 AI Act). AI systems may be subject to certain safety requirements even if they are not high-risk AI systems. The requirements of the GPSR are intended to act as a 'safety net' (Recital 166 AI Act), which suggests that the requirements are lower than those for high-risk AI systems under the AI Act. The GPSR has already entered into force and will apply **from 13 December 2024** (Article 52 GPSR).

Products within the meaning of the GPSR are all items that

- are supplied or made available alone or in combination with other items for a fee or free of charge, including as part of the provision of a service, and
- are **intended for consumers** or are likely to be used by consumers under reasonably foreseeable conditions even if they are not intended for them (Article 3(1) GPSR).

The GPSR applies only to AI systems that are integrated into **physical items** (embedded software). Stand-alone software, which is not embedded in a product, does not fall into the scope of the General Product Safety Regulation. Additionally, a product in scope of the GPSR must be (intended to be) used by consumers. A consumer is any natural person who acts for purposes which are outside their trade, business, craft or profession (Article 3(17) GPSR).

The central requirement of the GPSR is a **general safety requirement,** which stipulates that all products must be safe (Article 5 GPSR). This requirement is fulfilled if the product, under normal or reasonably foreseeable conditions of use, including the actual duration of use, presents no risks or only the minimum risks compatible with its use, which are considered acceptable and consistent with a high level of protection for the health and safety of consumers (Article 3(2) GPSR). A variety of circumstances and characteristics must be taken into account, including possible interactions with other products, its cybersecurity and its possible ability to evolve or learn (Article 6 GPSR). This general safety requirement thus sets rather low requirements and should therefore **not generally** lead **to any significant additional obligations for most AI systems.**

To serve this general safety requirement, obligations apply to **manufacturers** of products. The notion of 'manufacturer' corresponds to the notion of 'provider' within the meaning of the AI Act (Article 3(8) GPSR, see Sect. 1.3.1).

Providers of an AI system intended for consumers that are subject to GPSR must ensure that their products comply with the aforementioned general safety

requirement before placing it on the market (Article 9(1) GPSR). Providers must carry out an **internal risk analysis** and draw up **technical documentation** containing at least a general description of the product and its essential characteristics relevant to the safety assessment (Article 9(2) GPSR). Relevant European standards may be taken into account.

In addition, the GPSR also places obligations on **importers, distributors and authorised representatives** (Articles 10 to 12 GPSR), which in part resemble the obligations that apply to operators of high-risk AI systems (see Sect. 3.5). The GPSR does not contain any provisions for **deployers.**

As a regulation, the GPSR applies directly and does not require any implementing legislation by the EU member states.

Related Topics

Operators under the AI Act: Sect. 1.3.

Placing on the market (and making available on the market): Sect. 1.4.1.

Obligations of operators of high-risk AI systems: Sects. 3.3–3.5.

Market surveillance: Sect. 6.2.

Product Liability Directive: Sect. 7.4.2. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022).

7.4 What Rules Apply to the Liability for AI Applications?

Article 110 AI Act

Recital 9 (Consistency with the New Legislative Framework)

Unlike the GDPR, the AI Act does not contain a separate legal basis for claims for damages. Nevertheless, operators, in particular providers and deployers, may be liable under certain circumstances for actions that infringe their obligations under the AI Act. In the future, an AI Liability Directive, which is to be issued following the AI Act, may contain specific provisions on this. In addition, the EU Product Liability Directive and national liability rules must be observed. These three aspects are summarised below with references to their relationship to the AI Act.

7.4.1 What Does the Draft AI Liability Directive Provide for?

The proposal for the AI Act was accompanied by the proposal for an AI Liability Directive. In 2023, the legislative process for the AI Liability Directive was paused until the AI Act entered into force. At the time of writing, it cannot yet be predicted whether the newly appointed European Commission will continue to pursue the AI Liability Directive. Some argue that the draft AI Liability Directive (AILD) has already become redundant. The newly adopted Product Liability Directive (PLD) also applies to defective software and addresses difficulties to prove causality within opaque systems such as AI (see Sect. 7.4.2). However, a revised proposal of the AILD has supposedly been drafted to supplement both the AI Act and the new PLD. A recent impact assessment (from September 2024) that was conducted on behalf of the European Parliament recommends to continue the legislative process to implement an AILD. Since the European Commission has not yet published a new draft AILD, the following comments still relate to the European Commission's original draft (COM/2022/496 final) that will likely be subject to future amendments.

The AILD takes up the concepts of the AI Act and modifies certain aspects of non-contractual liability for damage caused by AI systems. Being a directive, the AILD would not apply directly after its entry into force but must be implemented by the EU member states through national legislation. The deadline for implementation will be 2 years (Article 7(1) draft AILD). The draft AILD provides only for a **minimum harmonisation**, i.e. the member states may also introduce or retain rules in their national law that are even more favourable to the claimant than the AI Liability Directive (Article 1(4) draft AILD).

The draft AILD **does not** contain **a legal basis for claims** and thus leaves the basic questions of liability to national law (see Sect. 7.4.3).

The draft AILD applies to **non-contractual fault-based civil law claims** before national courts in relation to damage caused by an AI system (Article 1(2) draft AILD). It does not apply to criminal law (Article 1(2)(1) draft AILD), liability in road transport (Article 1(3)(a) draft AILD), product liability law (Article 1(3)(b) draft AILD; for more details, see Sect. 7.4.2) and the exemptions from liability in the Digital Services Act (Article 1(3)(c) draft AILD).

All relevant legal concepts (e.g. 'AI system' and 'provider') are derived from the AI Act (Article 2 draft AILD).

The draft AILD contains two **rules to ease the burden of proof** for claimants who have been harmed by an AI system.

First, providers or deployers of AI systems would have to disclose **evidence** relating to an AI system that may have caused the damage if ordered to do so by a court (Article 3(1)–(3) draft AILD). This only applies to evidence that is actually available to the respective operator.

If an operator fails to comply with the disclosure obligation, the operator is presumed not to have complied with its duty of care (Article 3(5) draft AILD). However, the defendant may still rebut this presumption.

Second, a **link between the breach of the duty of care and the damage suffered** would be presumed if all of the following conditions are met (Article 4(1) draft AILD):

- The claimant has demonstrated, or the court has presumed, the fault of the defendant, or of a person for whose behaviour the defendant is responsible, consisting in the non-compliance with a duty of care directly intended to protect against the damage that occurred.
- Based on the circumstances of the individual case, it can be considered reasonably likely that the fault has influenced the output produced by the AI system or the failure of the AI system to produce an output.
- The claimant has demonstrated that the output produced by the AI system or the failure of the AI system to produce an output gave rise to the damage.

The defendant may also rebut this presumption.

Moreover, the presumption would not always apply, but only if it is necessary for the claimant. Regarding the conditions under which the presumption applies, the draft AILD distinguishes between high-risk AI systems (see Sect. 3.1) and other AI systems:

- The presumption generally applies to high-risk AI systems. By **derogation**, it does not apply if the defendant proves that the **claimant has access to sufficient evidence and expertise** under reasonable conditions (Article 4(4) draft AILD). In particular, the documentation and logs prepared and provided in accordance with the AI Act should be taken into account (Recital 27 draft AILD; for the corresponding obligations under the AI Act, see Sects. 3.2.4 and 3.2.5).
- With regard to other AI systems, the presumption of connection applies if, in the opinion of the competent court, it is excessively difficult for the claimant to prove the connection (Article 4(5) draft AILD). This condition should generally be met in the case of autonomous and/or opaque AI systems (Recital 28 draft AILD).

If the defendant had used the AI system in the course of a personal non-professional activity, the presumption that fault and damage are connected would only apply if the defendant materially interfered with the conditions of the operation of the AI system or if the defendant was obliged and able to determine the conditions of operation and failed to do so (Article 4(6) draft AILD).

In the case of claims for damages against providers and deployers of **high-risk AI systems**, the link between fault and damage is only presumed if the claimant demonstrated a specific form of fault of the provider or deployer. In the case of claims for damages against the **provider, the claimant** must prove that the provider has breached one of the following obligations (Article 4(2) draft AILD):

- data quality requirements (see Sect. 3.2.2),
- requirements for the explainability of the AI system (see Sect. 3.2.6),

- requirements regarding human oversight (see Sect. 3.2.7),
- requirements for accuracy, robustness, and cyber security (see Sect. 3.2.8),
- requirements to take corrective action immediately (see Sect. 3.3.9).

In the case of claims for damages against the **deployer,** the claimant would have to prove that the deployer has breached one of the following obligations (Article 4(3) draft AILD):

- obligation to use and/or monitor the high-risk AI system in accordance with the instructions for use (see Sects. 3.4.1–3.4.3),
- obligation to use input data that corresponds to the intended purpose of the high-risk AI system (see Sect. 3.4.1).

Related Topics

Requirements for high-risk AI systems: Sect. 3.1.

Obligations of providers of high-risk AI systems: Sect. 3.3.

Obligations of deployers of high-risk AI systems: Sect. 3.4.

Basic principles of liability for AI: Sect. 7.4.3. ◄

Further information

European Parliament, Proposal for a directive on adapting non-contractual civil liability rules to artificialintelligence. Complementary impact assessment (2024). ◄

7.4.2 What Does the Product Liability Directive Provide for?

Liability for defective products is regulated by the EU Product Liability Directive (PLD). It concerns **strict liability for defective products regardless of fault**. Together with the drafts of the AI Act and the AI Liability Directive, the European Commission has also proposed a draft for a **new Product Liability Directive** (draft PLD) to cover technological developments. The following presentation is based on the final compromise text of the PLD adopted by the European Parliament on 12 March 2024 following the conclusion of the trilogue negotiations (2022/0302 (COD), T9-0132/2024).

Persons who suffer damages as a result of a defective product are entitled to compensation (Article 5(1) draft PLD).

The notion of 'product', which is at the centre of product liability, includes all movables, even if it is integrated into immovables (land), as well as electricity,

digital manufacturing files, raw materials and software (Article 4(1) draft PLD). Under the previously applicable 'old' PLD, it was still disputed whether software was a product. The new draft therefore now explicitly clarifies that software is a product. Therefore, AI systems are typically also products within the meaning of the PLD (Recital 13 draft PLD).

A product is **defective** if it does not provide the safety which a person is entitled to expect or that is required under EU or national law (Article 7(1) draft PLD). In determining whether a product is defective, all circumstances should be taken into account, including, for example, the reasonably foreseeable use of the product, the effects on the product of its ability to continue to learn or acquire new features after it has been placed on the market or put into service, and the relevant product safety requirements (Article 7(2) draft PLD). The relevant product safety requirements also include the requirements of the AI Act for high-risk AI systems (see Chap. 3) which are integrated into the EU's New Legislative Framework of product safety law (see Recital 9 AI Act). Other provisions of the AI Act are not as clearly connected to product safety law since the AI Act does not follow the concept of the New Legislative Framework for all kinds of AI systems and models within its scope. However, the PLD assumes that AI systems in general—and not just high-risk AI systems—are products within its scope (Recital 13 draft PLD). Therefore, the requirements for other AI products may also be considered relevant product safety requirements in the context of product liability.

The **damages** for which compensation can be sought under the PLD include death or personal injury, damage to property, and the destruction and corruption of data that are not used for professional purposes (Article 6(1) draft PLD). All material losses are covered and, where provided for under national law, also non-material damage.

Claims for damages under the PLD shall generally be directed against the manufacturer of the defective product (Article 8(1)(a) draft PLD). In the case of AI systems, the provider of an AI system within in the meaning of the AI Act (see Sect. 1.3.1) shall be treated as the manufacturer of a product under the PLD (Recital 13 draft PLD). Manufacturers (providers) of components are also liable if their component caused the product to be defective. Additionally, other operators, such as importers (see Sect. 1.3.3), authorised representatives (see Sect. 1.3.6), or distributors (see Sect. 1.3.4) are liable if the manufacturer of the defective product is established outside the EU.

In addition to the right to file a claim, the draft PLD also contains an **obligation to disclose** evidence. If the plaintiff has submitted facts and evidence that are sufficient to support the plausibility of its claim, the defendant must disclose all evidence available to it (Article 9(1) draft PLD).

Related Topics

Operators under the AI Act: Sect. 1.3.

Requirements for high-risk AI systems: Chap. 3. ◄

7.4.3 Which National Liability Rules Apply?

National law remains the primary source for rules governing the liability for damage caused by the use of AI. It would exceed the scope of this handbook if we were to outline all relevant provisions in the national laws of all EU member states. Therefore, we only provide a short overview.

Claims for damages may generally arise both from contract law and from tort law. Contract law tends to protect the contracting parties more comprehensively but requires a legally binding contract between the claimant and the defendant. Tort law does not require such close link between the parties but often provides liability rules that are less favourable towards the person suffering damages. For example, claims from tort law may require fault, i.e. intent or negligence, or do not cover purely financial losses. Moreover, under contract law the defendant may be more likely to be responsible for damages caused by third parties that act on their behalf. Therefore, claims for damages under contract law are often more favourable to persons who have suffered damages.

The provisions of the AI Act can influence liability in several ways. For example, obligations under the AI Act may become part of the duty of care that contracting parties can expect each other to comply with. Besides, violations of the AI Act may be considered violations of legal interests or of protective laws for which compensation can be sought under national tort law. Also, the concept of negligence is often based on duties of care which, in turn, are often based on compliance with regulatory requirements. Thus, operators are more likely to be liable for damages caused by an AI system if they have not complied with their obligations under the AI Act.

To determine which national legislation is applicable to a damage caused by AI, the most relevant provisions of EU private international law, i.e., EU's rules on conflict of laws, shall be outlined as well. However, it must be highlighted once again that we can only provide a high-level overview in this handbook.

In the EU, the **harmonised rules for conflict of laws** apply in all member states. Private international law regarding civil liability is mainly governed by the Rome I Regulation (Regulation (EC) No 593/2008 on the law applicable to contractual obligations) and by the Rome II Regulation (Regulation (EC) No 864/2007 on the law applicable to non-contractual obligations). Both regulations give priority to the **choice of law** by the parties in a civil proceeding (Article 3 Rome I Regulation and Article 14 Rome II Regulation).

If the parties have not chosen the applicable law with regard to contractual relationships, the applicable law usually depends on the **type of contract that the parties have concluded** (Article 4 of the Rome I Regulation). For example, the law of the place where the seller resides applies to a sales contract. With regard to non-contractual relationships, the applicable law usually depends on the **place where the damage has occurred**, unless both parties have their habitual residence in the same country (Article 4 Rome II Regulation). Besides these two general rules, there are many more specific provisions that provide for a different jurisdiction to apply. Therefore, it is necessary to determine the applicable law for each case individually.

7.5 What International Laws and Framework Conditions Govern AI?

The regulation and standardisation of AI is the top global issue in digital politics and business. New legislative proposals are introduced, discussed and passed almost daily around the world. The proposals range from comprehensive laws, similar to the approach of the AI Act, to other sector-specific legislation that only address specific technologies (generative AI) or topics (such as deep fakes or the prevention of unfair influence on democratic elections). In addition, there is a large number of codes, principles and agreements that relate to the handling of AI, to which both states and companies have committed themselves. The International Standardisation Organization (ISO) is also developing AI standards together with its national standardisation bodies (see Sect. 7.6.1), which have a significant influence on the design of AI systems and the concretisation of the relevant framework and legislation, alongside 'de facto' standards, such as the AI Risk Management Framework (see Sect. 7.5.2.1) of the US National Institute of Standards and Technology (NIST).

Related Topics

NIST AI Risk Management Framework: Sect. 7.5.2.1.

ISO standards: Sect. 7.6.1. ◀

7.5.1 What International Agreements Are There?

Since 2019, various international organisations and bodies have agreed on guidelines and principles on how to deal with AI and to ensure a common regulatory approach. Although these guidelines are not directly binding for companies, they are an important **political and regulatory instrument** for achieving a minimum level of compatibility and harmonisation of national regulation of AI. Internationally operating companies in particular rely on basic concepts being handled in a comparable manner in order to be able to structure their AI governance programmes accordingly. The most important international agreements are briefly summarised below:

- The Recommendation on Artificial Intelligence of the Organisation for Economic Co-operation and Development (OECD) is the first international agreement on AI and was signed by the OECD member states in May 2019. The recommendations are intended to ensure that AI is used safely and responsibly, disinformation is prevented, transparency is guaranteed, and sustainability aspects are taken into account. It contains key principles of trustworthy AI, including a human-centred approach, transparency and explainability, robustness and security as well as accountability. These principles can now also be found in many other codes, guidelines and regulatory approaches. In addition, the **OECD recommenda-**

tions include a recognised definition of AI systems, which was revised in November 2023 and adopted by the NIST AI Risk Management Framework (see Sect. 7.5.2.1) and by the AI Act (in particular in the definition of AI systems, see Sect. 1.2.1). The revised guidelines were signed by 47 countries and the EU in May 2024 in order to promote a globally compatible regulatory approach to AI.

- In October 2023, the **G7 countries** adopted international guiding principles for artificial intelligence and a voluntary code of conduct for AI developers that builds on the OECD recommendations. The Code of Conduct is aimed at organisations that provide advanced AI systems, including most advanced AI models and generative AI systems. Developers are encouraged to take voluntary measures to ensure, inter alia, identification and mitigation of risks, transparency regarding the capabilities and limitations of AI, and labelling of AI-generated content. Companies, research institutions and other stakeholders should establish internal governance structures for this purpose in order to develop and use AI responsibly as part of a risk-based approach. The G7 countries emphasise that countries can choose different regulatory approaches to enforce the guiding principles within their territory. In the meantime, many countries beyond the G7 have also committed to taking the guiding principles into account in the national regulation of AI.
- At the beginning of November 2023, 28 countries and the European Union signed the **Bletchley Declaration** as part of the (first) AI Safety Summit organised by the United Kingdom (see also Sect. 7.5.2.6). The signatories commit to contribute to the safe use of AI for the common good and to respect human rights, transparency, fairness, accountability, human oversight and data protection through risk-based measures and international cooperation. In particular, the Bletchley Declaration focuses leading AI technology ('frontier' AI) such as high-performance general-purpose AI models. Accordingly, developers of frontier AI shall have a duty to ensure safety through testing, evaluation and other measures such as monitoring and risk mitigation.
- In March 2024, the United Nations (**UN**) also adopted an **AI resolution** ('*Seizing the opportunities of safe, secure and trustworthy artificial intelligence systems for sustainable development*') on the initiative of the USA, which deals with the use and regulation of AI. The resolution particularly emphasises the risks and benefits of AI in relation to the sustainability goals formulated by the UN and human rights. Principles are formulated to create 'interoperable' measures for evaluation and risk minimisation, public education about opportunities and risks, monitoring and risk management, AI safety, international standards, and technical solutions—e.g. to watermark and label AI-generated content—and to prevent discrimination or the violation of data protection and IP rights at national level.
- In May 2024, the **Council of Europe** adopted the **Framework Convention on AI, Human Rights, Democracy and the Rule of Law**. The Committee on Artificial Intelligence published a corresponding draft in March 2024, which was converted into a legally binding treaty by the 46 member states of the Council of Europe in May 2024. The treaty comprises 36 articles that address general obligations to protect human rights, democracy and the rule of law, respect for human

dignity and self-determination, transparency, accountability, freedom from discrimination, and data protection. The signatories also undertake to implement legal remedies and risk management systems to fulfil the purpose of the convention and to promote digital literacy in relation to the use of AI systems.

- The **Seoul Declaration for Safe, Innovative and Inclusive AI** has been adopted during the **AI Seoul Summit** in May 2024 and signed by Australia, Canada, the European Union, France, Germany, Italy, Singapore, UK and the USA. The declaration focuses on security aspects of AI and fosters a global network of national AI safety institutes. Various enterprises signed up to **Frontier AI Safety Committments**, pledging to develop safe and secure AI frontier models.

Related Topics

AI system within the meaning of the AI Act: Sect. 1.2.1.

NIST AI Risk Management Framework: Sect. 7.5.2.1.

Bletchley Declaration: Sect. 7.5.2.6. ◄

7.5.2 What National Regulatory Approaches Exist Outside the EU?

AI is increasingly regulated on national level. New legislative proposals are introduced almost daily. However, not all countries are opting for a 'hard' regulatory approach based on a comprehensive AI law, comparable to the AI Act. Alternatively, some states follow a soft law approach, implementing guidelines, recommendations, codes of conduct and technical standardisation. However, this does not mean that there are no laws regulating the use of AI. Rather, existing laws, especially in already regulated sectors such as health, financial services, transport, critical infrastructure, or the public sector, and general laws, e.g. anti-discrimination and copyright, are amended to also cover risks that are specific to AI. **Countries** that play a leading role in regulating artificial intelligence and their regulatory approaches are **presented** below.

7.5.2.1 How Is AI Regulated in the USA?

AI regulation in the USA is evolving dynamically. New legislative proposals on artificial intelligence are introduced almost weekly, roadmaps are published and implementation guidelines are passed. At the federal level, there are four major initiatives that characterise AI regulation, as well as hundreds of legislative proposals that are being discussed or have already been passed in the US states:

- In January 2023, the National Institute of Standards and Technology (**NIST) published** the **AI Risk Management Framework** (AI RMF). This practical

guide enables companies of all sizes, as well as developers and users of AI systems in general, to control AI-related risks and use AI responsibly, i.e., safely, transparently, explainably, fairly and in compliance with data protection law. The AI RMF was developed with the participation of experts from government, academia and business. Not least due to its adaptability and practical relevance, it is considered one of the most important approaches in AI governance, which is referred to in the Executive Order on the Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence, in the Voluntary AI Commitments and in numerous implementing regulations and draft laws of the US states. The NIST AI RMF is currently being expanded to include a model that deals with generative AI.

- The **Executive Order** on the Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence (EO), which was issued in October 2023 to develop safe and trustworthy AI at the federal level in the USA, sets out the guidelines for the development, use and promotion of AI by the US federal administration. Among other things, it requires key federal agencies to appoint a Chief AI Officer and issue further implementing regulations, including on AI and cyber security. It also mandates the further development of the NIST AI RMF, including with regard to risks that may arise in connection with generative AI. The EO is also intended to support employees, protect human rights and consumers and promote innovation and the use of AI in the federal administration.
- In order to make private-sector companies develop safe and transparent generative AI models, the US government has initiated Voluntary AI Commitments by leading US technology companies in July 2023. With the Voluntary Commitments, companies undertake to test AI models and systems for safety through red teaming (and to have them tested by third parties), to share and apply standards and best practices, to protect model weights (the core elements of AI models), to label AI-generated content (e.g. through watermarking), to publish information on the safety and performance of AI models, to prevent biases and discrimination, to protect personal data, and to promote the development of AI models for the common good.
- Federal data protection legislation, which has recently picked up speed again with the draft **American Privacy Rights Act** (APRA), also refers to AI. Data processing by algorithms (and thus also by AI systems) is subject to numerous requirements of the APRA draft. These include risk and impact assessments, transparency obligations and opt-out rights when algorithms and AI systems make consequential decisions, e.g. in relation to employment, education, healthcare, insurance, loans or access to public accommodations. However, the chances of APRA being passed before the upcoming US elections in 2024 are uncertain. Even if a data protection law at federal level would not be passed until one of the upcoming legislative periods, AI and algorithms will be the focus of federal legislators.
- There are countless legislative initiatives in the **US states**. These are aimed, among other things, at setting up AI advisory bodies, promoting AI innovation or the use of AI in the public sector or addressing protection against deep fakes or

disinformation. However, comprehensive AI laws are also being pushed forward. California, which has already played a pioneering role in data protection, is discussing a variety of legislative proposals that address AI safety, automated decision-making and transparency issues, among other things. In Illinois, New Jersey and New York, AI issues relating to the employment relationship are being discussed in particular. A law to regulate automated employment decision tools, which establishes employee rights in relation to automated decisions in the work environment, was already passed in New York City in December 2021.

- In May 2024, the first comprehensive AI law to regulate high-risk AI systems, the **Colorado AI Act**, was passed in Colorado. Like the European AI Act, the law contains obligations for providers and deployers of AI systems. However, it is applicable earlier than the corresponding provisions of the AI Act, namely from 1 February 2026. Here, too, individuals are protected against discrimination by algorithms and in the context of automated 'consequential decisions' in the areas of education, employment, financing and access to state benefits, healthcare, accommodation, insurance and legal advice. In this respect, there is a certain overlap with the categories of critical areas of high-risk AI systems that the AI Act defines in Annex III (see Sect. 3.1.2). **Providers** are subject to information and documentation obligations, e.g. with regard to foreseeable risks, the training data used, risk mitigation measures taken and various performance metrics of the AI system. In addition, any violations of the prohibition of discrimination must be reported to the competent authority. **Deployers** also have obligations to protect the individuals affected by the use of the AI system. Deployers must, among other things, make it transparent that a user is interacting with AI, implement a risk management strategy, carry out annual impact assessments and monitor the AI system in use. Deployers must also fulfil information obligations regarding the purpose, use of data, and functionality of the AI system and inform affected individuals about their rights. This concerns, among other things, opt-out rights regarding profiling and automated decisions as well as the right to be informed about the reasons underlying a consequential decision, to demand corrections and to seek human review of the consequential decision. The Colorado AI Act is very similar to a corresponding legislative initiative in the state of Connecticut, which was ultimately unsuccessful. Nevertheless, the Colorado AI Act could serve as a model with exemplary character. Similar to US data protection, this would at least lead to a certain degree of harmonisation in AI legislation at US state level.

▶ **Further Information** *Future of Privacy Forum*, Colorado AI Act Two-Pager Cheat Sheet (2024); *National Institute of Standards and Technology*, AI Risk Management Framework (2023), Initial Public Draft Generative Artificial Intelligence Profile (2024); *White House*, Executive Order on the Safe, Secure, and Trustworthy Development

and Use of Artificial Intelligence (2023), Voluntary AI Commitments (2023).

7.5.2.2 How Is AI Regulated in Canada?

Canada has been preparing comprehensive legal regulation of high-impact AI systems since 2022. The legislative process for the **AI and Data Act** (AIDA), also known as Bill C-27, has been lengthy. The bill aims to impose obligations on providers and deployers of high-impact AI systems and general purpose AI systems. The scope of application could go beyond that of the European AI Act due to the rather broad and unclear definition of a high impact or general purpose AI system. In addition, the roles and obligations of those involved in the AI lifecycle are not as clearly defined as they are in the European AI Act. High-risk AI systems are subject to the planned AIDA requirements, which are fundamentally similar to those of the European AI Act, including human oversight and monitoring of AI systems, transparency, risk management, fairness, security, accountability and the robustness of AI systems. In addition, the legislator is planning the use of Conformity assessments of AI systems for general use by third parties and the establishment of a national AI and Data Commissioner. Essential details, for example on the categorisation of AI systems that are to be subject to the scope of the law, are currently still being discussed or are subject to later implementation through implementing acts.

In September 2023, the Canadian government initiated a voluntary commitment by several large AI companies, resulting in the **Voluntary Code of Conduct** on the Responsible Development and Management of Advanced Generative AI Systems. The commitment contains general principles on accountability, safety, fairness and equality, transparency, human oversight and the robustness of AI systems.

▶ **Further Information** *Government of Canada*, Voluntary Code of Conduct on the Responsible Development and Management of Advanced Generative AI Systems (2023).

7.5.2.3 How Is AI Regulated in China?

China has addressed the development and use of AI in several legal acts in order to achieve its self-imposed goal of becoming a global leader in AI by 2030:

The **Interim Measures for the Management of Generative Artificial Intelligence Services** represent a de facto law on the regulation of generative AI. Although a comprehensive Chinese AI law is expected in the future, there are no indications that a corresponding draft law is being prepared yet. The Interim Measures, which came into force in August 2023, impose obligations on providers of generative AI systems that are accessible to the public. Systems that can exclusively be accessed internally or that are used for research and development are excluded from the scope of application. The requirements for generative AI services include registration obligations, security checks, the labelling of AI-generated content, requirements regarding the quality and legality of training data and the monitoring of illegal content created using a generative AI service.

- Prior to the adoption of the Interim Measures on generative AI services, regulations on deep synthesis internet technology (Provisions on the Administration of Deep Synthesis Internet Information Services) and algorithm-based recommendation systems (e.g. in the context of online platforms and search engines) had already been adopted. These include registration obligations, obligations to identify AI-based content or opt-out rights and, with regard to deep synthesis, overlap with the administrative measures on generative AI services.

▶ **Further Information** *Future of Privacy Forum*, China's Interim Measures for the Management of Generative Artificial Intelligence Services: A Comparison between the Final and Draft Versions of the Text (2024).

7.5.2.4 How Is AI Regulated in Singapore?

Singapore has been a pioneer in the promotion of AI for years. The city state follows a soft law approach and does not have comprehensive AI legislation. The country has developed the main guidelines in its national AI strategy, which was published in 2019 and updated in December 2023 in the National Artificial Intelligence Strategy 2.0. In addition to regulatory sandboxes, the Singapore government has launched sector-specific initiatives, for example on the responsible use of AI in the financial and healthcare sectors. The two most important AI governance measures are summarised here:

- The **AI Verify Framework,** which was developed by Singapore's Infocomm Media Development Authority (IMDA) and made available in May 2022, is a building block for promoting AI governance in companies. It is used to test AI models and includes both technical tools and organisational checks. However, the current state of development does not allow the testing of generative AI and large language models (LLMs). The use of the test programme is voluntary and results in a corresponding test report which demonstrates compliance with the essential recognised principles for the development of trustworthy AI, which are in line with the OECD recommendations (see Sect. 7.5.1). The eleven underlying principles include requirements for transparency, explainability, security and robustness, fairness, data governance, accountability, human oversight and general benefit.
- In January 2024, the **Model AI Governance Framework for Generative AI** was presented, which is currently still at the draft stage. This framework considers nine different dimensions that are intended to support a trustworthy AI ecosystem in the context of generative AI. It addresses accountability, the data used to develop models, the secure development and supply of AI, the reporting of security incidents, testing, security aspects, transparency regarding the origin of AI-generated content, research and development, and the use of AI for the common good. The document specifies implementation requirements that serve to establish an AI governance programme for generative AI.

Related Topics

OECD AI recommendations: Sect. 7.5.1. ◀

▶ **Further Information** *AI Verify Foundation*, What is AI Verify (2022); *Future of Privacy Forum*, AI Verify: Singapore's AI Governance Testing Initiative Explained (2023); *AI Verify Foundation,* Model AI Governance Framework for Generative AI – Draft (2024).

7.5.2.5 How Is AI Regulated in Japan?

Japan is prioritising the use of AI systems for the benefit of society against the backdrop of a rising average age. Japan, like the United Kingdom and Singapore (see Sects. 7.5.2.4 and 7.5.2.6), follows a soft law approach. Under Japan's leadership of the G7 states, the so-called **Hiroshima Process** was initiated, which led to the adoption of the corresponding G7 principles for states and the code of conduct to which companies can commit themselves (see Sect. 7.5.1).

So far, the country has refrained from broader legal regulation of AI and has favoured **self-regulation**. However, Japan's government is considering making large AI developers accountable and adopting at least a framework law for AI regulation. In a corresponding draft, developers would be obliged to publish information on their AI systems, share safety-relevant aspects with supervisory authorities and, in particular, prevent the use of AI for criminal activities and human rights violations.

Related Topics

AI guidelines of the G7 countries: Sect. 7.5.1. ◀

▶ **Further Information** *European Commission*, Hiroshima Process International Code of Conduct for Advanced AI Systems (2023); *OECD*, G7 Hiroshima Process on Generative Artificial Intelligence (2023).

7.5.2.6 How Is AI Regulated in the UK?

The United Kingdom is a prominent representative of the soft law approach. The former conservative government had not intended to pass a comprehensive AI law. This may change under the labour government, which was elected in July 2024—although it cannot yet be predicted how AI could be regulated in the future. For now, the new labour government is still relying on regulation through existing laws, such as the **UK GDPR** (General Data Protection Regulation; the EU's GDPR still applies in the UK after leaving the EU with minor amendments) or the Human Rights Act and the Equality Act. In addition, sectoral supervisory authorities that have already been established, including those working together in the Digital Regulation Cooperation Forum, are intended to ensure the safe and responsible use of AI.

- In March 2023, the UK government published a comprehensive **AI strategy paper** that emphasises the opportunities and innovation potential of AI and aims to position the UK as a global AI leader. The paper identifies five principles that existing regulators should consider in their work in relation to the safe and responsible use of AI. These general principles include safety and robustness, transparency and explainability, fairness, accountability and governance, and contestability and redress, i.e. the possibility of (legal) action against AI measures. The paper also focuses on tools and standards for the development of trustworthy AI, which serve as an aid to implementation. The global interoperability of different regulatory approaches was also a key concern of the former UK government.
- In addition, the United Kingdom initiated the **Bletchley Declaration** in November 2023 as part of the first AI Safety Summit, which 29 countries have signed up to (see also Sect. 7.5.1). The declaration focuses on the risks of so-called frontier AI, i.e., the next generation of particularly powerful AI systems. The United Kingdom has also set up a state **AI Safety Institute,** which has developed and made available a platform ('Inspect') for evaluating large language models (LLMs), among other things.

Related Topics

Bletchley Declaration: Sect. 7.5.1. ◀

▶ **Further Information** *UK AI Safety Institute*, Inspect – An open-source framework for large language model evaluations (2024); *UK Government*: A pro-innovation approach to AI regulation: Policy paper, government response (2023), Bletchley Declaration (2023).

7.6 What Technical Norms and Standards Cover AI?

Technical norms and standards that concretise and harmonise certain aspects of AI development and application play an important role in the AI ecosystem, in legally compliant design, and in AI governance. They are particularly important to providers and deployers of AI systems that are active internationally and have to comply with regulatory requirements in different countries. Standards also provide assistance with the technical implementation of key elements of secure and trustworthy AI, including risk management, data governance, transparency, and the security and robustness of AI systems.

▶ **Further Information** *The Alan Turing Institute*, AI Standards Hub (2024); *National Institute of Standards and Technology*, A Plan for a Global Engagement on AI Standards (Draft) (2024).

7.6.1 Which ISO Standards Cover AI?

The International Standardisation Organisation (ISO) has published a series of standards directly or indirectly addressing AI that have been in existence for some time and have recently been completed. Other AI standards are also currently being developed:

- ISO/IEC 42001:2003 Information technology — Artificial intelligence — Management system
- ISO/IEC AWI 42102 Information technology — Artificial intelligence — Taxonomy of AI system methods and capabilities
- ISO/IEC AWI TR 42103 Information technology — Artificial intelligence — Overview of synthetic data in the context of AI systems
- ISO/IEC AWI 42105 Information technology — Artificial intelligence — Guidance for human oversight of AI systems
- ISO/IEC DIS 42005 Information technology — Artificial intelligence — AI system impact assessment
- ISO/IEC DIS 42006 Information technology — Artificial intelligence — Requirements for bodies providing audit and certification of artificial intelligence management systems
- ISO/IEC AWI TR 42106 Information technology — Artificial intelligence — Overview of differentiated benchmarking of AI system quality characteristics
- ISO/IEC 22989:2022 Information technology — Artificial intelligence — Artificial intelligence concepts and terminology
- ISO/IEC 23053:2022 Framework for Artificial Intelligence (AI) Systems Using Machine Learning (ML)

In particular, the **ISO 42001** AI Management System Standard, which was published at the end of 2023, should be emphasised here. It specifies the requirements for setting up an Artificial Intelligence Management System (AIMS) for companies and other organisations of all sizes and sectors. Similar to ISO standard 27001, which describes management systems for information and cyber security, ISO 42001 is specifically geared towards the establishment of AI management systems. The standard aims to ensure the ethical development and use of AI, the management of risks and opportunities typically associated with the use of AI and the promotion of traceability, transparency and reliability of AI. The focus here is on AI governance and the implementation of corresponding internal company processes, policies and a plan-do-check-act method.

Despite their partially identical terminology, ISO standards are not specifically tailored to the requirements for high-risk AI systems and the obligations

of providers under the AI Act (see Sects. 3.2 and 3.3). It remains to be seen to what extent the European standardisation organisations will take up and implement the presumption of compliance with the requirements of the AI Act when drafting the harmonised standards. Although many terms are used in both ISO standards and the AI Act (such as 'AI system', 'risk management system' or 'risk'), it must be taken into account that these terms are not always defined identically.

Related Topics

Requirements for high-risk AI systems under the AI Act: Sect. 3.2.

Obligations for providers of high-risk AI systems under the AI Act: Sect. 3.3. ◀

▶ **Further Information** *International Standardisation Organisation*, Artificial Intelligence Management Standards (2024).

7.6.2 Which IEEE Standards Are Relevant?

The Institute of Electrical and Electronics Engineers (IEEE), a professional association in which electrical engineers, engineers, computer scientists and other members of technical professions are organised worldwide, has adopted several standards and recommendations that deal with AI and machine learning. In particular, the standard P7003, which is currently being adopted and deals with algorithmic biases, and the Recommended Practice for Organisational Governance of Artificial Intelligence should be noted.

▶ **Further Information** *Institute of Electrical and Electronics Engineers,* P7003 – Draft Standard for Algorithmic Bias Considerations (2023), The IEEE Global Initiative on Ethics of Autonomous and Intelligent Systems (2024), Recommended Practice for Organisational Governance of Artificial Intelligence (2020).

7.6.3 What Harmonised Standards Help to Implement the AI Act?

Articles 40(1), 53(4)
Recital 121 (Standardisation requests)

Harmonised standards play an important part in demonstrating conformity with the requirements for high-risk AI systems (see Sect. 3.2) and the obligations for providers of GPAI models (see Sect. 5.1). If **harmonised standards** are applied

to an AI system, conformity of the very system with the requirements of the AI Act will be presumed (Articles 40(1) and 53(4)).

Harmonised standards are technical standards that are developed by the European standardisation organisations, approved by the European Commission and officially published in the Official Journal of the EU. The endorsement by the European Commission distinguishes harmonised standards from other technical standards. If harmonised standards have not (yet) been officially approved, the European Commission can define comparable standards by means of **common specifications,** compliance with which also presumes conformity with the requirements of the AI Act. In contrast to harmonised standards, common specifications are not developed by the European standardisation organisations, but by the European Commission. Common specifications are therefore intended to play a subordinate role for the transitional period in which harmonised standards do not yet exist.

The reference to harmonised standards to demonstrate conformity is an essential component of European product safety law under the New Legislative Framework (see Sect. 1.1) and many manufacturers will therefore be familiar with their functioning from other EU harmonisation legislation.

The European Commission has already **requested standardisation** from the European standardisation organisations to develop harmonised standards. According to the request, the European standardisation organisations CEN/CENELEC should not only specify certain requirements for high-risk AI systems (see below), but also take into account, among other things, the energy-efficient development of AI models, costs for small and medium-sized enterprises, existing international standards and protection of EU fundamental rights. As far as possible, the standards will also take into account **existing standards**, such as ISO standard 42001 (see Sect. 7.6.1). This is important in practice in order to create a standardisation regime that is as compatible as possible at a global level and to reduce certification costs for companies.

In May 2023, the European Commission issued a standardisation request (C(2023) 3215 final) to the European Committee for Standardisation (CEN) and the European Committee for Electrotechnical Standardisation (CENELEC) that are to develop standards in the following areas:

- **Risk management systems** for AI systems,
- **Governance** and **quality** of **data sets** used to develop AI systems,
- Recording through **logging functions** of AI systems,
- **Transparency** and **information for users** of AI systems,
- **human supervision** of AI systems,
- Specifications for the **accuracy** of AI systems,
- Specifications for the **robustness** of AI systems,
- Specifications for the **cyber security** of AI systems,
- **Quality management systems** for providers of AI systems, including procedures for **post-market monitoring systems**, and
- **Conformity assessment** for AI systems.

The corresponding standards are to be developed by CEN and CENELEC **by 30 May 2025.** A further specification of the standardisation request, which takes into account the final version of the AI Act and contains specifications for general-purpose AI models, is currently in preparation.

Related Topics

Requirements for high-risk AI systems: Sect. 3.2.

Obligations for providers of GPAI models: Sect. 5.1.

New Legislative Framework: Sect. 1.1.

Existing ISO standards: Sect. 7.6.1. ◀

▶ **Further Information** *European Commission*, The 'Blue Guide' on the implementation of EU product rules 2022 (2022), Standardisation request to the European Committee for Standardisation and the European Committee for Electrotechnical Standardisation in support of Union policy on artificial intelligence (2023).

List of Online Resources Used with Links

Publisher	Title and year of publication	Hyperlink
Agencia Española de Protección de Datos (AEPD)	Adecuación al RGPD de tratamientos que incorporan Inteligencia Artificial. Una introducción (2020)	https://www.aepd.es/sites/default/files/2020-02/adecuacion-rgpd-ia.pdf
AI Verify Foundation	Model AI Governance Framework for Generative AI – Draft (2024)	https://aiverifyfoundation.sg/downloads/Proposed_MGF_Gen_AI_2024.pdf
	What is AI Verify (2022)	https://aiverifyfoundation.sg/what-is-ai-verify/
The Alan Turing Institute	AI Standards Hub (2024)	https://aistandardshub.org/the-ai-standards-hub/
	Human Rights, Democracy, and the Rule of Law Assurance Framework for AI Systems (2021)	https://zenodo.org/records/5981676/files/HUDERAF_CoE_Pub.pdf
Article 29 Working Party	Guidelines in relation to data protection officers (2017)	https://ec.europa.eu/newsroom/article29/items/612048
Bengio, Yoshua	International Scientific Report on the Safety of Advanced AI – Interim Report (2024)	https://www.gov.uk/government/publications/international-scientific-report-on-the-safety-of-advanced-ai
Bundesamt für Sicherheit in der Informationstechnik	Generative AI models (2024)	https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/KI/Generative_AI_Models.html
Cente of Information Policy Leadership	Building Accountable AI Programmes (2024)	https://www.informationpolicycentre.com/uploads/5/7/1/0/57104281/cipl_building_accountable_ai_programmes_23_feb_2024.pdf
Commission Nationale de l'Informatique et des Libertés (CNIL)	IA: comment être en conformité avec le RGPD? (2022)	https://www.cnil.fr/fr/intelligence-artificielle/ia-comment-etre-en-conformite-avec-le-rgpd

© The Editor(s) (if applicable) and The Author(s), under exclusive license to Springer-Verlag GmbH, DE, part of Springer Nature 2024

P. Voigt, N. Hullen, *The EU AI Act*, https://doi.org/10.1007/978-3-662-70201-7

Publisher	Title and year of publication	Hyperlink
	Guide d'auto-évaluation pour les systèmes d'intelligence artificielle (IA) (2022)	https://www.cnil.fr/fr/intelligence-artificielle/guide
	"Law Enforcement Directive": What Are We Talking About? (2021)	https://www.cnil.fr/en/law-enforcement-directive-what-are-we-talking-about
European Data Protection Board	Guidelines 9/2022 on personal data breach notification under GDPR, Version 2.0 (2023)	https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en
	Report of the work undertaken by the ChatGPT Taskforce (2024)	https://www.edpb.europa.eu/our-work-tools/our-documents/other/report-work-undertaken-chatgpt-taskforce_en
	Guidelines 1/2024 on processing of personal data based on Article 6(1)(f) GDPR (2024)	https://www.edpb.europa.eu/system/files/2024-10/edpb_guidelines_202401_legitimateinterest
European Commission	Adequacy decisions, How the EU determines if a non-EU country has an adequate level of data protection (2024)	https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/adequacy-decisions_en
	Artificial Intelligence – Questions and Answers (2023)	https://ec.europa.eu/commission/presscorner/api/files/document/print/en/qanda_21_1683/QANDA_21_1683_EN.pdf
	European Digital Innovation Hubs (2023)	https://digital-strategy.ec.europa.eu/en/activities/edihs
	Good practices for market surveillance (2017)	https://ec.europa.eu/docsroom/documents/23041
	Hiroshima Process International Code of Conduct for Advanced AI Systems (2023)	https://digital-strategy.ec.europa.eu/en/library/hiroshima-process-international-code-conduct-advanced-ai-systems
	Critical Infrastructure Resilience (2024)	https://home-affairs.ec.europa.eu/policies/internal-security/counter-terrorism-and-radicalisation/protection/critical-infrastructure-resilience_en
	Commission launches AI innovation package (2024)	https://ec.europa.eu/commission/presscorner/detail/en/IP_24_383
	The 'Blue Guide' on the implementation of EU product rules 2022 (2022)	https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:52022XC0629(04)
	List of Notified Bodies (2024)	https://webgate.ec.europa.eu/single-market-compliance-space/#/notified-bodies/notified-body-list

Publisher	Title and year of publication	Hyperlink
	Standardisation mandate to the European Committee for Standardisation and the European Committee for Electrotechnical Standardisation in support of the Union's policy on artificial intelligence (2023)	https://ec.europa.eu/growth/tools-databases/enorm/mandate/593_en
	Representative Actions Directive. EU law by topic – Consumer protection law (2023)	https://commission.europa.eu/law/law-topic/consumer-protection-law/representative-actions-directive_en
	Sectorial AI Testing and Experimentation Facilities under the Digital Europe Programme (2024)	https://digital-strategy.ec.europa.eu/en/activities/testing-and-experimentation-facilities
European Parliament	Briefing: Generative AI and watermarking (2023)	https://www.europarl.europa.eu/RegData/etudes/BRIE/2023/757583/EPRS_BRI(2023)757583_EN.pdf
	An area of freedom, security and justice: general aspects (2024)	https://www.europarl.europa.eu/factsheets/en/sheet/150/an-area-of-freedom-security-and-justice-general-aspects
	Proposal for a directive on adapting non-contractual civil liability rules to artificial intelligence. Complementary impact assessment (2024)	https://www.europarl.europa.eu/RegData/etudes/STUD/2024/762861/EPRS_STU(2024)762861
European Union Agency for Cybersecurity	Artificial Intelligence and Cybersecurity Research (2023)	https://www.enisa.europa.eu/publications/artificial-intelligence-and-cybersecurity-research
Future of Privacy Forum	AI Verify: Singapore's AI Governance Testing Initiative Explained (2023)	https://fpf.org/blog/ai-verify-singapores-ai-governance-testing-initiative-explained/
	China's Interim Measures for the Management of Generative Artificial Intelligence Services: A Comparison between the Final and Draft Versions of the Text (2024)	https://fpf.org/blog/chinas-interim-measures-for-the-management-of-generative-ai-services-a-comparison-between-the-final-and-draft-versions-of-the-text/
	Colorado AI Act Two-Pager Cheat Sheet (2024)	https://fpf.org/wp-content/uploads/2024/05/FPF-FINAL-CO-SB-205-Two-Pager-.pdf
	The Spectrum of Artificial Intelligence – An Infographic Tool (2020)	https://fpf.org/blog/the-spectrum-of-artificial-intelligence-an-infographic-tool/

Publisher	Title and year of publication	Hyperlink
Galdon Clavell, Gemma	Checklist for AI Auditing (2024)	https://www.edpb.europa.eu/system/files/2024-06/ai-auditing_checklist-for-ai-auditing-scores_edpb-spe-programme_en.pdf
Government of Canada	Voluntary Code of Conduct on the Responsible Development and Management of Advanced Generative AI Systems (2023)	https://ised-isde.canada.ca/site/ised/en/voluntary-code-conduct-responsible-development-and-management-advanced-generative-ai-systems
Der Hamburger Beauftragte für Datenschutz und Informationssicherheit	Large Language Models and Personal Data (2024)	https://datenschutzhamburg.de/fileadmin/user_upload/HmbBfDI/Datenschutz/Informationen/240715_Discussion_Paper_Hamburg_DPA
Heinrich Hertz Institute	Research Topics: Federated Learning (2024)	https://www.hhi.fraunhofer.de/en/departments/ai/research-groups/efficient-deep-learning/research-topics/federated-learning.html
High-Level Expert Group on AI	A definition of AI (2018)	https://ec.europa.eu/futurium/en/system/files/ged/ai_hleg_definition_of_ai_18_december_1.pdf
	Assessment List for Trustworthy AI (2020)	https://ec.europa.eu/newsroom/dae/document.cfm?doc_id=68342
	Ethics guidelines for trustworthy AI (2019)	https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai
International Association of Privacy Professionals	EU AI Act Compliance Matrix (2024)	https://iapp.org/media/pdf/resource_center/eu_ai_act_compliance_matrix.pdf
Information Commissioner's Office (ICO)	Guidance on AI and data protection (2023)	https://ico.org.uk/for-organisations-2/guide-to-data-protection/key-dp-themes/guidance-on-artificial-intelligence-and-data-protection/
International Organization for Standardisation	Artificial Intelligence Management Standards (2024)	https://www.iso.org/committee/6794475/x/catalogue/p/0/u/1/w/0/d/0
Institute of Electrical and Electronics Engineers	P7003 – Draft Standard for Algorithmic Bias Considerations (2023)	https://standards.ieee.org/ieee/7003/11357/
	The IEEE Global Initiative on Ethics of Autonomous and Intelligent Systems (2024)	https://standards.ieee.org/industry-connections/ec/autonomous-systems/
	Recommended Practice for Organisational Governance of Artificial Intelligence (2020)	https://standards.ieee.org/ieee/2863/10142/

Publisher	Title and year of publication	Hyperlink
Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder (DSK)	Orientierungshilfe: Künstliche Intelligenz und Datenschutz (2024)	https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf
National Institute of Standards and Technology	A Plan for a Global Engagement on AI Standards (Draft) (2024)	https://airc.nist.gov/docs/NIST.AI.100-5.Global-Plan.ipd.pdf
	AI Risk Management Framework (2023)	https://www.nist.gov/itl/ai-risk-management-framework/ai-rmf-development
	Initial Public Draft Generative Artificial Intelligence Profile (2024)	https://airc.nist.gov/docs/NIST.AI.600-1.GenAI-Profile.ipd.pdf
OECD	Advancing accountability in AI: Governing and managing risks throughout the lifecycle for trustworthy AI (2023)	https://doi.org/10.1787/2448f04b-en
	G7 Hiroshima Process on Generative Artificial Intelligence (2023)	https://www.oecd-ilibrary.org/science-and-technology/g7-hiroshima-process-on-generative-artificial-intelligence-ai_bf3c0c60-en
	Generative Artificial Intelligence Profile – Draft (2024)	https://airc.nist.gov/docs/NIST.AI.600-1.GenAI-Profile.ipd.pdf
	OECD Framework for the Classification of AI systems (2022)	https://www.oecd-ilibrary.org/deliver/cb6d9eca-en.pdf?itemId=%2Fcontent%2Fpaper%2Fcb6d9eca-en&mimeType=pdf
OECD.AI Policy Observatory	Catalogue of Tools & Metrics for Trustworthy AI (2024)	https://oecd.ai/en/catalogue/overview
	What is AI? Can you make a clear distinction between AI and non-AI systems? (2024)	https://oecd.ai/en/wonk/definition
UK AI Safety Institute	Inspect – An open-source framework for large language model evaluations (2024)	https://ukgovernmentbeis.github.io/inspect_ai/index.html
UK Government	A pro-innovation approach to AI regulation: Policy paper (2023)	https://www.gov.uk/government/publications/ai-regulation-a-pro-innovation-approach/white-paper#part-7-conclusion-and-next-steps

Publisher	Title and year of publication	Hyperlink
	A pro-innovation approach to AI regulation: Policy paper – Government Response (2023)	https://www.gov.uk/government/consultations/ai-regulation-a-pro-innovation-approach-policy-proposals/outcome/a-pro-innovation-approach-to-ai-regulation-government-response#a-regulatory-framework-to-keep-space-with-a-rapidly-advancing-technology
	Bletchley Declaration (2023)	https://www.gov.uk/government/publications/ai-safety-summit-2023-the-bletchley-declaration/the-bletchley-declaration-by-countries-attending-the-ai-safety-summit-1-2-november-2023
White House	Executive Order on the Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence (2023)	https://www.whitehouse.gov/briefing-room/presidential-actions/2023/10/30/executive-order-on-the-safe-secure-and-trustworthy-development-and-use-of-artificial-intelligence/
	Voluntary AI Commitments (2023)	https://www.whitehouse.gov/wp-content/uploads/2023/09/Voluntary-AI-Commitments-September-2023.pdf